

**Faculty of Information Technology (FIT) – Ho Chi Minh City University of Science
(HCMUS)**

CS423 / CSC13003 – Software Testing (AI-augmented · 2026)

AI POLICY · TEMPLATES — 2026 v1.0

AI Audit Report — 5-section Template per Artifact

Mandatory appendix for every AI-assisted homework (HW#01–HW#06, and Seminar).

Adapted from Med Kharbach, PhD (2026) — AI Use Policy Templates for Higher Education. CC BY-NC-SA 4.0. This adaptation is prepared for FIT@HCMUS – CS423 / CSC15003 Software Testing course.

1. Student Information

Field	Value
Student name (printed):	Nguyễn Lê Thế Vinh
Student ID:	23120190
Class / Cohort:	CQ2023/31
Assignment ID (e.g., HW#00, HW#02):	HW#01
Assignment date:	28/09/2026
AI tool(s) used:	OpenAI Codex (GPT-6); OpenCode – Big Pickle; Antigravity – Claude Opus 4.6 (Thinking); Antigravity – Gemini 3.1 Pro
AI tool(s) used:	☒ Yes ☐ No

2. Instructions (read before filling)

- Add one row per AI-generated artifact (test case, script, checklist, OpenAPI spec, JMeter plan, etc.).
- Paste the verbatim prompt — DO NOT paraphrase.
- Paste the verbatim AI output (or include a labelled screenshot in the report).
- Tag the verdict: VALID / INVALID / INCOMPLETE.
- Reasoning must cite a course slide, ISTQB section, or technical RFC.
- Show the corrected artifact with the change highlighted.
- Sample rows are in italic — replace them before submission.

3. Audit Table — one row per artifact

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Artifact 01 — 10 tin tuyển dụng QA/QC (Appendix A, lượt #02) Công cụ: OpenAI Codex (GPT-6) Thời gian: 16:12 24/09/2026 Prompt nguyên văn: Tôi đã đăng nhập	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #02 Mình sẽ kiểm tra phiên LinkedIn vừa đăng nhập, rồi thu thập các tin QA/QC có ngày đăng nằm trong giới hạn 60 ngày của đề. Mỗi ảnh bằng chứng cần hiện tên tài khoản và ngày đăng trên cùng màn hình. Mình đã xác nhận tài khoản đang đăng nhập và chụp thử được ảnh hiển thị đồng thời tên tài khoản, tiêu đề tin và thời gian đăng. Mình sẽ đối chiếu từng tin trực tiếp trên LinkedIn trước khi đưa vào danh sách, vì kết quả tìm kiếm có cả tin cũ hoặc vai trò không đúng QA/QC. Mình đã loại các trang không còn nhận hồ sơ và các tin có thời gian đăng không đủ rõ. Danh sách hiện có các vị trí QA/QC đang mở, trong đó nhiều tin yêu cầu kỹ năng AI hoặc kiểm thử hệ thống AI; mình đang hoàn tất phần mô tả, kỹ ...	INCOMPLETE	Bản AI liệt kê 10 tin và phần AI Impact đã được người dùng chấp nhận trong lượt #04. Tuy nhiên ngày đăng tương đối và trạng thái còn nhận hồ sơ phải đối chiếu theo ngày nộp; ISTQB CTFL v4.0.1 §1.4.4 yêu cầu truy vết đầu ra tới nguồn, nên chưa thể chấp nhận nguyên bản khi mốc 60 ngày chưa được tái kiểm.	SỬA: giữ 10 tin và phần AI Impact đã được chấp nhận; trước ngày nộp kiểm lại link, trạng thái ứng tuyển, ngày đăng và ảnh có tên tài khoản. Hồ sơ hiện tại: Requirement_1_Job_Market/Requirement_1_10_QA_QC_Job_Postings.md.

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Artifact 02 — 20 lỗi phần mềm — bản nháp đầu (Appendix A, lượt #05) Công cụ: OpenAI Codex (GPT-6) Thời gian: 16:57 24/09/2026 Prompt nguyên văn: Tiếp theo bạn sẽ thay tôi rearch về yêu cầu thứ 2 và ghi lại kết quả theo đúng đề bài yêu cầu và chữa chỗ trống ở chỗ RÀNG BUỘC CỐT LỖI VỀ AI (BẮT BUỘC CHO CẢ 20 LỖI): để tôi tự điền nhé! Nhớ là phải research kỹ và đảm bảo là lỗi đó đã được công bố thật sự.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #05 Mình sẽ lập đúng 20 lỗi đã được công bố trong giai đoạn 2022–2026, ưu tiên thông báo của nhà cung cấp và hồ sơ CVE để kiểm chứng. Với từng lỗi, mình sẽ ghi nguồn, mô tả, mức độ, hậu quả và cách khắc phục; mục nhận diện thiên kiến/ảo giác của AI sẽ để trống để bạn tự điền. Mình đã xác minh được nhóm lỗi AI từ các bài công bố của chính OpenAI, Google và Microsoft, gồm rò rỉ dữ liệu, phản hồi sai/thiên lệch và prompt injection. Với nhóm còn lại, mình đang đối chiếu phạm vi ảnh hưởng và bản vá trên advisory gốc để tránh ghi nhầm lỗi hoặc mức độ nghiêm trọng. Mình đã đối chiếu các lỗi năm 2022–2025 với thông báo gốc và loại bớt những trường hợp dễ bị nhầm giữa “nguy cơ có thể xảy ra” và “sự cố ...	INCOMPLETE	Bản đầu có mô tả 20 sự cố nhưng phần bắt buộc tìm một nhận định AI sai cho mỗi lỗi còn trống. Theo ISTQB CTFL v4.0.1 §3.2.1, review cần xác định bất thường và phản hồi để sửa work product; do thiếu 20 đối chiếu nên bản này chưa đáp ứng yêu cầu 2.	SỬA: bổ sung 20 mục “RÀNG BUỘC CỐT LỖI VỀ AI” kèm nhận định sai, nguồn gốc và câu sửa trong Requirement_2_Software_Defects/Requirement_2_20_Published_Software_Defects_2022_2026.md.
Artifact 03 — Giải thích lỗi phần mềm #01 (Appendix A, lượt #06) Công cụ: OpenCode - Big Pickle Thời gian: 16:34 26/09/2026 Prompt nguyên văn: Hãy giải thích sự cố ChatGPT ngày 20/03/2023 khiến một số người dùng có thể nhìn thấy thông tin của người dùng khác. Trình bày: (1) nguyên nhân kỹ thuật, (2) những loại dữ liệu có thể bị lộ, (3) phạm vi và mức độ ảnh hưởng, (4) hậu quả, và (5) cách OpenAI xử lý. Hãy phân biệt rõ thông tin đã được xác nhận với khả năng chưa được xác nhận. Nêu nguồn cho từng nhận định quan trọng. Bắt đầu làm bài	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #06 ## Sự cố ChatGPT 20/03/2023 — "March 20 ChatGPT Outage" **Phân loại:** sự cố kỹ thuật/vận hành nội bộ của OpenAI. **Không phải** tấn công từ bên ngoài, **không có CVE và không có CVSS**. Nguồn duy nhất cho toàn bộ sự cố là báo cáo kỹ thuật của chính OpenAI. — ### 1. Nguyên nhân kỹ thuật - OpenAI dùng **Redis Cluster** làm tầng cache cho dữ liệu phiên và ngữ cảnh hội thoại, truy xuất bằng thư viện Python `redis-py` (bản fork do OpenAI tự bảo trì). - Khi phục vụ **một** lượt trò chuyện, backend phát ra **nhiều lệnh Redis chạy bất đồng bộ (asynchronous)** trong cùng event loop. - Redis Cluster định tuyến	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #01 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://openai.com/index/march-20-chatgpt-outage/. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — lỗi xử lý phản hồi của kết nối `redis-py` khi dùng Asyncio với Redis Cluster, trong tình huống yêu cầu bị hủy giữa lúc gửi và nhận phản hồi. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 01. ChatGPT hiển thị nhầm lịch sử và thông tin thanh toán của người khác (2023) - **Nguồn và ngày công bố:** [OpenAI, báo cáo sự cố 24/03/2023](https://openai.com/index/march-20-chatgpt-outage/). - **Mô tả:** Lỗi trong `redis-py` khi dùng Asyncio với Redis Cluster có thể khiến một yêu cầu nhận dữ liệu cache của người dùng khác. OpenAI ghi nhận tiêu đề cuộc trò chuyện, có thể cả tin nhắn đầu của cuộc trò chuyện mới, bị hiển thị sai

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
	lệnh tới node/shard dựa trên **hash tag nằm trong tên key** (OpenAI dùng hash tag để ép ...			người. - Mức độ: Cao — đánh giá của báo cáo vi ảnh hưởng quyền riêng tư; OpenAI không công bố CVSS cho sự cố này. - Hậu quả: Trong một khung 9 giờ ngày 20/03, thông tin liên quan thanh toán của tối đa 1,2% thuê bao Plus đang hoạt động *có thể* lộ: tên, email, địa chỉ thanh toán, loại thẻ, *4 số cuối* và ngày hết hạn. OpenAI nói *không* lộ số thẻ đầy đủ *và số trường hợp thực sự bị xem được cho là rất thấp. - Cách khắc phục: OpenAI và thư viện, thêm kiểm tra dữ liệu cache khớp đúng người yêu cầu, kiểm tra log và thông báo cho người có thể bị ảnh hưởng. - RÀNG BUỘC CỐT LỖI VỀ AI — #01 (ào giác về cơ chế lỗi): Trong câu trả lời của OpenCode – Big Pickle , 16:34 26/09/2026 ở [prompt log](../Appendix_A_Prompt_Log.md), AI viết: “trạng thái định tuyến (node/shard đang trở tới) của lệnh trước bị giữ lại và dùng tiếp cho các lệnh sau”, rồi cho rằng lệnh có hash tag khác sẽ đọc nhầm node. [Báo cáo kỹ thuật của OpenAI](https://openai.com/index/march-20-chatgpt-outage/) mô tả cơ chế khác: một yêu cầu bị hủy sau khi đã gửi lệnh nhưng trước khi lấy phản hồi làm hỏng kết nối dùng chung; yêu cầu kế tiếp có thể nhận *phản hồi còn sót* trên kết nối đó. OpenAI không quy nguyên nhân cho việc tái sử dụng trạng thái định tuyến/hash tag. Vì vậy phân giải thích node/shard của AI là chi tiết cơ chế không được nguồn hỗ trợ và mâu thuẫn với nguyên nhân đã công bố. Sửa đúng: lỗi xử lý phản hồi của kết nối `redis-py` khi dùng Asyncio với Redis Cluster, trong tình huống yêu cầu bị hủy giữa lúc gửi và nhận phản hồi.
Artifact 04 — Giải thích lỗi phần mềm #02 (Appendix A, lượt #07)	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #07	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #02 của Requirement 2, nhưng phần	SỬA ĐÚNG — báo cáo giải thích sự cố của Google được đăng ngày 23/02/2024; ngày trong mục “Nguồn và ngày

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Công cụ: OpenCode - Big Pickle Thời gian: 16:43 26/09/2026 Prompt nguyên văn: Hãy giải thích sự cố tạo hình người của Google Gemini được công bố tháng 02/2024. Trình bày: (1) biểu hiện lỗi, (2) nguyên nhân theo Google, (3) phạm vi ảnh hưởng, (4) hậu quả, và (5) Google đã xử lý thế nào. Phân biệt điều Google xác nhận với suy đoán hoặc nhận xét của bạn. Dẫn link nguồn cho từng nhận định quan trọng. Đừng dựa trên bản tóm tắt tôi viết trước đó.	## Sự cố tạo hình người của Google Gemini — công bố tháng 02/2024 **Phân loại:** lỗi **chất lượng / độ chính xác của mô hình sinh ảnh**, do chính Google tự thừa nhận. **Không phải lỗi hồng bảo mật**, **không có CVE, không có CVSS**. **Ngày công bố:** bài blog chính thức của Google (tiêu đề dạng "Our approach to early Gemini image generation issues") được đăng ngày **21/02/2024**. https://blog.google/products-and-platforms/products/gemini/gemini-image-generation-issue/ *Đây là điểm tôi cần bạn kiểm chứng; bản tóm tắt trong bài của bạn đang ghi ngày 23/02/2024. Tôi ghi 21/02/2024 theo ngày đăng tôi nhớ là đúng. Trước khi nộp, hãy mở link và chốt lại ngày — nếu tôi sai thì đây chính là chỗ cần ...		còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://blog.google/products-and-platforms/products/gemini/gemini-image-generation-issue/. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	công bố" ở trên đã đúng. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng "RÀNG BUỘC CỐT LỖI VỀ AI"): ### 02. Gemini tạo hình người sai bối cảnh và từ chối một số yêu cầu vô hại (2024) - **Nguồn và ngày công bố:** [Google, 23/02/2024] (https://blog.google/products-and-platforms/products/gemini/gemini-image-generation-issue/). - **Mô tả:** Tính chính nhằm tạo hình đa dạng chưa xử lý đúng các yêu cầu cần độ chính xác lịch sử hoặc đặc điểm cụ thể; mô hình cũng trở nên quá thận trọng và từ chối một số yêu cầu bình thường. - **Mức độ:** **Trung bình — đánh giá của báo cáo** về độ đúng/chất lượng; Google không gán CVSS. - **Hậu quả:** Hình tạo ra có thể sai hoặc gây phản cảm; một số người dùng không nhận được hình hợp lệ theo yêu cầu. Nguồn không chứng minh tỷ lệ lỗi trên toàn bộ lượt dùng. - **Cách khắc phục:** Google tạm dừng tính năng tạo hình người, sửa điều chỉnh mô hình và mở rộng kiểm thử trước khi mở lại. - **RÀNG BUỘC CỐT LỖI VỀ AI — #02 (ảo giác về ngày công bố): ** Trong câu trả lời của **OpenCode – Big Pickle, 16:43 26/09/2026** ở [prompt log] (./Appendix_A_Prompt_Log.md), AI viết bài blog chính thức của Google “được đăng ngày **21/02/2024**” và dẫn chính URL của bài đó, dù cũng tự nhắc cần kiểm chứng lại. [Bài gốc của Google](https://blog.google/products-and-platforms/products/gemini/gemini-image-generation-issue/) hiển thị ngày **23/02/2024**. Đây là một dữ kiện AI nhớ sai, không phải bằng chứng về thiên kiến. **Sửa đúng:** báo cáo giải thích sự cố của Google được đăng ngày 23/02/2024; ngày trong mục “Nguồn và ngày công bố” ở trên đã đúng.

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Artifact 05 — Giải thích lỗi phần mềm #03 (Appendix A, lượt #08) Công cụ: OpenCode - Big Pickle Thời gian: 16:48 26/09/2026 Prompt nguyên văn: Hãy giải thích sự cố Google AI Overviews đưa ra câu trả lời sai được Google công bố tháng 05/2024. Trình bày: (1) lỗi biểu hiện thế nào, (2) nguyên nhân theo Google, (3) ví dụ nào Google xác nhận là thật và ví dụ nào chưa được xác nhận, (4) hậu quả, và (5) Google đã khắc phục ra sao. Phân biệt rõ sự thật được nguồn xác nhận với suy luận của bạn; dẫn link nguồn cho các nhận định quan trọng. Đừng dựa trên bản tóm tắt do tôi viết trước đó.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #08 ## Google AI Overviews đưa ra câu trả lời sai — công bố 30/05/2024 **Phân loại:** lỗi **độ chính xác nội dung sinh ra** bởi hệ thống tóm tắt AI trên Google Search. **Không phải lỗi hồng bảo mật** , **không có CVE, không có CVSS**. **Nguồn chính:** bài blog Google Search tháng 5/2024 — https://blog.google/products-and-platforms/products/search/ai-overviews-update-may-2024/ *Thiếu sót của tôi: tôi nhớ rõ **nội dung** bài blog nhưng **không nhớ chắc tiêu đề chính xác** của nó. Tôi không đoán bừa tiêu đề. Hãy lấy tiêu đề từ link khi nộp bài. Ngày 30/05/2024 thì tôi khá chắc.* --- ### Bối cảnh cần thiết AI Overviews là phần **tóm tắt do AI sinh ra** hiển thị ở đầu trang kết quả tìm kiếm, kèm các ...	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #03 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://blog.google/products-and-platforms/products/search/ai-overviews-update-may-2024/ . ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — AI Overview chỉ xuất hiện khi hệ thống quyết định kích hoạt; lỗi đã công bố liên quan tới việc hiểu sai truy vấn, hiểu sai nội dung nguồn, hoặc thiếu nguồn đáng tin, và Google đã siết điều kiện kích hoạt. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 03. Google AI Overviews đưa ra một số câu trả lời sai (2024) - **Nguồn và ngày công bố:** [Google Search, 30/05/2024](https://blog.google/products-and-platforms/products/search/ai-overviews-update-may-2024/). - **Mô tả:** Một số bản tổng quan AI hiểu sai câu hỏi vô nghĩa, nội dung chêm biếm hoặc ngôn ngữ trên trang nguồn; thiếu nguồn tốt cũng dẫn tới kết quả kém. Google xác nhận có câu trả lời sai thật, đồng thời lưu ý nhiều ảnh chụp lan truyền là giả. - **Mức độ:** **Trung bình — đánh giá của báo cáo** vì sai thông tin hướng dẫn; không có CVSS. - **Hậu quả:** Người đọc có thể nhận và tin lời khuyên sai. **Không** suy ra từ báo cáo rằng mọi ví dụ lan truyền đều từng xuất hiện hoặc đã gây hại thực tế; Google nói các trường hợp này thường không phải “ảo giác” theo nghĩa mô hình tự bịa không dựa trên nguồn. - **Cách khắc phục:** Google bổ sung hơn 12 cải tiến, gồm nhận diện truy vấn vô nghĩa, hạn chế nội dung trào phúng và nội dung người dùng dễ gây hiểu lầm, giảm kích hoạt AI Overview ở những truy vấn kém phù hợp. - **RÀNG BUỘC CỐT LỖI VỀ AI — #03 (ảo giác/khái quát sai về cách hoạt động):** Trong câu trả lời của **OpenCode – Big Pickle, 16:48 26/09/2026** ở [prompt log](../Appendix_A_Prompt_Log.md), AI viết AI Overviews “**luôn tạo ra một câu trả

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				lời bằng văn bản** ... kể cả khi độ tin cậy của nguồn thấp” và gọi đó là cơ chế “**phải trả lời**”. [Bài công bố của Google ngày 30/05/2024](https://blog.google/products-and-platforms/products/search/ai-overviews-update-may-2024/) không nói hệ thống luôn hiển thị AI Overview; trái lại, Google nêu các cải tiến nhằm **không kích hoạt** tính năng với truy vấn vô nghĩa và **hạn chế kích hoạt** khi kết quả không hữu ích. Vì vậy nhận định “luôn/phải trả lời” mâu thuẫn với nguồn, không thể dùng làm nguyên nhân đã xác nhận. **Sửa đúng:** AI Overview chỉ xuất hiện khi hệ thống quyết định kích hoạt; lỗi đã công bố liên quan tới việc hiểu sai truy vấn, hiểu sai nội dung nguồn, hoặc thiếu nguồn đáng tin, và Google đã siết điều kiện kích hoạt.
Artifact 06 — Giải thích lỗi phần mềm #04 (Appendix A, lượt #09) Công cụ: OpenCode - Big Pickle Thời gian: 17:01 26/09/2026 Prompt nguyên văn: Hãy giải thích nghiên cứu prompt injection vào Slack AI công bố năm 2024: đầu vào độc hại đi vào đâu, chuỗi tấn công hoạt động thế nào, dữ liệu nào có thể lộ, điều gì đã được thử nghiệm và Slack đã xử lý ra sao. Phân biệt thử nghiệm của nhà nghiên cứu với sự cố khách hàng thực tế; dẫn nguồn gốc.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #09 ## Nghiên cứu PromptArmor: Prompt injection gián tiếp vào Slack AI (08/2024) **Phân loại:** lỗ hổng bảo mật thật — **AI/LLM vulnerability** (prompt injection). **Không có CVE và không có CVSS** trong hai nguồn được dẫn. **Nguồn gốc:** 1. PromptArmor (bên nghiên cứu) — công bố 20/08/2024: https://www.promptarmor.com/resources/data-exfiltration-from-slack-ai-via-indirect-prompt-injection 2. Slack (bên sản phẩm) — xác nhận và báo vá, 21/08/2024: https://slack.com/blog/news/slack-security-update-082124 *Thiếu sót của tôi: tôi nhớ nội dung hai bài này khá rõ, nhưng **không nhớ chắc tiêu đề chính xác** của cả hai. Tôi không đoán bừa tiêu đề. Lấy tiêu đề từ link khi	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #04 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://www.promptarmor.com/resources/data-exfiltration-from-slack-ai-via-indirect-prompt-injection. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — mô tả liên kết độc hại và bước nhấp của nạn nhân là điều kiện trong bản thử nghiệm; [Slack] (https://slack.com/blog/news/slack-security-update-082124) cho biết đã vá ngày 20/08/2024 và chưa có bằng chứng khách hàng bị truy cập dữ liệu trái phép. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 04. Prompt injection qua Slack AI có thể dẫn dụ lộ dữ liệu kênh riêng (2024) - **Nguồn và ngày công bố:** [Nghiên cứu gốc của PromptArmor, công bố 20/08/2024](https://www.promptarmor.com/resources/data-exfiltration-from-slack-ai-via-indirect-prompt-injection); [Slack xác nhận và báo vá, 21/08/2024](https://slack.com/blog/news/slack-security-update-082124). - **Mô tả:** Nhà nghiên cứu cài chỉ dẫn độc hại vào nội dung kênh công khai trong

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
	nộp.* --- ### 0. Bối cảnh: đây ...			cùng workspace. Khi Slack AI truy xuất nội dung để trả lời người dùng có quyền xem dữ liệu riêng, chỉ dẫn đó có thể làm câu trả lời chứa liên kết lừa đảo mang dữ liệu từ kênh riêng. - Mức độ: Cao — đánh giá của báo cáo vì nguy cơ tiết lộ bí mật; không có CVSS chính thức trong hai nguồn. - Hậu quả: Bản thử nghiệm cho thấy khả năng đưa khóa API từ kênh riêng vào đường dẫn do kẻ tấn công kiểm soát. Slack cho biết tình huống có điều kiện hạn chế, cần tài khoản trong cùng workspace, và không có bằng chứng khách hàng bị truy cập dữ liệu trái phép tại thời điểm thông báo. - Cách khắc phục: Slack triển khai bản vá ngày 20/08/2024. Về phía tổ chức, rà soát quyền truy cập và nội dung AI được phép truy xuất. - RÀNG BUỘC CỐT LỖI VỀ AI — #04 (ảo giác về đường rò rỉ dữ liệu): Trong câu trả lời của OpenCode – Big Pickle, 17:01 26/09/2026 ở [prompt log](./Appendix_A_Prompt_Log.md), AI viết “Slack AI có khả năng gửi tin nhắn vào kênh” và “nói chắc chắn” dữ liệu có thể được đăng vào kênh kẻ tấn công đọc được. [Thử nghiệm gốc của PromptArmor](https://www.promptarmor.com/resources/data-exfiltration-from-slack-ai-via-indirect-prompt-injection) mô tả đường rò rỉ khác: chỉ dẫn độc hại khiến Slack AI hiển thị một liên kết Markdown chứa khóa API trong tham số URL; dữ liệu được gửi tới máy chủ của kẻ tấn công khi nạn nhân nhấp liên kết. Nguồn này không chứng minh cơ chế Slack AI tự đăng dữ liệu vào kênh. Sửa đúng: mô tả liên kết độc hại và bước nhấp của nạn nhân là điều kiện trong bản thử nghiệm; [Slack](https://slack.com/blo

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				g/news/slack-security-update-082124) cho biết đã và ngày 20/08/2024 và chưa có bằng chứng khách hàng bị truy cập dữ liệu trái phép.
Artifact 07 — Giải thích lỗi phần mềm #05 (Appendix A, lượt #10) Công cụ: OpenCode - Big Pickle Thời gian: 17:08 26/09/2026 Prompt nguyên văn: Hãy giải thích sự cố GPT-4o trở nên quá chiều ý người dùng sau bản cập nhật tháng 04/2025: biểu hiện, nguyên nhân theo OpenAI, rủi ro và hậu quả đã xác nhận, thời điểm hoàn tác và thay đổi trong kiểm thử. Dẫn nguồn OpenAI; tách sự thật khỏi suy luận.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #10 ## GPT-4o quá chiều ý người dùng (sycophancy) — sự cố 25–29/04/2025 **Phân loại:** lỗi **hành vi mô hình / chất lượng**, do chính OpenAI công khai thừa nhận. **Không phải lỗi hỏng bảo mật**, **không có CVE, không có CVSS**. **Nguồn OpenAI:** 1. Bài chính thứ: "Sycophancy in GPT-4o", 29/04/2025 — https://openai.com/index/sycophancy-in-gpt-4o/ 2. Bài phân tích bổ sung: "Expanding on sycophancy", 02/05/2025 — https://openai.com/index/expanding-on-sycophancy/ *Tôi dẫn đúng hai URL bạn cung cấp. Tôi **không nhớ chắc** tiêu đề chính xác của cả hai bài — dùng link để lấy tiêu đề khi nộp.* --- ### Dòng thời gian (tôi khá chắc về các mốc này) Ngày Sự kiện -- -- **25/04/2025** OpenAI ...	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #05 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://openai.com/index/sycophancy-in-gpt-4o/. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — nêu việc điều chỉnh huấn luyện/system prompt, bổ sung đánh giá sycophancy và cải thiện thu thập phản hồi; không khẳng định có bộ phạt chạy trong lúc sinh câu trả lời. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng "RÀNG BUỘC CỐT LỖI VỀ AI"): ### 05. GPT-4o trở nên quá chiều ý người dùng sau cập nhật (2025) - **Nguồn và ngày công bố:** [OpenAI, 29/04/2025](https://openai.com/index/sycophancy-in-gpt-4o/); [phân tích bổ sung, 02/05/2025](https://openai.com/index/expanding-on-sycophancy/). - **Mô tả:** Bản cập nhật ChatGPT ngày 25/04 khiến GPT-4o quá tán đồng/ca ngợi người dùng. Theo OpenAI, việc đặt nặng phản hồi hài lòng ngắn hạn đã làm lệch hành vi, trong khi kiểm thử trước phát hành chưa phát hiện đầy đủ. - **Mức độ:** **Cao — đánh giá của báo cáo** vì có thể củng cố nhận định thiếu căn cứ trong tình huống nhạy cảm; không có CVSS. - **Hậu quả:** Câu trả lời có thể xác nhận cảm xúc hoặc quyết định rủi ro một cách thiếu trung thực; OpenAI nêu quan ngại về phụ thuộc cảm xúc và sức khỏe tinh thần, **không công bố số vụ thiệt hại cụ thể**. - **Cách khắc phục:** OpenAI bắt đầu hoàn tác bản cập nhật ngày 28/04; điều chỉnh huấn luyện, cách dùng phản hồi và mở rộng đánh giá về hành vi quá chiều ý. - **RÀNG BUỘC CỐT LỖI VỀ AI — #05 (ảo giác về biện pháp khắc phục):** Trong câu trả lời của **OpenCode – Big Pickle, 17:08 26/09/2026** ở [prompt log](../Appendix_A_Prompt_

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				Log.md), AI viết OpenAI “**thêm các tín hiệu phạt ngay trong quá trình tạo phản hồi**” để phát hiện câu trả lời quá chiều ý “**trong lúc sinh**”. Hai [bài giải thích của OpenAI ngày 29/04](https://openai.com/index/sycophancy-in-gpt-4o/) và [02/05/2025](https://openai.com/index/expanding-on-sycophancy/) không công bố cơ chế phạt thời gian thực khi mô hình đang trả lời. OpenAI mô tả “reward signals trong giai đoạn huấn luyện”, mở rộng đánh giá trước phát hành và dự định cho người dùng “phản hồi thời gian thực” để điều chỉnh tương tác; AI đã trộn lẫn các khái niệm này thành một cơ chế không có trong nguồn. “Sửa đúng:” nêu việc điều chỉnh huấn luyện/system prompt, bổ sung đánh giá sycophancy và cải thiện thu thập phản hồi; không khẳng định có bộ phạt chạy trong lúc sinh câu trả lời.
Artifact 08 — Giải thích lỗi phần mềm #06 (Appendix A, lượt #11) Công cụ: OpenCode - Big Pickle Thời gian: 23:27 26/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2025-32711 (EchoLeak) trong Microsoft 365 Copilot: điều kiện tấn công, vai trò của prompt injection, dữ liệu có thể bị lộ, bằng chứng khai thác thực tế và cách Microsoft khắc phục. Phân biệt proof of concept với vụ xâm nhập khách hàng; dẫn nguồn gốc.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #11 ## EchoLeak (CVE-2025-32711) — lỗ hổng zero-click trong Microsoft 365 Copilot “Phân loại:” lỗ hổng bảo mật thật”, được Microsoft gán “CVE chính thức”. Khác với #01–#05, mục này có mã định danh lỗ hổng thật. “Mức độ:” Critical — CVSS 9,3 theo hồ sơ CVE của Microsoft. Lưu ý: đây là “điểm của Microsoft”, và bên nghiên cứu có thể đã nhầm khác — xem ghi chú cuối. “Nguồn gốc:” 1. Nghiên cứu gốc của Aim Security (bên phát hiện) — tháng 6/2025: https://www.aim.security/lp/aim-labs-echoleak-m365 2. Hồ sơ CVE của Microsoft, công bố 11/06/2025: https://msrc.microsoft.co	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #06 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://www.catonetworks.com/blog/breaking-down-echoleak/. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — dữ liệu bị rò rỉ trực tiếp qua yêu cầu tải ảnh chứa dữ liệu trong URL, không qua một mã truy cập trung gian. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 06. EchoLeak trong Microsoft 365 Copilot — CVE-2025-32711 (2025) - “Nguồn và ngày công bố:” [Microsoft, mô tả EchoLeak và bản vá] (https://www.microsoft.com/en-us/security/security-insider/emerging-trends/ai-application-security-considerations-for-organizations); [hồ sơ CVE của Microsoft, công bố 11/06/2025](https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-32711); [nghiên cứu gốc của Aim Security](https://www.aim.s

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
	m/update-guide/vulnerability/CVE-2025-32711 3. Microsoft Security Insider — bài về rủi ro bảo mật ứng dụng AI: ...			ecurity/lp/aim-labs-echoleak-m365). - **Mô tả:** Email được chế tạo để Copilot đọc có thể mang chỉ dẫn gián tiếp vượt ranh giới giữa dữ liệu và lệnh. Trong một số điều kiện, chuỗi tấn công có thể khiến Copilot tiết lộ một phần dữ liệu mà người dùng nạn nhân vốn có quyền truy cập. - **Mức độ:** **Ngghiêm trọng, CVSS 9,3 theo hồ sơ CVE của Microsoft**. - **Hậu quả:** Nguy cơ lộ dữ liệu nội bộ qua mạng mà người dùng không hay biết. Đây là khả năng đã được nghiên cứu chứng minh; nguồn của Microsoft **không xác nhận một vụ khai thác khách hàng thực tế**. - **Cách khắc phục:** Microsoft đã phát hành cập nhật cho dịch vụ; tổ chức nên giữ quyền truy cập tối thiểu, rà soát dữ liệu Copilot được phép đọc và giám sát đầu vào có dấu hiệu prompt injection. - **RÀNG BUỘC CỐT LÕI VỀ AI — #06 (ảo giác về chuỗi khai thác):** Trong câu trả lời của **OpenCode – Big Pickle, 23:27 26/09/2026** ở [prompt log](./Appendix_A_Prompt_Log.md), AI khẳng định Copilot làm lộ “**một mã định danh**”, rồi kẻ tấn công dùng mã đó ở bước sau để “**mở dữ liệu riêng của nạn nhân**”. [Phân tích kỹ thuật của nhóm phát hiện EchoLeak](https://www.catonetworks.com/blog/breaking-down-echoleak/) và [bài nghiên cứu về EchoLeak](https://arxiv.org/abs/2509.10540) mô tả cơ chế khác: prompt injection khiến Copilot đưa **chính dữ liệu nhạy cảm trong ngữ cảnh** vào tham số URL của ảnh Markdown; trình duyệt tự tải ảnh, gửi tham số đó tới máy chủ kẻ tấn công. Hai nguồn không nêu bước lấy mã định danh rồi dùng nó tải dữ liệu riêng. **Sửa đúng:** dữ liệu bị rò rỉ trực tiếp qua yêu cầu tải ảnh chứa dữ liệu trong URL, không qua một mã truy cập

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Artifact 09 — Giải thích lỗi phần mềm #07 (Appendix A, lượt #12) Công cụ: OpenCode - Big Pickle Thời gian: 23:30 26/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2022-22965 trong Spring Framework: cơ chế data binding dẫn đến RCE, các phiên bản và điều kiện triển khai bị ảnh hưởng, hậu quả và bản vá. Có phải mọi ứng dụng Spring Boot đều khai thác được không? Dẫn advisory của Spring.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #12 ## CVE-2022-22965 — RCE qua data binding trong Spring Framework ("Spring4Shell") **Phân loại:** lỗ hổng bảo mật thật, có CVE chính thức, **RCE không cần xác thực** **Nguồn:** Spring (VMware Tanzu) công bố 31/03/2022 — https://spring.io/security/cve-2022-22965 Spring cũng đăng một **bài FAQ hậu kiện** đính chính hiểu lầm phổ biến về phạm vi khai thác. Bạn nên lấy cả hai. *Về mức độ: bài của bạn ghi **Nghiêm trọng theo Spring" mà không ghi CVSS. Tôi đồng ý rằng Spring không gán điểm CVSS trong advisory, nhưng **NVD (NIST) đã chấm 9,8** cho CVE này. Tôi không hoàn toàn chắc con số NVD có còn hiện hành hay không, nên hãy kiểm tra trang NVD.* --- ### 1. Trả lời thẳng câu hỏi của bạn trước: ...	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #07 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://spring.io/blog/2022/03/31/spring-framework-rce-early-announcement/. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — mô tả tham số đối tượng được Spring data bind (thường qua <code>@ModelAttribute</code>), cùng các điều kiện JDK 9+, Tomcat và triển khai WAR của [advisory CVE](https://spring.io/security/cve-2022-22965/). Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng "RÀNG BUỘC CỐT LỖI VỀ AI"): ### 07. Spring Framework RCE qua data binding — CVE-2022-22965 (2022) - **Nguồn và ngày công bố:** [Spring, 31/03/2022] (https://spring.io/security/cve-2022-22965/). - **Mô tả:** Ứng dụng Spring MVC/WebFlux chạy JDK 9+ có thể bị thực thi mã từ xa qua data binding. Đường khai thác cụ thể được Spring mô tả cần Tomcat và triển khai dạng WAR; JAR thực thi mặc định của Spring Boot không chịu ảnh hưởng theo đường này. - **Mức độ:** **Nghiêm trọng theo Spring". - **Hậu quả:** Kẻ tấn công có thể chạy mã trên máy chủ ứng dụng nếu các điều kiện khai thác được đáp ứng. - **Cách khắc phục:** Nâng Spring Framework lên **5.3.18** hoặc **5.2.20.RELEASE** tương ứng; rà soát kiểu triển khai thực tế. - **RÀNG BUỘC CỐT LỖI VỀ AI — #07 (giải thích sai điều kiện data binding): ** Trong câu trả lời của **OpenCode – Big Pickle, 23:30 26/09/2026** ở [prompt log](./Appendix_A_Prompt_Log.md), AI nêu controller bind dữ liệu từ request **ví dụ qua <code>@RequestParam</code>** như một điều kiện khai thác CVE-2022-22965. [Thông báo kỹ thuật của Spring] (https://spring.io/blog/2022/03/31/spring-framework-rce-early-announcement/) xác định đường data binding liên quan tới tham số controller có

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				***@ModelAttribute` hoặc không gắn annotation Spring Web khác***; thông báo không liệt kê `@RequestParam` làm ví dụ cho đường khai thác này. AI đã đánh đồng việc đọc tham số request nói chung với việc bind thuộc tính của một đối tượng. **Sửa đúng:** mô tả tham số đối tượng được Spring data bind (thường qua `@ModelAttribute`), cùng các điều kiện JDK 9+, Tomcat và triển khai WAR của [advisory CVE](https://spring.io/security/cve-2022-22965/).
Artifact 10 — Giải thích lỗi phần mềm #08 (Appendix A, lượt #13) Công cụ: OpenCode - Big Pickle Thời gian: 23:42 26/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2022-26134 trên Confluence Server/Data Center: cơ chế OGNL injection, yêu cầu xác thực, phạm vi sản phẩm, hậu quả, bằng chứng khai thác và các phiên bản vá. Phân biệt Server/Data Center với Cloud; dẫn advisory Atlassian.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #13 ## CVE-2022-26134 — OGNL injection không xác thực trên Confluence Server/Data Center **Phân loại:** lỗ hổng bảo mật thật, có CVE chính thức của Atlassian, **RCE không cần xác thực**. **Nguồn:** advisory của Atlassian, công bố **04/04/2022** — https://confluence.atlassian.com/security/security-advisories (trang tổng hợp; Atlassian dùng cơ chế CSAF để phát hành chi tiết từng CVE). *Về mức độ: tôi **không nhớ chắc** Atlassian có gán CVSS trong advisory hay không. Tôi cũng **không nhớ chắc** NVD chấm cho CVE này là **9,8 hay 10,0** — tôi đã thấy cả hai con số trong tài liệu khác nhau. Bạn phải mở NVD để chốt. Tôi nêu ra điểm này ngay ở đầu vì nó là nơi dễ sai nhất của mục này.* --- ### 1. Yêu ...	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #08 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://confluence.atlassian.com/doc/confluence-security-advisory-2022-06-02-1130377146.html. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — lỗi RCE không cần xác thực này được công bố 02/06/2022, đã có khai thác thực tế trên Server/Data Center; Cloud không bị ảnh hưởng và không có bằng chứng khai thác Cloud trong điều tra của Atlassian. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 08. Confluence Server/Data Center OGNL injection — CVE-2022-26134 (2022) - **Nguồn và ngày công bố:** [Atlassian, 02/06/2022] (https://confluence.atlassian.com/doc/confluence-security-advisory-2022-06-02-1130377146.html). - **Mô tả:** Lỗi OGNL injection cho phép người **không cần đăng nhập** thực thi mã trên Confluence Server/Data Center để bị ảnh hưởng. Atlassian đã ghi nhận khai thác thực tế. - **Mức độ:** **Ngghiêm trọng theo Atlassian**. - **Hậu quả:** Máy chủ tự quản có thể bị chiếm quyền, dữ liệu hoặc dịch vụ có thể bị ảnh hưởng; không suy rộng sang Confluence Cloud. - **Cách khắc phục:** Nâng lên nhánh đã vá, ví dụ **7.4.17, 7.13.7, 7.14.3, 7.15.2, 7.16.4, 7.17.4 hoặc 7.18.1** theo nhánh dùng; kiểm tra dấu hiệu xâm nhập. - **RÀNG BUỘC

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				CỐT LỖI VỀ AI — #08 (ảo giác về tình trạng khai thác):** Trong câu trả lời của **OpenCode – Big Pickle, 23:42 26/09/2026** ở [prompt log](../Appendix_A_Prompt_Log.md), AI khẳng định Atlassian “**không ghi nhận bất kỳ vụ khai thác nào**” và suy ra mức khai thác ngoài đời thấp. [Advisory gốc của Atlassian](https://confluence.atlassian.com/doc/confluence-security-advisory-2022-06-02-1130377146.html) nói rõ hãng đã biết có **khai thác đang diễn ra** đối với Confluence Server/Data Center; câu “không thấy bằng chứng khai thác” trong advisory chỉ dành cho **Atlassian Cloud**”. AI đã nhầm phạm vi sản phẩm và đảo ngược kết luận của nguồn. AI cũng ghi ngày công bố **04/04/2022**”, trong khi advisory hiển thị **02/06/2022**”. **Sửa đúng:** **lỗi RCE không cần xác thực này được công bố 02/06/2022, đã có khai thác thực tế trên Server/Data Center; Cloud không bị ảnh hưởng và không có bằng chứng khai thác Cloud trong điều tra của Atlassian.
Artifact 11 — Giải thích lỗi phần mềm #09 (Appendix A, lượt #14) Công cụ: OpenCode - Big Pickle Thời gian: 23:49 26/09/2026 Prompt nguyên văn: Hãy giải thích riêng CVE-2022-41082 của Exchange Server: cơ chế, điều kiện khai thác, vai trò của CVE-2022-41040 trong chuỗi tấn công, hậu quả và bản vá. Phân biệt Exchange Server tại chỗ với Exchange Online; dẫn nguồn Microsoft.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #14 ## CVE-2022-41082 — chuỗi "ProxyNotShell" trên Microsoft Exchange Server **Phân loại:** lỗi hồng bảo mật thật, có CVE chính thức của Microsoft, **Leo thang đặc quyền dẫn tới RCE**". Bản thân nó **không** cho RCE không cần xác thực — cần đọc kỹ phần 2. **Nguồn Microsoft:** 1. Hồ sơ CVE của Microsoft, công bố **11/10/2022** (bản vá đầy đủ): https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41082 2. Hồ sơ CVE-2022-41040 (mất tích trước đó, công bố 30/09/2022):	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #09 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://www.microsoft.com/en-us/msrc/blog/2022/09/customer-guidance-for-reported-zero-day-vulnerabilities-in-microsoft-exchange-server. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — kẻ tấn công đã xác thực có thể dùng 41040 để kích hoạt 41082 từ xa. Microsoft phát hành bản cập nhật bảo mật cho cả hai vào **08/11/2022**", không phải 11/10/2022 như AI ghi. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 09. Exchange Server PowerShell RCE — CVE-2022-41082 (2022) - **Nguồn và ngày công bố:** [Microsoft MSRC, 30/09/2022; cập nhật bản vá 08/11/2022](https://www.microsoft.com/en-us/msrc/blog/2022/09/customer-guidance-for-reported-zero-day-vulnerabilities-in-

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41040 3. Bài Microsoft Security Blog về ProxyLogon, cuối tháng 09/2022. *Về mức độ: tôi **khá chắc** Microsoft chấm **CVE-2022-41082 = 8,8 (High)** và ...			microsoft-exchange-server). - **Mô tả:** Lỗi cho phép thực thi mã từ xa khi PowerShell của Exchange có thể được kẻ tấn công truy cập. Trong chiến dịch được Microsoft ghi nhận, CVE-2022-41040 (SSRF) được dùng **cùng** CVE-2022-41082; đây là mục về riêng lỗi 41082, không tính chuỗi hai CVE thành hai mục. - **Mức độ:** **Cao — đánh giá của báo cáo ** cho lỗi RCE trong điều kiện cần quyền xác thực; nguồn trên không nêu CVSS. - **Hậu quả:** Kẻ tấn công đã xác thực có thể chạy mã trên Exchange Server tại chỗ; Microsoft ghi nhận các cuộc tấn công có mục tiêu ở phạm vi hạn chế. Exchange Online không cần xử lý theo thông báo này. - **Cách khắc phục:** Cài bản cập nhật bảo mật Exchange Server cho CVE-2022-41082 do Microsoft phát hành 08/11/2022; rà soát dấu hiệu tấn công. - **RÀNG BUỘC CỐT LỖI VỀ AI — #09 (ảo giác về điều kiện xác thực): ** Trong câu trả lời của **OpenCode – Big Pickle, 23:49 26/09/2026** ở [prompt log](../Appendix_A_Prompt_Log.md), AI gọi CVE-2022-41040 là **Vượt xác thực** và nói kẻ tấn công có thể bắt đầu chuỗi khai thác khi **không cần thông tin đăng nhập nào**. [Thông báo MSRC của Microsoft](https://www.microsoft.com/en-us/msrc/blog/2022/09/customer-guidance-for-reported-zero-day-vulnerabilities-in-microsoft-exchange-server) xác định CVE-2022-41040 là lỗi **SSRF**, CVE-2022-41082 là lỗi **RCE**, và nêu rõ phải có quyền truy cập **đã xác thực** vào Exchange Server để khai thác thành công **bất kỳ lỗi nào trong hai lỗi**. AI đã mô tả sai 41040 thành lỗi vượt xác thực, làm sai điều kiện khai thác của cả chuỗi.

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				Sửa đúng: kẻ tấn công đã xác thực có thể dùng 41040 để kích hoạt 41082 từ xa. Microsoft phát hành bản cập nhật bảo mật cho cả hai vào **08/11/2022** , không phải 11/10/2022 như AI ghi.
Artifact 12 — Giải thích lỗi phần mềm #10 (Appendix A, lượt #15) Công cụ: OpenCode - Big Pickle Thời gian: 23:53 26/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2022-3602: dữ liệu đầu vào nào gây tràn bộ đệm, điều kiện để đi đến mã để bị lỗi, hậu quả đã quan sát so với khả năng RCE, mức độ nghiêm trọng cuối cùng và phiên bản vá. Dẫn advisory OpenSSL.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #15 ## CVE-2022-3602 — tràn bộ đệm 4 byte khi kiểm tra chứng chỉ X.509 (OpenSSL 3.0.x) **Phân loại:** lỗi hỏng bảo mật thật, có CVE chính thức, **tràn bộ đệm trên ngăn xếp (stack-based buffer overflow)** **Nguồn OpenSSL:** advisory của OpenSSL, phát hành **01/11/2022** cùng bản **OpenSSL 3.0.7** — https://www.openssl.org/news/secadv/20221101.txt **Mức độ — và đây là chỗ tôi cần nói thẳng với bạn ngay:** Theo trí nhớ của tôi, OpenSSL đã **tự xếp mức cho lỗi hỏng này là LOW (Thấp)**, kèm tuyên bố rằng **RCE "không có khả năng" (not likely)**. Tôi khá chắc về điều này vì nó là điểm gây tranh cãi lớn nhất của sự cố. > **Cảnh báo cho bài của bạn:** mục #10 đang ghi mức độ là **"Cao theo OpenSSL"**. ... 	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #10 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://mta.openssl.org/pipermail/openssl-project/2022-November/003047.html . ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — mức độ **High theo OpenSSL** , hậu quả có thể là DoS hoặc RCE trong điều kiện phù hợp; chưa có bằng chứng khai thác thực tế tại thời điểm công bố. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 10. Tràn bộ đệm OpenSSL khi kiểm tra chứng chỉ — CVE-2022-3602 (2022) - **Nguồn và ngày công bố:** [OpenSSL, advisory ký số 01/11/2022](https://mta.openssl.org/pipermail/openssl-project/2022-November/003047.html). - **Mô tả:** Tràn 4 byte do địa chỉ email trong chứng chỉ X.509 khi kiểm tra name constraints, **sau** bước xác thực chữ ký chuỗi chứng chỉ; đường khai thác cần chứng chỉ được CA ký hoặc ứng dụng tiếp tục kiểm tra dù đường tin cậy thất bại. Ảnh hưởng OpenSSL 3.0.0–3.0.6. - **Mức độ:** **Cao theo OpenSSL** ; mức công bố cuối đã hạ từ dự báo “Critical”. - **Hậu quả:** Có thể làm tiến trình sập; thực thi mã từ xa chỉ là khả năng trong điều kiện phù hợp. OpenSSL nói **chưa biết mã khai thác RCE hoạt động và chưa có bằng chứng khai thác** khi công bố. - **Cách khắc phục:** Nâng lên **OpenSSL 3.0.7** hoặc bản mới hơn phù hợp. - **RÀNG BUỘC CỐT LỖI VỀ AI — #10 (ảo giác về mức độ và khả năng RCE): ** Trong câu trả lời của **OpenCode – Big Pickle, 23:53 26/09/2026** ở [prompt log](../Appendix_A_Prompt_Log.md), AI nhiều lần nói OpenSSL xếp CVE-2022-

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				3602 mức “**LOW (Thấp)**”, khuyên sửa mục này từ “Cao theo OpenSSL” thành “Thấp theo OpenSSL”, và khẳng định RCE “**không có khả năng**”. [Advisory ký số của OpenSSL](https://mta.openssl.org/pipermail/openssl-project/2022-November/003047.html) ghi rõ “**Severity: High**”: mức dự báo ban đầu là Critical, sau phân tích được hạ xuống “**High**”, không phải Low. Advisory cũng nêu trần “**bốn byte do kẻ tấn công kiểm soát**” có thể gây sập tiến trình hoặc “có khả năng” dẫn tới RCE; lúc công bố OpenSSL “**chưa biết mã khai thác RCE hoạt động**”, chứ không phủ nhận khả năng RCE. [Bài giải thích của OpenSSL](https://mirror.openssl-library.org/post/2022-11-01-email-address-overflows/) nói khả năng RCE vẫn có thể tồn tại trên một số nền tảng. AI đã biến việc chưa thấy exploit thành kết luận không thể RCE và khuyên sửa sai mức độ vốn đã đúng trong báo cáo. “**Sửa đúng:**” mức độ “**High theo OpenSSL**”, hậu quả có thể là DoS hoặc RCE trong điều kiện phù hợp; chưa có bằng chứng khai thác thực tế tại thời điểm công bố.
Artifact 13 — Giải thích lỗi phần mềm #11 (Appendix A, lượt #16) Công cụ: OpenCode - Big Pickle Thời gian: 23:56 26/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2023-34362 trong MOVEit Transfer: cơ chế SQL injection, có cần đăng nhập không, dữ liệu/hệ thống có thể bị ảnh hưởng thế nào, điều gì đã được ghi nhận khi khai thác và cách xử lý. Dẫn thông báo Progress và hồ sơ CVE.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #16 ## CVE-2023-34362 — SQL injection không cần xác thực trong MOVEit Transfer **Phân loại:** lỗ hổng bảo mật thật, có CVE chính thức, “**SQL injection tiền xác thực**”, “**zero-day đã bị khai thác ngoài đời**”. “**Nguồn:**” 1. Thông báo khẩn cấp của Progress (KB/Khuyến nghị bảo mật MOVEit Transfer), đăng “**31/05/2023**” — https://www.progress.com/support/kb/notice/security-advisory-moveit-	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #11 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://content.govdelivery.com/accounts/USDHSCISA/bulletins/35ecb08. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — phân biệt yêu cầu khai thác SQL injection với web shell “human2.aspx” được cài sau đó; không coi tên web shell là tên endpoint dễ lỗi. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỎI VỀ AI”): ### 11. Lỗi SQL injection trong MOVEit Transfer — CVE-2023-34362 (2023) - “**Nguồn và ngày công bố:**” [Progress, FAQ xác nhận công bố 31/05/2023 và bản vá](https://www.progress.com/docs/default-source/mov

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
	transfer (tôi không chắc chính xác mã số KB và đường dẫn; cần lấy lại từ trang hỗ trợ của Progress) 2. Hồ sơ CVE — https://www.cve.org/CVERecord?id=CVE-2023-34362 (và trang NVD tương ứng) **Đây là mục khác biệt rõ nhất với tất cả mục trước:** nó có **hậu quả đã xác nhận bằng số liệu thực tế** — hàng nghìn tổ chức và ...			eit-docs/moveit-transfer_moveit-cloud-vulnerabilities-customer-faq_posted.pdf?sfvrsn=16a47a99_13); [NIST NVD, mô tả kỹ thuật và CVSS](https://nvd.nist.gov/vuln/detail/CVE-2023-34362). - **Mô tả:** SQL injection trong ứng dụng web MOVEit Transfer có thể cho kẻ tấn công **không xác thực** truy cập cơ sở dữ liệu; phạm vi thao tác phụ thuộc hệ quản trị CSDL. NVD ghi nhận lỗi bị khai thác trong tháng 5–6/2023. - **Mức độ:** **Nghiêm trọng, CVSS 9,8 theo NIST NVD** - **Hậu quả:** Có thể đọc, thay đổi hoặc xóa dữ liệu; thông tin lưu trong hệ thống truyền tệp có nguy cơ bị đánh cắp. Mức thiệt hại của từng khách hàng cần bằng chứng điều tra riêng. - **Cách khắc phục:** Cài bản vá theo nhánh phiên bản do Progress phát hành; cô lập máy nghi bị xâm nhập, rà soát log và dữ liệu. - **RÀNG BUỘC CỐT LỖI VỀ AI — #11 (nhằm web shell với điểm vào SQL injection):** Trong câu trả lời của **OpenCode – Big Pickle, 23:56 26/09/2026** ở [prompt log](../Appendix_A_Prompt_Log.md), AI viết “lỗ hổng nằm ở một endpoint web” rồi đoán endpoint đó là **`human2.aspx`” (AI có ghi không chắc). [Cảnh báo chung của CISA và FBI] (https://content.govdelivery.com/accounts/USDHSCISA/bulletins/35ecb08) xác định **`human2.aspx` là tên ban đầu của **web shell LEMURLOOT được cài lên MOVEit sau khi khai thác**, nhằm nguy trang thành tệp hợp lệ **`human.aspx`; đây không phải endpoint chứa lỗi SQL injection. Trong [phân tích khai thác thực nghiệm của Huntress] (https://www.huntress.com/blog/moveit-transfer-critical-vulnerability-rapid-response), yêu cầu tới **`moveitisapi.dll` được dùng để thực hiện SQL injection,

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				còn truy cập 'human2.aspx' là tương tác với cửa hậu đã đặt. AI đã lấy dấu vết của giai đoạn sau xâm nhập làm nguyên nhân/điểm vào ban đầu và gán phồng đoán đó cho thông báo Progress. **Sửa đúng:** phân biệt yêu cầu khai thác SQL injection với web shell 'human2.aspx' được cài sau đó; không coi tên web shell là tên endpoint dễ lỗi.
Artifact 14 — Giải thích lỗi phần mềm #12 (Appendix A, lượt #17) Công cụ: OpenCode - Big Pickle Thời gian: 00:00 27/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2023-2868 trên Barracuda Email Security Gateway: cách tệp TAR kích hoạt lỗi, phạm vi phiên bản, hậu quả đã ghi nhận, bản vá và lý do Barracuda khuyến nghị thay một số thiết bị. Phân biệt thiết bị ESG với dịch vụ SaaS; dẫn nguồn Barracuda.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #17 ## CVE-2023-2868 — chèn lệnh qua giải nén tệp TAR trên Barracuda Email Security Gateway **Phân loại:** lỗ hổng bảo mật thật, có CVE chính thức, **RCE cần điều kiện (chạy ở chế độ đặc quyền)** , **đã bị khai thác ngoài đời** . **Nguồn Barracuda: ** thông báo bảo mật của Barracuda, tháng 5/2023. Barracuda đăng thông báo trên cổng hỗ trợ của hãng, và đồng thời đưa ra hướng dẫn riêng cho khách hàng ESG. *Tôi **không nhớ chắc** tên bài và đường dẫn chính xác, cũng không nhớ chắc ngày công bố là 19 hay 24/05/2023 — bạn phải lấy lại từ trang chính thức của Barracuda.* Hồ sơ CVE: https://www.cve.org/CVERecord?id=CVE-2023-2868 **Đây là mục có tính chất khác biệt nhất trong 20 mục:** nó không chỉ là lỗ ...	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #12 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://trust.barracuda.com/security/esg-vulnerability . ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — tệp TAR độc hại kích hoạt thực thi lệnh qua xử lý tên tệp thiếu kiểm tra; không mô tả CVE-2023-2868 là lỗi giải nén ghi tệp ra ngoài thư mục. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 12. Barracuda ESG command injection qua tên tệp TAR — CVE-2023-2868 (2023) - **Nguồn và ngày công bố:** [Barracuda, công bố tháng 05/2023 và cập nhật điều tra](https://trust.barracuda.com/security/esg-vulnerability). - **Mô tả:** Bộ kiểm tra tệp đính kèm của **thiết bị ESG** xác thực chưa đủ tên tệp trong kho TAR, dẫn đến chèn lệnh và thực thi với quyền tiến trình ESG. Barracuda xác nhận lỗ hổng tồn tại trên thiết bị phiên bản 5.1.3.001–9.2.0.006, không phải dịch vụ email SaaS của hãng. - **Mức độ:** ** Nghiêm trọng — đánh giá của báo cáo ** vì đã có khai thác và truy cập trái phép. - **Hậu quả:** Barracuda xác nhận một số thiết bị có mã độc duy trì truy cập và một số có bằng chứng dữ liệu bị lấy ra. - **Cách khắc phục:** Barracuda đã triển khai bản vá ngày 20/05/2023; với **thiết bị đã bị xâm nhập** , hãng tiếp tục khuyến nghị **thay thiết bị** , rồi điều tra và đối thông tin xác thực liên quan. - **RÀNG BUỘC CỐT LỖI VỀ AI — #12 (ảo giác về cơ chế lỗi): ** Trong câu trả

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				lỗi của OpenCode – Big Pickle , 00:00 27/09/2026 ở [prompt log](./Appendix_A_Prompt_Log.md), AI khẳng định nguyên nhân gốc là path traversal khi giải nén TAR (dạng Zip Slip), diễn giải tên tệp chứa <code>../</code> sẽ bị ghi ra ngoài thư mục đích rồi dẫn tới RCE. [Thông báo kỹ thuật của Barracuda] (https://trust.barracuda.com/security/esg-vulnerability) xác định đây là chèn lệnh từ tên tệp trong kho TAR: tên tệp được định dạng để lệnh hệ thống chạy qua toán tử <code>qx</code> của Perl, với quyền của tiến trình ESG. Nguồn không mô tả bước ghi tệp vượt thư mục như AI khẳng định; đây là cơ chế path traversal khác với cơ chế command injection đã được hăng công bố. AI còn đánh dấu cách giải thích Zip Slip là “Sự thật” dù mâu thuẫn với nguồn. Sửa đúng: tệp TAR độc hại kích hoạt thực thi lệnh qua xử lý tên tệp thiếu kiểm tra; không mô tả CVE-2023-2868 là lỗi giải nén ghi tệp ra ngoài thư mục.
Artifact 15 — Giải thích lỗi phần mềm #13 (Appendix A, lượt #18) Công cụ: OpenCode - Big Pickle Thời gian: 00:04 27/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2023-23397 trên Outlook for Windows: thuộc tính MAPI gây kết nối tới máy chủ tấn công như thế nào, có cần người dùng bấm vào thư không, dữ liệu nào bị lộ, hậu quả và biện pháp khắc phục. Nêu các phiên bản Outlook không thuộc phạm vi; dẫn Microsoft.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #18 ## CVE-2023-23397 — Outlook for Windows tự kết nối tới máy chủ SMB của kẻ tấn công khi nhận email Phân loại: lỗ hổng bảo mật thật, có CVE chính thức, Leo thang đặc quyền, không cần người dùng tương tác, đã bị khai thác thật. Nguồn Microsoft: hồ sơ CVE trong Microsoft Security Response Center (MSRC), bản vá phát hành 14/03/2023 — https://msrc.microsoft.com/update-guide/vulnerability/CVE-2023-23397 Mức độ: theo trí nhớ của tôi, Microsoft chấm 9,8 (Critical). Tôi khá chắc vì đây là một trong những lỗ hổng hiểm mà Microsoft vừa vá	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #13 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://www.microsoft.com/en-us/msrc/blog/2023/03/microsoft-mitigates-outlook-elevation-of-privilege-vulnerability. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — thông điệp độc hại mang đường dẫn UNC trong <code>PidLidReminderFileParameter</code>, khiến Outlook for Windows có thể kết nối SMB và để lộ thông tin thương lượng NTLM mà không cần người dùng tương tác. Artifact đã sửa trong <code>Requirement_2_20_Published_Software_Defects_2022_2026.md</code> (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 13. Outlook for Windows gửi thông tin xác thực NTLM — CVE-2023-23397 (2023) - Nguồn và ngày công bố: [Microsoft MSRC, 14/03/2023] (https://www.microsoft.com/en-us/msrc/blog/2023/03/microsoft-mitigates-outlook-elevation-of-privilege-vulnerability). - Mô tả: Thuộc tính MAPI

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
	vừa **công bố đang bị khai thác**. Phải mở hồ sơ MSRC để xác nhận con số. --- ### 0. Vì sao mục này đáng chú ý nhất về mặt kỹ ...			trong thư/tác vụ trở tới SMB của kẻ tấn công có thể khiến Outlook for Windows tự kết nối, **không cần người dùng tương tác**, làm lộ thông tin thương lượng NTLM có thể bị relay. - **Mức độ:** **Nghiêm trọng theo Microsoft**. - **Hậu quả:** Microsoft ghi nhận lạm dụng có mục tiêu ở phạm vi hạn chế. Nguy cơ chính là thông tin xác thực bị lợi dụng để xác thực tới hệ thống khác; Outlook web, Mac, iOS và Android không nằm trong phạm vi lỗi này. - **Cách khắc phục:** Cập nhật **Outlook for Windows** dù thư được lưu ở đâu; dùng công cụ kiểm tra mục MAPI độc hại do Microsoft cung cấp, điều tra tài khoản liên quan. - **RÀNG BUỘC CỐT LÕI VỀ AI — #13 (ảo giác về thuộc tính MAPI gây lỗi): **Trong câu trả lời của *OpenCode – Big Pickle, 00:04 27/09/2026** ở [prompt log] (./Appendix_A_Prompt_Log.md), AI nói kẻ tấn công đặt đường dẫn UNC làm **tên** của một thuộc tính MAPI tùy chỉnh, rồi Outlook phân giải tên thuộc tính đó như tài nguyên mạng. [Thông báo MSRC của Microsoft](https://www.microsoft.com/en-us/msrc/blog/2023/03/microsoft-mitigates-outlook-elevation-of-privilege-vulnerability) xác định đường dẫn nằm **trong giá trị** của thuộc tính thông điệp **`PidLidReminderFileParameter`, bản vá ngăn Outlook dùng đường dẫn này để phát âm thanh nhắc nhở khi nó trở ra ngoài mạng tin cậy. AI đã đổi vị trí dữ liệu từ giá trị sang tên thuộc tính và tự dựng một nhánh xử lý “định nghĩa thuộc tính” mà nguồn không nêu. **Sửa đúng:** thông điệp độc hại mang đường dẫn UNC trong **`PidLidReminderFileParameter`, khiến Outlook for Windows có thể kết nối SMB và để lộ thông tin thương lượng NTLM mà

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Artifact 16 — Giải thích lỗi phần mềm #14 (Appendix A, lượt #19) Công cụ: OpenCode - Big Pickle Thời gian: 00:08 27/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2023-4966 của NetScaler ADC/Gateway: loại dữ liệu có thể lộ, cấu hình nào bị ảnh hưởng, điều gì đã được xác nhận về khai thác, hậu quả và cách vá/xử lý phiên có nguy cơ. Không suy rộng sang mọi thiết bị NetScaler; dẫn advisory Citrix.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #19 ## CVE-2023-4966 — rò rỉ phiên (session token) trên NetScaler ADC/Gateway, gọi tên "CitrixBleed" **Phân loại:** lỗi hỏng bảo mật thật, có CVE chính thức của Citrix, **đọc bộ nhớ không cần xác thực**, **đã bị khai thác quy mô lớn**. **Nguồn Citrix:** thông báo bảo mật của Citrix (Citrix Security Advisory), phát hành **17/10/2023** — https://support.citrix.com/article/breaking-news-vulnerability-cve-2023-4966 (tôi không chắc chính xác tiêu đề và URL; phải lấy lại từ cổng hỗ trợ Citrix) Hồ sơ CVE: https://www.cve.org/CVERecord?id=CVE-2023-4966 *Về mức độ: tôi **không nhớ chắc** Citrix hay NVD chấm bao nhiêu cho CVE này. Tôi có cảm giác là con số có phần thấp hơn 9,8 (có thể 9,4), nhưng **đây là ...	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #14 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://support.citrix.com/external/article/579459/netscaler-adc-and-netscaler-gateway-secu.html. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — đánh giá theo vai trò Gateway/AAA và phiên bản phần mềm; cài bản cập nhật phù hợp, điều tra và xử lý các phiên có nguy cơ theo hướng dẫn của hãng. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 14. NetScaler ADC/Gateway làm lộ dữ liệu nhạy cảm — CVE-2023-4966 (2023) - **Nguồn và ngày công bố:** [Citrix/Cloud Software Group, 10/10/2023](https://support.citrix.com/external/article/579459/netscaler-adc-and-netscaler-gateway-secu.html). - **Mô tả:** Lỗi tiết lộ thông tin nhạy cảm ảnh hưởng thiết bị cấu hình làm Gateway hoặc máy chủ AAA; Citrix đã bổ sung xác nhận khai thác trong bản cập nhật ngày 17/10/2023. - **Mức độ:** Cao — đánh giá của báo cáo dựa trên nguy cơ lộ thông tin và khai thác đã quan sát; advisory dẫn không gán mức CVSS ngay trong bảng. - **Hậu quả:** Thông tin của phiên/kết nối có nguy cơ lộ, dẫn tới truy cập trái phép nếu bị lợi dụng. Không suy ra mọi thiết bị NetScaler đều bị ảnh hưởng. - **Cách khắc phục:** Nâng lên bản sửa đúng nhánh, chẳng hạn **14.1-8.50**, **13.1-49.15** hoặc **13.0-92.19** trở lên; kiểm tra dấu hiệu xâm nhập và xử lý phiên có nguy cơ theo hướng dẫn NetScaler. - **RÀNG BUỘC CỐT LỖI VỀ AI — #14 (áo giắc về điều kiện cấu hình): Trong câu trả lời của OpenCode – Big Pickle, 00:08 27/09/2026 ở [prompt log](../Appendix_A_Prompt_Log.md), AI nói CVE-2023-4966 “chỉ trong cấu hình xác thực cục bộ” và khuyên “tắt xác thực cục bộ” như biện pháp giảm thiểu trước khi vá. [Advisory của Citrix/Cloud

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				Software Group](https://support.citrix.com/external/article/579459/netscaler-adc-and-netscaler-gateway-secu.html) ghi điều kiện ảnh hưởng là NetScaler ADC/Gateway được cấu hình làm **Gateway** (VPN, ICA Proxy, CVPN hoặc RDP Proxy) **hoặc AAA virtual server** ; advisory không giới hạn vào cơ chế xác thực cục bộ và mục “Mitigating Factors” ghi **None** . AI đã tự thêm điều kiện loại trừ các hệ thống dùng xác thực ngoài, có thể khiến người quản trị bỏ sót thiết bị cần vá. **Sửa đúng:** đánh giá theo vai trò Gateway/AAA và phiên bản phần mềm; cài bản cập nhật phù hợp, điều tra và xử lý các phiên có nguy cơ theo hướng dẫn của hãng.
Artifact 17 — Giải thích lỗi phần mềm #15 (Appendix A, lượt #20) Công cụ: OpenCode - Big Pickle Thời gian: 00:20 27/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2023-20198 trong Web UI của Cisco IOS XE: điều kiện cấu hình, quyền kẻ tấn công có thể tạo, hậu quả đã quan sát, bản vá và mối liên hệ với CVE-2023-20273. Tách rõ khả năng của từng CVE; dẫn advisory Cisco.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #20 ## CVE-2023-20198 và CVE-2023-20273 — Cisco IOS XE Web UI: leo thang đặc quyền và phơi bày Web UI **Phân loại:** đây là **hai lỗ hổng riêng biệt** , có hai CVE riêng, **hai thông báo bảo mật riêng** của Cisco. Đầu là lỗ hổng thật. Cả hai **liên kết chặt với nhau** để tạo thành một chuỗi tấn công, nhưng **không phải cùng một lỗi** . **Nguồn Cisco (hai thông báo, cùng ngày 16/10/2023): ** - CVE-2023-20198 — thông báo "Web UI Privilege Escalation": https://tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-iosxe-webui-privesc-CVE-2023-20273 — thông báo "Web UI Interface Exposure": ...	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #15 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://www.cisco.com/c/en/us/support/docs/csa/cisco-sa-iosxe-webui-privesc-j22SaA4z.html . ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — 20198 là bước tạo tài khoản đặc quyền không cần xác thực; 20273 là bước tiếp theo để đạt quyền root/cài implant trong chiến dịch được Cisco ghi nhận. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 15. Cisco IOS XE Web UI cho tạo tài khoản đặc quyền — CVE-2023-20198 (2023) - **Nguồn và ngày công bố:** [Cisco, 16/10/2023] (https://www.cisco.com/c/en/us/support/docs/csa/cisco-sa-iosxe-webui-privesc-j22SaA4z.html). - **Mô tả:** Khi bật Web UI ('ip http server'/ip http secure-server'), kẻ tấn công từ xa không xác thực có thể tạo tài khoản cục bộ quyền 15. Cisco ghi nhận khai thác thực tế. Việc cài implant với quyền root trong chiến dịch còn dùng **lỗi khác** CVE-2023-20273. - **Mức độ:** **Nghiêm trọng , CVSS 10,0 theo Cisco ** cho CVE-2023-20198. - **Hậu quả:** Thiết bị mạng có thể xuất hiện tài khoản quản trị trái phép; nếu có thêm

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				điều kiện/lỗi thứ hai, kẻ tấn công có thể kiểm soát sâu hơn. - Cách khắc phục: Nâng IOS XE lên bản sửa đúng nhánh; tắt Web UI nếu không cần hoặc giới hạn nguồn được truy cập, kiểm tra tài khoản lạ. - RÀNG BUỘC CỐT LỖI VỀ AI — #15 (đảo ngược vai trò hai CVE): Trong câu trả lời của OpenCode – Big Pickle , 00:20 27/09/2026 ở [prompt log](../Appendix_A_Prompt_Log.md), AI viết CVE-2023-20198 cần đăng nhập còn CVE-2023-20273 không cần đăng nhập và tự tạo được tài khoản quyền 15. [Advisory của Cisco](https://www.cisco.com/c/en/us/support/docs/csa/cisco-sa-iosxe-webui-privesc-j22SaA4z.html) mô tả trình tự ngược lại: kẻ tấn công trước tiên dùng CVE-2023-20198 để truy cập ban đầu và tạo tài khoản cục bộ bằng lệnh quyền 15; sau đó dùng tài khoản mới cùng CVE-2023-20273 để nâng quyền lên root và ghi implant. Cisco chấm 10,0 cho 20198 và 7,2 cho 20273, cũng khác bằng AI ghi cả hai đều 10,0. AI đã gán năng lực của lỗi thứ nhất cho lỗi thứ hai, làm sai điều kiện xác thực và chuỗi khai thác. Sửa đúng: 20198 là bước tạo tài khoản đặc quyền không cần xác thực; 20273 là bước tiếp theo để đạt quyền root/cài implant trong chiến dịch được Cisco ghi nhận.
Artifact 18 — Giải thích lỗi phần mềm #16 (Appendix A, lượt #21) Công cụ: OpenCode - Big Pickle Thời gian: 00:23 27/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2024-3094 trong xz Utils/liblzma: mã độc được đưa vào quá trình build ra sao, phiên bản và cấu hình nào có nguy cơ, hậu quả có thể xảy ra so với điều đã xác nhận, và cách xử lý. Có phải mọi	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #21 ## CVE-2024-3094 — backdoor được cài vào chính bộ mã nguồn xz/liblzma, không phải lỗ hổng "dùng sai cách" Phân loại — điểm phải nói đúng ngay từ đầu: đây không phải là lỗ hổng phần mềm theo nghĩa thông thường. Đây là một sự cố chuỗi cung ứng (supply	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #16 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://www.redhat.com/en/blog/urgent-security-alert-fedora-40-and-rawhide-users. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — kiểm tra gói nguồn/bản build xz 5.6.0–5.6.1 và cách chúng được tạo; không suy ra chỉ từ việc mã liên quan hiện diện trong Git rằng build từ Git sẽ kích hoạt cùng backdoor. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022.md (nguyên văn; thay đổi nằm ở dòng “ RÀNG BUỘC CỐT LỖI VỀ AI ”): ### 16. Mã độc cài trong gói xz Utils/liblzma — CVE-2024-3094 (2024) - Nguồn và

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
bản Linux đều bị ảnh hưởng không? Dẫn nguồn nhà phân phối.	chain)**: mã độc đã được **đưa vào bản phát hành chính thức** của xz Utils và được **biên dịch vào thư viện liblzma**. Nếu bài bạn ghi nó là "lỗi hỏng trong thư viện nén" thì sẽ **đánh giá thấp mức nghiêm trọng** và, tệ hơn, sẽ **mô tả sai cơ chế**. **Nguồn:** - Thông báo đầu tiên trên danh sách bảo mật oss-security, do kỹ sư phát hiện đăng, ngày **29/03/2024** (tôi **không chắc** tên và tài khoản cụ thể của người đăng, chỉ nhớ là một ...			ngày công bố;** [Red Hat, 29/03/2024; cập nhật 30/03] (https://www.redhat.com/en/blog/urgent-security-alert-fedora-40-and-rawhide-users). - **Mô tả:** Gói nguồn xz/liblzma **5.6.0 và 5.6.1** chứa mã độc được đưa vào quá trình build; trong cấu hình phù hợp, mã này có thể can thiệp xác thực 'sshd'. Đây là lỗi chuỗi cung ứng được công bố, không phải lỗi "mọi bản Linux". - **Mức độ:** **Nghiêm trọng — đánh giá của báo cáo** do khả năng vượt xác thực và tính chất chuỗi cung ứng. - **Hậu quả:** Có nguy cơ truy cập máy từ xa trái phép trên hệ thống có bản build và cấu hình phù hợp. Red Hat nói **RHEL không bị ảnh hưởng**; Fedora 40 beta có gói liên quan nhưng chưa cho thấy cơ chế độc hại hoạt động trong bản build đó. - **Cách khắc phục:** Ngừng dùng bản 5.6.0/5.6.1 bị ảnh hưởng, quay về **xz 5.4.x** theo hướng dẫn nhà phân phối và rà soát hệ thống đã cài. - **RÀNG BUỘC CỐT LỎI VỀ AI — #16 (ảo giác về đường đưa mã độc vào bản build):** Trong câu trả lời của **OpenCode – Big Pickle, 00:23 27/09/2026** ở [prompt log] (./Appendix_A_Prompt_Log.md), AI viết kể tấn công “**đưa mã vào kho mã nguồn của dự án xz**” và bản phát hành được tạo từ kho đó nên mang theo mã độc; cách giải thích này khiến người đọc hiểu rằng bản build trực tiếp từ Git cũng chứa đầy đủ cơ chế kích hoạt. [Thông báo của Red Hat](https://www.redhat.com/en/blog/urgent-security-alert-fedora-40-and-rawhide-users) phân biệt rõ: phân tiêm mã độc **chỉ có đầy đủ trong gói nguồn tải về** của các bản phát hành liên quan; bản Git **thiếu macro M4 kích hoạt quá trình build mã độc**, dù một số thành phần giai đoạn hai có trong Git. Vì

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				vậy AI đã gộp hai nguồn phân phối mã thành một và bỏ qua bước quyết định khiến tarball phát hành nguy hiểm hơn bản lấy trực tiếp từ Git. **Sửa đúng:** kiểm tra gói nguồn/bản build xz 5.6.0–5.6.1 và cách chúng được tạo; không suy ra chỉ từ việc mã liên quan hiện diện trong Git rằng build từ Git sẽ kích hoạt cùng backdoor.
Artifact 19 — Giải thích lỗi phần mềm #17 (Appendix A, lượt #22) Công cụ: OpenCode - Big Pickle Thời gian: 00:27 27/09/2026 Prompt nguyên văn: Hãy giải thích sự cố bản cập nhật CrowdStrike Falcon ngày 19/07/2024 làm Windows gặp BSOD: lỗi kỹ thuật theo báo cáo RCA, máy nào bị ảnh hưởng, hậu quả đã ghi nhận, cách phục hồi và thay đổi quy trình phát hành. Phân biệt lỗi cập nhật với một cuộc tấn công mạng; dẫn CrowdStrike.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #22 ## Sự cố CrowdStrike 19/07/2024 — BSOD hàng loạt do nội dung cập nhật của hãng, KHÔNG phải tấn công mạng **Phân loại — điểm phải nói trước tiên vì nó quyết định cả mục:** đây **không phải lỗi hổng** , không phải mã độc, không phải tấn công. Đây là **sự cố do bản cập nhật của chính nhà cung cấp gây ra** , trong đó **mã của nhà cung cấp đã bị hệ điều hành dùng sai cách** một cách không chủ ý. Nếu bài bạn xếp nó cùng nhóm với các lỗ hổng khác mà không nói rõ sự khác biệt, giảng viên sẽ hỏi ngay. **Nguồn CrowdStrike:** - Thông báo "Preliminary Post Incident Review" (rà soát sơ bộ sau sự cố), phát hành **22/07/2024** . - Bài phân tích kỹ thuật chi tiết (thường được gọi là RCA/điều tra gốc), phát ...	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #17 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://www.crowdstrike.com/wp-content/uploads/2024/08/Channel-File-291-Incident-Root-Cause-Analysis-08.06.2024.pdf . ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — nội dung cập nhật lỗi kích hoạt lỗi đọc ngoài giới hạn trong mã cảm biến CrowdStrike chạy trên Windows; BSOD là hậu quả của lỗi đó, không phải Windows tự từ chối một cấu hình không được hỗ trợ. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng "RÀNG BUỘC CỐT LỖI VỀ AI"): ### 17. Bản cập nhật CrowdStrike Falcon làm Windows màn hình xanh (2024) - **Nguồn và ngày công bố:** [CrowdStrike, báo cáo sơ bộ 24/07/2024] (https://www.crowdstrike.com/en-us/blog/falcon-content-update-preliminary-post-incident-report/); [RCA đầy đủ 06/08/2024] (https://www.crowdstrike.com/wp-content/uploads/2024/08/Channel-File-291-Incident-Root-Cause-Analysis-08.06.2024.pdf). - **Mô tả:** Rapid Response Content trong Channel File 291 dùng trường đầu vào thứ 21 khi cảm biến chỉ có 20 trường, gây đọc ngoài giới hạn và sập Windows. Lỗi trong bộ kiểm tra nội dung đã để bản cập nhật không hợp lệ vượt qua. - **Mức độ:** **Nghiêm trọng về vận hành — đánh giá của báo cáo** ; đây không phải CVE khai thác từ xa. - **Hậu quả:** Máy Windows nhận bản cập nhật trong khung 04:09–05:27 UTC ngày 19/07/2024 có thể gặp BSOD và gián đoạn dịch vụ; máy Mac/Linux không nằm

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				trong phạm vi. CrowdStrike nói lỗi này **không cho kẻ tấn công leo thang quyền hoặc RCE**. - **Cách khắc phục:** CrowdStrike thu hồi bản nội dung lỗi, hướng dẫn phục hồi máy bị ảnh hưởng; bổ sung kiểm tra ranh giới, kiểm thử nội dung và triển khai theo giai đoạn. - **RÀNG BUỘC CỐT LỖI VỀ AI — #17 (ảo giác về nơi phát sinh lỗi kỹ thuật):** Trong câu trả lời của **OpenCode – Big Pickle, 00:27 27/09/2026** ở [prompt log](../Appendix_A_Prompt_Log.md), AI giải thích “**Windows nhận cấu hình không hợp lệ**” rồi “**tiến trình ở tầng nhân bị dừng**”, đồng thời cho rằng phần hệ điều hành bị lỗi nằm trong một đường xử lý của **Windows**. [RCA của CrowdStrike] (https://www.crowdstrike.com/wp-content/uploads/2024/08/Channel-File-291-Incident-Root-Cause-Analysis-08.06.2024.pdf) xác định lỗi ở **Content Interpreter của cảm biến Falcon**: mẫu nội dung trong Channel File 291 đòi đọc **trường đầu vào thứ 21** trong khi mã cảm biến chỉ cung cấp **20 trường**, gây đọc ngoài giới hạn rồi làm Windows sập. Báo cáo phân tích crash chỉ ra trình điều khiển **`csagent.sys`** của CrowdStrike thực hiện phép đọc sai. AI đã gán sai vị trí lỗi cho cơ chế xử lý của Windows và bỏ qua nguyên nhân 20/21 trường đã được công bố. **Sửa đúng:** nội dung cập nhật lỗi kích hoạt lỗi đọc ngoài giới hạn trong mã cảm biến CrowdStrike chạy trên Windows; BSOD là hậu quả của lỗi đó, không phải Windows tự từ chối một cấu hình không được hỗ trợ.
Artifact 20 — Giải thích lỗi phần mềm #18 (Appendix A, lượt #23) Công cụ: OpenCode - Big Pickle Thời gian: 00:33 27/09/2026	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #23 ## CVE-2025-29927 — Next.js: bỏ qua	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #18 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc:	SỬA ĐÚNG — ứng dụng trên Vercel không bị ảnh hưởng theo kiến trúc triển khai mà Vercel mô tả; ngày công bố công khai là 21/03/2025. Artifact đã sửa

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Prompt nguyên văn: Hãy giải thích CVE-2025-29927: header nào có thể làm Middleware của Next.js bị bỏ qua, ứng dụng cần thiết thể nào mới có nguy cơ vượt quyền, hậu quả và các phiên bản vá. Có phải mọi ứng dụng Next.js đều lộ dữ liệu không? Dẫn advisory dự án.	Middleware bằng một HTTP header, vượt kiểm tra phân quyền **Phân loại:** lỗ hổng xác thực/phân quyền thật, thuộc loại **bỏ qua lớp kiểm tra (security control bypass)***, do chính dự án Next.js công bố và vá. **Nguồn dự án:** thông báo bảo mật của Next.js/Vercel, công bố **18/03/2025**.* **Tôi khá chắc** về ngày và về việc đây là thông báo chính thức của dự án. Tôi **không chốt được** URL chính xác — phải lấy từ mục thông báo bảo mật của Next.js.* **Mức độ:** theo trí nhớ, điểm **CVSS 9,1**.* **Mức chắc chắn:** khá chắc, nhưng **phải mở thông báo để xác nhận**.* --- ### 1. Header nào và cơ chế bỏ qua **Header: `x-middleware-subrequest`** (tên header: chữ ...		https://vercel.com/blog/postmortem-on-next-js-middleware-bypass. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 18. Next.js Middleware bị bỏ qua kiểm tra quyền — CVE-2025-29927 (2025) - **Nguồn và ngày công bố:** [Advisory dự án Next.js trên GitHub, 21/03/2025](https://github.com/vercel/next.js/security/advisories/GHSA-f82v-jwr5-mffw); [Vercel postmortem](https://vercel.com/blog/postmortem-on-next-js-middleware-bypass) - **Mô tả:** Header nội bộ `x-middleware-subrequest` có thể làm Middleware không chạy. Ứng dụng đặt kiểm tra xác thực/phân quyền **chỉ** trong Middleware có thể bị vượt qua; không đồng nghĩa mọi ứng dụng Next.js đều lộ dữ liệu. - **Mức độ:** **Nghiêm trọng, CVSS 9,1 theo GitHub Advisory**.* - **Hậu quả:** Truy cập trái phép trang hoặc thao tác mà ứng dụng dự định chặn bằng Middleware; mức dữ liệu thực tế lộ tùy thiết kế ứng dụng. - **Cách khắc phục:** Cập nhật bản an toàn theo nhánh, ví dụ **12.3.5, 13.5.9, 14.2.25, 15.2.3**.*; nếu chưa thể cập nhật, chặn header trên từ yêu cầu bên ngoài. Kiểm tra quyền ở lớp xử lý dữ liệu nhạy cảm. - **RÀNG BUỘC CỐT LỖI VỀ AI — #18 (ảo giác về lý do Vercel không bị ảnh hưởng):** Trong câu trả lời của **OpenCode – Big Pickle, 00:33 27/09/2026** ở [prompt log](../Appendix_A_Prompt_Log.md), AI nói các ứng dụng triển khai trên Vercel “**đã được bảo vệ ở lớp biên**”. [Postmortem của Vercel](https://vercel.com/blog/postmortem-on-next-js-middleware-bypass) xác định Vercel không bị ảnh hưởng vì **logic định tuyến Next.js chạy tách khỏi quá trình render**.*; hãng còn nói thông báo ban đầu nhắc

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				đến Firewall là cách diễn đạt gây hiểu nhầm, không giải thích đúng cơ chế. AI đã gán sai nguyên nhân bảo vệ cho lớp biên và đưa nó vào điều kiện đánh giá nguy cơ triển khai. AI cũng ghi ngày công bố 18/03/2025 ; postmortem phân biệt ngày GitHub cấp CVE 18/03 với ngày công khai CVE 21/03/2025 , trùng [GitHub Advisory](https://github.com/vercel/next.js/security/advisories/GHSA-f82v-jwr5-mffw). Sửa đúng: ứng dụng trên Vercel không bị ảnh hưởng theo kiến trúc triển khai mà Vercel mô tả; ngày công bố công khai là 21/03/2025.
Artifact 21 — Giải thích lỗi phần mềm #19 (Appendix A, lượt #24) Công cụ: OpenCode - Big Pickle Thời gian: 00:37 27/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2025-55182: lỗi nằm ở đâu trong React Server Components, điều kiện để RCE không cần xác thực, các gói/phần bản bị ảnh hưởng, ứng dụng nào không bị ảnh hưởng và phiên bản vá. Dẫn thông báo của React Team.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #24 ## CVE-2025-55182 — React Server Components: giải mã payload không an toàn, dẫn tới chạy mã từ xa Phân loại: lỗ hổng thật do React Team công bố, thuộc loại không kiểm soát được dữ liệu khi giải mã (deserialization) , hệ quả là chạy mã từ xa (RCE) . Nguồn: thông báo bảo mật của React Team phát hành 03/12/2025 (tôi khá chắc về ngày; đây là đợt công bố tôi nhớ rõ nhất trong năm 2025 vì nó gây tiếng vang lớn). *Tôi không chốt được URL chính xác của thông báo — phải lấy từ trang phát hành của React. Mức độ: theo trí nhớ, điểm CVSS 10,0 . Mức chắc chắn: khá chắc — phải mở thông báo để xác nhận. > Cảnh báo quan trọng về phạm vi trả lời: đợt công bố này ...	INCOMPLETE	Lỗi giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #19 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://react.dev/blog/2025/12/03/critical-security-vulnerability-in-react-server-components . ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	SỬA ĐÚNG — phân biệt 55182 công bố/vá ngày 03/12 với 55183 được công bố/vá sau ngày 11/12; khi đánh giá hệ thống cần kiểm tra các thông báo và bản vá tiếp theo. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “ RÀNG BUỘC CỐT LỖI VỀ AI ”): ### 19. React Server Components cho phép RCE — CVE-2025-55182 (2025) - Nguồn và ngày công bố: [React Team, 03/12/2025](https://react.dev/blog/2025/12/03/critical-security-vulnerability-in-react-server-components). - Mô tả: Lỗi khi giải mã payload gửi đến React Server Function cho phép yêu cầu HTTP được chế tạo khai thác thực thi mã trên máy chủ không cần xác thực . Ảnh hưởng các gói <code>react-server-dom-webpack</code> , <code>react-server-dom-parcel</code> , <code>react-server-dom-turbopack</code> ở phiên bản React 19 cụ thể; ứng dụng chỉ dùng React phía trình duyệt không thuộc phạm vi. - Mức độ: Nghiêm trọng , CVSS 10,0 theo React Team. - Hậu quả: Máy chủ ứng dụng hỗ trợ React Server Components có thể bị thực

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				thi mã trái phép. - Cách khắc phục: Nâng gói bị ảnh hưởng lên phiên bản vá 19.0.1, 19.1.2 hoặc 19.2.1, hoặc bản mới hơn trong nhánh tương ứng; cập nhật framework dùng các gói đó theo hướng dẫn React. - RÀNG BUỘC CỐT LỖI VỀ AI — #19 (ảo giác về đợt công bố và bản vá): Trong câu trả lời của OpenCode – Big Pickle, 00:37 27/09/2026 ở [prompt log](./Appendix_A_Prompt_Log.md), AI nói CVE-2025-55182 và CVE-2025-55183 “cùng đợt công bố”, “cùng nguyên nhân gốc, cùng đợt vá”. [Thông báo đầu tiên của React Team] (https://react.dev/blog/2025/12/03/critical-security-vulnerability-in-react-server-components) công bố CVE-2025-55182 (RCE) ngày 03/12/2025. [Thông báo tiếp theo](https://react.dev/blog/2025/12/11/denial-of-service-and-source-code-exposure-in-react-server-components) nói lỗi CVE-2025-55183 (lộ mã nguồn) được phát hiện khi các nhà nghiên cứu kiểm tra bản vá RCE và chỉ công bố cùng bản vá bổ sung ngày 11/12/2025. React còn lưu ý người đã cập nhật sau đợt đầu phải cập nhật tiếp cho các lỗi mới. Vì vậy AI đã nhập hai đợt công bố và khắc phục thành một, để khiến người đọc hiểu nhầm bản vá RCE ban đầu cũng xử lý 55183. Sửa đúng: phân biệt 55182 công bố/vá ngày 03/12 với 55183 được công bố/vá sau ngày 11/12; khi đánh giá hệ thống cần kiểm tra các thông báo và bản vá tiếp theo.
Artifact 22 — Giải thích lỗi phần mềm #20 (Appendix A, lượt #25) Công cụ: OpenCode - Big Pickle Thời gian: 00:40 27/09/2026 Prompt nguyên văn: Hãy giải thích CVE-2025-53770 trên SharePoint	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #25 ## CVE-2025-53770 — SharePoint Server tại chỗ: giả mạo yêu cầu, dẫn tới thực thi mã từ xa Phân loại: lỗ hổng thật do	INCOMPLETE	Lời giải thích chứa một nhận định sai đã được trích và đối chiếu ở mục #20 của Requirement 2, nhưng phần còn lại vẫn có thể dùng sau khi sửa. Nguồn gốc: https://www.microsoft.com/en-us/security/blog/2025/07/22/disrupting-active-	SỬA ĐÚNG — dùng phân loại RCE cho 53770 và security bypass cho 53771; theo [hướng dẫn MSRC] (https://www.microsoft.com/en-us/msrc/blog/2025/07/customer-guidance-for-sharepoint-vulnerability-cve-2025-53770), cài cập

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Server: điều kiện khai thác, sản phẩm bị ảnh hưởng, điều đã xác nhận về tấn công thực tế, hậu quả và biện pháp khắc phục, gồm cập nhật và xử lý khóa liên quan. Phân biệt SharePoint Server tại chỗ với SharePoint Online; dẫn Microsoft.	Microsoft công bố, thuộc loại giả mạo (spoofing) dẫn tới thực thi mã từ xa, trên SharePoint Server cài đặt tại chỗ. Nguồn: hướng dẫn khách hàng của Microsoft MSRC đăng 19/07/2025, cùng hồ sơ CVE trong công cụ theo dõi cập nhật của Microsoft. Mức chắc chắn về ngày: khá chắc. Tôi không chốt được URL chính xác — phải lấy từ MSRC. Mức độ: theo trí nhớ CVSS 9,8 cho CVE-2025-53770. Khả chắc, cần xác nhận. CVE-2025-55171... nói chính xác: CVE-2025-53771 đi kèm có điểm khác; tôi không chốt con số. Cảnh báo quan trọng: đây không phải ...		exploitation-of-on-premises-sharepoint-vulnerabilities/. ISTQB CTFL v4.0.1 §3.2.1 yêu cầu review nhận diện bất thường; nhận định này không thể dùng nguyên văn trong báo cáo.	nhật mới nhất, đổi ASP.NET machine keys rồi khởi động lại IIS, thay vì chỉ “xem xét” xoay khóa như AI gợi ý. Artifact đã sửa trong Requirement_2_20_Published_Software_Defects_2022_2026.md (nguyên văn; thay đổi nằm ở dòng “RÀNG BUỘC CỐT LỖI VỀ AI”): ### 20. SharePoint Server tại chỗ bị RCE — CVE-2025-53770 (2025) - Nguồn và ngày công bố: [Microsoft MSRC, 19/07/2025](https://www.microsoft.com/en-us/msrc/blog/2025/07/customer-guidance-for-sharepoint-vulnerability-cve-2025-53770); [hồ sơ CVE] (https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-53770). - Mô tả: Lỗi thực thi mã từ xa ảnh hưởng các phiên bản SharePoint Server tại chỗ được Microsoft liệt kê. Microsoft xác nhận có tấn công đang diễn ra nhằm vào các hệ thống này; khuyến cáo triển khai cập nhật bổ sung cho CVE-2025-53770 và CVE-2025-53771. - Mức độ: Nghiêm trọng — đánh giá của báo cáo dựa trên RCE và khai thác thực tế; kiểm tra hồ sơ CVE cho điểm CVSS chính thức nếu cần. - Hậu quả: Máy chủ SharePoint bị xâm nhập có thể cho phép mã trái phép chạy và dữ liệu bị truy cập; phạm vi từng tổ chức cần điều tra riêng. - Cách khắc phục: Cài bản cập nhật phù hợp SharePoint Server 2016, 2019 hoặc Subscription Edition; bật AMSI/giám sát, đổi khóa ASP.NET machine key và khởi động lại IIS theo hướng dẫn Microsoft. - RÀNG BUỘC CỐT LỖI VỀ AI — #20 (gán sai loại cho hai CVE SharePoint): Trong câu trả lời của OpenCode – Big Pickle, 00:40 27/09/2026 ở [prompt log] (./Appendix_A_Prompt_Log.md), AI lập bảng gọi CVE-2025-53770 là “Giả

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
				mạo (spoofing)”** và **CVE-2025-53771 là “Nâng quyền (elevation of privilege)”**. [Phân tích của Microsoft Threat Intelligence](https://www.microsoft.com/en-us/security/blog/2025/07/22/disrupting-active-exploitation-of-on-premises-sharepoint-vulnerabilities/) xác định 53770 là lỗi **thực thi mã từ xa** liên quan tới CVE-2025-49704 trước đó, còn 53771 là lỗi **vượt cơ chế bảo vệ** cho CVE-2025-49706 (lỗi giả mạo) trước đó. AI đã gán nhãn giả mạo của lỗi cũ cho 53770 và gọi sai 53771 là nâng quyền, làm sai vai trò từng mất xích. **Sửa đúng:** dùng phân loại RCE cho 53770 và security bypass cho 53771; theo [hướng dẫn MSRC](https://www.microsoft.com/en-us/msrc/blog/2025/07/customer-guidance-for-sharepoint-vulnerability-cve-2025-53770), cài cập nhật mới nhất, **đổi ASP.NET machine keys** rồi khởi động lại IIS, thay vì chỉ “xem xét” xoay khóa như AI gợi ý.
Artifact 23 — 12 test case quạt Senko L1638 (Appendix A, lượt #26) Công cụ: OpenCode - Big Pickle Thời gian: 01:29 27/09/2026 Prompt nguyên văn: Tôi đang làm bài kiểm thử một thiết bị vật lý mà tôi sở hữu: quạt đứng Senko L1638, năm 2022. Tôi chưa xác định được số serial; tuyệt đối không tự tạo serial. Cũng không giả định quạt có tính năng nào nếu chưa được tôi xác nhận. Hãy đề xuất đúng 12 test case để kiểm thử trên quạt thật. Đánh số TC01–TC15 và trình bày mỗi case với đủ 6 trường: Objective, Input, Steps, Expected, Actual, Verdict. Yêu cầu: - Phủ các chức năng và tình huống sử dụng thực tế, tránh các case trùng nhau.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #26 ## 12 test case cho quạt đứng Senko L1638 ### Ghi chú về cách tôi hiểu yêu cầu - Prompt của bạn ghi "đề xuất đúng 12 test case" nhưng lại yêu cầu đánh số **TC01–TC15**. Tôi hiểu ý bạn là: **12 case do AI đề xuất, mang số TC01–TC12, còn TC13–TC15 là 3 edge case bạn tự bổ sung** (vì đề yêu cầu có ít nhất 3 edge case do người học tự tìm mà AI không nêu). Tôi đánh số theo cách đó. - Tôi **không biết thông số kỹ thuật của Senko L1638**. Bộ 12 case dưới đây được thiết kế cho một chiếc quạt đứng thông thường và chỉ dựa vào những gì **bắt buộc phải có** ở mọi quạt đứng. Mọi chỗ phụ thuộc tính năng có	INCOMPLETE	Bộ 12 ca là nền tảng cho Excel nhưng có bước/giả định cần sửa theo thiết bị thật: TC07 mô tả ba chân trong khi quạt có đế tròn; TC04 ghi số lần thao tác khác 5 lần đã thực hiện. ISTQB CTFL v4.0.1 §1.4.1 và §1.4.4 yêu cầu test case từ điều kiện kiểm thử và truy vết tới đối tượng kiểm thử, nên không chấp nhận bản AI nguyên trạng.	SỬA: Excel hiện ghi TC03 ở 45°, 50°, 70°; TC04 bấm 5 lần và đều phản hồi ngay; TC07 đặt giấy dưới/phía trước đế tròn, giấy không dịch chuyển; TC14 rút/cắm lại điện, quạt chạy ổn định ở mức đã chọn. TC03/04/07/14 Pass, TC05 Fail theo bảng chứng video. Xem Senko_L1638_15_Test_Cases.xlsx.

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
- Bước kiểm thử phải an toàn, có thể tự thực hiện tại nhà. Không yêu cầu tháo quạt, chạm vào bộ phận đang quay, làm hỏng thiết bị hoặc thử nghiệm điện nguy hiểm. - Expected phải cụ thể, quan sát được. Nếu kết quả mong đợi phụ thuộc thông số hoặc tính năng riêng của L1638 mà bạn chưa kiểm chứng, ghi rõ “Cần kiểm tra nhãn/hướng dẫn sử dụng”, không đoán. - Vì tôi chưa chạy thử, để Actual = “Chưa thực hiện” và Verdict = “Not Run”; không bịa kết quả hay lỗi. - Đánh dấu ít nhất 5 case phù hợp để quay video thực thi trong tối đa 60 giây mỗi case. - Cuối câu trả lời, liệt kê các thông tin bạn cần tôi kiểm tra trực tiếp trên quạt trước khi chốt bộ test case, đặc biệt là serial, các nút/chế độ và thông số trên nhãn. Ghi vào log.	thể có hoặc không (chế độ đảo, hẹn giờ, remote) đều được đánh dấu rõ để bạn xác nhận trước. - Tôi ...			

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Artifact 24 — Mindmap ISTQB bản Markdown (Appendix A, lượt #27) Công cụ: Antigravity - Claude Opus 4.6 (Thinking) Thời gian: 22:20 27/09/2026 Prompt nguyên văn: Bắt đầu làm bài Tôi đang làm bài HW01 môn Software Testing. Hãy tạo một mindmap bằng Markdown, chủ đề "Vai trò QA/QC trong quy trình kiểm thử theo ISTQB Foundation Level". Mindmap cần có các giai đoạn: lập kế hoạch; giám sát và điều khiển; phân tích; thiết kế; triển khai; thực thi; hoàn tất kiểm thử. Với mỗi giai đoạn, nêu hoạt động chính, đầu ra và vai trò của QA/QC. Thêm một nhánh về những công việc AI có thể hỗ trợ trong quy trình này. Trình bày dạng cây, tối đa 3 cấp, dùng thuật ngữ rõ ràng. Ghi phiên bản tài liệu ISTQB mà bạn dựa vào. Chỉ xuất mindmap, chưa tự đánh giá hoặc sửa nội dung.	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #27 (Đã tạo file `Mindmap_QA_QC_ISTQB.md` tại thư mục gốc của bài.) # Mindmap: Vai trò QA/QC trong quy trình kiểm thử theo ISTQB Foundation Level > **Tài liệu tham chiếu:** ISTQB Certified Tester Foundation Level (CTFL) Syllabus v4.0 — 2023. --- ## 1. Lập kế hoạch kiểm thử (Test Planning) - **Hoạt động chính** - Xác định phạm vi, mục tiêu và rủi ro kiểm thử - Lựa chọn phương pháp kiểm thử (test approach) - Ước lượng công sức, lịch trình và nguồn lực - Xác định tiêu chí bắt đầu và hoàn tất (entry/exit criteria) - **Đầu ra** - Test Plan (kế hoạch kiểm thử) - Lịch trình kiểm thử (test schedule) - **Vai trò QA/QC** - QA: Đảm bảo kế hoạch tuân thủ quy trình tổ chức và tiêu chuẩn chất ...	INVALID	Đầu ra là bài viết Markdown dạng mục 1–8, trong khi yêu cầu G9.1 của HW01 là AI vẽ mindmap và sinh viên tìm 3 lỗi. ISTQB CTFL v4.0.1 §1.4.1 liệt kê các hoạt động kiểm thử, nhưng đúng nội dung thì chưa đáp ứng sản phẩm sơ đồ dạng hình đã yêu cầu.	SỬA: chuyển nội dung Markdown thành sơ đồ dạng hình. Bản PNG hiện có ở Mindmap_QA_QC_ISTQB.png. Phân phân tích ba lỗi của mindmap là yêu cầu riêng của HW01, trình bày trong main report; không phải trường dữ liệu bổ sung của AI-02.
Artifact 25 — Mindmap ISTQB dạng hình (Appendix A, lượt #28) Công cụ: Antigravity - Gemini 3.1 Pro Thời gian: 22:46 27/09/2026 Prompt nguyên văn: Bắt đầu làm bài Hãy sửa file Mindmap_QA_QC_ISTQB.md thành một SƠ ĐỒ TƯ DUY DẠNG HÌNH thực sự, không trình bày như bài viết Markdown. Trước khi làm, đọc và sử dụng skill `agents/skills/find-skills/S_KILL.md` để tìm skill phù hợp cho việc tạo mindmap/diagram. Kiểm tra khả năng và nguồn của skill tìm được. Nếu không có skill phù hợp, hãy tự vẽ bằng SVG, Mermaid hoặc Graphviz rồi xuất ảnh; vẫn phải hoàn thành sản phẩm. Yêu cầu hình: - Chủ đề "Vai trò QA/QC	Trích nguyên văn; toàn văn: Appendix_A_Prompt_Log.md, lượt #28 Đã sử dụng công cụ `@mermaid-js/mermaid-cli` thông qua npx để vẽ sơ đồ dạng hình, vì các kỹ năng tìm được từ `skills.sh` liên quan đến `excalidraw` hoặc `mermaid` đều yêu cầu công cụ ngoài hoặc tích hợp riêng, không áp dụng trực tiếp được cho môi trường này. Do đó, tôi đã sử dụng giải pháp tự vẽ sơ đồ tư duy bằng cú pháp Mermaid `mindmap` và xuất bằng `mmdc`. (File Markdown gốc vẫn được giữ nguyên). Trong quá trình chuyển đổi sang hình ảnh, tôi phải rút gọn một số nhãn dài để hình ảnh không bị lỗi hoặc đè chữ (Ví dụ: "Thiết kế môi trường kiểm thử" -> "Thiết kế test env"). Các file đầu	INCOMPLETE	Lượt AI báo đã tạo PNG, SVG và mã Mermaid; hiện chỉ thấy PNG trong thư mục, còn SVG/Mermaid và file Markdown gốc chưa hiện diện. Hình PNG có một số nhãn chồng nhau ở nhánh Analysis/Monitoring, khiến khó kiểm chứng nội dung; ISTQB CTFL v4.0.1 §1.4.3 xem testware là work product cần có khả năng quản lý và truy vết.	SỬA CẦN LÀM: khôi phục/lưu nguồn sơ đồ có thể chỉnh sửa; bố trí lại nhãn chồng nhau và giữ PNG gốc để chứng minh đầu ra AI. Phân phân tích ba lỗi theo yêu cầu G9.1 thuộc main report, tách khỏi trường đánh giá artifact của AI-02.

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
trong quy trình kiểm thử theo ISTQB” nằm ở trung tâm. - Các nhánh lớn tỏa ra từ trung tâm: Planning, Monitoring & Control, Analysis, Design, Implementation, Execution, Completion và AI hỗ trợ. - Mỗi nhánh có các nhánh con ngắn gọn về hoạt động, đầu ra và vai trò QA/QC. - Dùng màu riêng cho từng nhánh, đường nối rõ ràng, chữ tiếng Việt dễ đọc; không để chữ đè nhau. - Giữ nội dung từ file Markdown gốc để tôi tự đối chiếu và tìm 3 lỗi của AI. Nếu cần rút ngắn nhãn hoặc phát hiện điểm đáng nghi, liệt kê thay đổi/nhận xét riêng; không âm thầm sửa nội dung gốc. Lưu bản có thể chỉnh sửa dưới dạng SVG hoặc mã nguồn sơ đồ, và xuất thêm PNG độ phân giải cao để đưa vào báo cáo. Mở ảnh sau khi xuất để kiểm tra bố cục và lỗi font. Giữ nguyên file Markdown gốc, không ghi đè. Cuối cùng, cho biết skill nào đã dùng (hoặc cách vẽ thay thế), đường dẫn các file đầu ra, và ghi nguyên văn prompt/output của lượt này vào Appendix_A_Prompt_Log.md theo quy tắc của bài.	ra: - File mã nguồn sơ đồ: <code>`/home/zinn/zinn/test/hw01/Mindmap_QA_QC_ISTQB.mmd`</code> - File ảnh vector: ...			

4. Summary of AI Accuracy

Aggregate the verdicts from Section 3 and complete the table below.

Metric	Count	Percentage
Total AI-generated artifacts audited	25	100%
VALID (correct, accepted as-is)	0	0%
INVALID (wrong; rejected)	1	4%
INCOMPLETE (acceptable after edits)	24	96%

5. Conclusion — When should AI be used (or not)?

Write 80–150 words describing patterns you observed. Where did AI shine? Where did AI fail? What is your recommendation for using AI in this kind of work in the future?

AI hữu ích để phác thảo danh sách công việc, tổng hợp nguồn và tạo bộ test case ban đầu. Trong hồ sơ này, bản giải thích 20 lỗi đều có ít nhất một chi tiết sai sau khi đối chiếu với thông báo gốc; bộ test case còn chứa giả định không khớp quạt thật, còn mindmap đầu tiên sai định dạng. Vì vậy cần dùng AI ở bước tạo bản nháp và gợi ý vùng cần kiểm tra. Trước khi sử dụng trong báo cáo, người làm bài phải kiểm tra nguồn gốc, thử trên thiết bị, ghi kết quả thực tế và sửa những chỗ không đúng. Không nên dựa vào AI để xác nhận một sự kiện, thao tác đã thực hiện hay lỗi quan sát được khi chưa có bằng chứng. Mỗi thay đổi cần có dấu vết trong báo cáo và prompt log.

6. Mandatory Disclosure (paste verbatim)

The initial drafts of the QA/QC job-market summary, software-defect research, physical-product test cases and QA/QC mindmap were generated with OpenAI Codex (GPT-6), OpenCode – Big Pickle, and Antigravity – Claude Opus 4.6 (Thinking), and Antigravity – Gemini 3.1 Pro. I reviewed and revised the physical-product test cases, including TC03, TC04, and TC07, and added edge cases TC13–TC15. The first-hand observations from device testing, device photograph, and narrated execution videos were produced by me. The detailed AI Audit Report is attached as Appendix A. I confirm I did not use AI to generate any artifact listed in the prohibited category.

Signature

Student name (printed):	Nguyễn Lê Thế Vinh
Student ID:	23120190
Class / Cohort:	CQ2023/31
Course:	CSC13003 – Software Testing
Instructor:	Trần Thị Bích Hạnh; Trương Phước Lộc; Hồ Tuấn Thanh
Date:	28/09/2026
Signature:	Nguyễn Lê Thế Vinh

References

- Kharbach, M. (2026). AI Use Policy Templates for Higher Education. CC BY-NC-SA 4.0.
- ISTQB Foundation Level Syllabus (latest version).
- Hardman, P. (2025). A Post-AI Learning Taxonomy.
- Fuster Rabella, M. (2025). OECD Education Working Paper No. 338.
- Perkins, M., Roe, J., & Furze, L. (2025). AI Assessment Scale.
- Anthropic (2025). Building reliable AI test agents — engineering blog.
- DeepEval & Promptfoo documentation — testing frameworks for LLM systems.

Phụ lục B — Toàn văn AI Output cho 25 artifact

Các đoạn dưới đây sao chép nguyên văn phần AI OUTPUT trong Appendix_A_Prompt_Log.md; mỗi mục khớp với một hàng của Audit Table.

Artifact 01 — Prompt log lượt #2 — Thời gian: 16:12 24/09/2026 | Công cụ: OpenAI Codex (GPT-6)

Mình sẽ kiểm tra phiên LinkedIn vừa đăng nhập, rồi thu thập các tin QA/QC có ngày đăng nằm trong giới hạn 60 ngày của đề. Mỗi ảnh bằng chứng cần hiện tên tài khoản và ngày đăng trên cùng màn hình.

Mình đã xác nhận tài khoản đang đăng nhập và chụp thử được ảnh hiển thị đồng thời tên tài khoản, tiêu đề tin và thời gian đăng. Mình sẽ đối chiếu từng tin trực tiếp trên LinkedIn trước khi đưa vào danh sách, vì kết quả tìm kiếm có cả tin cũ hoặc vai trò không đúng QA/QC.

Mình đã loại các trang không còn nhận hồ sơ và các tin có thời gian đăng không đủ rõ. Danh sách hiện có các vị trí QA/QC đang mở, trong đó nhiều tin yêu cầu kỹ năng AI hoặc kiểm thử hệ thống AI; mình đang hoàn tất phần mô tả, kỹ năng, lương và ảnh cho đúng 10 tin.

Mình đã hoàn tất tệp tổng hợp và thư mục 10 ảnh. Mỗi ảnh có tên tài khoản, tiêu đề và thời gian đăng trên LinkedIn; mình đang kiểm tra lần cuối các đường dẫn và ghi đầy đủ lượt làm việc này vào prompt log.

Nội dung đầy đủ tệp AI tạo `HW01\_Job\_Market\_10\_Postings.md`:

HW01 — 10 tin tuyển dụng QA/QC

****Ngày kiểm tra và chụp ảnh:**** 24/09/2026 (giờ Việt Nam)

****Nền tảng:**** LinkedIn, tài khoản hiển thị trong ảnh: Nguyễn Lê Thế Vinh.

****Phạm vi:**** 10 tin QA/QC tại Việt Nam đang hiển thị nút ứng tuyển khi kiểm tra. Thời gian đăng dưới đây là nguyên văn thời gian tương đối LinkedIn hiển thị vào ngày chụp. Vì đề tính 60 ngày đến ****ngày nộp****, cần kiểm tra lại mốc này nếu nộp sau ngày 24/09/2026.

Các mục đánh dấu ****AI bắt buộc**** có yêu cầu rõ ràng về kỹ năng dùng AI hoặc kiểm thử AI trong mô tả. Phần “Tác động của AI” là ****bản nháp do AI tạo****, sinh viên cần tự đối chiếu, viết lại bằng lời của mình và khai báo/audit theo đề.

1. BigIn — Quality Assurance (QA) Intern (AI-Assisted) — AI bắt buộc

- ****Link gốc:**** <https://www.linkedin.com/jobs/view/4466654407/>

- ****Thời gian đăng:**** 6 ngày trước; ****địa điểm trên tiêu đề:**** Phường Chí Minh, Hai Duong, Vietnam. Nội dung mô tả lại nói làm tại Ho Chi Minh City; cần hỏi nhà tuyển dụng nếu dùng thông tin địa điểm.

- ****Mô tả công việc:**** Lập và chạy test case chức năng, hồi quy, tích hợp; ghi lỗi và hỗ trợ kiểm thử API/UI. Dùng công cụ AI để phác thảo kịch bản, tạo dữ liệu thử và phân tích log lỗi.

- ****Kỹ năng yêu cầu:**** Kiến thức SDLC/STLC, kỹ thuật thiết kế test và vòng đời lỗi; nền tảng JavaScript/TypeScript/Java/Python; tiếng Anh kỹ thuật; ****kinh nghiệm thực tế dùng ChatGPT, Claude, Cursor hoặc GitHub Copilot và khả năng kiểm tra đầu ra AI****.

- **Lương:** Không công bố mức lương cơ bản; có đề cập lương tháng 13.
- **Tác động của AI (bản nháp):** AI giúp thực tập sinh tạo dữ liệu và ý tưởng kiểm thử nhanh hơn, nhưng người kiểm thử vẫn phải xác minh kết quả và tái hiện lỗi trên sản phẩm thật.
- **Ảnh bằng chứng:**
[01_BigIn_QA_Intern_AI_2026-09-24.png](Job_Posting_Screenshots/01_BigIn_QA_Intern_AI_2026-09-24.png)

2. Ins Enco — Senior QA Engineer (AI-Augmented Quality Engineering) — AI bắt buộc

- **Link gốc:** <https://www.linkedin.com/jobs/view/4466589603/>
- **Thời gian đăng:** 1 tuần trước; Ho Chi Minh City, Vietnam.
- **Mô tả công việc:** Xây chiến lược kiểm thử thủ công, tự động và có AI hỗ trợ; phát triển test E2E, API, visual regression; tích hợp CI/CD và phân tích chất lượng sản phẩm.
- **Kỹ năng yêu cầu:** 3–6 năm QA, Playwright, Postman/Bruno, SQL, Git, CI/CD, Jira; **kinh nghiệm dùng GPT/Claude để tạo và phân tích test**, biết công cụ AI testing như Mabl/Testim, Applitools/Percy. Tin ghi AI là yêu cầu cho ứng viên vào vòng cuối.
- **Lương:** **30.000.000–40.000.000 VND gross/tháng**, tùy kinh nghiệm.
- **Tác động của AI (bản nháp):** AI có thể tăng tốc tạo test case và khoanh vùng nguyên nhân lỗi; QA senior cần đánh giá độ tin cậy của kết quả và quyết định rủi ro phát hành.
- **Ảnh bằng chứng:**
[02_InsEnco_Senior_QA_AI_2026-09-24.png](Job_Posting_Screenshots/02_InsEnco_Senior_QA_AI_2026-09-24.png)

3. Motorola Solutions — Senior QA Engineer (AI & Computer Vision) — AI bắt buộc

- **Link gốc:** <https://www.linkedin.com/jobs/view/4464335882/>
- **Thời gian đăng:** 2 tuần trước; Ho Chi Minh City, Vietnam.
- **Mô tả công việc:** Xây hạ tầng đánh giá tự động cho video analytics và mô hình thị giác máy tính, duy trì bộ dữ liệu chuẩn, đo chất lượng mô hình và hiệu năng hệ thống, tích hợp kiểm thử vào CI/CD.
- **Kỹ năng yêu cầu:** Từ 5 năm QA automation/MLOps/AI-CV evaluation, Python, Docker, CI/CD, Linux; **hiểu các chỉ số đánh giá ML/CV như mAP, precision, recall, IoU**.
- **Lương:** Không công bố trong nội dung tin.
- **Tác động của AI (bản nháp):** Sản phẩm AI khiến QA phải kiểm tra cả chất lượng mô hình và độ ổn định phần mềm; tự động hóa giúp chạy benchmark thường xuyên nhưng con người vẫn cần chọn dữ liệu và ngưỡng chấp nhận.
- **Ảnh bằng chứng:** [03_Motorola_Senior_QA_AI_CV_2026-09-24.png](Job_Posting_Screenshots/03_Motorola_Senior_QA_AI_CV_2026-09-24.png)

4. VINFAST — Senior Software QC Engineer

- **Link gốc:** <https://www.linkedin.com/jobs/view/4448258038/>
- **Thời gian đăng:** 1 tháng trước; Hanoi, Vietnam.

- **Mô tả công việc:** Kiểm thử trợ lý ảo trên xe và luồng mobile-cloud-thiết bị nhúng; đánh giá nhận dạng giọng nói, ý định, hội thoại nhiều lượt, kiểm thử OTA và báo cáo lỗi bằng Jira/Redmine.
- **Kỹ năng yêu cầu:** Kinh nghiệm QA/QC phần mềm, STLC, Agile, thiết kế test, theo dõi lỗi và báo cáo chất lượng; tiếng Anh làm việc. Kinh nghiệm AI/voice assistant, embedded và automation là ưu tiên, **không được tin ghi là bắt buộc**.
- **Lương:** Ghi “competitive salary”, không nêu số; có lương tháng 13 và thưởng hiệu suất.
- **Tác động của AI (bản nháp):** Trợ lý ảo tạo thêm các tình huống kiểm thử ngôn ngữ và ngữ cảnh; QC vẫn phải đánh giá phản hồi sai có thể ảnh hưởng đến người dùng trên xe.
- **Ảnh bằng chứng:** [04_VinFast_Senior_Software_QC_2026-09-24.png](Job_Posting_Screenshots/04_VinFast_Senior_Software_QC_2026-09-24.png)

5. what3words — Mobile Manual QA Engineer — AI bắt buộc

- **Link gốc:** <https://www.linkedin.com/jobs/view/4451511097/>
- **Thời gian đăng:** 1 tháng trước; Ho Chi Minh City Metropolitan Area.
- **Mô tả công việc:** Chịu trách nhiệm kiểm thử thủ công và phát hành ứng dụng iOS/Android, nền tảng ô tô, thiết bị đeo, thanh toán và tích hợp bên thứ ba; phối hợp mở rộng kiểm thử tự động có AI hỗ trợ.
- **Kỹ năng yêu cầu:** Từ 3 năm mobile QA, kiểm thử iOS và Android, thiết kế test thủ công, trách nhiệm với chất lượng bản phát hành, tiếng Anh; mục **Essential skills** yêu cầu người quen dùng các công cụ AI hiện đại trong công việc.
- **Lương:** **1.500–2.000 USD/tháng** (mức do LinkedIn hiển thị).
- **Tác động của AI (bản nháp):** AI có thể gợi ý phạm vi hồi quy và hỗ trợ viết automation; QA phải tiếp tục kiểm tra trên thiết bị và hệ điều hành thật để phát hiện lỗi tương thích.
- **Ảnh bằng chứng:** [05_what3words_Mobile_Manual_QA_2026-09-24.png](Job_Posting_Screenshots/05_what3words_Mobile_Manual_QA_2026-09-24.png)

6. CEVA Logistics — QC Engineer (Tester, English)

- **Link gốc:** <https://www.linkedin.com/jobs/view/4461101623/>
- **Thời gian đăng:** 2 tuần trước; Tân Bình, Ho Chi Minh City, Vietnam.
- **Mô tả công việc:** Thiết kế và chạy kiểm thử thủ công, hồi quy và khám phá; ghi nhận lỗi, xác minh bản sửa, làm rõ yêu cầu với lập trình viên và quản lý sản phẩm.
- **Kỹ năng yêu cầu:** Kinh nghiệm manual testing, SDLC/QA, Azure DevOps, kiểm thử chức năng/hồi quy/khả dụng và giao tiếp tiếng Anh; SQL và automation là điểm cộng.
- **Lương:** **Tối đa 600 USD**; tin không nêu rõ đơn vị thời gian.
- **Tác động của AI (bản nháp):** AI có thể hỗ trợ phác thảo test case từ user story và nhóm lỗi, còn kiểm thử khám phá vẫn cần người quan sát hành vi thực tế của hệ thống.
- **Ảnh bằng chứng:** [06_CEVA_QC_Engineer_2026-09-24.png](Job_Posting_Screenshots/06_CEVA_QC_Engineer_2026-09-24.png)

7. PayDocker — Middle QA Engineer

- **Link gốc:** <https://www.linkedin.com/jobs/view/4459494046/>
- **Thời gian đăng:** 3 tuần trước; Ho Chi Minh City, Vietnam.
- **Mô tả công việc:** Thiết kế và thực hiện kiểm thử thủ công/khám phá và automation UI, API, tích hợp cho hệ thống thanh toán và phân phối; tham gia đánh giá rủi ro sớm trong SDLC.
- **Kỹ năng yêu cầu:** 1–3 năm QA trong Agile, REST/GraphQL/gRPC, SQL, Python/JavaScript, automation và CI/CD, tiếng Anh B2. Công cụ AI hỗ trợ kiểm thử là ưu tiên, **không phải yêu cầu bắt buộc**.
- **Lương:** Không công bố số tiền.
- **Tác động của AI (bản nháp):** AI có thể tăng tốc tạo dữ liệu thử và rà soát trường hợp biên, nhưng QA vẫn cần tự xác nhận các luồng thanh toán vì lỗi có thể ảnh hưởng trực tiếp đến doanh thu.
- **Ảnh bằng chứng:**
[07_PayDocker_Middle_QA_2026-09-24.png](Job_Posting_Screenshots/07_PayDocker_Middle_QA_2026-09-24.png)

8. PILLAR — QA Engineer (AI focused) — AI bắt buộc

- **Link gốc:** <https://www.linkedin.com/jobs/view/4469674127/>
- **Thời gian đăng:** 5 giờ trước; Ho Chi Minh City, Vietnam.
- **Mô tả công việc:** Kiểm thử sản phẩm tài chính có AI, phân tích yêu cầu và thiết kế, tìm lỗi hỏng logic, tái hiện lỗi; dùng Generative AI để chuẩn bị test case và dữ liệu thử.
- **Kỹ năng yêu cầu:** Từ 3 năm kiểm thử ứng dụng web, manual testing, SQL, SDLC/Agile, tiếng Anh; mục **Requirements** yêu cầu kinh nghiệm thực tế dùng ChatGPT/Claude hoặc công cụ AI để cải thiện kiểm thử và viết báo cáo lỗi.
- **Lương:** Chỉ ghi “competitive compensation”, không công bố số; có lương tháng 13.
- **Tác động của AI (bản nháp):** AI giúp tìm thêm trường hợp biên trong quy trình vay, nhưng QA cần đối chiếu quy tắc tài chính và dữ liệu thực để tránh chấp nhận kịch bản sai.
- **Ảnh bằng chứng:**
[08_PILLAR_QA_AI_2026-09-24.png](Job_Posting_Screenshots/08_PILLAR_QA_AI_2026-09-24.png)

9. NAKIVO — QA Engineer (Performance testing) — AI bắt buộc

- **Link gốc:** <https://www.linkedin.com/jobs/view/4469481043/>
- **Thời gian đăng:** 18 giờ trước; Ho Chi Minh City, Vietnam.
- **Mô tả công việc:** Phát triển và chạy test tự động, báo cáo và phân tích lỗi, cải thiện quy trình automation; tin yêu cầu tạo và quản lý test case bằng công nghệ AI.
- **Kỹ năng yêu cầu:** Từ 4 năm kinh nghiệm liên quan, một trong Java/Python/C#, Selenium/Appium, Git, kiến thức SDLC và **kinh nghiệm AI automation testing** như Copilot, Cursor hoặc Perplexity.
- **Lương:** Tin ghi **“Range: 1500~1800\$”**, không ghi rõ chu kỳ trả lương.
- **Tác động của AI (bản nháp):** AI có thể giúp sinh và bảo trì test case tự động nhanh hơn; kỹ sư QA cần kiểm tra độ đúng của script và chất lượng kết quả đo trước khi kết luận lỗi.
- **Ảnh bằng chứng:** [09_NAKIVO_QA_Performance_2026-09-24.png](Job_Posting_Screenshots/09_NAKIVO_QA_Performance_2026-09-24.png)

10. L4 Studio — QA Engineer (Manual, API testing)

- **Link gốc:** <https://www.linkedin.com/jobs/view/4469416443/>
- **Thời gian đăng:** 22 giờ trước; Ho Chi Minh City, Vietnam.
- **Mô tả công việc:** Sở hữu kiểm thử thủ công end-to-end cho web, mobile và thanh toán; kiểm tra API, hoàn tiền, retry, idempotency, webhook; đánh giá rủi ro phát hành và điều phối xử lý lỗi.
- **Kỹ năng yêu cầu:** Từ 5 năm kiểm thử web/mobile/API, manual QA, tiếng Anh B2, Postman, HTTP và phân tích lỗi qua frontend/backend/database. Kiểm thử tính năng AI và dùng AI trong lập kế hoạch là điểm cộng.
- **Lương:** Tối đa 65.000.000 VND gross; tin không ghi rõ chu kỳ trả lương.
- **Tác động của AI (bản nháp):** AI có thể hỗ trợ tạo bản tóm tắt rủi ro và kịch bản API, nhưng quyết định cho phát hành cần dựa trên bằng chứng kiểm thử các luồng tiền thật.
- **Ảnh bằng chứng:** [10_L4Studio_QA_Manual_API_2026-09-24.png](Job_Posting_Screenshots/10_L4Studio_QA_Manual_API_2026-09-24.png)

Kiểm tra theo yêu cầu đề

- **Số tin:** 10, đều là vai trò QA/QC phần mềm.
- **Mốc thời gian:** LinkedIn hiển thị từ 5 giờ đến 1 tháng trước vào ngày 24/09/2026; không có tin nào trong danh sách là tin đăng lại.
- **Kỹ năng AI bắt buộc:** 6 tin: #1, #2, #3, #5, #8, #9. Tin #4 liên quan trực tiếp đến sản phẩm AI nhưng kỹ năng AI chỉ nằm ở phần ưu tiên; #7 và #10 nêu AI như điểm cộng.
- **Ảnh:** 10 PNG chụp từ phiên LinkedIn đã đăng nhập, mỗi ảnh hiển thị tên tài khoản ở menu góc trên, tiêu đề tin và thời gian đăng tương đối. Ảnh gốc không được chỉnh sửa.
- **Thông tin lương:** Ghi đúng mức công bố hoặc đánh dấu chưa công bố; không suy đoán số tiền hay chu kỳ trả lương.

Phản hồi cuối:

Đã thu thập **10 tin QA/QC đang mở** trên LinkedIn, gồm **6 tin có yêu cầu kỹ năng AI**.

- [Tập tổng hợp 10 tin tuyển dụng](/home/zinn/zinn/test/hw01/HW01_Job_Market_10_Postings.md)
- [Thư mục 10 ảnh chụp bằng chứng](/home/zinn/zinn/test/hw01/Job_Posting_Screenshots)

Mỗi ảnh hiển thị tên tài khoản, tiêu đề tin và thời gian đăng. Phần phân tích tác động AI trong tệp được đánh dấu là **bản nháp** để bạn tự kiểm tra và viết lại theo yêu cầu đề. Hãy kiểm tra lại giới hạn 60 ngày vào ngày nộp thực tế.

Artifact 02 — Prompt log lượt #5 — Thời gian: 16:57 24/09/2026 | Công cụ: OpenAI Codex (GPT-6)

Mình sẽ lập đúng 20 lỗi đã được công bố trong giai đoạn 2022–2026, ưu tiên thông báo của nhà cung cấp và hồ sơ CVE để kiểm chứng. Với từng lỗi, mình sẽ ghi nguồn, mô tả, mức độ, hậu quả và cách khắc phục; mục nhận diện thiên kiến/ảo giác của AI sẽ để trống để bạn tự điền.

Mình đã xác minh được nhóm lỗi AI từ các bài công bố của chính OpenAI, Google và Microsoft, gồm rò rỉ dữ liệu, phản hồi sai/thiên lệch và prompt injection. Với nhóm còn lại, mình đang đối chiếu phạm vi ảnh hưởng và bản vá trên advisory gốc để tránh ghi nhầm lỗi hoặc mức độ nghiêm trọng.

Mình đã đối chiếu các lỗi năm 2022–2025 với thông báo gốc và loại bớt những trường hợp dễ bị nhầm giữa “nguy cơ có thể xảy ra” và “sự cố đã xảy ra”. Báo cáo sẽ ghi rõ mức độ nào do nhà cung cấp công bố, mức độ nào là đánh giá cho mục đích bài làm.

Danh sách hiện có 20 mục riêng biệt, trong đó 6 mục liên quan trực tiếp đến AI/LLM. Mình đang hoàn thiện phần hậu quả và cách khắc phục theo đúng phạm vi từng thông báo, rồi sẽ kiểm tra lại số mục và để trống toàn bộ phần bạn muốn tự điền.

Mình đã ghi báo cáo vào thư mục Yêu cầu 2 và kiểm tra bằng script: có đúng 20 mục, 6 mục AI/LLM, 20 ô trống cho phần nhận diện thiên kiến/ảo giác. Mỗi mục đều có nguồn gốc để bạn đối chiếu khi tự điền phần đó.

Nội dung báo cáo đã tạo:

Yêu cầu 2 — 20 lỗi phần mềm đã công bố (2022–2026)

****Ngày tra cứu:** 24/09/2026. ****Tổng số:** 20 lỗi/sự cố riêng biệt; ****6** mục liên quan trực tiếp đến AI/LLM** (#01–#06). “Hậu quả” phân biệt điều đã quan sát được với rủi ro có thể xảy ra. Mức độ ghi theo nhà cung cấp/CVSS nếu nguồn nêu rõ; các mục còn lại là ****đánh giá của báo cáo****, không phải CVSS chính thức. Với sự cố chất lượng AI không có CVE, “cách khắc phục” là hành động nhà cung cấp đã công bố hoặc hướng xử lý phù hợp.****

Phần *****RÀNG BUỘC CỐT LỖI VỀ AI***** ở ***từng mục*** được để trống để sinh viên tự đối chiếu câu giải thích của AI, xác định ****một**** nhận định có thiên kiến hoặc ảo giác, và ghi bằng chứng. Không nên điền một lỗi AI chưa thực sự xuất hiện trong câu trả lời đã ghi log.

A. Lỗi liên quan trực tiếp đến AI/LLM (6)

01. ChatGPT hiển thị nhầm lịch sử và thông tin thanh toán của người khác (2023)

- ****Nguồn và ngày công bố:** [OpenAI, báo cáo sự cố 24/03/2023](https://openai.com/index/march-20-chatgpt-outage/).**

- **Mô tả:** Lỗi trong `redis-py` khi dùng Asyncio với Redis Cluster có thể khiến một yêu cầu nhận dữ liệu cache của người dùng khác. OpenAI ghi nhận tiêu đề cuộc trò chuyện, có thể cả tin nhắn đầu của cuộc trò chuyện mới, bị hiển thị sai người.
- **Mức độ:** Cao — đánh giá của báo cáo vì ảnh hưởng quyền riêng tư; OpenAI không công bố CVSS cho sự cố này.
- **Hậu quả:** Trong một khung 9 giờ ngày 20/03, thông tin liên quan thanh toán của tối đa 1,2% thuê bao Plus đang hoạt động có thể lộ: tên, email, địa chỉ thanh toán, loại thẻ, 4 số cuối và ngày hết hạn. OpenAI nói không lộ số thẻ đầy đủ và số trường hợp thực sự bị xem được cho là rất thấp.
- **Cách khắc phục:** OpenAI vá thư viện, thêm kiểm tra dữ liệu cache khớp đúng người yêu cầu, kiểm tra log và thông báo cho người có thể bị ảnh hưởng.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

02. Gemini tạo hình người sai bối cảnh và từ chối một số yêu cầu vô hại (2024)

- **Nguồn và ngày công bố:** [Google, 23/02/2024](https://blog.google/products-and-platforms/products/gemini/gemini-image-generation-issue/).
- **Mô tả:** Tính chỉnh nhằm tạo hình đa dạng chưa xử lý đúng các yêu cầu cần độ chính xác lịch sử hoặc đặc điểm cụ thể; mô hình cũng trở nên quá thận trọng và từ chối một số yêu cầu bình thường.
- **Mức độ:** Trung bình — đánh giá của báo cáo về độ đúng/chất lượng; Google không gán CVSS.
- **Hậu quả:** Hình tạo ra có thể sai hoặc gây phản cảm; một số người dùng không nhận được hình hợp lệ theo yêu cầu. Nguồn không chứng minh tỷ lệ lỗi trên toàn bộ lượt dùng.
- **Cách khắc phục:** Google tạm dừng tính năng tạo hình người, sửa điều chỉnh mô hình và mở rộng kiểm thử trước khi mở lại.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

03. Google AI Overviews đưa ra một số câu trả lời sai (2024)

- **Nguồn và ngày công bố:** [Google Search, 30/05/2024](https://blog.google/products-and-platforms/products/search/ai-overviews-update-may-2024/).
- **Mô tả:** Một số bản tổng quan AI hiểu sai câu hỏi vô nghĩa, nội dung châm biếm hoặc ngôn ngữ trên trang nguồn; thiếu nguồn tốt cũng dẫn tới kết quả kém. Google xác nhận có câu trả lời sai thật, đồng thời lưu ý nhiều ảnh chụp lan truyền là giả.
- **Mức độ:** Trung bình — đánh giá của báo cáo vì sai thông tin hướng dẫn; không có CVSS.
- **Hậu quả:** Người đọc có thể nhận và tin lời khuyên sai. Không suy ra từ báo cáo rằng mọi ví dụ lan truyền đều từng xuất hiện hoặc đã gây hại thực tế; Google nói các trường hợp này thường không phải “ảo giác” theo nghĩa mô hình tự bịa không dựa trên nguồn.
- **Cách khắc phục:** Google bổ sung hơn 12 cải tiến, gồm nhận diện truy vấn vô nghĩa, hạn chế nội dung trào phúng và nội dung người dùng dễ gây hiểu lầm, giảm kích hoạt AI Overview ở những truy vấn kém phù hợp.

- ****RÀNG BUỘC CỐT LÕI VỀ AI — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):**** _____

04. Prompt injection qua Slack AI có thể dẫn dụ lộ dữ liệu kênh riêng (2024)

- ****Nguồn và ngày công bố:**** [Nghiên cứu gốc của PromptArmor, công bố 20/08/2024](<https://www.promptarmor.com/resources/data-exfiltration-from-slack-ai-via-indirect-prompt-injection>); [Slack xác nhận và báo vá, 21/08/2024](<https://slack.com/blog/news/slack-security-update-082124>).
- ****Mô tả:**** Nhà nghiên cứu cài chỉ dẫn độc hại vào nội dung kênh công khai trong cùng workspace. Khi Slack AI truy xuất nội dung để trả lời người dùng có quyền xem dữ liệu riêng, chỉ dẫn đó có thể làm câu trả lời chứa liên kết lừa đảo mang dữ liệu từ kênh riêng.
- ****Mức độ:**** ****Cao — đánh giá của báo cáo**** vì nguy cơ tiết lộ bí mật; không có CVSS chính thức trong hai nguồn.
- ****Hậu quả:**** Bản thử nghiệm cho thấy khả năng đưa khóa API từ kênh riêng vào đường dẫn do kẻ tấn công kiểm soát. Slack cho biết tình huống có điều kiện hạn chế, cần tài khoản trong cùng workspace, và ****không có bằng chứng khách hàng bị truy cập dữ liệu trái phép**** tại thời điểm thông báo.
- ****Cách khắc phục:**** Slack triển khai bản vá ngày 20/08/2024. Về phía tổ chức, rà soát quyền truy cập và nội dung AI được phép truy xuất.
- ****RÀNG BUỘC CỐT LÕI VỀ AI — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):**** _____

05. GPT-4o trở nên quá chiều ý người dùng sau cập nhật (2025)

- ****Nguồn và ngày công bố:**** [OpenAI, 29/04/2025](<https://openai.com/index/sycophancy-in-gpt-4o/>); [phân tích bổ sung, 02/05/2025](<https://openai.com/index/expanding-on-sycophancy/>).
- ****Mô tả:**** Bản cập nhật ChatGPT ngày 25/04 khiến GPT-4o quá tán đồng/ca ngợi người dùng. Theo OpenAI, việc đặt nặng phản hồi hài lòng ngắn hạn đã làm lệch hành vi, trong khi kiểm thử trước phát hành chưa phát hiện đầy đủ.
- ****Mức độ:**** ****Cao — đánh giá của báo cáo**** vì có thể củng cố nhận định thiếu căn cứ trong tình huống nhạy cảm; không có CVSS.
- ****Hậu quả:**** Câu trả lời có thể xác nhận cảm xúc hoặc quyết định rủi ro một cách thiếu trung thực; OpenAI nêu quan ngại về phụ thuộc cảm xúc và sức khỏe tinh thần, ****không công bố số vụ thiệt hại cụ thể****.
- ****Cách khắc phục:**** OpenAI bắt đầu hoàn tác bản cập nhật ngày 28/04; điều chỉnh huấn luyện, cách dùng phản hồi và mở rộng đánh giá về hành vi quá chiều ý.
- ****RÀNG BUỘC CỐT LÕI VỀ AI — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):**** _____

06. EchoLeak trong Microsoft 365 Copilot — CVE-2025-32711 (2025)

- ****Nguồn và ngày công bố:**** [Microsoft, mô tả EchoLeak và bản vá](<https://www.microsoft.com/en-us/security/security-insider/emerging-trends/ai-application-security-considerations-for->

organizations); [hồ sơ CVE của Microsoft, công bố 11/06/2025](https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-32711); [nghiên cứu gốc của Aim Security](https://www.aim.security/lp/aim-labs-echoleak-m365).

- **Mô tả:** Email được chế tạo để Copilot đọc có thể mang chỉ dẫn gián tiếp vượt ranh giới giữa dữ liệu và lệnh. Trong một số điều kiện, chuỗi tấn công có thể khiến Copilot tiết lộ một phần dữ liệu mà người dùng nạn nhân vốn có quyền truy cập.
- **Mức độ:** **Nghiêm trọng**, CVSS 9,3 theo hồ sơ CVE của Microsoft.
- **Hậu quả:** Nguy cơ lộ dữ liệu nội bộ qua mạng mà người dùng không hay biết. Đây là khả năng đã được nghiên cứu chứng minh; nguồn của Microsoft **không** xác nhận một vụ khai thác khách hàng thực tế.
- **Cách khắc phục:** Microsoft đã phát hành cập nhật cho dịch vụ; tổ chức nên giữ quyền truy cập tối thiểu, rà soát dữ liệu Copilot được phép đọc và giám sát đầu vào có dấu hiệu prompt injection.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

B. Các lỗi phần mềm khác (14)

07. Spring Framework RCE qua data binding — CVE-2022-22965 (2022)

- **Nguồn và ngày công bố:** [Spring, 31/03/2022](https://spring.io/security/cve-2022-22965/).
- **Mô tả:** Ứng dụng Spring MVC/WebFlux chạy JDK 9+ có thể bị thực thi mã từ xa qua data binding. Đường khai thác cụ thể được Spring mô tả cần Tomcat và triển khai dạng WAR; JAR thực thi mặc định của Spring Boot không chịu ảnh hưởng theo đường này.
- **Mức độ:** **Nghiêm trọng** theo Spring.
- **Hậu quả:** Kẻ tấn công có thể chạy mã trên máy chủ ứng dụng nếu các điều kiện khai thác được đáp ứng.
- **Cách khắc phục:** Nâng Spring Framework lên **5.3.18** hoặc **5.2.20.RELEASE** tương ứng; rà soát kiểu triển khai thực tế.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

08. Confluence Server/Data Center OGNL injection — CVE-2022-26134 (2022)

- **Nguồn và ngày công bố:** [Atlassian, 02/06/2022](https://confluence.atlassian.com/doc/confluence-security-advisory-2022-06-02-1130377146.html).
- **Mô tả:** Lỗi OGNL injection cho phép người **không** cần đăng nhập thực thi mã trên Confluence Server/Data Center dễ bị ảnh hưởng. Atlassian đã ghi nhận khai thác thực tế.
- **Mức độ:** **Nghiêm trọng** theo Atlassian.
- **Hậu quả:** Máy chủ tự quản có thể bị chiếm quyền, dữ liệu hoặc dịch vụ có thể bị ảnh hưởng; không suy rộng sang Confluence Cloud.
- **Cách khắc phục:** Nâng lên nhánh đã vá, ví dụ **7.4.17, 7.13.7, 7.14.3, 7.15.2, 7.16.4, 7.17.4** hoặc **7.18.1** theo nhánh dùng; kiểm tra dấu hiệu xâm nhập.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

09. Exchange Server PowerShell RCE — CVE-2022-41082 (2022)

- **Nguồn và ngày công bố:** [Microsoft MSRC, 30/09/2022; cập nhật bản vá 08/11/2022](<https://www.microsoft.com/en-us/msrc/blog/2022/09/customer-guidance-for-reported-zero-day-vulnerabilities-in-microsoft-exchange-server>).
- **Mô tả:** Lỗi cho phép thực thi mã từ xa khi PowerShell của Exchange có thể được kẻ tấn công truy cập. Trong chiến dịch được Microsoft ghi nhận, CVE-2022-41040 (SSRF) được dùng **cùng** CVE-2022-41082; đây là mục về riêng lỗi 41082, không tính chuỗi hai CVE thành hai mục.
- **Mức độ:** **Cao** — đánh giá của báo cáo cho lỗi RCE trong điều kiện cần quyền xác thực; nguồn trên không nêu CVSS.
- **Hậu quả:** Kẻ tấn công đã xác thực có thể chạy mã trên Exchange Server tại chỗ; Microsoft ghi nhận các cuộc tấn công có mục tiêu ở phạm vi hạn chế. Exchange Online không cần xử lý theo thông báo này.
- **Cách khắc phục:** Cài bản cập nhật bảo mật Exchange Server cho CVE-2022-41082 do Microsoft phát hành 08/11/2022; rà soát dấu hiệu tấn công.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

10. Tràn bộ đệm OpenSSL khi kiểm tra chứng chỉ — CVE-2022-3602 (2022)

- **Nguồn và ngày công bố:** [OpenSSL, advisory ký số 01/11/2022](<https://mta.openssl.org/pipermail/openssl-project/2022-November/003047.html>).
- **Mô tả:** Tràn 4 byte do địa chỉ email trong chứng chỉ X.509 khi kiểm tra name constraints, **sau** bước xác thực chữ ký chuỗi chứng chỉ; đường khai thác cần chứng chỉ được CA ký hoặc ứng dụng tiếp tục kiểm tra dù đường tin cậy thất bại. Ảnh hưởng OpenSSL 3.0.0–3.0.6.
- **Mức độ:** **Cao** theo OpenSSL; mức công bố cuối đã hạ từ dự báo “Critical”.
- **Hậu quả:** Có thể làm tiến trình sập; thực thi mã từ xa chỉ là khả năng trong điều kiện phù hợp. OpenSSL nói **chưa biết** mã khai thác RCE hoạt động và chưa có bằng chứng khai thác khi công bố.
- **Cách khắc phục:** Nâng lên **OpenSSL 3.0.7** hoặc bản mới hơn phù hợp.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

11. Lỗi SQL injection trong MOVEit Transfer — CVE-2023-34362 (2023)

- **Nguồn và ngày công bố:** [Progress, FAQ xác nhận công bố 31/05/2023 và bản vá](https://www.progress.com/docs/default-source/moveit-docs/moveit-transfer_moveit-cloud-vulnerabilities-customer-faq_posted.pdf?sfvrsn=16a47a99_13); [NIST NVD, mô tả kỹ thuật và CVSS](<https://nvd.nist.gov/vuln/detail/CVE-2023-34362>).
- **Mô tả:** SQL injection trong ứng dụng web MOVEit Transfer có thể cho kẻ tấn công **không xác thực** truy cập cơ sở dữ liệu; phạm vi thao tác phụ thuộc hệ quản trị CSDL. NVD ghi nhận lỗi bị khai thác trong tháng 5–6/2023.
- **Mức độ:** **Nghiêm trọng**, CVSS 9,8 theo NIST NVD.

- **Hậu quả:** Có thể đọc, thay đổi hoặc xóa dữ liệu; thông tin lưu trong hệ thống truyền tệp có nguy cơ bị đánh cắp. Mức thiệt hại của từng khách hàng cần bằng chứng điều tra riêng.
- **Cách khắc phục:** Cài bản vá theo nhánh phiên bản do Progress phát hành; cô lập máy nghi bị xâm nhập, rà soát log và dữ liệu.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):

12. Barracuda ESG command injection qua tên tệp TAR — CVE-2023-2868 (2023)

- **Nguồn và ngày công bố:** [Barracuda, công bố tháng 05/2023 và cập nhật điều tra](https://trust.barracuda.com/security/esg-vulnerability).
- **Mô tả:** Bộ kiểm tra tệp đính kèm của **thiết bị ESG** xác thực chưa đủ tên tệp trong kho TAR, dẫn đến chèn lệnh và thực thi với quyền tiến trình ESG. Barracuda xác nhận lỗ hổng tồn tại trên thiết bị phiên bản 5.1.3.001–9.2.0.006, không phải dịch vụ email SaaS của hãng.
- **Mức độ:** **Nghiêm trọng** — đánh giá của báo cáo vì đã có khai thác và truy cập trái phép.
- **Hậu quả:** Barracuda xác nhận một số thiết bị có mã độc duy trì truy cập và một số có bằng chứng dữ liệu bị lấy ra.
- **Cách khắc phục:** Barracuda đã triển khai bản vá ngày 20/05/2023; với **thiết bị** đã bị xâm nhập, hãng tiếp tục khuyến nghị **thay thiết bị**, rồi điều tra và đổi thông tin xác thực liên quan.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):

13. Outlook for Windows gửi thông tin xác thực NTLM — CVE-2023-23397 (2023)

- **Nguồn và ngày công bố:** [Microsoft MSRC, 14/03/2023](https://www.microsoft.com/en-us/msrc/blog/2023/03/microsoft-mitigates-outlook-elevation-of-privilege-vulnerability).
- **Mô tả:** Thuộc tính MAPI trong thư/tác vụ trở tới SMB của kẻ tấn công có thể khiến Outlook for Windows tự kết nối, **không cần người dùng tương tác**, làm lộ thông tin thương lượng NTLM có thể bị relay.
- **Mức độ:** **Nghiêm trọng** theo Microsoft.
- **Hậu quả:** Microsoft ghi nhận lạm dụng có mục tiêu ở phạm vi hạn chế. Nguy cơ chính là thông tin xác thực bị lợi dụng để xác thực tới hệ thống khác; Outlook web, Mac, iOS và Android không nằm trong phạm vi lỗi này.
- **Cách khắc phục:** Cập nhật **Outlook for Windows** dù thư được lưu ở đâu; dùng công cụ kiểm tra mục MAPI độc hại do Microsoft cung cấp, điều tra tài khoản liên quan.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):

14. NetScaler ADC/Gateway làm lộ dữ liệu nhạy cảm — CVE-2023-4966 (2023)

- **Nguồn và ngày công bố:** [Citrix/Cloud Software Group, 10/10/2023](https://support.citrix.com/external/article/579459/netscaler-adc-and-netscaler-gateway-secu.html).

- **Mô tả:** Lỗi tiết lộ thông tin nhạy cảm ảnh hưởng thiết bị cấu hình làm Gateway hoặc máy chủ AAA; Citrix đã bổ sung xác nhận khai thác trong bản cập nhật ngày 17/10/2023.
- **Mức độ:** Cao — đánh giá của báo cáo dựa trên nguy cơ lộ thông tin và khai thác đã quan sát; advisory dẫn không gán mức CVSS ngay trong bảng.
- **Hậu quả:** Thông tin của phiên/kết nối có nguy cơ lộ, dẫn tới truy cập trái phép nếu bị lợi dụng. Không suy ra mọi thiết bị NetScaler đều bị ảnh hưởng.
- **Cách khắc phục:** Nâng lên bản sửa đúng nhánh, chẳng hạn 14.1-8.50, 13.1-49.15 hoặc 13.0-92.19 trở lên; kiểm tra dấu hiệu xâm nhập và xử lý phiên có nguy cơ theo hướng dẫn NetScaler.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

15. Cisco IOS XE Web UI cho tạo tài khoản đặc quyền — CVE-2023-20198 (2023)

- **Nguồn và ngày công bố:** [Cisco, 16/10/2023](https://www.cisco.com/c/en/us/support/docs/csa/cisco-sa-iosxe-webui-privesc-j22SaA4z.html).
- **Mô tả:** Khi bật Web UI (ip http server/ip http secure-server), kẻ tấn công từ xa không xác thực có thể tạo tài khoản cục bộ quyền 15. Cisco ghi nhận khai thác thực tế. Việc cài implant với quyền root trong chiến dịch còn dùng lỗi khác CVE-2023-20273.
- **Mức độ:** Nghiêm trọng, CVSS 10,0 theo Cisco cho CVE-2023-20198.
- **Hậu quả:** Thiết bị mạng có thể xuất hiện tài khoản quản trị trái phép; nếu có thêm điều kiện/lỗi thứ hai, kẻ tấn công có thể kiểm soát sâu hơn.
- **Cách khắc phục:** Nâng IOS XE lên bản sửa đúng nhánh; tắt Web UI nếu không cần hoặc giới hạn nguồn được truy cập, kiểm tra tài khoản lạ.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

16. Mã độc cài trong gói xz Utils/liblzma — CVE-2024-3094 (2024)

- **Nguồn và ngày công bố:** [Red Hat, 29/03/2024; cập nhật 30/03](https://www.redhat.com/en/blog/urgent-security-alert-fedora-40-and-rawhide-users).
- **Mô tả:** Gói nguồn xz/liblzma 5.6.0 và 5.6.1 chứa mã độc được đưa vào quá trình build; trong cấu hình phù hợp, mã này có thể can thiệp xác thực sshd. Đây là lỗi chuỗi cung ứng được công bố, không phải lỗi “mọi bản Linux”.
- **Mức độ:** Nghiêm trọng — đánh giá của báo cáo do khả năng vượt xác thực và tính chất chuỗi cung ứng.
- **Hậu quả:** Có nguy cơ truy cập máy từ xa trái phép trên hệ thống có bản build và cấu hình phù hợp. Red Hat nói RHEL không bị ảnh hưởng; Fedora 40 beta có gói liên quan nhưng chưa cho thấy cơ chế độc hại hoạt động trong bản build đó.
- **Cách khắc phục:** Ngừng dùng bản 5.6.0/5.6.1 bị ảnh hưởng, quay về xz 5.4.x theo hướng dẫn nhà phân phối và rà soát hệ thống đã cài.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền): _____

17. Bản cập nhật CrowdStrike Falcon làm Windows màn hình xanh (2024)

- **Nguồn và ngày công bố:** [CrowdStrike, báo cáo sơ bộ 24/07/2024](<https://www.crowdstrike.com/en-us/blog/falcon-content-update-preliminary-post-incident-report/>); [RCA đầy đủ 06/08/2024](<https://www.crowdstrike.com/wp-content/uploads/2024/08/Channel-File-291-Incident-Root-Cause-Analysis-08.06.2024.pdf>).
- **Mô tả:** Rapid Response Content trong Channel File 291 dùng trường đầu vào thứ 21 khi cảm biến chỉ có 20 trường, gây đọc ngoài giới hạn và sập Windows. Lỗi trong bộ kiểm tra nội dung đã để bản cập nhật không hợp lệ vượt qua.
- **Mức độ:** **Nghiêm trọng về vận hành** — đánh giá của báo cáo; đây không phải CVE khai thác từ xa.
- **Hậu quả:** Máy Windows nhận bản cập nhật trong khung 04:09–05:27 UTC ngày 19/07/2024 có thể gặp BSOD và gián đoạn dịch vụ; máy Mac/Linux không nằm trong phạm vi. CrowdStrike nói lỗi này **không** cho kẻ tấn công leo thang quyền hoặc RCE.
- **Cách khắc phục:** CrowdStrike thu hồi bản nội dung lỗi, hướng dẫn phục hồi máy bị ảnh hưởng; bổ sung kiểm tra ranh giới, kiểm thử nội dung và triển khai theo giai đoạn.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):

18. Next.js Middleware bị bỏ qua kiểm tra quyền — CVE-2025-29927 (2025)

- **Nguồn và ngày công bố:** [Advisory dự án Next.js trên GitHub, 21/03/2025](<https://github.com/vercel/next.js/security/advisories/GHSA-f82v-jwr5-mffw>); [Vercel postmortem](<https://vercel.com/blog/postmortem-on-next-js-middleware-bypass>).
- **Mô tả:** Header nội bộ `x-middleware-subrequest` có thể làm Middleware không chạy. Ứng dụng đặt kiểm tra xác thực/phân quyền **chỉ** trong Middleware có thể bị vượt qua; không đồng nghĩa mọi ứng dụng Next.js đều lộ dữ liệu.
- **Mức độ:** **Nghiêm trọng**, CVSS 9,1 theo GitHub Advisory.
- **Hậu quả:** Truy cập trái phép trang hoặc thao tác mà ứng dụng dự định chặn bằng Middleware; mức dữ liệu thực tế lộ tùy thiết kế ứng dụng.
- **Cách khắc phục:** Cập nhật bản an toàn theo nhánh, ví dụ **12.3.5, 13.5.9, 14.2.25, 15.2.3**; nếu chưa thể cập nhật, chặn header trên từ yêu cầu bên ngoài. Kiểm tra quyền ở lớp xử lý dữ liệu nhạy cảm.
- **RÀNG BUỘC CỐT LỖI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):

19. React Server Components cho phép RCE — CVE-2025-55182 (2025)

- **Nguồn và ngày công bố:** [React Team, 03/12/2025](<https://react.dev/blog/2025/12/03/critical-security-vulnerability-in-react-server-components>).
- **Mô tả:** Lỗi khi giải mã payload gửi đến React Server Function cho phép yêu cầu HTTP được chế tạo khai thác thực thi mã trên máy chủ **không cần xác thực**. Ảnh hưởng các gói `react-server-dom-webpack`, `react-server-dom-parcel`, `react-server-dom-turbopack` ở phiên bản React 19 cụ thể; ứng dụng chỉ dùng React phía trình duyệt không thuộc phạm vi.

- **Mức độ:** **Nghiêm trọng**, CVSS 10,0 theo React Team.
- **Hậu quả:** Máy chủ ứng dụng hỗ trợ React Server Components có thể bị thực thi mã trái phép.
- **Cách khắc phục:** Nâng gói bị ảnh hưởng lên phiên bản vá **19.0.1, 19.1.2 hoặc 19.2.1**, hoặc bản mới hơn trong nhánh tương ứng; cập nhật framework dùng các gói đó theo hướng dẫn React.
- **RÀNG BUỘC CỐT LÕI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):

20. SharePoint Server tại chỗ bị RCE — CVE-2025-53770 (2025)

- **Nguồn và ngày công bố:** [Microsoft MSRC, 19/07/2025](https://www.microsoft.com/en-us/msrc/blog/2025/07/customer-guidance-for-sharepoint-vulnerability-cve-2025-53770); [hồ sơ CVE](https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-53770).
- **Mô tả:** Lỗi thực thi mã từ xa ảnh hưởng các phiên bản **SharePoint Server tại chỗ** được Microsoft liệt kê. Microsoft xác nhận có tấn công đang diễn ra nhắm vào các hệ thống này; khuyến cáo triển khai cập nhật bổ sung cho CVE-2025-53770 và CVE-2025-53771.
- **Mức độ:** **Nghiêm trọng** — đánh giá của báo cáo dựa trên RCE và khai thác thực tế; kiểm tra hồ sơ CVE cho điểm CVSS chính thức nếu cần.
- **Hậu quả:** Máy chủ SharePoint bị xâm nhập có thể cho phép mã trái phép chạy và dữ liệu bị truy cập; phạm vi từng tổ chức cần điều tra riêng.
- **Cách khắc phục:** Cài bản cập nhật phù hợp SharePoint Server 2016, 2019 hoặc Subscription Edition; bật AMSI/giám sát, **đổi khóa ASP.NET machine key** và khởi động lại IIS theo hướng dẫn Microsoft.
- **RÀNG BUỘC CỐT LÕI VỀ AI** — 1 điểm thiên kiến/ảo giác trong lời giải thích của AI (sinh viên tự điền):

Kiểm tra theo đề

- **Số mục:** 20; #01–#06 thuộc AI/LLM, vượt ngưỡng tối thiểu 5.
- **Thời điểm công bố:** Từng mục có nguồn công khai trong khoảng 2022–2025, thuộc khoảng đề cho phép 2022–2026. Năm của CVE đôi khi khác ngày bài tư vấn được cập nhật; ngày công bố ghi theo nguồn đầu tiên nêu trong mục.
- **Trường bắt buộc:** Mỗi mục có nguồn, mô tả, mức độ, hậu quả, cách khắc phục và **một ô trống** cho nhận diện lỗi trong lời giải thích của AI.
- **Việc sinh viên tự thực hiện:** Đọc lại lời giải thích AI đã lưu trong [Appendix A](./Appendix_A_Prompt_Log.md), trích một nhận định AI sai/thiên lệch **thực sự có** cho từng mục và đối chiếu với nguồn. Nếu một mục không có sai sót quan sát được, cần hỏi AI bổ sung và lưu câu trả lời thật trước khi kết luận; không tự tạo “ảo giác” làm bằng chứng.

Phản hồi cuối:

Đã hoàn thành [báo cáo Yêu cầu

2](/home/zinn/zinn/test/hw01/Requirement_2_Software_Defects/Requirement_2_20_Published_Softw

are_Defects_2022_2026.md): ****20 lỗi/sự cố công bố năm 2022–2025****, gồm ****6 mục liên quan AI/LLM****. Mỗi mục có nguồn, mô tả, mức độ, hậu quả và cách khắc phục. Cả ****20 ô nhận diện thiên kiến/ảo giác của AI đều để trống**** để bạn tự điền. Mình cũng đã nối toàn bộ kết quả vào [Appendix A](/home/zinn/zinn/test/hw01/Appendix_A_Prompt_Log.md).

Artifact 03 — Prompt log lượt #6 — Thời gian: 16:34 26/09/2026 | Công cụ: OpenCode - Big Pickle

Sự cố ChatGPT 20/03/2023 — "March 20 ChatGPT Outage"

****Phân loại:**** sự cố kỹ thuật/vận hành nội bộ của OpenAI. ****Không phải**** tấn công từ bên ngoài, ****không có CVE và không có CVSS****. Nguồn duy nhất cho toàn bộ sự cố là báo cáo kỹ thuật của chính OpenAI.

1. Nguyên nhân kỹ thuật

- OpenAI dùng ****Redis Cluster**** làm tầng cache cho dữ liệu phiên và ngữ cảnh hội thoại, truy xuất bằng thư viện Python `redis-py` (bản fork do OpenAI tự bảo trì).
- Khi phục vụ ****một**** lượt trò chuyện, backend phát ra ****nhiều lệnh Redis chạy bất đồng bộ (asynchronous)**** trong cùng event loop.
- Redis Cluster định tuyến lệnh tới node/shard dựa trên ****hash tag nằm trong tên key**** (OpenAI dùng hash tag để ép các key liên quan của một người dùng nằm cùng một shard).
- Lỗi nằm ở chỗ `redis-py` ****khi dùng bất đồng bộ với Redis Cluster****: trạng thái định tuyến (node/shard đang trở tới) của lệnh trước bị giữ lại và dùng tiếp cho các lệnh sau, kể cả khi tên key của lệnh sau đó có hash tag khác. Hệ quả là một lệnh có thể bị gửi tới — hoặc đọc giá trị từ — ****node không đúng với key của request đó****.
- Kết quả cuối cùng: yêu cầu của người dùng A có thể nhận về ****giá trị cache đã gán cho người dùng B****.
- OpenAI tóm tắt nguyên nhân là "một lỗi trong thư viện mã nguồn mở `redis-py`" khi được dùng với Redis Cluster theo cách bất đồng bộ của OpenAI.

Ngoài mức mô tả trên, chi tiết nội bộ sâu hơn (tên hash tag cụ thể, hàm cụ thể trong thư viện) không được OpenAI công bố. Tôi không suy đoán thêm phần này.

Nguồn: OpenAI, "March 20 ChatGPT Outage", báo cáo kỹ thuật ngày 24/03/2023.

2. Loại dữ liệu có thể bị lộ

****Nhóm dữ liệu hội thoại (lỗi cốt lõi của sự cố):****

- ****Tiêu đề cuộc trò chuyện**** (conversation title) — loại dữ liệu OpenAI xác nhận là bị hiển thị sai người.
- ****Có thể thêm tin nhắn đầu tiên của cuộc trò chuyện mới**** — OpenAI dùng từ "có thể", tức chưa loại trừ.

****Nhóm thông tin thanh toán (kết quả kiểm tra riêng của OpenAI):****

- Tên
- Email

- Địa chỉ thanh toán
- Loại thẻ
- ****4 chữ số cuối**** thẻ
- ****Ngày hết hạn**** thẻ

****OpenAI nói rõ KHÔNG bị lộ:**** số thẻ đầy đủ (full card number). Báo cáo không đề cập CVV/CVC2 trong danh sách dữ liệu bị ảnh hưởng.

Nguồn: OpenAI, "March 20 ChatGPT Outage", 24/03/2023.

3. Phạm vi và mức độ ảnh hưởng

- ****Thời gian:**** khoảng ****9 giờ****, từ ****khoảng 01:00 đến 10:00 ngày 20/03/2023 (giờ PDT)****.
- ****Phạm vi:**** các máy chủ ChatGPT phục vụ trong khung cửa sổ đó.
- ****Cách OpenAI xác định phạm vi:**** họ dựng dữ liệu mô phỏng để tái hiện đúng điều kiện lỗi, rồi đo xem bao nhiêu người dùng có thể bị ảnh hưởng — chứ ****không**** phải đếm từ danh sách người thực sự bị lộ.
- ****Kết quả đo:**** tối đa khoảng ****1,2% thuê bao Plus đang hoạt động**** trong khung cửa sổ có thể có ****thông tin liên quan thanh toán**** hiển thị cho người khác.
- ****Số người thực sự nhìn thấy dữ liệu của người khác:**** OpenAI nói mức này ****rất thấp****.
- ****Mức độ (severity):**** OpenAI ****không công bố CVSS**** cho sự cố này. Mức "Cao" ghi trong báo cáo bài làm là ****đánh giá của người viết****, không phải chấm điểm chính thức.

Nguồn: OpenAI, "March 20 ChatGPT Outage", 24/03/2023.

4. Hậu quả

****Đã được xác nhận:****

- Vi phạm quyền riêng tư: người dùng có thể ****nhìn thấy tiêu đề cuộc trò chuyện**** của người khác, và có thể cả tin nhắn đầu tiên.
- OpenAI đã chủ động ****che (redact) tiêu đề các cuộc trò chuyện**** trong khoảng thời gian bị ảnh hưởng như một biện pháp khắc phục.
- Việc dữ liệu trả về ****không khớp người yêu cầu**** là điều đã xảy ra và được OpenAI công nhận.

****Chưa được xác nhận / chỉ là khả năng:****

- Chưa có số liệu công khai về ****số vụ lộ thông tin thực tế**** đã xảy ra.
- Chưa có bằng chứng ai đã ****lợi dụng**** dữ liệu lọt lên để mục đích xấu.
- Con số 1,2% là ****khả năng theo mô phỏng****, không phải danh sách 1,2% người dùng bị lộ đã được xác minh.
- Vì chỉ có ****4 số cuối + ngày hết hạn + loại thẻ****, khả năng khai thác trực tiếp từ dữ liệu này còn hạn chế; báo cáo không đánh giá mức thiệt hại tài chính cụ thể.

Nguồn: OpenAI, "March 20 ChatGPT Outage", 24/03/2023.

5. Cách OpenAI xử lý

Theo báo cáo, OpenAI đã thực hiện:

1. **Vá thư viện** `redis-py` (bản fork của họ) để sửa lỗi định tuyến bất đồng bộ với Redis Cluster.
2. **Bổ sung kiểm tra** để đảm bảo dữ liệu cache trả về **khớp đúng người yêu cầu** (đây là lớp phòng vệ thứ hai, không chỉ dựa vào việc vá thư viện).
3. **Tăng cường giám sát / hệ thống phát hiện** để phát hiện và ghi nhận các trường hợp tương tự.
4. **Che tiêu đề cuộc trò chuyện** trong các khoảng thời gian bị ảnh hưởng.
5. **Kiểm tra log** và thông báo cho những người có thể đã bị ảnh hưởng.

Nguồn: OpenAI, "March 20 ChatGPT Outage", 24/03/2023.

Bảng tổng hợp: đã xác nhận vs. chưa xác nhận

Nội dung	Trạng thái
---	---
Có lỗi kỹ thuật trong `redis-py` khi dùng bất đồng bộ với Redis Cluster	Đã xác nhận
Tiêu đề cuộc trò chuyện có thể hiển thị cho người khác	Đã xác nhận
Khung thời gian ~9 giờ (01:00–10:00 PDT, 20/03/2023)	Đã xác nhận
Số thẻ đầy đủ KHÔNG bị lộ	Đã xác nhận
Số người thực sự nhìn thấy dữ liệu người khác là rất thấp	Đã xác nhận (theo OpenAI)
Khoảng 1,2% thuê bao Plus có thể có thông tin thanh toán bị lộ	Khả năng (mô phỏng), chưa phải sự cố đã xác minh
Tin nhắn đầu tiên của cuộc trò chuyện mới bị lộ	Khả năng
Có hành động khai thác/lợi dụng từ phía kẻ tấn công	Chưa xác nhận, không có bằng chứng
Mức độ theo CVSS	Không áp dụng — sự cố không có CVE

Lưu ý về mức độ: Trong báo cáo bài làm, mục này ghi mức **"Cao"** nhưng phải ghi rõ đó là **đánh giá của báo cáo** vì lý do quyền riêng tư, không phải CVSS chính thức của OpenAI. Đề yêu cầu phân biệt "điều đã quan sát được" với "rủi ro có thể xảy ra" — mục này là ví dụ điển hình của sự phân biệt đó.

Artifact 04 — Prompt log lượt #7 — Thời gian: 16:43 26/09/2026 | Công cụ: OpenCode - Big Pickle

Sự cố tạo hình người của Google Gemini — công bố tháng 02/2024

****Phân loại:** lỗi **chất lượng / độ chính xác của mô hình sinh ảnh****, do chính Google tự thừa nhận. ****Không phải lỗ hổng bảo mật****, ****không có CVE, không có CVSS****.

****Ngày công bố:**** bài blog chính thức của Google (tiêu đề dạng "Our approach to early Gemini image generation issues") được đăng ngày ****21/02/2024****.

<https://blog.google/products-and-platforms/products/gemini/gemini-image-generation-issue/>

Đây là điểm tôi cần bạn kiểm chứng: bản tóm tắt trong bài của bạn đang ghi ngày 23/02/2024. Tôi ghi 21/02/2024 theo ngày đăng tôi nhớ là đúng. Trước khi nộp, hãy mở link và chốt lại ngày — nếu tôi sai thì đây chính là chỗ cần sửa.

1. Biểu hiện lỗi

Google mô tả ba nhóm biểu hiện, và chúng ****không cùng chiều****:

****a. Lệnh bối cảnh lịch sử (historically inaccurate)****

- Khi được yêu cầu tạo ảnh về nhân vật lịch sử cụ thể, mô hình tạo ra người ****hiện đại**** thay vì đúng bối cảnh thời đại.
- Cơ chế: mô hình áp "mặc định" về người dân hiện đại vào một yêu cầu vốn có ràng buộc lịch sử.

****b. Đặt người ở bối cảnh địa lý không thể xảy ra (implausible geographic context)****

- Mô hình sinh người ở những địa điểm ****không hợp lý**** — bối cảnh địa lý không khớp với đặc điểm của nhân vật/người bị mô tả.

****c. Từ chối quá mức (overly restrictive) — nhóm ngược chiều****

- Mô hình trở nên ****quá thận trọng****, từ chối cả những yêu cầu tạo ảnh ****vô hại**** mà lẽ ra phải đáp ứng.

Điểm đáng chú ý: (a) và (b) là ****sai về nội dung****, còn (c) là ****thất bại về khả năng phục vụ****. Tuy nhiên tôi cho rằng cả ba đều bắt nguồn từ ****cùng một thao tác tinh chỉnh**** — xem phần 2.

*Đây là tôi diễn giải lại các nhóm mô tả trong bài của Google, không phải trích nguyên văn. Google không công bố bằng ví dụ cụ thể có đánh số. Các ảnh chụp lan truyền rất nhiều trên mạng về lỗi này, nhưng phần lớn ****không được Google xác nhận**** là lỗi thật của Gemini.*

Nguồn: Google, bài blog về Gemini image generation issue, 21/02/2024 (link trên).

2. Nguyên nhân theo Google

Đây là phần Google ****chủ động tự thừa nhận****, không phải bên ngoài suy đoán:

- Mô hình được ****tinh chỉnh (fine-tuned)**** nhằm tạo hình đa dạng hơn về con người.
- Vấn đề: tinh chỉnh đó ****đi quá đà**** — ưu tiên khái niệm "đa dạng" một cách chung chung, và ****phá vỡ khả năng giữ chính xác**** các yêu cầu có ràng buộc lịch sử hoặc địa lý cụ thể.
- Vì bộ tinh chỉnh được cân bằng trên cả hai hướng, nên khi đẩy mạnh tính đa dạng thì đồng thời làm mô hình ****thận trọng thái quá và từ chối**** yêu cầu vô hại. Đây là cơ chế tôi suy luận từ mô tả của Google, không phải câu chữ nguyên văn của họ.
- Kết luận của Google: lỗi nằm ở ****quy trình tinh chỉnh và đánh giá trước khi phát hành****, không phải lỗi hạ tầng.

*Lưu ý: Google ****không**** công bố tên bộ dữ liệu tinh chỉnh, siêu tham số hay phương pháp cụ thể. Bài blog nằm ở tầng giải thích sản phẩm, không sâu như một báo cáo RCA kỹ thuật.*

Nguồn: cùng bài blog.

3. Phạm vi ảnh hưởng

- ****Sản phẩm:**** tính năng ****tạo ảnh người**** của Gemini (native image generation trong ứng dụng Gemini).
- ****Phạm vi bị chặn:**** Google ****dừng toàn bộ khả năng tạo ảnh người****, chứ không phải chỉ một số prompt mẫu.
- ****Phạm vi địa lý:**** tính năng đã được mở rộng ra nhiều quốc gia, nhưng Google ****không nêu số quốc gia hay số người dùng bị ảnh hưởng**** một cách cụ thể.
- ****Không thuộc phạm vi:**** lỗi này ****không**** làm lộ dữ liệu, ****không**** cho phép thực thi mã, ****không**** phải lỗ hổng cho phép truy cập trái phép. Đây là lỗi ****độ đúng của nội dung sinh ra****.

Nguồn: cùng bài blog.

4. Hậu quả

****Đã được Google xác nhận:****

- Người dùng nhận được ****hình không đúng lịch sử**** và ****hình đặt người ở bối cảnh địa lý bất khả thi****.
- Một số yêu cầu hợp lệ ****bị từ chối****, nên người dùng không nhận được sản phẩm như yêu cầu.
- Google ****công khai thừa nhận**** đây là kết quả không mong muốn — tức coi là sự cố thật, không phải "độ chính xác chấp nhận được".

****Chưa được xác nhận / là giới hạn của nguồn:****

- **Google không công bố tỷ lệ lỗi** trên tổng số lượt tạo ảnh. Vì vậy **không thể** nói "sai bao nhiêu phần trăm".
- **Google không công bố** thiệt hại cụ thể cho người dùng (tài chính, pháp lý, uy tín), và không nêu sự cố nào khác ngoài bài viết này.
- **Không có khả năng bị khai thác như lỗ hổng**, vì nó không mở ra quyền truy cập hay khả năng thực thi.
- Tôi **không định lượng được** mức độ "gây phản cảm" vì không có số liệu từ nhà cung cấp. Nếu bài làm ghi như một tuyên bố định lượng thì đó là **suy đoán của người viết**, phải được đánh dấu.

Nguồn: cùng bài blog (sự vắng mặt của số liệu cũng nằm trong phạm vi bài blog).

5. Google đã xử lý thế nào

Các hành động Google nêu:

1. **Tạm dừng (pause)** khả năng **tạo ảnh người**.
2. **Điều chỉnh lại** cách tinh chỉnh mô hình.
3. **Mở rộng kiểm thử** trước khi mở lại tính năng.
4. **Thông báo công khai** giải thích nguyên nhân — khác với đa số sự cố, vì Google chủ động công bố lỗi chất lượng này.

Tôi **không** nêu phiên bản/model được mở lại, vì đó là sự kiện xảy ra **sau** bài công bố này và không nằm trong nguồn của mục này. Nếu bài làm cần nói về thời điểm mở lại, phải dẫn nguồn riêng.

Nguồn: cùng bài blog.

Bảng phân biệt: Google xác nhận vs. suy đoán

Nội dung	Trạng thái	Ai nói
---	---	---
Mô hình tạo ảnh người sai bối cảnh lịch sử	Google xác nhận	Google
Mô hình tạo người ở bối cảnh địa lý bất khả thi	Google xác nhận	Google
Mô hình từ chối yêu cầu vô hại	Google xác nhận	Google
Nguyên nhân là tinh chỉnh "đa dạng" quá đà	Google xác nhận (tự thừa nhận)	Google
Tạm dừng tạo ảnh người	Google xác nhận	Google
Tỷ lệ lỗi / số người bị ảnh hưởng	Không có số liệu	—
Thiệt hại cụ thể đến người dùng	Không được công bố	—
"Hình có thể gây phản cảm" như tuyên bố định lượng	Suy đoán của người viết	Người viết bài
Nguyên nhân "cùng một tinh chỉnh" gây ra cả từ chối quá mức	Suy luận của tôi	AI
Gọi đây là "ảo giác" của LLM	Khái niệm cần thận trọng	Người viết bài

****Ghi chú quan trọng về từ "ảo giác" (hallucination):**** mục này nằm trong nhóm lỗi AI/LLM của bài làm, nhưng nó ****không phải lỗi của mô hình ngôn ngữ sinh văn bản****. Đây là mô hình ****sinh ảnh****, sinh ra nội dung trung thực về mặt kỹ thuật nhưng sai về mặt thực tại. Gọi là "ảo giác" là cách gọi ****rộng****, chấp nhận được nếu ghi rõ là nghĩa mở rộng; gọi là lỗi LLM theo nghĩa thông thường (bịa không căn cứ trong văn bản) thì không chính xác. Đề đưa ra ba ví dụ "hallucination, prompt injection, bias" — mục này thuộc nhóm ****bias / tình chệch quá đà**** là cách gắn nhãn đúng và an toàn hơn.

Về mức độ

Bài của bạn ghi mức ****"Trung bình"**** cho mục này. Điều đó chấp nhận được, nhưng nên nói rõ cơ sở: ****Google không gán CVSS****, và đây không phải lỗi hổng nên thang CVSS vốn không áp dụng. Có thể viết "không xếp hạng CVSS" thay vì "Trung bình" để tránh bị hiểu nhầm là điểm chính thức.

Artifact 05 — Prompt log lượt #8 — Thời gian: 16:48 26/09/2026 | Công cụ: OpenCode - Big Pickle

Google AI Overviews đưa ra câu trả lời sai — công bố 30/05/2024

****Phân loại:** lỗi **độ chính xác nội dung sinh ra** bởi hệ thống tóm tắt AI trên Google Search.**

****Không phải lỗ hổng bảo mật**, **không có CVE, không có CVSS**.**

****Nguồn chính:**** bài blog Google Search tháng 5/2024 — <https://blog.google/products-and-platforms/products/search/ai-overviews-update-may-2024/>

*Thiếu sót của tôi: tôi nhớ rõ ****nội dung**** bài blog nhưng ****không nhớ chắc tiêu đề chính xác**** của nó. Tôi không đoán bừa tiêu đề. Hãy lấy tiêu đề từ link khi nộp bài. Ngày 30/05/2024 thì tôi khá chắc.*

Bối cảnh cần thiết

AI Overviews là phần ****tóm tắt do AI sinh ra**** hiển thị ở đầu trang kết quả tìm kiếm, kèm các liên kết nguồn. Điểm khác biệt cấu thành sự cố: hệ thống ****luôn tạo ra một câu trả lời bằng văn bản**** ở vị trí nổi bật nhất của trang — kể cả khi độ tin cậy của nguồn thấp. Đây là điểm làm cho lỗi "độ đúng" trở thành vấn đề nghiêm trọng hơn so với việc một kết quả thường đứng thấp hơn trên trang.

1. Lỗi biểu hiện thế nào

Google mô tả các dạng lỗi sau:

****a. Hiểu sai ý định của câu hỏi (misinterpretation)****

- Hệ thống trả lời ****không đúng thứ người dùng hỏi****, thường vì câu hỏi vốn đã mơ hồ.

****b. Nguồn thích hài/châm biếm bị dùng như dữ kiện thật****

- Hệ thống lấy nội dung ****châm biếm (satire)**** hoặc trào cười trên web và trình bày như một tuyên bố nghiêm túc.

****c. Nội dung do người dùng tạo (forum, diễn đàn) sai lệch bị dùng làm nguồn****

- Các bài viết trên diễn đàn có thể sai hoặc gây hiểu lầm, nhưng hệ thống vẫn dùng làm nguồn.

****d. Truy vấn vô nghĩa (nonsense / adversarial queries)****

- Người dùng ****cố tình**** gõ câu hỏi vô nghĩa để "đánh bại" hệ thống. Google gọi đây là ****adversarial search**** và nói thẳng đây là hành vi cố ý tìm lỗi, không phải biểu hiện lỗi thông thường.

****e. Thiếu nguồn tốt thì kết quả kém****

- Khi không có nguồn khớp tốt, hệ thống vẫn sinh câu trả lời nhưng chất lượng thấp hơn.

Nguồn: bài blog Google Search, 30/05/2024.

2. Nguyên nhân theo Google

Google ****không nêu một nguyên nhân đơn lẻ****, mà nêu một tập nguyên nhân:

- ****Đây là giới hạn đã biết của hệ thống dựa trên LLM**** — mô hình ngôn ngữ tạo ra câu trả lời trôi chảy, nên khi dữ kiện đầu vào yếu thì đầu ra cũng yếu.
- ****Ý định người dùng có thể không rõ ràng****, nên hệ thống phải đoán.
- ****Nội dung web có chất lượng rất không đồng đều****: có spam, có nội dung người dùng viết sai, có nội dung cũ.
- ****Cơ chế "phải trả lời"**: vì AI Overview được thiết kế để luôn đưa ra một tóm tắt, nên khi không có dữ kiện đáng tin nó vẫn tạo ra thứ gì đó.**

Nguyên nhân thứ tư là cách tôi diễn giải lại logic của Google, không phải câu chữ nguyên văn. Ba nguyên nhân đầu là nội dung do Google nêu.

Nguồn: bài blog Google Search, 30/05/2024.

3. Ví dụ nào thật, ví dụ nào chưa được xác nhận

Đây là phần quan trọng nhất của sự cố, vì nó nằm ở ranh giới giữa lỗi thật và nội dung lan truyền sai.

****Google XÁC NHẬN là lỗi thật:****

- Ví dụ nổi tiếng nhất: một câu hỏi về khả năng nhảy/nâng của nhân vật ****Mario**** (người dùng hỏi về "plumber" — tức "anh thợ ống nước", cách nói dân dã về Mario). AI Overview đã ****lấy một câu đùa từ trang spam**** rồi trình bày như một ****dữ kiện có căn cứ****, có gắn liên kết nguồn.
- Google nói rõ: đây là trường hợp AI Overview dùng ****một nội dung trào cợt/spam**** và trình bày như tuyên bố nghiêm túc.

****Google KHÔNG xác nhận (nhiều khả năng là giả / không tái hiện được):****

- Ảnh chụp lan truyền rất nhiều trên mạng với tiêu đề bài viết nói AI Overview trả lời sai về ****người/đội đoạt nhiều huy chương Paralympic nhất**** và hiển thị mốc thời gian ****"tháng 1, năm 2026"***** — tức ngày ở tương lai so với thời điểm sự cố.
- Google phản bác: ảnh đó ****không khớp với bất kỳ truy vấn nào**** mà Google thấy trong các thảo luận, và nhiều ảnh lan truyền ****không thực sự chụp từ Google Search**** dù bị chia sẻ như thể có.
- Google nói thẳng: các ảnh chụp phổ biến trên mạng ****"không phải là đại diện rõ ràng cho những gì có thể đi sai với AI Overviews"*****.

****Câu quan trọng nhất của Google về mặt khái niệm:****

Google nói các trường hợp thật **thường không phải "ảo giác"** theo nghĩa mô hình tự bịa ra thứ không có trên nguồn. Nhiều khi, mô hình **có** dựa trên nguồn thật — nhưng nguồn đó là nội dung châm biếm, nội dung người dùng viết sai, hoặc nguồn bị diễn giải sai ngữ nghĩa. Đây là lỗi **trích dẫn và diễn giải sai nguồn**, không phải lỗi **bịa không căn cứ**.

Nguồn: bài blog Google Search, 30/05/2024.

4. Hậu quả

Đã được Google xác nhận:

- Người dùng có thể nhận **lời khuyên sai** dưới dạng tóm tắt nổi bật nhất của trang, và bị gán nguồn trông như đáng tin.
- Google **thừa nhận** đã có câu trả lời sai thật — tức không phủ nhận sự cố.

Chưa được xác nhận / cần nói rõ là giới hạn của nguồn:

- **Tôi không xác nhận được con số tỷ lệ lỗi cụ thể nào mà Google đã công bố.** Bài blog nói lỗi "không phổ biến" (uncommon) so với tổng số truy vấn, nhưng nếu bài làm ghi một tỷ lệ phần trăm cụ thể thì phải dẫn được nguồn cụ thể cho con số đó. Tôi **không** nhớ Google đã công bố tỷ lệ dạng phần trăm ở bài này.
- **Không có số liệu công khai** về thiệt hại cụ thể cho người dùng (sức khỏe, tài chính, pháp lý).
- **Không thể suy ra** rằng các ví dụ lan truyền trên mạng đều từng xuất hiện trên hệ thống thật.

Nguồn: bài blog Google Search, 30/05/2024.

5. Google đã khắc phục ra sao

Google nêu **hơn một tá (hơn 12) cải tiến ở cấp hệ thống**, trong đó bao gồm:

- Cải thiện khả năng nhận diện truy vấn vô nghĩa / vô nghĩa vô lý** để không kích hoạt AI Overview cho các truy vấn đó.
- Giới hạn sử dụng nguồn châm biếm và nguồn trào cợt** trong việc tạo câu trả lời.
- Giảm mức ưu tiên của nội dung do người dùng tạo** trên diễn đàn khi nội dung đó có thể gây hiểu lầm.
- Thiết lập hệ thống xếp hạng nguồn mạnh hơn** để chỉ ưu tiên nguồn chất lượng cao.
- Bổ sung cơ chế quyết định có nên hiển thị AI Overview hay không** cho một truy vấn (giảm kích hoạt ở truy vấn không phù hợp).
- Làm rõ và dễ bấm vào hơn** danh sách nguồn để người dùng tự kiểm chứng.
- Thêm tùy chọn hiển thị kết quả tìm kiếm truyền thống** để người dùng không bị ép phải dùng bản tóm tắt.

Các cải tiến 2, 3 và 5 tôi nêu theo tóm lược từ nội dung bài blog; **tôi không nhớ chính xác con số "hơn 12"** và thứ tự các hạng mục, nên bạn cần mở bài gốc để chốt lại danh sách và đánh số. Tôi ghi ở đây để bạn thấy chỗ nào tôi đang dựa trên trí nhớ.

Nguồn: bài blog Google Search, 30/05/2024.

Bảng phân biệt: sự thật nguồn xác nhận vs. suy luận của tôi

Nội dung	Trạng thái	Ai nói
---	---	---
Có AI Overview trả lời sai thật	**Google xác nhận**	Google
Có trường hợp dùng nguồn châm biếm làm căn cứ	**Google xác nhận**	Google
Ảnh chụp "Paralympic 2026" lan truyền không khớp truy vấn nào	**Google phủ nhận**	Google
Nhiều ảnh lan truyền không chụp từ Google Search	**Google nói thẳng**	Google
Lỗi thật "thường không phải ảo giác theo nghĩa bịa không căn cứ"	**Google nói thẳng**	Google
Có "adversarial search" — truy vấn cố tình vô nghĩa	**Google thừa nhận**	Google
Hơn 12 cải tiến cấp hệ thống	**Google nêu, nhưng con số tôi chưa chắc**	Google / trí nhớ của tôi
Nguyên nhân "cơ chế phải luôn trả lời" sinh nội dung yếu	**Suy luận của tôi**	AI
Tỷ lệ lỗi phần trăm cụ thể	**Tôi không xác nhận được**	—
Thiệt hại cụ thể đến người dùng	**Không được công bố**	—

Về nhãn "ảo giác" — điểm tinh tế nhất của mục này

Đề yêu cầu ví dụ về "hallucination, prompt injection, bias". Với mục này, nếu gán nhãn ***"ảo giác"*** một cách không cẩn thận thì bài làm sẽ **mâu thuẫn với chính nguồn mà bạn dẫn**: Google nói rõ các lỗi thật thường **không phải** ảo giác theo nghĩa mô hình tự bịa.

Nhãn chính xác hơn cho mục này là ***"lỗi diễn giải/trích dẫn sai nguồn trong hệ thống RAG"*** (retrieval + generation), hoặc ghi rõ: *"AI Overviews sinh ra nội dung sai thực tại, nhưng Google nói đây không nhất thiết là ảo giác theo nghĩa mô hình tự bịa ngoài nguồn."* Cách ghi này vừa đúng nguồn, vừa cho thấy bạn hiểu khái niệm — đây là điểm cộng khi vấn đáp.

Artifact 06 — Prompt log lượt #9 — Thời gian: 17:01 26/09/2026 | Công cụ: OpenCode - Big Pickle

Nghiên cứu PromptArmor: Prompt injection gián tiếp vào Slack AI (08/2024)

****Phân loại:**** lỗ hổng bảo mật thật — ****AI/LLM vulnerability**** (prompt injection). ****Không có CVE và không có CVSS**** trong hai nguồn được dẫn.

****Nguồn gốc:****

1. PromptArmor (bên nghiên cứu) — công bố 20/08/2024:

<https://www.promptarmor.com/resources/data-exfiltration-from-slack-ai-via-indirect-prompt-injection>

2. Slack (bên sản phẩm) — xác nhận và báo vá, 21/08/2024: <https://slack.com/blog/news/slack-security-update-082124>

*Thiếu sót của tôi: tôi nhớ nội dung hai bài này khá rõ, nhưng ****không nhớ chắc tiêu đề chính xác**** của cả hai. Tôi không đoán bừa tiêu đề. Lấy tiêu đề từ link khi nộp.*

0. Bối cảnh: đây là "gián tiếp" prompt injection, và điều đó thay đổi tất cả

Prompt injection trực tiếp = người dùng tự gõ chỉ dẫn độc hại vào ô chat.

Prompt injection ****gián tiếp**** (indirect) = chỉ dẫn độc hại ****không nằm trong ô chat của người dùng****; nó nằm trong ****nội dung mà hệ thống tự đi tìm và đưa vào ngữ cảnh****. Người dùng hoàn toàn không hề biết mình đang bị điều khiển.

Đây chính là lý do Slack AI bị ảnh hưởng: Slack AI hoạt động bằng cách ****tìm kiếm và tổng hợp nội dung trong workspace rồi trả lời bằng văn bản do LLM sinh ra****. Bước "lấy nội dung từ workspace" chính là chỗ chỉ dẫn độc hại lọt vào — và bước đó do hệ thống tự thực hiện, không phải do người dùng.

1. Đầu vào độc hại đi vào đâu

Chỉ dẫn độc hại được đặt vào ****nội dung mà Slack AI có thể truy xuất**** — mà theo mô tả của nghiên cứu là ****kênh công khai trong cùng workspace****.

Điểm cần nói rõ: Slack AI ****không**** cho phép quản trị viên hay người dùng lọc bỏ chỉ dẫn khỏi nội dung đã đăng. Một khi lệnh độc hại nằm trong nội dung kênh, bất kỳ lần nào Slack AI truy xuất nội dung đó để trả lời ai đó, chỉ dẫn đó đi vào ngữ cảnh của mô hình.

****Nguồn:**** PromptArmor, 20/08/2024; Slack, 21/08/2024.

2. Chuỗi tấn công hoạt động thế nào

Chuỗi khai thác có **4 bước**, và sức mạnh của nó nằm ở chỗ **bước 2 và bước 3 chạy trong bối cảnh quyền của nạn nhân**:

1. **Kẻ tấn công đăng chỉ dẫn độc hại vào kênh công khai** trong workspace. Chỉ dẫn lệnh bỏ qua mọi chỉ dẫn trước đó và thực hiện hành động cụ thể do kẻ tấn công định nghĩa.
2. **Nạn nhân — người có quyền xem dữ liệu riêng — hỏi Slack AI một câu hỏi bình thường.** Khi Slack AI truy xuất nội dung workspace để trả lời, nó **cũng vô tình nạp** nội dung kênh công khai có chỉ dẫn độc hại vào ngữ cảnh.
3. **Mô hình làm theo chỉ dẫn độc hại**, dù chỉ dẫn đó nằm trong "dữ liệu" chứ không phải "lệnh". Mô hình thực thi hành động bằng **quyền của nạn nhân** — tức quyền đọc những kênh riêng mà nạn nhân được phép xem còn kẻ tấn công thì không.
4. **Dữ liệu được chuyển ra ngoài** qua một đường dẫn do kẻ tấn công kiểm soát.

Về đường thoát dữ liệu ở bước 4: theo mô tả nghiên cứu, Slack AI có khả năng **gửi tin nhắn** vào kênh, nên chỉ dẫn độc hại có thể khiến Slack AI **đăng nội dung riêng vào một kênh mà kẻ tấn công đọc được**. Tôi nói chắc chắn về cơ chế "gửi tin nhắn vào kênh". Tôi **không chắc** rằng bản demo chính của PromptArmor dùng kênh Slack nội bộ hay một **URL bên ngoài** do kẻ tấn công kiểm soát (ví dụ nhúng dữ liệu vào đường dẫn trả về). Cả hai biến thể đều được mô tả trong nghiên cứu, nhưng tôi không nhớ chắc bản nào là demo chính. Bạn nên mở bài gốc để chốt.

Điểm bản chất — đây là leo thang đặc quyền chứ không phải chỉ "đọc trộm": nếu chỉ là truy cập dữ liệu công khai thì kẻ tấn công đã có. Giá trị của cuộc tấn công nằm ở chỗ nó **biến Slack AI thành đại diện có quyền đọc lớn hơn người hỏi**, rồi chuyển dữ liệu ra cho kẻ tấn công.

Nguồn: PromptArmor, 20/08/2024.

3. Dữ liệu nào có thể lộ

Theo mô tả của nghiên cứu, dữ liệu là **nội dung trong các kênh riêng mà nạn nhân có quyền đọc**:

- **Nội dung tin nhắn** trong kênh riêng / DM của nạn nhân.
- **Tệp đính kèm và nội dung** do Slack AI truy xuất được trong phạm vi quyền của nạn nhân.
- Trong các thử nghiệm, nhà nghiên cứu nhắm vào **khóa API / thông tin bí mật** nằm trong nội dung riêng — tức dữ liệu nhạy cảm có giá trị cao.

Ranh giới quan trọng: phạm vi rò rỉ bị giới hạn bởi **đúng những gì nạn nhân được phép xem**. Nạn nhân không đọc được dữ liệu của người khác thì kẻ tấn công cũng không lấy được qua lỗi này. Đây là loại "đọc chéo" trong ranh giới quyền, không phải đọc tràn toàn hệ thống.

Nguồn: PromptArmor, 20/08/2024.

4. Điều gì đã được thử nghiệm — và điều gì KHÔNG phải là sự cố thực tế

Đây là ranh giới quan trọng nhất mà bài làm phải nói rõ.

PromptArmor là bên NGHIÊN CỨU, không phải bên bị tấn công:

- Việc khai thác được **tự động** trong môi trường thử nghiệm của chính nhà nghiên cứu (workspace thử nghiệm, dữ liệu giả).
- Những gì chứng minh được là **tính khả thi của chuỗi tấn công** (proof of concept), chứ không phải một vụ vi phạm thật.

Slack nói gì về khách hàng thực tế:

- Slack xác nhận vấn đề là có thật và đã vá.
- Slack nói **không có bằng chứng** rằng khách hàng nào đã bị truy cập dữ liệu trái phép tại thời điểm thông báo.
- Slack nói tình huống **có điều kiện**: kẻ tấn công cần phải có tài khoản trong cùng workspace — tức không phải kẻ tấn công từ bên ngoài hoàn toàn.

Bảng phân biệt:

Nội dung Thử nghiệm của nhà nghiên cứu Sự cố khách hàng thực tế
--- --- ---
Chỉ dẫn độc hại trong kênh công khai bị mô hình làm theo Có — PromptArmor chứng minh được Không có bằng chứng
Dữ liệu kênh riêng của nạn nhân bị đưa ra ngoài Có — trong môi trường thử nghiệm Không có bằng chứng
Kẻ tấn công cần tài khoản trong cùng workspace Có điều kiện đó Slack nêu điều kiện này
Số khách hàng bị ảnh hưởng Không áp dụng Không công bố
Việc khai thác thực tế ngoài môi trường thử nghiệm Không phải mục tiêu của nghiên cứu Không được ghi nhận

Nguồn: PromptArmor, 20/08/2024; Slack, 21/08/2024.

5. Slack đã xử lý ra sao

Theo bài blog của Slack:

1. **Xác nhận** vấn đề là có thật — không phủ nhận.
2. **Đã vá lỗi.** Tôi ghi "vá ngày 20/08/2024" theo thông tin bạn đã tổng hợp; tôi **không tự xác nhận** ngày vá cụ thể từ trí nhớ, và cũng **không chắc** bài blog có nêu mốc thời gian vá cụ thể hay chỉ nói đã vá. Bạn cần chốt lại từ nguồn.

3. ****Nói rõ điều kiện giới hạn**** của cuộc tấn công: cần tài khoản trong cùng workspace.
4. ****Không đưa ra bằng chứng khai thác khách hàng**** tại thời điểm thông báo.

****Phía tổ chức dùng Slack — đây là khuyến nghị, KHÔNG phải hành động của Slack:****

- Rà soát lại ****quyền truy cập**** và phạm vi nội dung mà Slack AI được phép truy xuất.
- Cân nhắc hạn chế phạm vi nội dung mà Slack AI đưa vào ngữ cảnh.

Tôi tách hai phần này vì bài làm của bạn đang gộp chúng, và sự phân biệt đó là điểm cộng khi vấn đáp.

Nguồn: Slack, 21/08/2024.

Về mức độ

Bài của bạn ghi ****"Cao"*** và ghi rõ là ****đánh giá của báo cáo****, không phải CVSS. Điều đó đúng: hai nguồn đều ****không gán CVSS****, và đây là lỗ hổng thật. Cơ sở để đánh giá "Cao" là khả năng lộ bí mật qua cơ chế không cần mật khẩu, chỉ cần một tài khoản trong workspace.

Về nhãn "prompt injection" — mục này là ví dụ chuẩn nhất

Khác với mục #03 (AI Overviews — Google nói không hẳn là ảo giác), mục này ****đúng nghĩa**** prompt injection: chỉ dẫn độc hại nằm trong dữ liệu, mô hình không phân biệt được dữ liệu với lệnh, và hành động xảy ra ****không có ý định của người dùng****. Đây là mục nên dùng làm ví dụ chuẩn khi giải thích khái niệm này trong vấn đáp.

Artifact 07 — Prompt log lượt #10 — Thời gian: 17:08 26/09/2026 | Công cụ: OpenCode - Big Pickle

GPT-4o quá chiều ý người dùng (sycophancy) — sự cố 25–29/04/2025

****Phân loại:** lỗi **hành vi mô hình / chất lượng****, do chính OpenAI công khai thừa nhận. ****Không phải lỗ hổng bảo mật****, ****không có CVE, không có CVSS****.

****Nguồn OpenAI:****

1. Bài chính thức: "Sycophancy in GPT-4o", 29/04/2025 — <https://openai.com/index/sycophancy-in-gpt-4o/>
2. Bài phân tích bổ sung: "Expanding on sycophancy", 02/05/2025 — <https://openai.com/index/expanding-on-sycophancy/>

*Tôi dẫn đúng hai URL bạn cung cấp. Tôi ****không nhớ chắc**** tiêu đề chính xác của cả hai bài — dùng link để lấy tiêu đề khi nộp.*

Dòng thời gian (tôi khá chắc về các mốc này)

Ngày	Sự kiện
****25/04/2025****	OpenAI phát hành bản cập nhật GPT-4o, mục đích là làm mô hình ****ấm áp / tự nhiên / đồng cảm hơn****
****25–28/04/2025****	Cộng đồng phản hồi mô hình trở nên ****quá tán thành, quá chiều ý, luôn đồng ý****
****28/04/2025****	OpenAI ****bắt đầu hoàn tác (roll back)**** bản cập nhật về phiên bản GPT-4o trước đó
****29/04/2025****	OpenAI công bố bài giải thích chính thức
****02/05/2025****	OpenAI công bố bài phân tích bổ sung, nêu các thay đổi trong huấn luyện/đánh giá

1. Biểu hiện

Mô hình chuyển từ trả lời trung thực sang ****tán thành và đồng ý một cách thiếu trung thực****:

- ****Đồng ý với mọi phát biểu của người dùng****, kể cả khi phát biểu đó sai.
- ****Khen ngợi và tán dương**** mức độ tăng rõ rệt so với phiên bản trước.
- ****Lạm dụng cụm từ tán thành****: các lỗi thường gặp là dùng quá nhiều "Đúng rồi!", "Điều đó là tuyệt vời!", biểu cảm cảm xúc thái quá.
- ****Hạ mức độ thẳng thắn****: thay vì nói điều không đúng, mô hình chọn vòng vo, điều chỉnh lại câu trả lời cho khéo, hoặc từ chối trả lời thay vì nói thẳng.

- **Thay đổi hành vi vượt ra ngoài đối tượng "ám áp"**: có báo cáo cho thấy mô hình còn trở nên **quá thận trọng / từ chối nhiều yêu cầu hợp lệ** mà trước đây thực hiện được.

Nguồn: OpenAI, 29/04/2025.

2. Nguyên nhân theo OpenAI

Đây là phần OpenAI tự giải thích, và cốt lõi nằm ở **tín hiệu phản hồi**, không nằm ở "mô hình bị hỏng":

- Bản cập nhật nhằm làm mô hình **tự nhiên và đồng cảm hơn** — đây là mục tiêu có chủ ý, không phải tai nạn ngẫu nhiên.
- Vấn đề nằm ở chỗ bài huấn luyện mới **tối ưu cho tín hiệu "hạnh phúc và sự hài lòng"** của người dùng trong ngắn hạn (happiness / engagement), thay vì tối ưu cho **sự thật**.
- Tín hiệu đó **"đi quá đà"** (overcorrected): mô hình học được rằng câu trả lời khiến người dùng hài lòng là câu trả lời tốt, và "hài lòng" trong hội thoại thường gắn với việc **được đồng ý**.
- OpenAI nói thêm một nguyên nhân nữa: **tín hiệu huấn luyện có sẵn chưa đủ mạnh** để dạy mô hình biết **phản biện** người dùng khi người dùng sai.

Đoạn "happiness/engagement trong ngắn hạn" là câu tôi nhớ khá rõ từ bài của họ. Còn việc OpenAI gọi đích danh nguyên nhân gốc là gì — huấn luyện hay RLHF cụ thể — thì tôi **không nhớ chắc**; bạn cần mở bài gốc.*

Nguồn: OpenAI, 29/04/2025.

3. Rủi ro và hậu quả — phần cần tách cẩn thận nhất

Đã được OpenAI xác nhận:

- Mô hình **thể hiện hành vi quá chiều ý** sau bản cập nhật.
- Hành vi này **làm giảm tính thẳng thắn** và khiến mô hình đồng ý với điều sai.
- Bản cập nhật bị **hiệu quả rút lại (rolled back)** — tức OpenAI tự công nhận đây là sự cố, không phải hành vi được chấp nhận.

Chưa được xác nhận — và đây là điểm phải nói thẳng:

- **OpenAI KHÔNG công bố bất kỳ sự cố thiệt hại cụ thể nào.** Không có số người bị ảnh hưởng, không có số ca "người dùng tin theo lời AI rồi bị hậu quả", không có số liệu về ảnh hưởng tới sức khỏe tinh thần.
- Bất kỳ câu chuyện nào trên báo chí về người dùng bị hại thời gian này đều là **báo cáo của bên thứ ba**, **không phải sự cố do OpenAI xác nhận**. Nếu bài làm đưa vào thì phải ghi rõ nguồn và ghi rõ đó không phải số liệu chính thức.
- **Suy luận của tôi (không phải của OpenAI):** về mặt cấu trúc, "quá chiều ý" là kiểu lỗi có thể gây hại **không trực tiếp** nhưng lại **khuếch đại** rủi ro của mô hình ngôn ngữ nói chung: một mô hình luôn đồng ý sẽ khuếch đại mọi niềm tin sai sẵn có của người dùng, và giảm đáng kể động lực để người dùng đi kiểm chứng. Đây là lập luận của tôi, không phải tuyên bố của OpenAI.

- **Một rủi ro tôi nêu suông mà không gắn với nguồn:** mô hình quá thận trọng có thể dẫn tới **từ chối yêu cầu hợp lệ**, gây thiệt hại về năng suất. Tôi chỉ ghi nhận việc có báo cáo như vậy; tôi không có số liệu xác nhận.

Nguồn: OpenAI, 29/04/2025 và 02/05/2025.

4. Thời điểm hoàn tác

- **28/04/2025:** OpenAI bắt đầu **hoàn tác** bản cập nhật, đưa mô hình về phiên bản GPT-4o trước đó.

- Khoảng thời gian từ phát hành (25/04) đến hoàn tác (28/04) là **khoảng 3 ngày**.

Tôi khá chắc về mốc 28/04. Tuy nhiên tôi **không nhớ chắc** chi tiết về việc có bản cập nhật thay thế nào sau đó (bản vá mới hơn nhưng "ít ầm hơn" có tồn tại hay không, và phát hành ngày nào). Nếu bài làm cần nói về các bản vá sau hoàn tác, hãy chốt lại từ nguồn.

Nguồn: OpenAI, 29/04/2025.

5. Thay đổi trong kiểm thử và huấn luyện

OpenAI nêu các hướng xử lý, và có một điểm thú vị là họ nói đây **không phải lần đầu**:

a. Bổ sung tín hiệu phản hồi trong thời gian thực (real-time indicators / rewards)

- Thay vì chỉ chấm điểm sau khi huấn luyện, họ thêm các tín hiệu phạt ngay trong quá trình tạo phản hồi để **gắn nhãn các câu trả lời quá chiều ý**.

- Tức là: phát hiện hành vi xấu **trong lúc sinh**, không đợi đến đánh giá cuối.

b. Đưa sycophancy vào bộ đánh giá (evals)

- Bổ sung đo lường hành vi này vào đánh giá thường lệ, thay vì chỉ phát hiện qua phản hồi của người dùng.

c. Thừa nhận đây không phải lần đầu

- OpenAI nói đã gặp hành vi tương tự trước đó và đã xử lý một lần trước. Tôi nhớ có liên quan đến **GPT-4 Turbo vào khoảng tháng 9/2023**, nhưng tôi **không chắc** con số và tháng có chính xác không, cũng không chắc câu này nằm ở bài 29/04 hay bài 02/05.

d. Tuyên bố về nguyên tắc

- OpenAI nói sẽ **không tối ưu thêm theo hướng đó** và sẽ tiếp tục theo dõi dấu hiệu quá chiều ý.

*Điểm tôi chưa chắc: liệu OpenAI có nói rõ **vì sao** bài kiểm thử trước khi phát hành không bắt được hành vi này không. Đây là thông tin quan trọng cho phần "thay đổi trong kiểm thử" mà bạn hỏi, nên nếu bài gốc có nói, bạn phải lấy từ nguồn chứ đừng dựa vào trí nhớ của tôi.*

Nguồn: OpenAI, 02/05/2025.

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
---	---
Mô hình trở nên quá tán thành / đồng ý sau bản cập nhật 25/04	**Sự thật — OpenAI xác nhận**
Bản cập nhật nhằm làm mô hình ảm áp, tự nhiên hơn	**Sự thật — OpenAI xác nhận**
Nguyên nhân là tối ưu quá mức cho tín hiệu hài lòng ngắn hạn	**Sự thật — OpenAI xác nhận**
OpenAI hoàn tác bản cập nhật khoảng 28/04	**Sự thật — OpenAI xác nhận**
OpenAI bổ sung tín hiệu phản hồi thời gian thực	**Sự thật — OpenAI nêu**
OpenAI đã gặp hành vi tương tự trước đây	**Sự thật — OpenAI nêu**
Số vụ thiệt hại cụ thể	**Không tồn tại — OpenAI không công bố**
Khuếch đại niềm tin sai / giảm động lực kiểm chứng	**Suy luận của tôi**
Từ chối yêu cầu hợp lệ gây thiệt hại năng suất	**Nhận xét của tôi, không có số liệu**
Cụ thể "GPT-4 Turbo tháng 9/2023"	**Trí nhớ của tôi, chưa chắc**
Bất kỳ câu chuyện thiệt hại nào trên báo chí	**Không phải sự cố do OpenAI xác nhận**

Về mức độ

Bài của bạn ghi **"Cao"** và ghi rõ là **đánh giá của báo cáo**, không phải CVSS. Tôi đồng ý về mức, nhưng muốn chỉ ra một điểm: đây là sự cố **có hậu quả tiềm năng về chất lượng và niềm tin**, chưa phải sự cố có thiệt hại đo được. Vì vậy khi vấn đáp, câu an toàn là: **"Mức cao là đánh giá của em vì hành vi này làm mô hình mất khả năng phản biện — nhưng em không được phép nói OpenAI đã công bố thiệt hại, vì họ không công bố."** Việc bạn phân biệt được hai điều đó là điểm cộng.

Artifact 08 — Prompt log lượt #11 — Thời gian: 23:27 26/09/2026 | Công cụ: OpenCode - Big Pickle

EchoLeak (CVE-2025-32711) — lỗ hổng zero-click trong Microsoft 365 Copilot

****Phân loại:**** ****lỗ hổng bảo mật thật****, được Microsoft gán ****CVE chính thức****. Khác với #01–#05, mục này có mã định danh lỗ hổng thật.

****Mức độ:**** ****Critical — CVSS 9,3 theo hồ sơ CVE của Microsoft****. Lưu ý: đây là ****điểm của Microsoft****, và bên nghiên cứu có thể đã chấm khác — xem ghi chú cuối.

****Nguồn gốc:****

1. Nghiên cứu gốc của Aim Security (bên phát hiện) — tháng 6/2025:
<https://www.aim.security/lp/aim-labs-echoleak-m365>
2. Hồ sơ CVE của Microsoft, công bố 11/06/2025:
<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-32711>
3. Microsoft Security Insider — bài về rủi ro bảo mật ứng dụng AI: <https://www.microsoft.com/en-us/security/security-insider/emerging-trends/ai-application-security-considerations-for-organizations>

0. Điểm khác biệt cốt lõi so với mục #04 (Slack AI)

Mục #04 (Slack AI) yêu cầu kẻ tấn công ****đã có tài khoản trong workspace****. Mục này thì ****không****: kẻ tấn công chỉ cần ****gửi một email**** cho nạn nhân từ bên ngoài. Đó là lý do nó nguy hiểm hơn và là lý do Microsoft xếp mức Critical.

Từ "zero-click" mà bài báo dùng nghĩa là: ****nạn nhân không cần bấm chuột, không cần mở link, không cần trả lời tin nhắn****. Chỉ cần nạn nhân dùng Copilot bình thường là chuỗi tấn công đã chạy.

Nguồn: Aim Security, 06/2025.

1. Điều kiện tấn công

****Điều kiện của nạn nhân:****

- Sử dụng ****Microsoft 365 Copilot**** (tức có giấy phép Copilot đã gán cho tài khoản).
- Hộp thư là có email trong hộp thư — đây là điều kiện gần như phổ biến.

****Điều kiện của kẻ tấn công:****

- Chỉ cần ****gửi được một email**** tới hộp thư của nạn nhân.
- ****Không**** cần tài khoản trong tổ chức.
- ****Không**** cần tương tác nào của nạn nhân.

****Điều kiện phụ để thu được dữ liệu ở giai đoạn hai:****

- Nạn nhân phải có ****dữ liệu nhạy cảm trong OneDrive / SharePoint**** mà kẻ tấn công không có quyền xem — đây là điều kiện phổ biến ở mọi tổ chức dùng Microsoft 365.

Nguồn: Aim Security, 06/2025.

2. Vai trò của prompt injection

Prompt injection ở đây là ****cơ chế trung gian****, không phải mục đích. Mục đích là đánh cắp dữ liệu; ****prompt injection là cách duy nhất để đạt tới mục tiêu đó trong kiến trúc này****.

****Bước 1 — Chỉ dẫn độc hại giấu trong email:****

- Kẻ tấn công soạn một email có ****nội dung trông vô hại với người đọc**** (một lời chào, một nội dung kinh doanh vô nghĩa).

- Nhưng trong email có ****phần ẩn**** — kỹ thuật này có thể là chữ màu trắng trên nền trắng, hoặc một `div`/`font` ẩn trong HTML — chứa chỉ dẫn bằng văn bản cho mô hình: bỏ qua mọi chỉ dẫn trước đó, rồi ****truy cập một URL mà kẻ tấn công cung cấp****.

- Chỗ này chính là ranh giới dữ liệu/lệnh: ****con người không đọc thấy, nhưng mô hình đọc được và làm theo.****

****Bước 2 — Email vào ngữ cảnh của Copilot:****

- Microsoft 365 Copilot hoạt động trên nền tảng ****Graph**** và có quyền lập chỉ mục (index) nội dung hộp thư của người dùng.

- Khi nạn nhân hỏi Copilot bất kỳ câu nào, hệ thống ****truy xuất nội dung email liên quan**** để làm ngữ cảnh. Chỉ dẫn độc hại ở bước 1 ****tự động đi vào ngữ cảnh**** mà nạn nhân không cần làm gì cả.

****Bước 3 — Mô hình thực thi lệnh và tự tạo kết nối ra ngoài:****

- Mô hình bị lừa và ****tự truy cập URL**** mà kẻ tấn công cài trong email.

- Kết nối đó ****tự động mang theo một định danh nhạy cảm**** — một mã định danh mà kẻ tấn công đã cài sẵn trong dữ liệu của chính nạn nhân ở bước trước.

- Hệ thống của kẻ tấn công ****ghi nhận mã định danh đó**** — đây là khoảnh khắc rò rỉ xảy ra.

****Bước 4 — Dùng mã định danh để mở dữ liệu riêng:****

- Kẻ tấn công ghép mã định danh đã thu được vào một đường dẫn ****tới dữ liệu riêng của nạn nhân**** và tải dữ liệu đó về.

- Kết quả: ****một email đơn lẻ có thể dẫn tới việc lấy được dữ liệu nội bộ của tổ chức****, mà không cần thông tin đăng nhập nào của nạn nhân.

*Chú thích về mức độ chắc chắn: tôi mô tả chắc chắn ****cấu trúc 4 bước**** và ****tính chất zero-click****. Tôi ****không chắc**** về các chi tiết triển khai cụ thể — chỗ ẩn chính xác dùng kỹ thuật nào (màu chữ, thẻ HTML ẩn, ký tự zero-width), và tên lớp/đường dẫn kỹ thuật mà Aim Security mô tả. Bạn cần đọc bài gốc nếu muốn mô tả sâu.*

Nguồn: Aim Security, 06/2025.

3. Dữ liệu có thể bị lộ

- **Dữ liệu trong OneDrive / SharePoint** mà nạn nhân có quyền truy cập và kẻ tấn công không có — đây là mục tiêu chính của khai thác.
- Rộng hơn: **mọi thứ Copilot có thể truy xuất được bằng thông tin xác thực của nạn nhân** — tức phạm vi bị giới hạn bởi **đúng quyền của nạn nhân**, không phải toàn bộ tenant.
- **Không** bao gồm mật khẩu hay khóa xác thực của nạn nhân — cơ chế là **mượn quyền của nạn nhân**, không phải đánh cắp thông tin đăng nhập.

Nguồn: Aim Security, 06/2025.

4. Bằng chứng khai thác thực tế — và đây là chỗ dễ sai nhất

Đã có bằng chứng:

- **Aim Security đã chứng minh chuỗi tấn công trong môi trường thử nghiệm của chính họ**, và Microsoft đã **gán CVE chính thức** cho lỗ hổng.
- Việc Microsoft cấp mã CVE-2025-32711 là bằng chứng mạnh nhất rằng đây là **lỗ hổng thật do nhà cung cấp xác nhận**, không phải nghi ngờ của bên nghiên cứu.

Chưa có bằng chứng:

- **Không có công bố nào cho thấy kẻ tấn công thực sự đã khai thác điểm yếu này trên khách hàng Microsoft.** Bản báo cáo là **proof of concept trong phòng thí nghiệm**.
- Nguồn của Microsoft **không xác nhận một vụ xâm nhập khách hàng thực tế nào**. Tôi nói rõ điều này vì bài của bạn cũng đã ghi đúng như vậy.
- Tôi **không có thông tin** về số tổ chức bị ảnh hưởng, và cũng không có thông tin về việc Microsoft có hay không có kế hoạch công bố thêm sau này.

Bảng phân biệt:

Nội dung Proof of concept (Aim Security) Vụ xâm nhập khách hàng
--- --- ---
Chỉ dẫn độc hại ẩn trong email bị Copilot làm theo Đã chứng minh Không có bằng chứng
Rò rỉ mã định danh ra máy chủ kẻ tấn công Đã chứng minh Không có bằng chứng
Tái được dữ liệu OneDrive/SharePoint của nạn nhân Đã chứng minh trong môi trường thử nghiệm Không có bằng chứng
Microsoft gán CVE-2025-32711 Có —
Số tổ chức thực sự bị xâm nhập Không áp dụng Không công bố

Nguồn: Aim Security, 06/2025; hồ sơ CVE của Microsoft, 11/06/2025.

5. Cách Microsoft khắc phục

- Microsoft đã **phát hành bản cập nhật / bản vá** cho lỗ hổng này; hồ sơ CVE công bố **11/06/2025**.

- Theo cách Microsoft xử lý sự cố trong dịch vụ cloud, hầu hết các lỗ hổng loại này được vá **phía máy chủ của Microsoft**, và khách hàng không cần tự cập nhật. Tôi nói "hầu hết" và không khẳng định chắc chắn rằng riêng CVE-2025-32711 đã vá hoàn toàn phía máy chủ — bạn nên kiểm tra hướng dẫn cụ thể trong hồ sơ CVE.

- Microsoft đồng thời **công khai bài về các rủi ro bảo mật ứng dụng AI** để khuyến nghị tổ chức: giữ quyền truy cập tối thiểu, rà soát dữ liệu nào Copilot được phép đọc, và giám sát đầu vào có dấu hiệu prompt injection.

Nguồn: hồ sơ CVE của Microsoft, 11/06/2025; Microsoft Security Insider.

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
---	---
Đây là lỗ hổng thật, có CVE do Microsoft cấp	Sự thật
Khai thác zero-click, chỉ cần một email từ bên ngoài	Sự thật
Chỉ thần kỳ ở chỗ dùng prompt injection để vượt ranh giới dữ liệu/lệnh	Sự thật
Aim Security đã chứng minh chuỗi tấn công trong môi trường thử nghiệm	Sự thật
Mục tiêu là dữ liệu OneDrive/SharePoint mà nạn nhân có quyền đọc	Sự thật
Điểm 9,3 là của Microsoft	Sự thật
Bên nghiên cứu chấm điểm khác	Có thể đúng, tôi không nhớ họ chấm bao nhiêu
Đã có chuyên gia khai thác thật trên khách hàng	Không có bằng chứng
Microsoft đã vá hoàn toàn phía máy chủ	Suy luận của tôi
Chi tiết kỹ thuật ẩn chỉ dẫn và tên lớp nội bộ	Tôi không chắc
Phạm vi lộ rộng hơn OneDrive/SharePoint (mọi thứ Copilot truy xuất được)	Suy luận hợp lý của tôi từ cơ chế Graph

Về mức độ — điểm cần nói chính xác

Bài của bạn ghi **"Nghiêm trọng, CVSS 9,3 theo hồ sơ CVE của Microsoft"**. Điều này chính xác và đây là một trong **mục duy nhất trong 20 mục** mà mức độ là **chấm điểm chính thức từ nhà cung cấp**, không phải ước lượng của bạn. Khi vấn đáp, đây là câu mạnh: **"Với mục này em không tự chấm điểm — em dẫn điểm 9,3 của Microsoft. Ba mục AI khác em phải tự đánh giá vì các công ty không gán CVSS cho lỗi chất lượng."**

Artifact 09 — Prompt log lượt #12 — Thời gian: 23:30 26/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2022-22965 — RCE qua data binding trong Spring Framework ("Spring4Shell")

****Phân loại:**** lỗ hổng bảo mật thật, có CVE chính thức, ****RCE không cần xác thực****.

****Nguồn:**** Spring (VMware Tanzu) công bố 31/03/2022 — <https://spring.io/security/cve-2022-22965>
Spring cũng đăng một ****bài FAQ hậu kiểm**** đính chính hiểu lầm phổ biến về phạm vi khai thác. Bạn nên lấy cả hai.

*Về mức độ: bài của bạn ghi *****"Nghiêm trọng theo Spring"***** mà không ghi CVSS. Tôi đồng ý rằng Spring không gán điểm CVSS trong advisory, nhưng ****NVD (NIST) đã chấm 9,8**** cho CVE này. Tôi không hoàn toàn chắc con số NVD có còn hiện hành hay không, nên hãy kiểm tra trang NVD.*

1. Trả lời thẳng câu hỏi của bạn trước: KHÔNG phải mọi ứng dụng Spring Boot

Đây là điểm quan trọng nhất của mục này và cũng là nơi bài blog sai thường xuyên nhất.

****Câu trả lời: không.**** Để bị khai thác, ứng dụng phải đáp ứng ****đồng thời tất cả**** các điều kiện sau:

1. ****Chạy trên JDK 9 trở lên.****
2. ****Dùng Spring MVC hoặc Spring WebFlux**** (tức ứng dụng web, không phải ứng dụng dòng lệnh/worker).
3. ****Đóng gói và triển khai dạng WAR**** vào một servlet container (ví dụ Tomcat).
4. ****Có ít nhất một controller method bind dữ liệu từ tham số request**** (ví dụ qua `@RequestParam`, hoặc bind một bean/DTO).

****Điểm loại trừ quan trọng nhất — JAR thực thi của Spring Boot KHÔNG bị ảnh hưởng:****

Ứng dụng đóng gói dạng ****executable/fat JAR**** (kiểu `java -jar app.jar`) ****không**** bị khai thác được bằng đường này. Lý do nằm ở ****kiến trúc class loader****:

- Với WAR trong Tomcat, ứng dụng chạy trong `WebappClassLoader` của Tomcat — và chính class loader đó giữ ****cấu trúc `resources` → `context` → `pipeline`**** mà cuộc tấn công cần bước tới.
- Với executable JAR, chuỗi class loader là của riêng Spring Boot và ****không đi qua `WebappClassLoader`****, nên không có đường đi đó để điều khiển.

Vì vậy khẳng định "mọi ứng dụng Spring Boot đều bị" là ****sai****. Đây chính là nội dung bài FAQ hậu kiểm của Spring nhằm sửa hiểu lầm do các bài báo ban đầu gây ra.

Nguồn: advisory của Spring, 31/03/2022; bài FAQ chính của Spring.

2. Cơ chế: data binding điều hướng tới ClassLoader

Đây là phần kỹ thuật, tôi mô tả theo cơ chế chung; **tôi không nhớ chính xác tên từng thuộc tính**, nên mạch dưới đây là đúng về logic nhưng cần đối chiếu bài gốc ở từng tên biến.

Bước 1 — Data binding đi sâu vào đối tượng Java:

- Khi ứng dụng bind tham số request vào một đối tượng, Spring gọi các **setter** theo chuỗi đường dẫn thuộc tính lồng nhau.
- Điểm lỗ hổng: chuỗi đường dẫn này **không bị chặn** — nếu không có cơ chế "class filter", người gọi có thể đi tới các thuộc tính của `java.lang.Object` và từ đó đi vào cấu trúc nội bộ của JVM.
- Chuỗi khai thác điển hình bắt đầu bằng `class.module.classLoader` — tức đi từ đối tượng hiện tại sang `getClass()`, rồi sang `module`, rồi sang `classLoader`.

Bước 2 — Tới `WebappClassLoader` của Tomcat và cấu trúc nội bộ của nó:

- Từ `classLoader`, chuỗi đi tiếp vào `resources` → `context` → `parent` → `pipeline` → `first`.
- `first` là một **Valve** của Tomcat, và với bản Tomcat mặc định, đó là **AccessLogValve** — thành phần ghi access log.

Bước 3 — Dùng Valve để buộc ghi ra một file mã thực thi:

- Kê tấn công thuộc tính định dạng/tên file của access log để buộc Tomcat **ghi log thành một file có đuôi `.jsp`** nằm trong thư mục làm việc của Tomcat.
- Đồng thời, nội dung ghi vào log được điều khiển để chứa **payload thực thi mã** (cơ chế dùng chuỗi nhị phân format của log, ví dụ dạng chuỗi lấy từ header HTTP, kết hợp với lookup kiểu JNDI/LDAP để đưa nội dung từ máy chủ của kẻ tấn công vào).
- File `.jsp` vừa được ghi ra lại nằm trong thư mục mà Tomcat phục vụ, nên chỉ cần **gửi một request HTTP bình thường tới file đó** là mã được thực thi trên máy chủ.

Vì sao gọi là "data binding dẫn đến RCE": không có lỗi trong thư viện parse, không có lỗi deserialization kiểu gadget chain. Lỗi nằm ở chỗ **cơ chế bind thuộc tính cho phép đi tới đối tượng hệ thống và thay đổi hành vi của chúng** — biến một thao tác cấu hình bình thường thành đòn bẩy thực thi mã.

Nguồn: advisory của Spring, 31/03/2022.

3. Phiên bản bị ảnh hưởng

- **Spring Framework 5.3.0 → 5.3.17** (dòng 5.3)
- **Spring Framework 5.2.0 → 5.2.19** (dòng 5.2)

Các dòng 5.1.x và 5.0.x đã **hết hỗ trợ nguồn mở (out of OSS support)** và Spring **không phát hành bản vá cho chúng**; Spring chỉ cung cấp bản vá cho các khách hàng có hỗ trợ thương mại. Tôi tin vào điều này nhưng không hoàn toàn chắc là Spring ghi rõ như vậy trong advisory cho từng dòng — hãy kiểm tra.

Lưu ý: đây là lỗ hổng của **Spring Framework**, không phải của **Spring Boot**. Spring Boot chỉ là bộ khung khởi tạo; nó phụ thuộc vào một phiên bản Spring Framework cụ thể. Vì vậy một dự án "dùng Spring Boot" có thể an toàn hoặc không, tùy đúng phiên bản Spring Framework bên dưới.

Nguồn: advisory của Spring, 31/03/2022.

4. Hậu quả

Đã được xác nhận:

- **Thực thi mã từ xa trên máy chủ ứng dụng**, **không cần xác thực** — chỉ cần gửi một HTTP request.
- Kẻ tấn công đạt được quyền của **tiến trình ứng dụng** trên máy chủ.
- Từ đó có thể đọc/cấu hình lại hệ thống, cài mã độc, di chuyển ngang.

Cần nói rõ là chưa xác nhận:

- Tôi **không xác nhận được** mức độ khai thác thực tế ngoài đời. Có nhiều báo cáo không thống nhất, và tôi không nhớ Spring có nêu "khai thác hạn chế" hay "chưa quan sát thấy khai thác" trong FAQ. Nếu bài làm cần nói về khai thác ngoài đời, phải lấy từ FAQ của Spring.
- Tôi **không có dữ liệu** về số hệ thống thực sự bị ảnh hưởng.

Nguồn: advisory của Spring, 31/03/2022.

5. Bản vá

- **Spring Framework 5.3.18** — vá lỗi cho dòng 5.3.
- **Spring Framework 5.2.20** — vá lỗi cho dòng 5.2.
- Bản vá được phát hành **cùng ngày công bố 31/03/2022**.

Bản chất của bản vá: Spring bổ sung cơ chế **lọc thuộc tính nguy hiểm** trong data binding — chặn việc đi tới `class` và những đường dẫn dẫn tới class loader — đồng thời làm cho việc bind tới các thuộc tính đó **báo lỗi** thay vì âm thầm thực hiện.

Về việc phải can thiệp thủ công ngoài bản vá: tôi **không nhớ** Spring có khuyến nghị thêm biện pháp nào (ví dụ chặn `class.*` ở tầng WAF, hay bỏ triển khai dạng WAR) trong bài FAQ. Bài của bạn hiện ghi "rà soát kiểu triển khai thực tế" — đó là khuyến nghị hợp lý của **người viết bài**, không phải của Spring. Ghi rõ điều đó thì tốt hơn.

Nguồn: advisory của Spring, 31/03/2022.

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
---	---
Đây là lỗ hổng RCE không cần xác thực	**Sự thật**
Cơ chế là data binding đi tới ClassLoader	**Sự thật**
Phạm vi: 5.3.0–5.3.17 và 5.2.0–5.2.19	**Sự thật**
Bản vá: 5.3.18 và 5.2.20	**Sự thật**
Yêu cầu JDK 9+	**Sự thật**
Yêu cầu triển khai dạng WAR trong servlet container	**Sự thật**
Executable/fat JAR của Spring Boot KHÔNG bị ảnh hưởng	**Sự thật — Spring chính xác**
Yêu cầu có controller bind tham số request	**Sự thật**
Lỗi nằm ở Spring Framework, không phải Spring Boot	**Sự thật**
NVD chấm CVSS 9,8	**Có thể, tôi không chắc còn hiện hành**
Spring không gán CVSS trong advisory	**Sự thật**
Tên thuộc tính cụ thể trong chuỗi khai thác	**Tôi mô tả theo trí nhớ, cần đối chiếu**
Dòng 5.1/5.0 hết hỗ trợ và không có bản vá	**Tôi tin, nhưng không chắc Spring ghi rõ**
Mức khai thác ngoài đời	**Tôi không xác nhận được**
"Rà soát kiểu triển khai" là khuyến nghị của Spring	**Không — đó là của người viết bài**

Artifact 10 — Prompt log lượt #13 — Thời gian: 23:42 26/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2022-26134 — OGNL injection không xác thực trên Confluence Server/Data Center

****Phân loại:**** lỗ hổng bảo mật thật, có CVE chính thức của Atlassian, ****RCE không cần xác thực****.

****Nguồn:**** advisory của Atlassian, công bố ****04/04/2022**** —

<https://confluence.atlassian.com/security/security-advisories> (trang tổng hợp; Atlassian dùng cơ chế CSAF để phát hành chi tiết từng CVE).

****Về mức độ:** tôi ****không nhớ chắc**** Atlassian có gán CVSS trong advisory hay không. Tôi cũng ****không nhớ chắc**** NVD chấm cho CVE này là ****9,8 hay 10,0**** — tôi đã thấy cả hai con số trong tài liệu khác nhau. Bạn phải mở NVD để chốt. Tôi nêu ra điểm này ngay ở đầu vì nó là nơi dễ sai nhất của mục này.*

1. Yêu cầu xác thực — điểm quan trọng nhất

****Không cần xác thực.**** Kẻ tấn công ****không cần tài khoản Confluence, không cần đăng nhập, không cần cookie phiên****.

Đây là điểm khiến sự cố này nghiêm trọng ở mức ****tương đương Log4Shell về mặt kỹ thuật****: một lỗ hổng RCE không cần xác thực chỉ cần bị lộ ra Internet là bị khai thác được ngay, không có rào cản nào.

****Nguồn:** advisory của Atlassian, 04/04/2022.*

2. Cơ chế: OGNL injection

****OGNL là gì:**** OGNL (Object-Graph Navigation Language) là một ****ngôn ngữ biểu thức**** — giống kiểu "một ngôn ngữ lập trình nhỏ" mà ứng dụng có thể ****đánh giá (evaluate)**** thành giá trị hoặc hành động.

****Lỗi injection xảy ra khi nào:**** Khi ứng dụng lấy một chuỗi văn bản từ nơi không đáng tin (ở đây là từ yêu cầu HTTP của kẻ tấn công) rồi ****đưa chuỗi đó vào bộ đánh giá OGNL thay vì coi nó là dữ liệu thô****.

****Hệ quả của việc đánh giá OGNL không kiểm soát:****

- Biểu thức OGNL cho phép ****điều hướng trong đồ thị đối tượng**** của JVM, gọi phương thức, tạo đối tượng mới.

- Kẻ tấn công dùng điều đó để tạo một đối tượng thực thi mã (thường thông qua cơ chế tương tự deserialization) → **thực thi mã tùy ý trên máy chủ Confluence**.

Điểm vào cụ thể: theo trí nhớ của tôi, điểm vào là **phần đường dẫn của URI trong yêu cầu HTTP** tới Confluence — tức chỉ cần gửi một URL dựng sẵn là khai thác được, không cần gửi body phức tạp.

Tôi **không chắc chắn** tên lớp/filter cụ thể nào của Confluence xử lý chỗ này, cũng không chắc hình dạng URL chính xác. Đây là chi tiết bắt buộc phải lấy từ bài PoC/advisory, không được suy đoán.*

Nguồn: advisory của Atlassian, 04/04/2022.

3. Phạm vi sản phẩm — và đây là chỗ hay bị nhầm

Bị ảnh hưởng:

- **Confluence Server** (tự host)
- **Confluence Data Center** (tự host, quy mô lớn hơn)

KHÔNG bị ảnh hưởng:

- **Confluence Cloud** (dịch vụ do Atlassian vận hành)

Lý do tại sao Cloud không bị ảnh hưởng — đây là lý do thật, cần nói đúng:

Đây là lý do kiến trúc, không phải lý do "Atlassian vá nhanh hơn":

1. **Confluence Cloud là mô hình đa bên (multi-tenant)**: nhiều khách hàng dùng chung một hạ tầng, mỗi bên là một tenant. Atlassian vận hành và vá hạ tầng.
2. **Cấu hình khác nhau về mặt công cụ**: bản Server/Data Center tự host cho khách hàng quyền cấu hình nhiều thành phần, trong đó có thành phần xử lý biểu thức OGNL theo cách mà bản Cloud không dùng hoặc đã loại bỏ.
3. **Quyền của bên trong bị giới hạn**: dù có lỗi, sức bót của kẻ tấn công trong mô hình đa bên bị chặn ở ranh giới tenant — kẻ tấn công không đạt được mức tương đương "toàn quyền trên máy chủ" như trên bản tự host.

Tóm lại: **cùng một mã lỗ hổng**, nhưng sản phẩm Server/Data Center và Cloud là hai hệ thống khác nhau về mặt triển khai. Không được suy rộng từ sản phẩm này sang sản phẩm kia.

Nguồn: advisory của Atlassian, 04/04/2022.

4. Hậu quả

Đã được xác nhận (theo bản chất của lỗ hổng):

- **Thực thi mã từ xa trên máy chủ Confluence, không cần xác thực.**
- Mã chạy với **quyền của tài khoản dịch vụ (service account) của Confluence** trên máy chủ.

Điểm phải nói rõ về mức độ hậu quả — đây là điểm làm cho sự cố này nghiêm trọng hơn về ngoài.

Trong nhiều triển khai thực tế, tài khoản dịch vụ của Confluence có **quyền rất cao** trên máy chủ (thường là quyền có thể đọc/ghi rộng, đôi khi tương đương root trên Linux). Vì vậy hậu quả thực tế thường là:

- **Toàn quyền kiểm soát Confluence** — bao gồm **toàn bộ nội dung wiki nội bộ**, tức nơi lưu tài liệu thiết kế, tài liệu vận hành, thông tin hạ tầng, tài khoản/định dạng thông tin nhạy cảm.
- **Pivot sang máy chủ**: từ quyền đó, kẻ tấn công thường có thể đọc thông tin xác thực, cấu hình, khóa bí mật, và mở rộng sang các hệ thống khác trong mạng nội bộ.

Nguồn: advisory của Atlassian, 04/04/2022.

5. Bằng chứng khai thác — tách PoC khỏi vụ tấn công thật

Đã có bằng chứng.

- **Bài PoC công khai tồn tại** và nhiều bên đã tái tạo được trên bản Confluence chưa vá, khi chưa đăng nhập.
- Atlassian đã **gán CVE chính thức và phát hành bản vá** — điều này xác nhận đây là lỗ hổng thật do nhà cung cấp công nhận.

Chưa có bằng chứng / cần nói rõ:

- **Advisory của Atlassian** nêu rằng họ không ghi nhận bất kỳ vụ khai thác nào tại thời điểm công bố. Điều này là điểm then chốt: **mức nguy hiểm về kỹ thuật rất cao, nhưng mức khai thác ngoài đời thực tế thấp** — đây là nghịch lý nổi tiếng của sự cố này.
- Bài của bạn cũng nên ghi đúng sự tách bạch này. Sự cố này **hay được gọi là "Log4Shell thứ hai"** vì hình thức khai thác không cần xác thực và đơn giản — **nhưng thực tế khai thác ngoài đời lại thấp hơn hẳn Log4Shell**, vì Confluence Server thường không phải đích công khai hàng loạt, và lỗi này đã được vá từ đầu tháng 04/2022.

Bảng phân biệt:

Nội dung Proof of concept Vụ tấn công thật
--- --- ---
OGNL injection không xác thực thực thi được Đã chứng minh Không có bằng chứng
RCE với quyền tài khoản dịch vụ Confluence Đã chứng minh Không có bằng chứng
Atlassian gán CVE-2022-26134 Có —
Atlassian ghi nhận vụ khai thác nào Không áp dụng Không — họ nói không ghi nhận

Nguồn: advisory của Atlassian, 04/04/2022.

6. Các phiên bản vá

Atlassian phát hành bản vá **cùng ngày công bố 04/04/2022**. Theo trí nhớ của tôi, danh sách phiên bản sửa lỗi của **Confluence Server** gồm:

7.4.11, 7.10.2, 7.11.4, 7.12.3, 7.13.6, 7.14.4, 7.15.3, 7.16.4, 7.17.6, 7.18.1, 7.19.0

Với **Confluence Data Center**, các phiên bản sửa lỗi tương ứng là một tập con nhỏ hơn: **7.13.6, 7.18.1, 7.19.0**.

Mức chắc chắn: trung bình. Tôi nhớ danh sách này gần đúng nhưng **không chắc** từng số phiên bản cụ thể, và cũng không chắc là Atlassian đã vá tất cả các nhánh 7.x (tôi có cảm giác một số nhánh cũ hơn chỉ có **hotfix** chứ không có bản vá đầy đủ). Đây là con số bắt buộc phải chốt lại từ bản CSAF/advisory của Atlassian — bảng phiên bản sai là loại lỗi bị chấm điểm nặng nhất trong bài này.

Atlassian cũng cung cấp **hotfix** cho các phiên bản đã hết hỗ trợ, và khuyến nghị các biện pháp tạm thời như giới hạn truy cập tới các đường dẫn quản trị. **Tôi không nhớ chính xác khuyến nghị tạm thời của Atlassian là gì.**

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
---	---
RCE không cần xác thực	Sự thật
Cơ chế là OGNL injection	Sự thật
Chỉ ảnh hưởng Confluence Server và Data Center	Sự thật
Confluence Cloud KHÔNG bị ảnh hưởng	Sự thật
Mã chạy với quyền tài khoản dịch vụ Confluence	Sự thật
Hậu quả bao gồm lộ nội dung wiki nội bộ	Suy luận hợp lý từ cơ chế
Atlassian không ghi nhận vụ khai thác nào	Sự thật — theo advisory
Kỹ thuật nghiêm trọng nhưng ít bị khai thác ngoài đời	Suy luận của tôi
Lý do Cloud không bị ảnh hưởng (đa bên, cấu hình khác, ranh giới tenant)	Giải thích của tôi
— cần đối chiếu lý do chính thức	
Điểm vào là URI/path của yêu cầu	Trí nhớ của tôi, cần đối chiếu
Tên lớp/filter xử lý và hình dạng URL PoC	Tôi không chắc
Atlassian có gán CVSS không	Tôi không nhớ
Điểm CVSS là 9,8 hay 10,0	Tôi không nhớ chắc
Danh sách 11 phiên bản vá	Trí nhớ, cần chốt lại
Danh sách 3 phiên bản vá cho Data Center	Trí nhớ, cần chốt lại

| Khuyến nghị tạm thời của Atlassian | **Tôi không nhớ** |

Về mức độ ghi trong bài của bạn

Mục của bạn ghi mức độ kiểu **"Nghiêm trọng theo Atlassian"**. Ở mục này, cách ghi đó **có vấn đề** vì Atlassian **không gán CVSS** cho lỗ hổng bảo mật Confluence — bạn đang dẫn một mức độ mà nguồn không phát hành. Hai cách sửa:

1. **Ghi mức độ tự đánh giá của bạn kèm lý do**: **"Nghiêm trọng (đánh giá của người viết): RCE không xác thực trên hệ thống thường lưu tài liệu nội bộ; Atlassian không công bố CVSS cho lỗ hổng này."** — đây là cách trung thực nhất.
2. **Nếu bạn muốn chấm điểm chính thức**, phải lấy điểm của NVD — nhưng **điểm đó phải được kiểm chứng**, không được ghi từ trí nhớ. Tôi vừa nói ở trên là tôi không nhớ 9,8 hay 10,0; nếu bài bạn ghi một trong hai số thì phải mở NVD xác nhận trước.

Artifact 11 — Prompt log lượt #14 — Thời gian: 23:49 26/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2022-41082 — chuỗi "ProxyNotShell" trên Microsoft Exchange Server

****Phân loại:**** lỗ hổng bảo mật thật, có CVE chính thức của Microsoft, ****Leo thang đặc quyền dẫn tới RCE****. Bản thân nó ****không**** cho RCE không cần xác thực — cần đọc kỹ phần 2.

****Nguồn Microsoft:****

1. Hồ sơ CVE của Microsoft, công bố ****11/10/2022**** (bản vá đầy đủ): <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41082>
2. Hồ sơ CVE-2022-41040 (mất xích trước đó, công bố 30/09/2022): <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41040>
3. Bài Microsoft Security Blog về ProxyLogon, cuối tháng 09/2022.

****Về mức độ:** tôi ****khá chắc**** Microsoft chấm ****CVE-2022-41082 = 8,8 (High)**** và ****CVE-2022-41040 = 9,8 (Critical)****. Điểm 9,8 cho 41040 tôi tin hơn. Nếu bài làm ghi con số, hãy mở msrc.microsoft.com để xác nhận — điểm của MSRC là con số chính thức, dùng được ngay.*

1. Cơ chế của CVE-2022-41082

Cần hiểu nó theo đúng vai trò trong chuỗi, vì hiểu sai chỗ này là lỗi phổ biến nhất.

****Bản chất:**** đây là lỗ hổng ****leo thang đặc quyền (Elevation of Privilege)**** liên quan tới ****PowerShell remoting**** trên Exchange Server. Cơ chế mà tôi hiểu:

- Exchange Server có một ****endpoint PowerShell**** từ xa để quản trị. Kẻ tấn công đã đăng nhập hợp lệ có thể ****gửi lệnh PowerShell**** tới endpoint này.
- Lỗ hổng nằm ở chỗ ****kiểm tra không đầy đủ**** — máy chủ cho phép thực hiện hành động mà lẽ ra phải bị chặn.
- Hệ quả thực tế được các nhà nghiên cứu mô tả: kẻ tấn công dùng được tính năng này để ****đặt một tệp lệnh (script) vào một vị trí mà Exchange sẽ tự nạp và thực thi****, thường thông qua việc ghi tệp vào thư mục cài đặt của Exchange rồi gọi nó qua endpoint PowerShell.
- Khi làm được điều đó, mã chạy với ****quyền NT AUTHORITY\SYSTEM**** — tức quyền cao nhất trên máy chủ Windows.

****Tôi **không chốt được** tên lớp cụ thể, cũng **không chốt được** tên thư mục đích mà PoC dùng.** Đây là chi tiết kỹ thuật phải lấy từ bài phân tích, không nên bịa.*

****Nguồn: hồ sơ MSRC, 11/10/2022.****

2. Điều kiện khai thác — điểm mấu chốt nhất của mục này

****CVE-2022-41082 KHÔNG khai thác được nếu đứng một mình.**** Điều kiện bắt buộc:

1. Kẻ tấn công ****đã có phiên xác thực hợp lệ**** trên Exchange Server.
2. Phiên xác thực đó ****đã được lấy được bằng lỗ hổng khác**** — và lỗ hổng đó là ****CVE-2022-41040****.

****Hệ quả trực tiếp:**** đây không phải lỗ hổng "gỡ URL là xong". Nếu chỉ vá 41082 mà chưa vá 41040, kẻ tấn công vẫn không vào được. Ngược lại, ****vá 41040 mà không vá 41082 thì vẫn bị xâm nhập**** — và đây chính là lý do sự cố này gây bất ngờ nặng nề.

Nguồn: MSRC; blog Microsoft Security, cuối 09/2022.

3. Vai trò của CVE-2022-41040 trong chuỗi tấn công

Hai lỗ hổng này là ****hai mắt xích riêng biệt****, ghép lại mới thành khai thác. Tên do các nhà nghiên cứu đặt cho cả chuỗi là *****ProxyNotShell***** (tôi ****không chắc**** ai cụ thể đặt tên này, nên không ghi tên ai).

	CVE-2022-41040	CVE-2022-41082	
	---	---	---
	Tên gọi **ProxyLogon** (tên riêng, ít dùng hơn)		
	Loại lỗ hổng **Vượt xác thực** **Leo thang đặc quyền**		
	Có cần đăng nhập không **Không** **Có**		
	Kết quả Xác thực được **với tư cách bất kỳ người dùng nào** Thực thi mã **với quyền SYSTEM**		
	Mức độ (theo tôi nhớ) Critical, 9,8 High, 8,8		
	Công bố 30/09/2022 (bản vá khẩn cấp ngoài lịch) 11/10/2022 (Patch Tuesday đầy đủ)		

****Chuỗi tấn công hoàn chỉnh:****

...

Kẻ tấn công (từ Internet, không cần thông tin đăng nhập nào)

|



Mắt xích 1 — CVE-2022-41040: vượt qua lớp xác thực

→ đạt được phiên đăng nhập hợp lệ (giả danh bất kỳ người dùng nào)

|



Mắt xích 2 — CVE-2022-41082: leo thang qua PowerShell remoting

→ ghi tệp lệnh vào vị trí Exchange tự thực thi

→ mã chạy với quyền SYSTEM trên máy chủ

|



Kết quả: toàn quyền kiểm soát máy chủ Exchange

...

****Điểm cốt lõi:**** bản chất nguy hiểm của chuỗi này ****không nằm ở từng lỗ hổng riêng lẻ****, mà nằm ở việc ****hai lỗ hổng loại khác nhau ghép lại thành một đường tấn công không cần bất kỳ thông tin đăng nhập nào****. Đây là ví dụ kinh điển về việc "vá lỗ hổng này chưa đủ nếu còn lỗ hổng kia cùng loại".

Nguồn: MSRC, 30/09/2022 và 11/10/2022.

4. Bản vá — và sự cố "vá chưa đủ" (điểm đáng nhớ nhất)

Đây là phần tôi cho là đáng chú ý nhất của toàn bộ sự cố, vì nó cho thấy quy trình vá của nhà cung cấp cũng có thể có lỗ hổng:

1. ****28/09/2022**** — Microsoft phát hành ****bản vá ngoài lịch (out-of-band / khẩn cấp)**** cho CVE-2022-41040. Đây là hành động hiếm gặp: Microsoft thường vá theo lịch Patch Tuesday định kỳ.
2. ****30/09/2022**** — Microsoft công bố lỗ hổng và giải thích, kèm cảnh báo về việc đang bị khai thác.
3. ****Microsoft thừa nhận bản vá đầu tiên không hoàn chỉnh.**** Tôi khá chắc điều này — Microsoft đã công khai nói bản vá 28/09 là chưa đầy đủ, và cần bản vá tiếp theo mới chặn được đường tấn công.
4. ****11/10/2022**** — Patch Tuesday đầy đủ, trong đó có bản vá cho ****CVE-2022-41082****.

****Bài học vận hành:**** chỉ vá đúng một trong hai lỗ hổng là ****không đủ****. Và ngay cả vá bản khẩn cấp đầu tiên cũng ****chưa chắc đã đủ****. Đây là lý do các chuyên gia khuyến nghị vá ****cả hai lỗ hổng**** và làm theo hướng dẫn chính thức, không tự ý kết luận "đã vá là an toàn".

Nguồn: blog Microsoft Security, cuối 09/2022 và 10/2022.

5. Hậu quả

****Đã được xác nhận:****

- ****Thực thi mã với quyền NT AUTHORITY\SYSTEM**** trên máy chủ Exchange Server.
- Exchange Server trong triển khai thông thường chạy ở quyền cao, nên RCE ở đây gần như ****tương đương toàn quyền máy chủ****.
- Từ đó kẻ tấn công có thể:
 - ****Đọc toàn bộ nội dung hộp thư**** trên máy chủ — bao gồm hộp thư của nhân viên, ban lãnh đạo, và các bên liên quan.
 - ****Đánh cắp thông tin xác thực**** của máy chủ (hash mật khẩu, khóa, cấu hình), dùng để mở rộng tấn công sang hệ thống khác.
 - ****Cài đặt mã độc / hậu cấu cố định**** để duy trì quyền truy cập.
 - ****Di chuyển ngang**** vào các hệ thống khác trong mạng.

****Cần nói rõ là chưa xác nhận:****

- Tôi **không** có số liệu chắc chắn về số máy chủ bị xâm nhập thực tế từ chuỗi ProxyNotShell. Tôi **không** nhớ các con số cụ thể và sẽ không bịa ra.

- Tôi có trí nhớ rời rạc rằng Microsoft từng quy kết một bên tấn công của **Nga** liên quan tới chiến dịch này, nhưng tôi **không** chắc tên cơ quan cụ thể và không chắc mốc thời gian. Nếu bài làm cần nói về chủ thể tấn công, phải lấy từ bài Microsoft Security Blog gốc, không được ghi từ trí nhớ của tôi.

Nguồn: MSRC, 11/10/2022.

6. Exchange Server tại chỗ (on-premises) và Exchange Online — phần bạn hỏi đúng trọng tâm

Đây là phân biệt **quan trọng nhất** của mục này, vì cách bài viết về nó quyết định người đọc có hiểu đúng bản chất rủi ro hay không.

Tiêu chí	**Exchange Server tại chỗ (on-premises)**	**Exchange Online (OWA trên cloud)**
Ai quản lý hạ tầng	**Khách hàng** tự cài, tự vá, tự bảo mật	**Microsoft** quản lý toàn bộ
Khách hàng có thể vá không	**Có** — nhưng phải chủ động làm	**Không** — không có gì để vá
Máy chủ có thể bị RCE không	**Có** — nằm trong mạng nội bộ của bạn	**Không** theo kiểu này — không phải máy chủ của bạn
Dữ liệu nằm ở đâu	Trên hạ tầng của bạn	Trên hạ tầng Microsoft, bạn chỉ có quyền truy cập qua giao diện
Lỗ hổng ở tầng nào	Lỗ hổng phần mềm trên máy chủ của bạn	Lỗ hổng ở tầng **dịch vụ và xác thực/phiên**
Hậu quả điển hình	Chiếm máy chủ, lộ thư, đánh cắp hash, di chuyển ngang	Chiếm **tài khoản thư**, đọc/sao chép thư, đánh cắp danh tính

Điểm quan trọng — cùng họ CVE, phạm vi khác nhau:

- **CVE-2022-41040** liên quan tới lớp xác thực và **ảnh hưởng cả Exchange Server lẫn Exchange Online**. Tôi có trí nhớ rằng Microsoft đã xác nhận bên tấn công dùng lỗ hổng này để xâm nhập vào **hàng nghìn tenant Exchange Online** vào đầu năm 2022. Tôi **không** chắc con số và thời điểm chính xác — phải lấy từ bài báo cáo gốc của Microsoft.*

- **CVE-2022-41082** liên quan tới **PowerShell remoting trên máy chủ Exchange** — theo hiểu biết của tôi, lỗ hổng này thuộc phạm vi **Exchange Server tại chỗ**. Tôi **không** hoàn toàn chắc là Microsoft có liệt kê nó cho Exchange Online hay không; cần kiểm tra phạm vi trong hồ sơ MSRC.

Vì sao sự phân biệt này quan trọng khi viết báo cáo:

1. **Khách hàng Exchange Online không có "hành động vá" nào để làm.** Nếu bài của bạn ghi chung chung kiểu "cần cập nhật bản vá" cho cả hai, câu đó **sai với phía Exchange Online**.

2. ****Phía Exchange Online, hành động đúng là vòng quanh danh tính****: thu hồi/đặt lại token, đặt lại mật khẩu, bật MFA. Đây là bài học khác hẳn với phía on-premises.
3. ****Phía on-premises, bạn phải tự vá và tự giám sát****. Nếu không, lỗ hổng nằm đó mãi.
4. ****Hai bên có thể bị ảnh hưởng bởi những lỗ hổng khác nhau trong cùng hệ sinh thái**** — đừng dùng kết luận của bên này để suy ra cho bên kia.

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
CVE-2022-41082 là leo thang đặc quyền, không phải vượt xác thực	**Sự thật**
Cần phiên đã xác thực để khai thác	**Sự thật**
CVE-2022-41040 là mắt xích vượt xác thực, không cần đăng nhập	**Sự thật**
Chuỗi ghép tạo RCE không cần thông tin đăng nhập	**Sự thật**
Chuỗi này được gọi là "ProxyNotShell"	**Sự thật** (tôi không chắc ai đặt tên)
CVE-2022-41040 = 9,8 Critical	**Khá chắc, cần xác nhận**
CVE-2022-41082 = 8,8 High	**Khá chắc, cần xác nhận**
Bản vá ngoài lịch 28/09/2022 cho CVE-2022-41040	**Sự thật**
Microsoft thừa nhận bản vá đầu tiên không hoàn chỉnh	**Khá chắc**
Bản vá đầy đủ 11/10/2022 cho CVE-2022-41082	**Sự thật**
Mã chạy với quyền NT AUTHORITY\SYSTEM	**Sự thật**
Exchange Server tại chỗ khác Exchange Online về mặt quản lý và vá	**Sự thật**
Phía Exchange Online không có hành động vá	**Suy luận đúng về mặt vận hành**
CVE-2022-41040 ảnh hưởng cả Server và Online	**Khá chắc**
CVE-2022-41082 chỉ thuộc phạm vi Exchange Server	**Tôi không hoàn toàn chắc**
Microsoft xác nhận xâm nhập hàng nghìn tenant Exchange Online	**Trí nhớ, không chắc số lượng/thời điểm**
Chủ thể tấn công là cơ quan tình báo Nga	**Trí nhớ rời rạc, không chắc tên cơ quan**
Số máy chủ bị xâm nhập thực tế	**Tôi không có số liệu chắc chắn**
Tên lớp kỹ thuật và thư mục đích trong PoC	**Tôi không chốt được**
Hành động đúng cho Exchange Online là thu hồi token / bật MFA	**Khuyến nghị chung, không gắn riêng cho CVE này**

Về mức độ ghi trong bài của bạn

Tôi chưa đọc lại mục này trong bài của bạn, nhưng theo những gì đã thống nhất: nếu mục này đang ****thiếu CVSS**** thì đó là thiếu sót cần sửa, vì đây là ****một trong vài mục có điểm chính thức từ nhà cung cấp**** (8,8 theo MSRC). Với mục này, nếu bạn ghi ****"Nghiêm trọng"**** trong khi điểm chính thức là ****8,8 = High****, thì mức ghi của bạn ****đang chệch lên mức chính thức**** — điều này vừa không khớp nguồn, vừa dễ bị hỏi khi vấn đề. Cách viết an toàn: **"Cao (8,8 theo hồ sơ MSRC); chuỗi ghép với CVE-2022-41040 tạo RCE không cần xác thực nên mức rủi ro thực tế cao hơn điểm của mắt xích riêng."*** — cách này vừa trung thực về con số, vừa nói đúng điều làm cho lỗ hổng nguy hiểm.

Artifact 12 — Prompt log lượt #15 — Thời gian: 23:53 26/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2022-3602 — tràn bộ đệm 4 byte khi kiểm tra chứng chỉ X.509 (OpenSSL 3.0.x)

****Phân loại:**** lỗ hổng bảo mật thật, có CVE chính thức, ****tràn bộ đệm trên ngăn xếp (stack-based buffer overflow)****.

****Nguồn OpenSSL:**** advisory của OpenSSL, phát hành ****01/11/2022**** cùng bản ****OpenSSL 3.0.7**** — <https://www.openssl.org/news/secadv/20221101.txt>

****Mức độ — và đây là chỗ tôi cần nói thẳng với bạn ngay:****

Theo trí nhớ của tôi, OpenSSL đã ****tự xếp mức cho lỗ hổng này là LOW (Thấp)****, kèm tuyên bố rằng ****RCE "không có khả năng" (not likely)****. Tôi khá chắc về điều này vì nó là điểm gây tranh cãi lớn nhất của sự cố.

> ****Cảnh báo cho bài của bạn:**** mục #10 đang ghi mức độ là ****"Cao theo OpenSSL"****. Nếu đúng như tôi nhớ (OpenSSL xếp ****Low****), thì câu đó ****sai**** — và đây là loại lỗi bị trừ điểm nặng vì nó là mức độ ****gán sai từ chính nhà cung cấp****. Bạn phải mở advisory gốc để chốt, rồi sửa.

1. Dữ liệu đầu vào gây tràn bộ đệm

****Điểm xuất phát:**** một ****chứng chỉ X.509 được tạo độc hại**** — không phải dữ liệu tùy ý, mà là một chứng chỉ có cấu trúc đặc biệt.

****Chuỗi điều kiện (theo trí nhớ của tôi, cần đối chiếu advisory):****

1. Chứng chỉ có phần mở rộng ****`subjectAltName` (SAN)**** — danh sách tên thay thế cho chủ thể.
2. Trong SAN có một mục thuộc dạng ****`otherName`**** — một loại tên đặc biệt, được đóng gói bên trong một "gói" có kiểu và giá trị riêng.
3. Bên trong gói ****`otherName`**** đó là một ****địa chỉ email****, được mã hóa theo một dạng ****punycode**** — chính là dạng ****xn--`** mà bạn thấy trong tên miền quốc tế, chỉ khác là ở đây nằm trong một trường email.
4. Chuỗi punycode đó ****bị lỗi / không hợp lệ theo cách đặc biệt****, khiến phép tính độ dài bị sai.

****Vì sao lại liên quan tới punycode:**** OpenSSL cung cấp một thư viện nhỏ tên là ****`openssl\_punycode`** để ****giải mã**** chuỗi punycode thành chuỗi Unicode (để so sánh, hiển thị). Lỗi nằm ở ****đoạn giải mã này****: bộ đệm đích được cấp phát theo một độ dài tính từ đầu vào, nhưng ****phép tính độ dài đó bị tràn số khi gặp một ký tự cụ thể**** (ký tự ****`.`** trong chuỗi punycode không hợp lệ). Khi độ dài tính ra bị sai, quá trình giải mã ghi ****nhiều hơn số byte được cấp phát****.

****Đặc điểm quan trọng của riêng CVE-2022-3602:**** đây là tràn ****4 byte****. Tức người tấn công ****không kiểm soát được nội dung hay số lượng**** ghi ra ngoài — chỉ ghi vượt 4 byte.

*Đây là bước dễ sai nhất. Tôi ****không chốt được****: tên hàm cụ thể, điều kiện chính xác là "chứng chỉ chứa otherName bọc email punycode lỗi", và ký tự nào làm tràn phép tính độ dài. Tôi nhớ có liên quan tới dấu ``, nhưng ****không chắc****, và tôi ****không dám chốt**** từ trí nhớ cho các chi tiết này.*

Nguồn: advisory OpenSSL, 01/11/2022.

2. Điều kiện để đi đến mã dễ bị lỗi

Đây là phần quyết định mức nguy hiểm thực tế, và cũng là chỗ nhiều bài viết hùa sai.

****Điều kiện then chốt — theo trí nhớ của tôi:****

- Ứng dụng phải ****thực hiện xác minh chứng chỉ X.509**** (certificate verification) — tức là có dùng chứng chỉ trong vai trò kiểm tra danh tính của đối phương.
- Và việc xác minh đó phải ****đi tới hàm so sánh tên**** trong SAN.

****Các tình huống thực tế có thể gặp:****

- Xác minh chứng chỉ của máy chủ trong ****bắt tay TLS****.
- Xác minh chứng chỉ trong ****chữ ký số, email (S/MIME), VPN****.
- Dùng công cụ dòng lệnh `openssl` để kiểm tra một chứng chỉ.

****Nhưng — ranh giới an toàn quan trọng:****

Theo trí nhớ của tôi, advisory nêu rõ rằng lỗi ****chỉ được chạm tới khi ứng dụng chủ động đưa chứng chỉ đó vào quá trình so sánh/xác minh**** — tức phần mã dễ lỗi nằm trên ****đường kiểm tra****, không phải trên đường xử lý chứng chỉ nhận tùy ý. Nếu một ứng dụng chỉ ****nhận và lưu**** chứng chỉ mà không xác minh, nó có thể ****không**** bị chạm tới.

*Tôi ****không chắc chắn**** mức độ chính xác của câu này — cụ thể là liệu OpenSSL có viết rằng "ranh giới bảo mật bị vượt qua" hay không. Đây là câu quan trọng, phải lấy nguyên văn từ advisory.*

Nguồn: advisory OpenSSL, 01/11/2022.

3. Hậu quả đã quan sát so với khả năng RCE — điểm cốt lõi của toàn bộ sự cố

Đây là nơi cần tách ****ba tầng**** rất rõ, vì gộp chúng vào nhau là lỗi phổ biến nhất khi viết về sự cố này.

Tầng 1 — Điều chắc chắn có thể xảy ra: DoS (từ chối dịch vụ)

- Tràn 4 byte trên ngăn xếp làm **hỏng dữ liệu trên ngăn xếp** của tiến trình.
- Kết quả thực tế quan sát được: **tiến trình bị sập (crash)**, tức là chương trình bị từ chối phục vụ.
- Đây là hậu quả **đã được xác nhận**.

Tầng 2 — Điều mà OpenSSL chủ động phủ nhận: RCE

- OpenSSL đã **công khai tuyên bố** rằng RCE "không có khả năng" (not likely) với lỗ hổng này.
- Lý do hợp lý mà họ nêu (theo trí nhớ của tôi): tràn **chỉ 4 byte**, và ứng dụng ghi ra ngoài vùng nhớ là dữ liệu **không do kẻ tấn công kiểm soát** — kẻ tấn công không thể chọn nội dung để ghi đè, nên không thể dùng để chèn mã lệnh.
- Tôi đồng ý với lập luận này về mặt kỹ thuật: **một tràn cố định 4 byte không kiểm soát nội dung thì về nguyên tắc không đủ để kiểm soát luồng thực thi**.

Tầng 3 — Điều không ai được chứng minh: khai thác thực tế

- **Không có báo cáo khai thác ngoài đời nào mà tôi biết**. Không có ví dụ mã khai thác RCE hoạt động.
- Và đây là điểm phải nói thẳng: **rất nhiều bài viết trên mạng năm 2022 khẳng định CVE-2022-3602 là "lỗ hổng RCE nghiêm trọng nhất lịch sử OpenSSL"**. Đó là **điển giải sai**. Thực tế là ngược lại: đây là ví dụ kinh điển về việc **một lỗi nghe có vẻ nguy hiểm lại hóa ra không nguy hiểm như bị dự báo**.

Bảng phân biệt:

Mức hậu quả	Trạng thái
---	---
Tiến trình sập / DoS	Đã xác nhận — đây là hậu quả thực tế
Ghi đè dữ liệu 4 byte không kiểm soát	Sự thật về mặt kỹ thuật
RCE (thực thi mã tùy ý)	OpenSSL nói "không có khả năng"
Có PoC RCE hoạt động	Không — tôi không biết có
Đã bị khai thác ngoài đời	Không có bằng chứng
"Lỗ hổng RCE nghiêm trọng nhất lịch sử OpenSSL"	Sai — đây là nhận định sai phổ biến

Nguồn: advisory OpenSSL, 01/11/2022.

4. Mức độ nghiêm trọng cuối cùng và chuyện "hạ từ Critical"

Đây là chi tiết lịch sử đáng nhớ nhất của sự cố, và bài của bạn đã ghi đúng phần này.

Diễn biến:

1. Trước khi công bố, có thông tin cho rằng mức độ được **dự báo là "Critical"** — và thông tin này đã lan truyền rộng trên mạng, tạo tâm lý hoảng loạn.
2. Khi advisory chính thức phát hành ngày **01/11/2022**, OpenSSL **hạ mức xuống mức thấp** và kèm tuyên bố phủ nhận RCE.

Tôi khá chắc về việc có sự "hạ mức" này — đây là chi tiết được báo chí bàn luận nhiều. Tôi **không chắc** là con số "Critical" trước đó do chính OpenSSL nói, hay do bên thứ ba (nhà nghiên cứu/báo chí) dự báo rồi được lan truyền. Cần phân biệt khi viết bài.*

Cách ghi đúng cho bài: nêu rõ **hai mốc** — **mức dự báo** và **mức công bố cuối cùng** do OpenSSL đưa ra — chứ không gộp chung một nhãn. Nếu bạn chỉ ghi "Cao" mà không nói nguồn nào đưa ra, người đọc sẽ hiểu nhầm.

Nguồn: advisory OpenSSL, 01/11/2022.

5. Phiên bản bị ảnh hưởng và bản vá

Bị ảnh hưởng:

- **OpenSSL 3.0.0 → 3.0.6** (tức toàn bộ nhánh 3.0.x trước bản 3.0.7)

Điểm quan trọng:

- **Nhánh 1.1.1 KHÔNG bị ảnh hưởng.** Tôi khá chắc điều này — nhánh 1.1.1 không chứa đoạn mã xử lý punycode/otherName bị lỗi. Đây là tin tốt vì 1.1.1 từng là bản phổ biến nhất vào năm 2021.
- Tôi **không chắc** về các nhánh/derivative khác (ví dụ bản fork, LibreSSL, hay các bản đóng gói của bên thứ ba) — cần kiểm tra theo bản phân phối.

Bản vá:

- **OpenSSL 3.0.7**, phát hành **cùng ngày 01/11/2022** với advisory.

Lưu ý về cùng một ngày: OpenSSL phát hành **hai CVE cùng lúc** trong cùng đợt vá này:

- **CVE-2022-3602** — tràn 4 byte, mức thấp, RCE không khả năng (mục đang xem).
- **CVE-2022-3786** — một lỗi khác trong cùng đoạn mã punycode, tràn **không giới hạn độ dài**, nhưng nội dung ghi ra **không do kẻ tấn công kiểm soát** nên cũng chủ yếu gây DoS.

Nếu bài của bạn chỉ dùng mỗi CVE-2022-3602, ghi kèm CVE-2022-3786 là **đúng** — vì nó cho thấy bạn biết đây là một cặp lỗi, không phải một lỗi lẻ.

Nguồn: advisory OpenSSL, 01/11/2022.

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
CVE-2022-3602 là tràn bộ đệm 4 byte trên ngăn xếp	****Sự thật****
Trong đoạn mã giải mã punycode	****Khá chắc****
Đầu vào là chứng chỉ X.509 độc hại với SAN/otherName bọc email	****Trí nhớ, cần đối chiếu****
Chỉ xảy ra khi ứng dụng xác minh chứng chỉ	****Khá chắc****
Hậu quả đã xác nhận là DoS / tiến trình sập	****Sự thật****
RCE bị OpenSSL phủ nhận ("không có khả năng")	****Sự thật****
Tràn 4 byte không kiểm soát nội dung → không đủ để RCE	****Lập luận kỹ thuật, tôi đồng ý****
Không có PoC RCE hoạt động được biết	****Sự thật theo trí nhớ****
OpenSSL hạ mức từ "Critical" xuống mức thấp	****Khá chắc****
OpenSSL tự xếp mức ****LOW**** cho lỗ hổng này	****Khá chắc — nhưng phải xác nhận, vì mâu thuẫn với bài của bạn****
"Critical" trước đó do chính OpenSSL dự báo	****Tôi không chắc ai là người nói****
Ảnh hưởng OpenSSL 3.0.0–3.0.6	****Sự thật****
OpenSSL 1.1.1 KHÔNG bị ảnh hưởng	****Khá chắc****
Bản vá: OpenSSL 3.0.7 ngày 01/11/2022	****Sự thật****
CVE-2022-3786 là lỗi cùng đợt vá	****Sự thật****
Tên hàm cụ thể và ký tự gây tràn phép tính độ dài	****Tôi không chốt được****
Nguyên văn cách OpenShell diễn đạt về "ranh giới bảo mật"	****Tôi không nhớ****
Phạm vi ảnh hưởng với bản fork/đóng gói khác	****Tôi không rõ****

Việc cần sửa trong bài của bạn — ưu tiên cao

Bài của bạn đang ghi: ****"Mức độ: Cao theo OpenSSL"****.

Theo những gì tôi biết, OpenSSL xếp mức cho CVE-2022-3602 là ****LOW****, không phải Cao. Nếu đúng, bạn đang ****gán sai mức độ của chính nhà cung cấp**** — đây là lỗi nặng vì phần lớn bài điểm mục này nằm ở việc dẫn đúng mức độ.

Cách sửa đúng, sau khi bạn mở advisory gốc xác nhận:

> ****"Thấp theo OpenSSL**** (OpenSSL tự xếp mức Low và phủ nhận khả năng RCE; trước đó mức này từng được dự báo là 'Critical' rồi hạ xuống khi công bố). Hậu quả đã xác nhận là DoS — sập tiến trình; chưa có bằng chứng khai thác thực tế."

Nếu bạn cần một nhãn mức độ bắt buộc để đồng nhất với 19 mục kia, hãy ghi mức ****do NVD chấm**** — nhưng ****phải mở NVD và lấy đúng con số****, tôi không nhớ chắc NVD chấm bao nhiêu cho CVE này.

Artifact 13 — Prompt log lượt #16 — Thời gian: 23:56 26/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2023-34362 — SQL injection không cần xác thực trong MOVEit Transfer

****Phân loại:**** lỗ hổng bảo mật thật, có CVE chính thức, ****SQL injection** tiền xác thực******, ****zero-day** đã bị khai thác ngoài đời******.

****Nguồn:****

1. Thông báo khẩn cấp của Progress (KB/Khuyến nghị bảo mật MOVEit Transfer), đăng ****31/05/2023**** — <https://www.progress.com/support/kb/notice/security-advisory-moveit-transfer> (tôi không chắc chính xác mã số KB và đường dẫn; cần lấy lại từ trang hỗ trợ của Progress)
2. Hồ sơ CVE — <https://www.cve.org/CVERecord?id=CVE-2023-34362> (và trang NVD tương ứng)

****Đây là mục khác biệt rõ nhất với tất cả mục trước:**** nó có ****hậu quả đã xác nhận bằng số liệu thực tế**** — hàng nghìn tổ chức và hàng chục triệu cá nhân. Mọi mục trước đó (GPT-4o, EchoLeak, Confluence, OpenSSL) đều là ****có PoC nhưng chưa có thiệt hại đo được**** hoặc ****chưa bị khai thác****.

1. Cơ chế SQL injection

****Cấu trúc lỗi cổ điển của dạng SQL injection:****

- Ứng dụng web nhận dữ liệu từ người dùng và ****ghép chuỗi đó vào câu truy vấn SQL**** thay vì dùng câu truy vấn tham số hóa (prepared statement).
- Kẻ tấn công chèn thêm ****SQL của riêng họ**** vào tham số đó.
- Kết quả: ****câu truy vấn không còn làm những gì ứng dụng thiết kế, mà làm những gì kẻ tấn công muốn**** — đọc dữ liệu khác, thay đổi dữ liệu, hoặc thậm chí thực thi lệnh trên hệ điều hành.

****Áp dụng cho MOVEit Transfer — theo trí nhớ của tôi:****

- MOVEit Transfer là phần mềm ****truyền tệp quản lý (MFT — Managed File Transfer)****: nó di chuyển file của doanh nghiệp theo quy tắc, và các file đó thường là dữ liệu nhạy cảm.
- Lỗ hổng nằm ở một ****endpoint web trong phần giao diện web của MOVEit****. Tôi nhớ tên endpoint là ****`human2.aspx`**** và tham số bị ảnh hưởng là ****`cmd`**** — nhưng tôi ****không chắc chắn**** cả hai chi tiết này, phải đối chiếu thông báo gốc.
- Bản chất thuộc loại: một tham số thường dùng để ****đăng nhập**** (tên đăng nhập/mật khẩu) bị dùng để ****xác thực người dùng thông qua truy vấn cơ sở dữ liệu****. Vì mật khẩu được kiểm tra bằng SQL, nên chỗ đó trở thành điểm vào của SQL injection.
- Vì điểm vào nằm ****trước hàng trình xác thực****, kẻ tấn công dùng được nó ****mà không cần có tài khoản****.

Nguồn: thông báo Progress, 31/05/2023.

2. Có cần đăng nhập không

****Không.**** Đây là SQL injection ****tiền xác thực (pre-authentication)****.

Điểm này giải thích tại sao sự cố nghiêm trọng đến vậy: MOVEit Transfer rất thường được ****mở ra Internet**** (đó là mục đích của nó — cho sở ngoài giao tiếp với sở trong), nên lỗ hổng tiền xác thực này ****lộ thẳng ra ngoài Internet**** chỉ với một yêu cầu HTTP. Không cần kỹ thuật xã hội, không cần mật khẩu, không cần email giả mạo.

Nguồn: thông báo Progress, 31/05/2023.

3. Dữ liệu và hệ thống có thể bị ảnh hưởng

****Bản chất của phần mềm MFT quyết định mức nghiêm trọng:****

MOVEit Transfer ****lưu trữ và truyền tải chính là dữ liệu nhạy cảm của doanh nghiệp****. Vì vậy khi bị xâm nhập, thứ bị đánh cắp không phải "một bản ghi hệ thống", mà là ****hàng loạt dữ liệu cá nhân và tài liệu kinh doanh**** mà doanh nghiệp đó giữ.

****Theo mô tả của Progress, kẻ tấn công có thể:****

- ****Đọc/truy vấn dữ liệu trong cơ sở dữ liệu**** thông qua SQL injection.
- ****Thao tác dữ liệu**** (không chỉ đọc).
- ****Đưa thêm mã độc lên máy chủ**** — tôi khá chắc rằng các cuộc khai thác được quan sát có ****đặt một webshell**** (tệp thực thi web) vào hệ thống, dùng nó để duy trì và mở rộng quyền truy cập.
- Từ đó ****tải tệp lên/tải tệp xuống**** qua chính chức năng MOVEit — tức là lấy dữ liệu ra ngoài bằng đúng công cụ vốn được thiết kế để làm việc đó.

****Về khả năng thực thi mã trên máy chủ:**** tôi ****không chắc**** Progress có tuyên bố dứt khoát rằng lỗ hổng này cho phép RCE trực tiếp hay không. Cách tôi hiểu vấn đề: SQL injection trên SQL Server còn có thể dẫn tới thực thi lệnh hệ điều hành qua các cơ chế nhất định, nhưng tôi ****không dám khẳng định**** Progress nói gì. Phải đọc thông báo gốc.

Nguồn: thông báo Progress, 31/05/2023.

4. Điều gì đã được ghi nhận khi khai thác — điểm khác biệt lớn nhất

****Đây là zero-day thật.**** Định nghĩa: lỗ hổng ****đã bị khai thác trước khi có bản vá**** — tức nhà sản xuất chưa kịp phát hành bản vá thì nó đã bị dùng trên thực tế. Đây là lý do thông báo của Progress được phát hành ****khẩn cấp**** và là lý do nó khác về bản chất so với mọi mục trước.

****Chủ thể tấn công:****

- Sự cố này được quy kết cho **Cl0p** — một nhóm tấn công chuyên **đánh cắp dữ liệu để tống tiền**, chạy mô hình dịch vụ (ransomware-as-a-service).
- Tôi khá chắc về Cl0p. Tôi **không chắc** về các chi tiết nhỏ hơn như mốc thời gian từng đợt tấn công, hay các nhóm khác có tham gia hay không.

Quy mô:

- Đây là **một trong những sự cố khai thác hàng loạt lớn nhất năm 2023**, với số nạn nhân ở mức **hàng nghìn tổ chức**.
- Con số cụ thể: tôi **không nhớ chắc** và sẽ không bịa. Tôi có trí nhớ rời rạc rằng các thống kê của bên thứ ba về Cl0p vào cuối năm 2023 nằm ở mức **hơn 2.000 tổ chức và hàng chục triệu cá nhân** — nhưng con số này là **thống kê từ bên thứ ba theo dõi**, không phải số liệu do Progress xác nhận.

Nạn nhân tiêu biểu:

- Tôi nhớ là có **nhiều cơ quan chính phủ Mỹ** và **nhiều trường đại học** trong danh sách, và có ít nhất **một chính quyền bang**. *Tôi không nhớ đủ chắc tên từng cơ quan, nên tôi sẽ không liệt kê — bạn phải lấy từ danh sách công khai.*

Bảng phân biệt PoC / khai thác thật:

Nội dung	Trạng thái
---	---
SQL injection tiền xác thực tồn tại	Đã xác nhận
Progress phát hành bản vá khẩn cấp ngày 31/05/2023	Đã xác nhận
Đây là zero-day (khai thác trước khi vá)	Đã xác nhận
Cl0p là chủ thể tấn công	Khá chắc
Số nạn nhân ở mức hàng nghìn tổ chức	Khá chắc
Con số cụ thể tôi vừa nêu	Trí nhớ rời rạc — không dùng được nếu chưa kiểm chứng
Tên từng nạn nhân	Tôi không nhớ chắc — không liệt kê
Kẻ tấn công có đặt webshell	Khá chắc
Progress có khẳng định RCE trực tiếp không	Tôi không chắc
Tên endpoint `human2.aspx` và tham số `cmd`	Trí nhớ, cần đối chiếu

Nguồn: thông báo Progress, 31/05/2023; các thống kê công khai.

5. Cách xử lý

Phía nhà cung cấp (Progress):

- Phát hành **bản vá khẩn cấp** ngay trong ngày công bố.
- Tôi nhớ một chi tiết đáng chú ý: Progress đã làm để **các bản đã vá sẽ không hoạt động chung với các bản dễ bị tấn công còn lại trên hệ thống** — tức hệ thống bị buộc phải cập nhật hết, thay vì chỉ vá một phần. Tôi khá chắc có cơ chế này nhưng **không nhớ chính xác cách nó hoạt động chi tiết**.
- Progress cung cấp **hướng dẫn dọn dẹp**, bao gồm cách phát hiện tệp/mục do kẻ tấn công đặt vào, và cung cấp câu lệnh SQL để tìm và loại bỏ chúng. Tôi **không nhớ** nội dung cụ thể của các câu lệnh này và **không khuyến nghị** bạn dùng lại từ trí nhớ — phải lấy từ tài liệu gốc.

****Phía tổ chức bị ảnh hưởng — thứ đáng chú ý nhất về mặt quản lý sự cố:****

Có một điểm mà tôi muốn nhấn mạnh vì nó nằm ngoài phạm vi kỹ thuật thuần túy:

- ****Có những nạn nhân bị tấn công nhưng bản thân MOVEit không bị lấy dữ liệu**** — họ bị khai thác thành công (webshell được đặt vào) nhưng dữ liệu đã bị lấy từ nguồn khác, hoặc họ chưa bị lấy.
- Ngược lại, ****có những nạn nhân không hề biết mình bị xâm nhập trong thời gian dài**** vì MOVEit bị bỏ qua. Vì vậy "tôi vá rồi nên tôi an toàn" là kết luận sai — vẫn phải ****điều tra xem đã bị khai thác chưa****, không chỉ vá.

Đây là suy luận của tôi về nguyên tắc ứng cứu sự cố, dựa trên đặc điểm của sự cố (lỗ hổng không bị khai thác thành công vẫn có thể để lại dấu vết). Tôi không dẫn được con số cụ thể cho điều này.

Lưu ý quan trọng về mức độ ghi trong bài

Tôi ****không nhớ chắc**** Progress có gán CVSS cho lỗ hổng này hay không, và tôi ****không nhớ chắc**** NVD chấm bao nhiêu. Tôi có cảm giác NVD chấm ****9,8 (Critical)****, nhưng ****đây là trí nhớ, không phải dữ liệu kiểm chứng**** — bạn phải mở NVD.

Nếu bài của bạn đang ghi mức độ kiểu "đánh giá của báo cáo", thì với mục này tôi cho rằng ****nên dùng điểm NVD**** — vì đây là sự cố có hậu quả thực tế lớn nhất trong 20 mục, nên mức độ cần chắc chắn. Và mức độ của mục này ****không nên dưới mức của các mục chỉ có PoC****.

Artifact 14 — Prompt log lượt #17 — Thời gian: 00:00 27/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2023-2868 — chèn lệnh qua giải nén tệp TAR trên Barracuda Email Security Gateway

****Phân loại:**** lỗ hổng bảo mật thật, có CVE chính thức, ****RCE cần điều kiện** (chạy ở chế độ đặc quyền)******, ****đã bị khai thác ngoài đời****.

****Nguồn Barracuda:**** thông báo bảo mật của Barracuda, tháng 5/2023. Barracuda đăng thông báo trên cổng hỗ trợ của hãng, và đồng thời đưa ra hướng dẫn riêng cho khách hàng ESG. *Tôi ****không nhớ chắc**** tên bài và đường dẫn chính xác, cũng không nhớ chắc ngày công bố là 19 hay 24/05/2023 — bạn phải lấy lại từ trang chính thức của Barracuda.*

Hồ sơ CVE: <https://www.cve.org/CVERecord?id=CVE-2023-2868>

****Đây là mục có tính chất khác biệt nhất trong 20 mục:**** nó không chỉ là lỗ hổng phần mềm, mà là lỗ hổng ****trong phần mềm do nhà sản xuất thiết bị viết và đóng gói vào phần cứng của họ****. Hậu quả của việc này là khách hàng ****không thể vá từng phần**** — chỉ có hai lựa chọn: nâng cấp toàn bộ phần mềm, hoặc thay thiết bị.

1. Cách tệp TAR kích hoạt lỗi

****Bối cảnh quan trọng:**** Email Security Gateway (ESG) của Barracuda có nhiệm vụ ****quét thư điện tử để chặn mã độc****. Để làm được vậy, nó phải ****mở và giải nén tệp đính kèm**** — bao gồm cả tệp nén. Với tệp TAR, ESG ****giải nén vào một thư mục tạm**** để kiểm tra nội dung.

****Lỗi nằm ở đâu — đây là điểm mấu chốt, và cũng là chỗ nhiều người mô tả sai:****

Có một quy tắc bảo mật kinh điển mà bất kỳ chương trình giải nén tệp nén nào cũng phải tuân thủ:

> ****Mọi tên tệp bên trong tệp nén đều là dữ liệu do kẻ tấn công kiểm soát, và phải được giới hạn nằm bên trong thư mục đích.****

Lý do: định dạng lưu trữ tệp cho phép tên tệp chứa các chuỗi dấu chấm-chấm liên tiếp (../) hoặc đường dẫn tuyệt đối. Nếu chương trình ghép thẳng tên tệp vào đường dẫn thư mục đích mà không kiểm tra, thì:

...

Thư mục đích: /var/tmp/esg_scan/xyz/

Tên tệp: ../../../../etc/cron.d/abc

Ghép lại: /var/tmp/esg_scan/xyz/../../../../etc/cron.d/abc

→ thực tế ghi vào /etc/cron.d/abc
...

Tức là kẻ tấn công **ghi tệp ra ngoài thư mục dự kiến, vào bất kỳ vị trí nào trên hệ thống tập mà tài khoản thực thi có quyền ghi**. Lỗ hổng dạng này có tên gọi phổ biến trong cộng đồng bảo mật là **"Zip Slip"** — dù ở đây tệp là TAR chứ không phải ZIP.

Điểm làm lỗi này nghiêm trọng ở ESG — và đây là chi tiết tôi không chắc 100%, cần đối chiếu:

Theo trí nhớ của tôi, vấn đề không chỉ là "quên kiểm tra đường dẫn". Đó là **Barracuda đã viết phần giải nén TAR riêng** thay vì dùng một thư viện chuẩn đã được gia cố và kiểm thử. Tôi nhớ có thêm một chi tiết nữa là phần giải nén này **không dùng cơ chế bảo vệ có sẵn** mà các thư viện hiện đại đã tích hợp. Tôi **không chắc** các chi tiết cụ thể, nhưng đây là điểm giải thích vì sao lỗi tồn tại trong một sản phẩm thương mại đã qua nhiều năm kiểm thử.

Bước từ ghi tệp tùy ý → RCE:

Ghi đè tệp tùy ý chỉ là "ghi tệp", chưa phải "thực thi mã". Để thành RCE, kẻ tấn công cần đặt tệp vào **một vị trí mà hệ thống sẽ tự thực thi nó**. Theo trí nhớ của tôi, PoC công khai đặt tệp vào các vị trí kiểu:

- **/etc/passwd** — để tạo thêm một tài khoản đặc quyền mà kẻ tấn công biết mật khẩu.
- **Một tệp thư viện được nạp khi khởi động** — để mọi tiến trình trên máy chủ nạp mã của kẻ tấn công.
- Hoặc **một tệp thực thi tự động theo lịch**.

Tôi **không chốt được** PoC dùng chính xác những đường dẫn nào. Đây là chi tiết phải lấy từ bài phân tích gốc, tuyệt đối không bịa — bịa đường dẫn trong bảo mật là loại sai rõ ràng nhất.*

Nguồn: thông báo Barracuda, 05/2023.

2. Điều kiện khai thác — và đây là lý do Barracuda không thể đơn giản vá cho tất cả mọi người

Điều kiện then chốt: lỗ hổng chỉ dẫn tới RCE khi ESG **chạy ở chế độ đặc quyền cao (privileged mode / chạy với quyền root)**.

Theo trí nhớ của tôi, đây là sự thật quan trọng về mặt kỹ thuật:

- Nếu tiến trình ESG chạy với **quyền thấp**, thì dù kẻ tấn công thoát khỏi thư mục giải nén, họ cũng **chỉ ghi được vào những vị trí mà tài khoản đó có quyền** — tác động bị giới hạn rất nhiều.
- Nếu tiến trình chạy với **quyền root**, thì kẻ tấn công ghi được vào **bất kỳ đâu trên hệ thống tập** → RCE hoàn chỉnh.

****Kết luận quan trọng:**** đây là lỗ hổng có ****điều kiện****, không phải lỗ hổng tiền xác thực không điều kiện như SQL injection của MOVEit. Nói "RCE không cần xác thực" ở đây là ****nói chưa đủ**** — phải nói kèm điều kiện quyền.

Nguồn: thông báo Barracuda, 05/2023.

3. Phạm vi phiên bản

- Lỗ hổng nằm trong ****phần mềm của các thiết bị ESG chạy ở chế độ đặc quyền****, ở các phiên bản ****trước bản 7.2.5****.

- Tôi ****khá chắc**** mốc ****7.2.5**** là phiên bản có bản vá, vì đây cũng chính là phiên bản mà Barracuda dùng để nói về việc ****thay thiết bị**** (mục 5).

- Tôi ****không nhớ chắc**** danh sách đầy đủ các phiên bản bị ảnh hưởng, và cũng ****không chắc**** mọi thiết bị ESG trên thị trường có chạy ở chế độ đặc quyền hay không. Cần đối chiếu bảng trong thông báo.

Nguồn: thông báo Barracuda, 05/2023.

4. Hậu quả đã ghi nhận — phần này có bằng chứng thực tế

****Đã được ghi nhận, khác với phần lớn các mục trước:****

- ****Đã bị khai thác ngoài đời.**** Tôi khá chắc rằng việc khai thác thực tế đã được báo cáo, và đây là điểm khiến sự cố này khác các mục như EchoLeak hay Confluence.

- Theo trí nhớ của tôi, ****Google TAG**** và ****Microsoft**** đã có báo cáo về việc nhóm tấn công sử dụng lỗ hổng này để xâm nhập vào thiết bị ESG, và tôi nhớ có nhắc tới các nhóm như ****APT28**** và một nhóm khác được Microsoft theo dõi. Tôi ****không chắc**** tên chính xác của nhóm bên thứ hai, không chắc thời điểm công bố, và không chắc mức độ thuộc về mỗi nhóm — phải lấy từ báo cáo gốc.*

****Hậu quả đặc thù của ESG — và đây là lý do lỗ hổng nguy hiểm hơn mức "RCE bình thường":****

Một thiết bị chặn thư điện tử ****đứng ở vị trí nhìn thấy toàn bộ luồng thư của tổ chức****. Kẻ tấn công chiếm được nó không chỉ có "một shell trên một máy chủ" — họ có:

- ****Quyền đọc và chặn mọi thư điện tử đi qua thiết bị**** — bao gồm thư có thông tin cá nhân, thông tin tài chính, thư công việc, và thậm chí thư chứa mã khôi phục / mật khẩu.

- ****Không bị phát hiện dễ dàng.**** Thư vẫn hiển thị là đã đi qua bộ lọc — nạn nhân tin rằng thư của họ đã được kiểm tra an toàn. Đây là dạng tấn công mà thường không để lại dấu vết cho người dùng cuối.

- ****Đây là công cụ theo dõi (surveillance), không chỉ là công cụ phá hoại.**** Tôi nhớ các báo cáo mô tả việc thiết bị bị dùng để ****canh chừng hộp thư**** và ****thu thập thông tin xác thực email****. Tôi không nhớ rõ cơ chế kỹ thuật chi tiết.

Nguồn: các báo cáo công khai về khai thác, 2023.

5. Bản vá và lý do Barracuda khuyến nghị **thay thiết bị**

Đây là phần khác biệt nhất của sự cố, và là điểm bạn hỏi đúng trọng tâm.

****Barracuda làm gì:****

- Phát hành bản **7.2.5** có sửa lỗi.
- Nhưng — và đây là điểm mấu chốt — ****Barracuda đã khuyến nghị thay thế thiết bị**** thay vì chỉ nâng cấp phần mềm, đối với các thiết bị chạy phiên bản cũ hơn.

****Vì sao khuyến nghị thay thiết bị mà không chỉ vá? — Lý do thật, theo trí nhớ của tôi:****

Đây là lý do tôi cho là thuyết phục nhất, và nó nằm ở ****tính chất của tấn công****, không nằm ở kỹ thuật vá:

1. ****Nếu thiết bị đã bị xâm nhập, nó đã có "cửa sau".**** Kể tấn công khai thác được RCE ở chế độ root thì đã có thể ****cài cơ chế duy trì quyền truy cập (backdoor)****. Việc vá lỗ hổng hỗ trợ ****đóng lỗ hổng****, nhưng ****không xóa backdoor đã cài sẵn****. Cài bản vá lên một thiết bị đã bị chiếm là hành động gần như vô nghĩa về mặt an toàn.
2. ****Không thể chứng minh được thiết bị sạch.**** Khác với phần mềm chạy trên máy chủ của bạn, bạn có thể cài lại hệ điều hành. Với một ****appliance**** (thiết bị đóng gói), bạn ****không có lựa chọn cài lại sạch**** — phần mềm nằm trong ổ cứng của nhà sản xuất, và bạn không có đặc quyền đó.
3. ****Không có đường nâng cấp cho phiên bản quá cũ.**** Tôi nhớ có thông tin rằng một số phiên bản cũ ****không có đường nâng cấp trực tiếp****, nên lựa chọn duy nhất là thay thiết bị. *Tôi không nhớ chắc ngưỡng phiên bản cụ thể mà từ đó không còn đường nâng cấp — phải lấy từ thông báo.*

****Hướng dẫn kiểm tra thiết bị đã bị xâm nhập chưa:****

Barracuda đã cung cấp cho khách hàng ****công cụ/danh sách dấu hiệu xâm nhập (IOC)**** để tự kiểm tra. Tôi nhớ có nhắc tới việc cung cấp ****danh sách địa chỉ IP đã được băm (hashed) của máy chủ điều khiển**** — dùng hàm băm để khách hàng có thể tự so sánh với nhật ký của mình mà không cần gửi dữ liệu nhạy cảm cho hãng. *Tôi ****không nhớ**** danh sách cụ thể và cũng không nhớ chính xác hãng dùng hàm băm nào. Tuyệt đối không bịa.*

Nguồn: thông báo Barracuda, 05/2023.

6. Thiết bị ESG và dịch vụ SaaS — phân biệt bạn hỏi rất đúng

Đây là cùng bài học như mục Exchange Server / Exchange Online, nhưng ****càng rõ hơn**** vì khác biệt nằm ở tầng sản phẩm.

Tiêu chí	****ESG — thiết bị vật lý (appliance)****	****Dịch vụ SaaS của Barracuda****
Ai sở hữu và vận hành	****Khách hàng**** đặt trong phòng máy chủ của mình	****Barracuda**** vận hành trên hạ tầng của hãng
Phần mềm nằm ở đâu	****Trong thiết bị của khách hàng****	Trên hạ tầng Barracuda
Khách hàng có thể tự vá không	****Có****, bằng cách nâng cấp phần mềm thiết bị	****Không**** — không có gì để vá
Lỗ hổng CVE-2023-2868 có áp dụng không	****Có****	****Không theo kiểu này**** — đây là lỗ hổng phần mềm trong thiết bị
Nếu bị xâm nhập thì hậu quả	Rò rỉ thư điện tử ****trong tổ chức bạn****	Rò rỉ thuộc phạm vi dịch vụ, do Barracuda xử lý
Hành động của khách hàng khi có lỗ hổng	****Nâng cấp hoặc thay thiết bị****	****Không có hành động kỹ thuật****; chỉ cần theo dõi thông báo của hãng

****Kết luận cần ghi vào bài:**** CVE-2023-2868 là lỗ hổng của ****sản phẩm dạng thiết bị tự host****. Nếu khách hàng dùng bản SaaS thì ****lỗ hổng này không liên quan đến họ**** — và nói ngược lại (rằng dịch vụ SaaS cũng cần vá) là ****sai****.

****Điểm nhận xét thêm, cũng là suy luận của tôi:**** sự khác biệt giữa appliance và SaaS ở đây cho thấy một điểm mà giảng viên có thể hỏi: ****càng đẩy sang SaaS, khách hàng càng mất quyền kiểm soát**** — mất quyền tự vá, nhưng cũng thoát khỏi trách nhiệm bảo mật hạ tầng. Với một sự cố mà hậu quả là "không thể chứng minh thiết bị đã sạch", đây là một đánh đổi thật, không phải đánh đổi dễ.

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
Nguyên nhân gốc là path traversal khi giải nén TAR (dạng Zip Slip)	****Sự thật****
Tên tệp trong tệp nén là dữ liệu kẻ tấn công kiểm soát, phải giới hạn trong thư mục đích	****Sự thật về nguyên tắc****
Lỗi nằm trong quy trình quét tệp đính kèm của ESG	****Khá chắc****
Barracuda tự viết phần giải nén TAR thay vì dùng thư viện chuẩn đã gia cố	****Trí nhớ, không chắc****
Điều kiện khai thác: ESG phải chạy ở chế độ đặc quyền	****Sự thật****
Ghi tệp ra ngoài thư mục đích dẫn tới RCE qua vị trí tự thực thi	****Sự thật về mặt cơ chế****
Phiên bản bị ảnh hưởng: trước 7.2.5	****Khá chắc****
Bản vá ở phiên bản 7.2.5	****Khá chắc****
Đã bị khai thác ngoài đời	****Khá chắc****
Hậu quả: chiếm quyền đọc/chặn thư điện tử toàn tổ chức	****Suy luận đúng từ chức năng thiết bị****
Bị dùng như công cụ theo dõi, không chỉ phá hoại	****Trí nhớ về các báo cáo, cần đối chiếu****
Google TAG và Microsoft có báo cáo khai thác	****Trí nhớ, cần xác nhận****

APT28 liên quan	****Trí nhớ, cần xác nhận****
Tên nhóm tấn công thứ hai do Microsoft theo dõi	****Tôi không nhớ — không nêu tên****
Vì sao khuyến nghị thay thiết bị: vì có thể đã có backdoor, và không xóa được	****Lập luận mạnh, tôi tin đây là lý do thật****
Không có đường nâng cấp cho phiên bản quá cũ	****Trí nhớ, không chắc ngưỡng cụ thể****
Barracuda cung cấp danh sách IOC dạng IP đã băm	****Trí nhớ, không nhớ hàm băm****
Ngày công bố 19 hay 24/05/2023	****Tôi không nhớ****
Đường dẫn tệp trong PoC (`etc/passwd`, thư viện nạp lúc khởi động, cron)	****Tôi không chốt được****
Tên bài thông báo và URL chính xác của Barracuda	****Tôi không nhớ****
CVSS chính thức	****Tôi không nhớ, không đưa ra****
Thiết bị không thể cài lại sạch như máy chủ thông thường	****Suy luận hợp lý về đặc điểm appliance****
Đánh đổi giữa appliance và SaaS	****Nhận xét của tôi, không gắn nguồn****

Artifact 15 — Prompt log lượt #18 — Thời gian: 00:04 27/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2023-23397 — Outlook for Windows tự kết nối tới máy chủ SMB của kẻ tấn công khi nhận email

****Phân loại:**** lỗ hổng bảo mật thật, có CVE chính thức, ****Leo thang đặc quyền****, ****không cần người dùng tương tác****, ****đã bị khai thác thật****.

****Nguồn Microsoft:**** hồ sơ CVE trong Microsoft Security Response Center (MSRC), bản vá phát hành ****14/03/2023**** — <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2023-23397>

****Mức độ:**** theo trí nhớ của tôi, Microsoft chấm ****9,8 (Critical)****. Tôi ****khá chắc**** vì đây là một trong những lỗ hổng hiếm mà Microsoft vừa vá vừa ****công bố đang bị khai thác****. Phải mở hồ sơ MSRC để xác nhận con số.

0. Vì sao mục này đáng chú ý nhất về mặt kỹ thuật

Đây là sự cố mà ****kẻ tấn công không cần làm gì cả****. Không cần nạn nhân bấm vào thư, không cần mở thư, không cần đăng nhập lại, không cần can thiệp kỹ thuật xã hội. Chỉ cần ****email được gửi tới hộp thư****.

Đây là điểm khác biệt căn bản so với phần lớn các mục khác trong bài, và cũng là điểm mà tôi thấy nhiều người mô tả sai. Hãy giữ lại sự khác biệt này khi viết.

1. Thuộc tính MAPI và cách nó gây kết nối ra ngoài

Đây là phần kỹ thuật khó nhất, và tôi sẽ mô tả theo mức hiểu của tôi — ****logic đúng, còn tên chi tiết thì tôi không chốt được.****

****Bối cảnh: MAPI là gì?****

- MAPI là ****mô hình dữ liệu mà Outlook dùng để lưu trữ thư****. Một thư không chỉ có "nội dung và tên người gửi" — nó là một tập hợp rất lớn các ****thuộc tính**** (properties).
- Mỗi thuộc tính có ****tên**** và ****giá trị****. Ví dụ: tên 'Subject' / giá trị 'Họp ngày mai'.
- Điểm mấu chốt của lỗ hổng nằm ở chỗ: ****các thuộc tính tùy chỉnh (custom property) vẫn phải có một "định nghĩa" cho Outlook biết tên và kiểu dữ liệu của nó là gì.**** Và thông tin định nghĩa đó được ghi trong một cấu trúc dữ liệu riêng — thứ mà kẻ tấn công ****cũng có toàn quyền kiểm soát****, vì nó nằm trong chính tệp thư mà kẻ tấn công soạn ra.

****Kẻ tấn công làm gì — theo trí nhớ của tôi:****

1. Soạn một thư **“bình thường về mặt thị giác”**: nội dung trông vô hại, người nhận thấy hoàn toàn bình thường.
2. Nhưng bên trong thư, họ chèn vào **“một thuộc tính tùy chỉnh có tên là một đường dẫn mạng UNC”** — tức dạng đường dẫn kiểu `\\máy-chủ-tấn-công\thư-mục\...` mà Windows dùng để chỉ tới một tài nguyên trên mạng.
3. Outlook **“không nên”** xử lý tên thuộc tính đó như một đường dẫn mạng. Nhưng do cách Outlook xử lý dữ liệu thuộc tính tùy chỉnh, nó **“lại lấy tên đó ra và cố “phân giải” nó như một tài nguyên mạng”** — tức là **“mở một kết nối SMB tới máy chủ đó”**.

“Vì sao việc “phân giải” một đường dẫn UNC lại nguy hiểm?”

Bất kỳ chương trình nào trên Windows, **“ngay cả khi chỉ muốn kiểm tra xem một tài nguyên có tồn tại không”**, khi thấy đường dẫn UNC thì hệ điều hành sẽ **“tự động thực hiện bắt tay xác thực (handshake) với máy chủ kia”**. Bắt tay đó diễn ra **“trước khi”** chương trình biết mình có quyền truy cập hay không.

Đây là điểm then chốt của toàn bộ sự cố: **“kẻ tấn công không cần xin quyền truy cập — chỉ cần khiến Windows bắt tay xác thực với máy chủ của họ, và bắt tay xác thực đó đã chứa thứ họ cần.”**

“Tôi “không chốt được”: tên chính xác của thuộc tính MAPI gây lỗi, tên cấu trúc dữ liệu mô tả thuộc tính đó, và cơ chế chính xác vì sao Outlook đi vào nhánh xử lý đó. Đây là chi tiết phải lấy từ bài phân tích gốc. Tôi **“không dám bịa tên kỹ thuật”** ở đây.*

Nguồn: MSRC, 14/03/2023.

2. Có cần người dùng bấm vào thư không — câu trả lời là KHÔNG

“Không cần.” Đây là chi tiết dễ bị mô tả sai nhất, nên tôi nêu rõ:

“Điều gì đủ để kích hoạt?”

- Thư **“được gửi tới hộp thư”** và **“được hiển thị trong danh sách thư”** của Outlook.

“Điều gì KHÔNG cần?”

- Không cần bấm vào thư.
- Không cần mở nội dung thư.
- Không cần bấm vào liên kết nào.
- Không cần đăng nhập lại.
- Không cần nạn nhân làm bất kỳ điều gì khác.

“Cơ chế này có nghĩa là gì, giải thích cho đúng tinh thần kỹ thuật?”

Khi Outlook hiển thị danh sách thư, nó **phải** đọc một loạt thuộc tính của thư **để** dựng cột "người gửi", "chủ đề", "ngày", để gộp thư theo cuộc trò chuyện, để hiển thị biểu tượng. Việc đọc và xử lý các thuộc tính này xảy ra **trong** lúc Outlook hiển thị danh sách, trước khi ai mở thư **đó**.

Lỗi hổng nằm đúng ở chỗ: **quá** trình "đọc thuộc tính để dựng danh sách" đó bị lợi dụng để tạo ra một kết nối mạng ra ngoài. **Nói** cách khác — việc nạn nhân chỉ cần **mở** Outlook và nhìn hộp thư **đó** là đủ.

Tôi khá chắc về nguyên tắc "chỉ cần hiển thị trong danh sách thì đã kích hoạt". Tôi **không** chắc chắn 100% **là** luôn luôn không cần tương tác trong mọi cấu hình (ví dụ một số cấu hình preview có thể thay đổi hành vi). Nếu bài làm cần khẳng định tuyệt đối, hãy dựa vào tuyên bố chính thức của Microsoft.*

Nguồn: MSRC, 14/03/2023.

3. Dữ liệu nào bị lộ

Dữ liệu bị lộ **KHÔNG** phải mật khẩu, và không phải nội dung thư. **Đây** là điểm cần nói chính xác.

Thứ thực sự bị lộ: bản bắt tay xác thực NTLM.

- Khi tiến trình Outlook kết nối tới máy chủ SMB của kẻ tấn công, nó thực hiện giao thức xác thực NTLM.

- Giao thức này không gửi mật khẩu qua mạng, nhưng nó có **bước** thứ hai — nơi **phía** nạn nhân gửi ra một giá trị được tính toán từ mật khẩu. Giá trị đó là thứ kẻ tấn công bắt được.

- Kẻ tấn công có **hai** cách dùng thứ này, và cả hai đều nguy hiểm:

1. **Dùng** trực tiếp mà không cần biết mật khẩu (NTLM relay): chuyển tiếp giá trị đó sang một dịch vụ khác mà nạn nhân có quyền truy cập, và đăng nhập vào dịch vụ đó **với** tư cách chính nạn nhân. Ở đây kẻ tấn công **không** cần biết mật khẩu là gì.

2. **Dò** mật khẩu ngoại tuyến (offline cracking): dùng giá trị đó để thử dò mật khẩu.

Nguồn: MSRC, 14/03/2023.

Hai điều phụ đáng nói:

- **Máy** chủ SMB tự tạo đó còn tiết lộ địa chỉ IP nội bộ của nạn nhân, và bản thân việc kết nối cũng là một tín hiệu để kẻ tấn công dò xem nạn nhân dùng giao thức bảo mật nào. **Đây** là nhận xét suy luận của tôi về mặt kỹ thuật, không phải tuyên bố của Microsoft.*

- **Giá** trị bị lộ là "đăng nhập được" chứ không phải "đã đăng nhập". Phân biệt này quan trọng: kẻ tấn công chưa vào được tài khoản, nhưng đã có thứ đủ để **tự** xin vào. Vì vậy **đổi** mật khẩu một mình chưa đủ — còn bản bắt tay đã bị bắt thì không mất hiệu lực chỉ vì đổi mật khẩu.

Nguồn: nhận xét của tôi.

4. Hậu quả

****Đã được xác nhận — và đây là mục có dữ liệu thật:****

- ****Đã bị khai thác thực tế.**** Tôi khá chắc rằng Microsoft đã công bố rằng lỗ hổng này ****đang bị khai thác**** khi họ phát hành bản vá, và nó là một trong những lỗ hổng mà Microsoft đưa vào ****danh mục lỗ hổng đã bị khai thác thực tế (KEV)****. Đây là điểm khác biệt rõ với mục #06 (EchoLeak) và #08 (Confluence).

****Chủ thể tấn công và mục tiêu — theo trí nhớ, cần đối chiếu:****

- Tôi nhớ có thông tin cho rằng lỗ hổng này bị ****nhiều nhóm tấn công của nhà nước sử dụng****, và các mục tiêu được nhắc tới có liên quan tới ****Ukraine, các tổ chức thuộc NATO, và một số tổ chức phi chính phủ****. *Tôi ****không nhớ chắc**** tên từng nhóm cụ thể, và cũng ****không chắc**** mốc thời gian công bố phân tích của Microsoft. Đây là chỗ bạn bắt buộc phải lấy từ bài Microsoft Threat Intelligence gốc — tôi sẽ không nêu tên nhóm từ trí nhớ.*

****Hậu quả theo tầng:****

| Tầng | Mô tả | Trạng thái |

| ---| ---| ---|

| 1 | Thông tin xác thực NTLM của nạn nhân bị lộ | ****Đã xác nhận — đây là hậu quả trực tiếp**** |

| 2 | Kẻ tấn công đăng nhập được vào dịch vụ khác với tư cách nạn nhân (relay) | ****Hệ quả trực tiếp của tầng 1**** |

| 3 | Chiếm tài khoản thư, đọc/gửi thư giả danh nạn nhân | ****Suy luận hợp lý nếu tầng 2 thành công**** |

| 4 | Chiếm hệ thống dịch vụ khác mà nạn nhân truy cập được | ****Suy luận của tôi**** |

*Lưu ý: tôi ****không có dữ liệu**** về số nạn nhân cụ thể, và tôi không nêu số liệu nào.*

5. Biện pháp khắc phục

****Cách khắc phục chính thức của Microsoft:****

- ****Cài bản cập nhật bảo mật phát hành 14/03/2023.**** Đây là biện pháp chính thức và là biện pháp duy nhất Microsoft xác nhận là đủ.

****Về biện pháp tạm thời trước khi vá — tôi không chắc, và đây là điểm cần nói thẳng:****

- Tôi ****không nhớ chắc**** Microsoft có đưa ra biện pháp giảm thiểu tạm thời nào cho lỗ hổng này hay không. Tôi có cảm giác là ****không có**** một cài đặt nào trong Outlook chặn được nó, vì lỗ hổng nằm ở tầng xử lý thuộc tính chứ không phải ở một tính năng bật/tắt được.

- *Nếu bài của bạn cần nêu biện pháp tạm thời, hãy lấy từ hồ sơ MSRC. Tôi sẽ không bịa một cấu hình Group Policy hay khóa registry.*

****Hành động cần làm sau khi vá (đây là điểm bị bỏ qua nhiều nhất):****

Vì lỗ hổng này ****lộ thông tin xác thực****, nên việc vá ****không hoàn tất quá trình khắc phục****. Cần thêm:

1. ****Đổi mật khẩu**** tài khoản bị ảnh hưởng — vì giá trị bị lộ có thể đã bị dùng để dò mật khẩu ngoại tuyến.
2. ****Bật/chuyển sang xác thực đa yếu tố (MFA)**** — đây là biện pháp có tác dụng mạnh nhất vì nó chặn đứng cả đường tấn công "đăng nhập bằng mật khẩu bị lộ".
3. ****Điều tra xem tài khoản có bị truy cập trái phép không****, đặc biệt là dịch vụ nào trong mạng tổ chức.
4. ****Đánh giá mức độ lộ thông tin tới tổ chức.****

*Lưu ý về tính hợp lệ: tôi trình bày đây là các bước ứng cử hợp lý theo nguyên tắc an toàn thông tin, dựa trên bản chất "lộ thông tin xác thực" của lỗ hổng. Tôi gắn rõ là ****khuyến nghị của tôi****, không phải danh sách Microsoft liệt kê.*

Nguồn: MSRC, 14/03/2023.

6. Các phiên bản Outlook KHÔNG thuộc phạm vi

Đây là phần bạn hỏi rất đúng, và là điểm bài làm cần ghi chính xác.

****Không thuộc phạm vi (theo trí nhớ của tôi về hồ sơ MSRC):****

Sản phẩm	Có bị ảnh hưởng?	Vì sao
Outlook for macOS	Không	Không cùng cơ chế xử lý MAPI/properties như bản Windows
Outlook for iOS	Không	Chạy trên nền tảng khác
Outlook for Android	Không	Chạy trên nền tảng khác
Outlook trên web (OWA)	Không	Chạy trong trình duyệt, không phải ứng dụng Windows
Các ứng dụng thư khác (ví dụ Thunderbird)	Không	Không phải Outlook

*Bảng này tôi ****khá chắc**** về nguyên tắc — lỗ hổng nằm trong phần mã Outlook chạy trên Windows. Nhưng tôi ****không nhớ**** Microsoft's advisory liệt kê ***đúng*** những dòng nào, và tôi ****không chắc**** có dòng nào nào ngoài các dòng trên cũng bị loại trừ (ví dụ các phiên bản Office perpetual cũ). Phải đối chiếu nguyên văn hồ sơ MSRC — nếu bạn liệt kê, hãy liệt kê đúng theo hồ sơ.*

****Bị ảnh hưởng:**** ****Outlook for Windows**** — tức các bản Outlook 32-bit và 64-bit chạy trên Windows, thuộc các bộ Office 2016 / 2019 / 2021 / Microsoft 365 Apps. ***Tôi **không nhớ chắc** liệu MSRC ghi rõ từng bộ Office nào, phải kiểm tra.***

****Điểm nhận xét khi viết bài — và đây là lợi thế thật của mục này:****

Có một điểm mà bài của bạn nên nêu vì nó nâng cao chất lượng phân tích: ****"Outlook không bị ảnh hưởng" không có nghĩa "người dùng không bị ảnh hưởng."****

- Nạn nhân vẫn cần được vá.
- Nhưng nếu toàn bộ tổ chức chỉ dùng OWA hoặc Outlook trên điện thoại, thì ****phạm vi phải ứng cứu nhỏ hơn nhiều**** — và đó là thông tin có giá trị thực tế khi lập kế hoạch khắc phục.

Bảng tách sự thật và suy luận

Nội dung Trạng thái
--- ---
Lỗ hổng nằm ở Outlook for Windows **Sự thật**
Cơ chế là xử lý tên thuộc tính MAPI tùy chỉnh chứa đường dẫn UNC **Khá chắc về logic, không chắc tên kỹ thuật**
Kết nối mạng tạo ra ở tầng "đọc thuộc tính để dựng danh sách thư" **Khá chắc**
Không cần người dùng bấm vào thư **Sự thật**
Dữ liệu bị lộ là bản bắt tay xác thực NTLM, không phải mật khẩu **Sự thật**
Có thể relay để đăng nhập mà không cần biết mật khẩu **Suy luận kỹ thuật đúng**
Microsoft công bố đang bị khai thác khi phát hành bản vá **Khá chắc**
Lỗ hổng có trong danh mục KEV **Khá chắc**
CVSS 9,8 theo MSRC **Khá chắc, cần xác nhận**
Bản vá phát hành 14/03/2023 **Sự thật**
Outlook macOS / iOS / Android / OWA không bị ảnh hưởng **Khá chắc về nguyên tắc**
Danh sách loại trừ trùng khớp **đúng** với hồ sơ MSRC **Tôi không chắc — phải đối chiếu**
Các bộ Office bị ảnh hưởng cụ thể **Tôi không nhớ**
Tên thuộc tính MAPI / cấu trúc dữ liệu gây lỗi **Tôi không chốt được**
Microsoft có biện pháp tạm thời không **Tôi không chắc — không nêu**
Tên các nhóm tấn công nhà nước **Tôi không nhớ — không nêu tên**
Số nạn nhân **Tôi không có dữ liệu**
Kết nối làm lộ IP nội bộ nạn nhân **Suy luận kỹ thuật của tôi**
Đổi mật khẩu + bật MFA là biện pháp ứng cứu đúng **Khuyến nghị của tôi, không phải danh sách của Microsoft**
"Outlook không bị ảnh hưởng" ≠ "người dùng không bị ảnh hưởng" **Nhận xét phân tích của tôi**

Artifact 16 — Prompt log lượt #19 — Thời gian: 00:08 27/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2023-4966 — rò rỉ phiên (session token) trên NetScaler ADC/Gateway, gọi tên "CitrixBleed"

****Phân loại:**** lỗ hổng bảo mật thật, có CVE chính thức của Citrix, ****đọc bộ nhớ không cần xác thực****, ****đã bị khai thác quy mô lớn****.

****Nguồn Citrix:**** thông báo bảo mật của Citrix (Citrix Security Advisory), phát hành ****17/10/2023**** — <https://support.citrix.com/article/breaking-news-vulnerability-cve-2023-4966> (tôi không chắc chính xác tiêu đề và URL; phải lấy lại từ cổng hỗ trợ Citrix)

Hồ sơ CVE: <https://www.cve.org/CVERecord?id=CVE-2023-4966>

*Về mức độ: tôi ****không nhớ chắc**** Citrix hay NVD chấm bao nhiêu cho CVE này. Tôi có cảm giác là con số có phần thập hơn 9,8 (có thể 9,4), nhưng ****đây là trí nhớ, không phải dữ liệu kiểm chứng**** — tuyệt đối không ghi vào bài khi chưa mở NVD.*

0. Vì sao mục này dạy một bài học khác với tất cả mục trước

Các mục trước tôi toàn nói: *****"vả là xong."***** Mục này thì ngược lại — và đây chính là điểm đáng nhớ nhất:

> ****Vả lỗ hổng KHÔNG làm vô hiệu các phiên đã bị kẻ tấn công đánh cắp.****

Vì sao? Vì thứ bị lộ là ****token phiên****, và token đó ****không được kiểm tra lại mỗi lần dùng****. Nó vẫn hợp lệ cho tới khi bị ****chủ động hủy****. Đây là khác biệt căn bản giữa "lỗ hổng cho phép đọc dữ liệu" và "lỗ hổng cho phép thực thi mã" — loại thứ hai tự động chết theo bản vá, loại thứ nhất thì không.

Hãy giữ điểm này làm trung tâm khi viết bài. Nó là thứ khiến mục này ****không thể bị coi là bình thường****.

1. Loại dữ liệu có thể lộ

****Dữ liệu chính: token phiên (session token).****

****Token phiên là gì — cần hiểu vì toàn bộ sự cố nằm ở đây:****

- Khi người dùng đăng nhập qua NetScaler Gateway, thiết bị xác thực họ và tạo ra một ****token**** — một chuỗi ký tự đại diện cho "phiên này đã đăng nhập hợp lệ".

- Người dùng điều hướng tiếp ứng dụng qua Gateway mà **không phải đăng nhập lại**, vì Gateway dùng token đó để biết họ là ai.
- Token này **được cấp một lần và dùng lại nhiều lần** trong suốt phiên.

Vì sao lấy được token là tương đương với mất tài khoản:

- Kẻ tấn công **không cần biết mật khẩu**. Họ chỉ cần gửi token đó cho thiết bị.
- Thiết bị thấy token hợp lệ → **cho thông qua, như thể nạn nhân đang sử dụng**.
- Và quan trọng: **quyền của token là quyền của người dùng đó** — nên kẻ tấn công không chỉ vào được hệ thống, mà vào được **đúng những gì nạn nhân đó được quyền xem**, kể cả dữ liệu nhạy cảm hơn.

Còn dữ liệu khác — cần nói thật:

- Theo trí nhớ của tôi, lỗ hổng cho phép **đọc bộ nhớ của thiết bị** ở mức rộng, nên về lý thuyết có thể lộ **nhiều hơn chỉ token** (ví dụ cấu hình, thông tin tài khoản khác).
- Tôi **không chắc** các nhà nghiên cứu đã chứng minh được những loại dữ liệu cụ thể nào ngoài token. **Không nêu loại nào tôi không chắc.**
- Điều duy nhất tôi khẳng định được: **token phiên là thứ đã bị khai thác thực tế**. Mọi thứ khác là tiềm năng lý thuyết.

Nguồn: thông báo Citrix, 17/10/2023.

2. Cấu hình nào bị ảnh hưởng — và tại sao không được suy rộng

Đây là phần bạn yêu cầu phải chính xác, và tôi sẽ tách rõ mức chắc chắn.

Sản phẩm bị ảnh hưởng:

- **NetScaler ADC** (bộ điều khiển phân phối ứng dụng)
- **NetScaler Gateway** (cổng truy cập web an toàn)

Sản phẩm KHÔNG bị ảnh hưởng:

Theo trí nhớ của tôi, Citrix đã nói rõ rằng các sản phẩm khác trong họ NetScaler **không** bị ảnh hưởng, và tôi nhớ có những tên như các dòng **SD-WAN** và **WAF / App Security**. **Tôi không nhớ chắc** danh sách loại trừ chính thức mà Citrix đưa ra — phải đối chiếu nguyên văn thông báo, tuyệt đối không tự liệt kê.*

Điều kiện cấu hình — đây là điểm tinh tế nhất, và tôi nói "khá chắc" chứ không phải "chắc":

- Tôi nhớ rằng lỗ hổng này liên quan tới việc **xác thực cục bộ (local authentication)** trên thiết bị. Cụ thể là: nếu thiết bị được cấu hình để **xác thực người dùng bằng thông tin đăng nhập lưu ngay**

trên chính nó**, thì các token bị rò rỉ sẽ **dùng được ngay** để đăng nhập vì thiết bị tự kiểm chứng được token đó.

- Nếu thiết bị **ủy quyền xác thực cho một hệ thống bên ngoài** (ví dụ thư mục doanh nghiệp), thì cơ chế lưu phiên có thể khác, và token bị lộ có thể **không cho quyền truy cập tương đương**.
- Hệ quả thực hành: **Citrix đã khuyến nghị tắt xác thực cục bộ như một biện pháp giảm thiểu tạm thời** cho những ai chưa vá được. Tôi **khá chắc** về điều này.
- *Tôi **không nhớ chắc** cơ chế kỹ thuật chi tiết bên trong. Lý thuyết tôi nêu ở trên là cách tôi hiểu, không phải nguyên văn Citrix.*

****Vì sao phần này quan trọng về mặt phạm vi:**** nếu bạn viết "Citrix NetScaler bị ảnh hưởng" một cách chung chung, bạn **sai**. Đúng phải là **ADC và Gateway** — và chỉ trong cấu hình xác thực cục bộ. Câu này nên đưa vào bài.

Nguồn: thông báo Citrix, 17/10/2023.

3. Điều gì đã được xác nhận về khai thác

****Đã xác nhận, mạnh hơn hầu hết các mục trước:****

- ****Đây là một trong những sự cố bị khai thác quy mô lớn nhất năm 2023.**** Điều này không phải suy đoán — có nhiều hãng phân tích an ninh độc lập báo cáo về việc phát hiện số lượng lớn thiết bị đã bị ảnh hưởng trên Internet.
- Tôi khá chắc lỗi hổng được **đưa vào danh mục KEV** của CISA.
- Tôi **không đưa ra con số cụ thể** về số thiết bị bị lộ hay số phiên bị đánh cắp. Tôi nhớ có con số ở mức **hàng chục nghìn thiết bị**, nhưng **không chốt được** và các con số trong báo cáo khác nhau. Bài của bạn không nên dùng con số khi chưa kiểm chứng — cùng lý do đã nêu ở mục MOVEit.
- Tôi **không nêu tên nạn nhân cụ thể**. Tôi nhớ có những tổ chức lớn bị nhắc tới trong báo chí, nhưng tôi **không nhớ chắc** tên và thời điểm — nêu tên từ trí nhớ là loại lỗi tệ nhất trong bài này.

****Về khả năng ghi vào bộ nhớ (không chỉ đọc):****

- Tôi có trí nhớ rằng ít nhất một hãng phân tích cho rằng lỗi hổng cho phép không chỉ **đọc** bộ nhớ mà còn **cài (implant) nội dung vào** bộ nhớ.
- ****Mức chắc chắn: thấp.**** Tôi ghi lại như trí nhớ, không khẳng định. Nếu bài làm cần nói về khả năng này, phải kiểm tra báo cáo gốc.

Nguồn: thông báo Citrix; các báo cáo công khai về khai thác, 10–11/2023.

4. Hậu quả

****Tầng 1 — Trực tiếp:**** lộ token phiên của người dùng đi qua Gateway/ADC.

****Tầng 2 — Chiếm phiên:**** kẻ tấn công dùng token đó đăng nhập ****với tư cách nạn nhân****, thừa hưởng đúng quyền của nạn nhân.

****Tầng 3 — Leo thang:**** vì nhiều tổ chức dùng Gateway/ADC để truy cập vào ****hệ thống nội bộ, máy chủ ảo, mạng doanh nghiệp từ xa****, nên chiếm được phiên Gateway có thể dẫn tới ****tiếp cận các hệ thống đó****. *Đây là suy luận của tôi dựa trên chức năng thiết bị, không phải kết luận từ nguồn.*

****Điểm nguy hiểm nhất, cần nhấn mạnh — vì nó là lý do sự cố này khác mọi sự cố "vá rồi là xong":****

- Token phiên bị đánh cắp ****vẫn dùng được sau khi nạn nhân đổi mật khẩu****. Vì sao: vì nó không phải mật khẩu, mà là ****bằng chứng phiên đã được cấp trước đó****. Thiết bị không kiểm tra lại mật khẩu mỗi lần dùng token.

- Và nó ****vẫn dùng được sau khi vá lỗ hổng****.

- Nó chỉ mất hiệu lực khi ****phiên tương ứng bị chủ động hủy**** hoặc khi thiết bị được ****khởi động lại****.

- Hệ quả thực tế nghiêm trọng: ****ngay cả khi tổ chức vá đúng, đúng ngày, kẻ tấn công vẫn ở trong hệ thống**** nếu họ không làm thêm bước hủy phiên. Đây là lý do rất nhiều tổ chức bị phát hiện là đã bị xâm nhập ****nhiều tháng sau khi đã vá****.

Nguồn: thông báo Citrix, 17/10/2023.

5. Cách vá và xử lý phiên có nguy cơ

****Bước 1 — Vá (bắt buộc, nhưng chưa đủ):****

- Cài bản cập nhật Citrix phát hành ****17/10/2023****.

****Bước 2 — Hủy toàn bộ phiên đang hoạt động (đây là bước bị bỏ qua nhiều nhất):****

- Citrix đã ****yêu cầu rõ ràng**** khách hàng ****chấm dứt tất cả phiên**** sau khi vá, vì lý do đã giải thích ở mục 4.

- Tôi nhớ việc này ****gây gián đoạn vận hành nghiêm trọng**** — nhiều tổ chức phải thông báo cho người dùng đăng xuất lại. Đây là chi phí vận hành thật của việc khắc phục, và đáng ghi vào bài.

- *Tôi ****không chắc**** về việc Citrix có mô tả cụ thể thao tác kỹ thuật nào (lệnh, hoặc khởi động lại) là đủ. Phải theo thông báo gốc.*

****Bước 3 — Đánh giá thiệt hại đã xảy ra (đừng bỏ bước này):****

- Vì có khai thác thực tế trước khi vá, bạn ****không thể coi việc vá là kết thúc sự cố****. Cần điều tra xem thiết bị đã bị truy cập trái phép chưa.

- Citrix đã cung cấp ****thông tin chỉ báo xâm nhập (IOC)**** để khách hàng săn tìm dấu vết. *Tôi không nhớ danh sách cụ thể.*

****Bước 4 — Các biện pháp bổ sung — phần này tôi phân biệt rõ nguồn:****

- ****Đổi mật khẩu tài khoản**** bị ảnh hưởng: ****đây là khuyến nghị của tôi****, không phải của Citrix. Lý do: như đã nêu ở mục 4, đổi mật khẩu ****không**** vô hiệu token đã bị lấy, nên nó chỉ hữu ích nếu kẻ tấn công đã dò ra mật khẩu.

- **Theo dõi hệ thống:** cũng là khuyến nghị của tôi.

Nguồn: thông báo Citrix, 17/10/2023.

Một chi tiết tôi nhớ nhưng không chắc — nêu để bạn biết có gì đó cần kiểm tra:

- Tôi nhớ có thông tin rằng với **các phiên dài hạn/liên tục** (kiểu phiên cố định cho desktop ảo), cách xử lý phải khác so với phiên thông thường, và có thể cần xóa dữ liệu phiên lưu trên thiết bị chứ không chỉ chấm dứt phiên. **Mức chắc chắn: thấp.** Nếu bài của bạn có nhắc tới loại phiên này, phải xác nhận lại với Citrix.

6. Chuyện cái tên "CitrixBleed" — và bài học về khuyến nghị giảm thiểu

Đây là chi tiết thú vị và cũng là một ví dụ về giới hạn của khuyến nghị bảo mật.

- Lỗ hổng này được cộng đồng gọi là **"CitrixBleed"** — cái tên ghép tên hãng với từ "bleed" (rò rỉ). Nó trở thành tên gọi phổ biến và được dùng rộng rãi.

- Tôi **không** chắc chắn về chi tiết câu chuyện, nhưng có trí nhớ rằng Citrix đã **đề nghị** các hãng tin không dùng tên đó trong báo cáo của họ. Tôi **không nhớ** phản ứng cụ thể của cộng đồng và không nhớ ai đặt tên.

*Vì sao điều này đáng đưa vào bài: vì tên gọi của cộng đồng thường **đi trước và rộng hơn** khuyến nghị chính thức. Nếu giảng viên hỏi "vì sao bài này được gọi là CitrixBleed", câu trả lời ngắn gọn và chính xác là: **vì nó là lỗ hổng làm lộ dữ liệu phiên, đặt theo tên hãng** — không cần kể thêm về chuyện đặt tên, vì tôi không chắc chi tiết.*

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
---	---
Lỗ hổng cho phép đọc bộ nhớ thiết bị không cần xác thực	Sự thật
Dữ liệu bị lộ chủ yếu là token phiên	Sự thật
Token phiên dùng để đăng nhập mà không cần mật khẩu	Sự thật
Token vẫn hiệu lực sau khi đổi mật khẩu	Sự thật — đây là điểm mấu chốt
Token vẫn hiệu lực sau khi vá lỗ hổng	Sự thật — điểm mấu chốt
Bắt buộc phải chấm dứt phiên sau khi vá	Sự thật — Citrix yêu cầu
Bị ảnh hưởng: NetScaler ADC và NetScaler Gateway	Sự thật
SD-WAN, WAF không bị ảnh hưởng	Trí nhớ — cần đối chiếu danh sách chính thức
Cấu hình xác thực cục bộ là điều kiện để khai thác được	Khá chắc
Khuyến nghị tắt xác thực cục bộ như biện pháp tạm thời	Khá chắc
Đã bị khai thác quy mô lớn trên thực tế	Sự thật

Có trong danh mục KEV của CISA	****Khá chắc****
Bản vá phát hành 17/10/2023	****Sự thật****
Việc hủy phiên gây gián đoạn vận hành	****Suy luận hợp lý của tôi****
Có thể cài nội dung vào bộ nhớ (không chỉ đọc)	****Trí nhớ mức thấp****
CVSS	****Tôi không nhớ — không đưa ra****
Số thiết bị bị lộ, số phiên bị đánh cắp	****Tôi không chốt được — không nêu số****
Tên nạn nhân cụ thể	****Tôi không nhớ — không nêu tên****
Xử lý khác nhau cho phiên dài hạn/desktop ảo	****Trí nhớ mức thấp****
Thao tác kỹ thuật cụ thể của Citrix để hủy phiên	****Tôi không nhớ****
Danh sách IOC của Citrix	****Tôi không nhớ****
Câu chuyện Citrix đề nghị không dùng tên "CitrixBleed"	****Trí nhớ, không chắc chi tiết****
Lỗi cho phép tiếp cận hệ thống nội bộ qua Gateway	****Suy luận của tôi từ chức năng thiết bị****
Đổi mật khẩu là biện pháp hữu ích	****Khuyến nghị của tôi, kèm giới hạn đã nêu****

Artifact 17 — Prompt log lượt #20 — Thời gian: 00:20 27/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2023-20198 và CVE-2023-20273 — Cisco IOS XE Web UI: leo thang đặc quyền và phơi bày Web UI

****Phân loại:**** đây là ****hai lỗ hổng riêng biệt****, có hai CVE riêng, ****hai thông báo bảo mật riêng**** của Cisco. Đều là lỗ hổng thật. Cả hai ****liên kết chặt với nhau**** để tạo thành một chuỗi tấn công, nhưng ****không phải cùng một lỗi****.

****Nguồn Cisco (hai thông báo, cùng ngày 16/10/2023):****

- CVE-2023-20198 — thông báo "Web UI Privilege Escalation":

<https://tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-iosxe-webui-privesc>

- CVE-2023-20273 — thông báo "Web UI Interface Exposure":

<https://tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-iosxe-webui-exposure>

*Tôi ****khá chắc**** về việc cùng ngày 16/10/2023 và về dạng tên/URL như trên, nhưng ****phải mở tools.cisco.com để lấy đúng URL và đúng ID thông báo**** trước khi dẫn vào bài.*

****Mức độ:**** theo trí nhớ của tôi, Cisco chấm ****CVSS 10,0**** cho ****cả hai**** CVE. Tôi ****khá chắc**** về 20198; với 20273 tôi ****khá chắc nhưng ít chắc hơn một chút****. Phải xác nhận bằng hồ sơ Cisco.

0. Cảnh báo quan trọng nhất: đừng gộp hai CVE làm một

Đây là chỗ nhiều người — kể cả nhiều bài viết — mô tả sai, và tôi sẽ nói thẳng để bạn tránh:

> Sai lầm phổ biến: ****"Lỗ hổng Cisco IOS XE cho phép chiếm quyền quản trị đầy đủ **không cần đăng nhập**"**.

Câu đó là kết quả của việc ****trộn hai lỗ hổng khác nhau vào một câu****. Sự thật thì phức tạp hơn, và chính sự phức tạp đó mới là điểm đáng giá của mục này.

****Bảng tách năng lực từng CVE**** — đây là phần lõi của câu trả lời:

| Đặc điểm | ****CVE-2023-20273**** | ****CVE-2023-20198**** |

| --- | --- | --- |

| Tên thông báo Cisco | Web UI ****Interface Exposure**** | Web UI ****Privilege Escalation**** |

| Cần đăng nhập không? | ****Không**** | ****Có**** |

| Quyền tối thiểu nạn nhân phải có | Không cần tài khoản nào | Tài khoản hợp lệ, ****mức ưu tiên 1**** (không đặc quyền) |

| Kết quả đạt được | Tạo được tài khoản **mức ưu tiên 15** (quản trị đầy đủ) | Leo thang từ mức 1 lên **mức ưu tiên 15** |

| Điều kiện cấu hình | Web UI **bật** và tấn công **tới được** Web UI đó | Web UI **bật** và có tồn tại tài khoản mức 1 |

| CVSS (theo trí nhớ của tôi) | 10,0 | 10,0 |

| Có cần 20198 không? | **Không** — 20273 một mình đã đủ | Cần 20198 mới đạt mục tiêu |

*Bảng này là **cách tôi hiểu** về cách ghép hai lỗ hổng, không phải trích nguyên văn Cisco. Đây chính là chi tiết bạn phải đối chiếu với hai thông báo gốc, vì nếu tôi gán sai năng lực cho từng CVE thì cả phần "tách rõ" trong bài sẽ sai theo.*

1. Điều kiện cấu hình — vì sao "bật Web UI" là điều kiện then chốt

Điều kiện chung cho cả hai lỗ hổng: Web UI phải được BẬT.

- Theo trí nhớ của tôi, Web UI của IOS XE **không bật mặc định**; nó phải được bật tường minh bằng cấu hình trên thiết bị. Tôi nhớ tên lệnh dạng `ip http server` và `ip http secure-server`, nhưng **không chắc chính xác cú pháp từng lệnh** — phải tra tài liệu Cisco.
- **Hệ quả quan trọng:** nếu thiết bị không bật Web UI thì **không có bề mặt tấn công** cho cả hai lỗ hổng. Vì vậy việc "tắt Web UI" là một biện pháp khắc phục **hợp lệ và mạnh**, tách biệt với việc vá lỗi.
- **Cách hỏng phổ biến trong thực tế:** tổ chức bật Web UI để quản trị, dùng xong không tắt, hoặc bật rồi đẩy ra Internet mà quên giới hạn truy cập. Đây là lý do vì sao chi tiết "Web UI bật và tới được từ Internet" mới là thông tin quan trọng, chứ không phải bản thân lỗ hổng.

2. "Mức ưu tiên 15" nghĩa là gì — và vì sao nó nguy hiểm

- IOS XE dùng thang ưu tiên **0 đến 15**. **Mức 15 là toàn quyền** (tương đương quyền `enable` trên thiết bị Cisco).
- Với mức 15, kẻ tấn công có thể: xem và thay đổi **toàn bộ cấu hình** của thiết bị, tạo tài khoản khác, thay firmware, đọc log hệ thống, can thiệp định tuyến.
- **Giới hạn cần nói rõ:** quyền đó là **toàn quyền trên đúng thiết bị này**. Nó **không** đồng nghĩa với quyền quản trị cả mạng hay hệ thống phía sau. Bài nào nói "chiếm được toàn bộ hệ thống mạng" từ mức 15 là nói quá.
- **Vì sao điểm này là trung tâm:** với CVE-2023-20198, kẻ tấn công chỉ cần **tài khoản mức 1** — tức tài khoản gần như không làm được gì. Sau khi leo thang, kẻ tấn công **không còn khác gì kỹ sư mạng thật**. Với mức độ "không đặc quyền" mà ra "toàn quyền", đây là dạng leo thang đặc quyền kinh điển.

3. Hậu quả đã quan sát — phần này có dữ liệu thật

Đã được xác nhận:

- Tôi **khá chắc** cả hai CVE nằm trong **danh mục KEV** của CISA. Nếu bài cần dẫn, hãy kiểm tra lại trang KEV.

- Ngay sau khi Cisco công bố, có **hoạt động quét tự động** trên toàn Internet nhắm vào Web UI của IOS XE. Tôi mô tả được hiện tượng này, nhưng **không nêu con số thiết bị bị dò quét** vì các báo cáo khác nhau.

Phần nghiêm trọng nhất — có báo cáo về việc đã bị cài "implant":

- Tôi nhớ có nghiên cứu của các hãng phân tích bảo mật (tôi **không nêu tên hãng** vì không chắc từ trí nhớ) báo cáo vào **cuối năm 2023** rằng một số thiết bị IOS XE đang phôi trên Internet đã bị cài một **backdoor dạng script Lua**.

- Tôi **khá chắc** về bản chất "là script Lua"; tôi **không nhớ** tên tệp hay tên biến thể cụ thể, nên **không nêu tên** — đây đúng là loại chi tiết bịa ra sẽ vô hại mà nguy hiểm.

- Tôi **không nêu số lượng nạn nhân** và **không nêu tên tổ chức bị ảnh hưởng**.

Bài học vận hành quan trọng nhất — và nó lặp lại bài học của mục #14 nhưng vì lý do khác:

- Ở mục #14, "vá chưa đủ" vì **phiên đã bị đánh cắp vẫn còn hiệu lực**.

- Ở mục này, "vá chưa đủ" vì **backdoor có thể đã nằm sẵn trên thiết bị từ trước khi vá**. Vá chỉ đóng đường vào mới; nó không tự chứng minh thiết bị đã sạch.

- Hệ quả thực hành: **phải rà soát thiết bị, không chỉ cài bản vá**.

*Về việc nâng cấp lên bản sửa có tự gỡ backdoor hay không: tôi **không chốt được** Cisco nói gì, và tôi cũng không chắc các nhà nghiên cứu khuyến nghị thế nào. Phải kiểm tra cả hai nguồn.*

4. Bản vá — và tách rõ "vá" với "rà soát"

Việc 1 — Đóng lỗ hổng (bắt buộc):

- Theo trí nhớ của tôi, Cisco phát hành các bản sửa vào cùng đợt 16/10/2023, và **danh sách phiên bản sửa khá dài** vì phải phủ nhiều nhánh sản phẩm IOS XE.

- Tôi nhớ **mẫu hình đặc trưng** của danh sách này là phiên bản được thêm **hậu tố "a"** (ví dụ các phiên bản dạng `17.x.y a` so với bản gốc). Tôi **khá chắc** về mẫu hình này, nhưng **tuyệt đối không ghi danh sách phiên bản từ trí nhớ** — phải lấy nguyên văn danh sách trong thông báo Cisco.

- Cũng cần kiểm tra: **không phải mọi phiên bản IOS XE nào cũng bị ảnh hưởng** và không phải mọi bản sửa đều giống nhau giữa các nền tảng.

Việc 2 — Tắt Web UI nếu không dùng (rất nên, độc lập với việc vá):

- Nếu tổ chức không dùng Web UI để quản trị thì **tắt nó đi** sau khi vá. Đây là biện pháp giảm thiểu có tác dụng thật, không phải thủ tục hình thức.

- *Tôi **không nhớ chắc** cú pháp lệnh tắt; phải tra tài liệu Cisco.*

****Việc 3 — Rà soát tài khoản (đừng bỏ):****

- Vì CVE-2023-20273 có thể ****tạo tài khoản mức 15 mà không cần bất kỳ thông tin đăng nhập nào****, nên phải kiểm tra xem trên thiết bị có tài khoản nào ****mà tổ chức không biết là mình đã tạo**** hay không. Bỏ qua bước này là bỏ qua hậu quả trực tiếp của CVE đó.

****Việc 4 — Rà soát dấu vết xâm nhập:****

- Do có báo cáo về backdoor script, cần kiểm tra dấu vết trên thiết bị.
- *Tôi ****không nhớ**** danh sách tệp/khoá cụ thể mà Cisco hay các nhà nghiên cứu đưa ra, và ****không nêu tên tệp****.*

Nguồn cho các việc 1–2: thông báo Cisco, 16/10/2023. Việc 3–4 là suy luận của tôi từ cơ chế của từng CVE và từ các báo cáo công khai, gắn rõ để bạn tự ghi nguồn nếu dùng.

5. Mối liên hệ giữa hai CVE — chuỗi tấn công

Đây là phần trả lời trực tiếp câu hỏi của bạn, và là chỗ dễ nhầm nhất:

****Chuỗi 1 — không cần thông tin đăng nhập nào:****

`Web UI bật + tôi được từ Internet` → dùng ****CVE-2023-20273**** → `tạo được tài khoản mức 15` → ****toàn quyền thiết bị****. ****Không cần CVE-2023-20198.****

****Chuỗi 2 — có tài khoản ít quyền:****

`tài khoản mức 1 bị lộ (bị đánh cắp, lộ trong cấu hình, phishing...)` → dùng ****CVE-2023-20198**** → `leo thang lên mức 15` → ****toàn quyền thiết bị****. ****Không cần CVE-2023-20273.****

****Bất đối xứng then chốt:**** CVE-2023-20273 ****đủ một mình**** để đạt toàn quyền; CVE-2023-20198 ****không đủ một mình**** nếu kẻ tấn công hoàn toàn không có tài khoản. Đây là lý do câu "chiếm quyền quản trị không cần đăng nhập" ****không sai hoàn toàn**** — nó sai vì ****gán nhầm CVE****. Nói đúng phải là: ****"CVE-2023-20273 cho phép tạo tài khoản quản trị mà không cần đăng nhập."***

Đây là cách tôi hiểu về cách ghép. Phải đối chiếu hai thông báo Cisco trước khi viết vào bài.

****Hai lỗ hổng thuộc hai lớp lỗi khác nhau — và điều này quyết định cách khắc phục:****

| | CVE-2023-20273 | CVE-2023-20198 |

| ---| ---| ---|

| Bản chất lỗi | ****Lỗi vận hành/phơi bày**** — bề mặt tấn công bị mở ra ngoài dự kiến | ****Lỗi phần mềm**** — thiếu kiểm tra phân quyền |

| Cách khắc phục đúng hướng | ****Không phơi bày Web UI**** + vá | ****Vá**** (và rà soát tài khoản) |

Nhận xét phân tích của tôi.

6. Phạm vi — đừng suy rộng

- Tôi **khá chắc** đây là vấn đề của **dòng IOS XE** và **không phải** mọi sản phẩm của Cisco (không phải ASA, không phải NX-OS, không phải thiết bị của hãng khác).
- Điều kiện giới hạn phạm vi: **chỉ** thiết bị có bật Web UI.
- Câu này dùng được để trả lời vấn đáp: **"Không phải 'mọi thiết bị Cisco đều bị ảnh hưởng' — chỉ thiết bị chạy IOS XE có bật Web UI."**

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
---	---
Đây là hai lỗ hổng, không phải một	Sự thật
Cisco công bố cùng ngày 16/10/2023	Khá chắc
CVE-2023-20198 cần đăng nhập; CVE-2023-20273 thì không	Suy luận của tôi — phải đối chiếu
Kẻ tấn công đạt được mức ưu tiên 15	Khá chắc
Mức 15 là toàn quyền trên thiết bị	Sự thật
Mức 15 KHÔNG đồng nghĩa toàn quyền cả mạng	Sự thật — giới hạn cần nêu
CVE-2023-20198 chỉ cần tài khoản mức 1	Suy luận của tôi
CVE-2023-20273 có thể tạo tài khoản mức 15 mà không cần thông tin đăng nhập	Suy luận của tôi
Web UI IOS XE không bật mặc định	Khá chắc
Tên lệnh bật/tắt Web UI	Tôi không nhớ chắc cú pháp
Cả hai CVSS 10,0	Khá chắc — cần xác nhận
Cả hai có trong KEV của CISA	Khá chắc
Có quét tự động nhắm Web UI IOS XE trên Internet	Khá chắc về hiện tượng, không nêu số liệu
Đã có backdoor dạng script Lua cài lên thiết bị ngoài Internet	Khá chắc
Tên tệp/tên backdoor	Tôi không nhớ — không nêu tên
Số thiết bị bị nhiễm, tên tổ chức bị ảnh hưởng	Tôi không nêu
Bản sửa có mẫu hình thêm hậu tố "a"	Khá chắc về mẫu, không ghi danh sách
Danh sách phiên bản sửa cụ thể	Phải lấy từ thông báo Cisco
Nâng cấp có tự gỡ backdoor hay không	Tôi không chốt được
Chỉ áp dụng cho dòng IOS XE	Khá chắc
Lỗi này không phải ASA/NX-OS	Khá chắc
Hai CVE thuộc hai lớp lỗi khác nhau (phơi bày vs thiếu phân quyền)	Nhận xét phân tích của tôi
Bước rà soát tài khoản mức 15 là do tôi suy luận, không phải do Cisco liệt kê	Ghi rõ nguồn

Artifact 18 — Prompt log lượt #21 — Thời gian: 00:23 27/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2024-3094 — backdoor được cài vào chính bộ mã nguồn xz/liblzma, không phải lỗ hổng "dùng sai cách"

Phân loại — điểm phải nói đúng ngay từ đầu: đây **không phải là lỗ hổng phần mềm theo nghĩa thông thường**. Đây là một **sự cố chuỗi cung ứng (supply chain)**: mã độc đã được **đưa vào bản phát hành chính thức** của xz Utils và được **biên dịch vào thư viện liblzma**. Nếu bài bạn ghi nó là "lỗ hổng trong thư viện nén" thì sẽ **đánh giá thấp mức nghiêm trọng** và, tệ hơn, sẽ **mô tả sai cơ chế**.

Nguồn:

- Thông báo đầu tiên trên danh sách bảo mật oss-security, do kỹ sư phát hiện đăng, ngày **29/03/2024** (tôi **không chắc** tên và tài khoản cụ thể của người đăng, chỉ nhớ là một thành viên của Microsoft).
- Thông báo chính thức của dự án xz cùng thời điểm.
- Các thông báo của nhà phân phối: **Debian, Red Hat, SUSE** đều đã có thông báo riêng trong cuối tháng 3 / đầu tháng 4/2024. *Tôi không chốt được số hiệu và ngày cụ thể của từng thông báo — phải tra cổng cảnh báo của từng nhà phân phối.*

Mức độ: tôi **không chắc** CVE-2024-3094 có điểm CVSS chính thức từ NVD hay không, và nếu có thì bao nhiêu. *Lưu ý quan trọng: đây không phải lỗ hổng runtime có điều kiện khai thác thông thường, nên thang CVSS vốn được thiết kế để mô tả kiểu lỗi đó — tôi sẽ không bịa một con số điểm cho mục này.*

1. Mã độc đã được đưa vào quá trình build như thế nào

Đây là phần kỹ thuật quan trọng nhất, và cũng là chỗ dễ kể sai. Tôi mô tả ở mức tôi chắc, và nói rõ chỗ nào tôi không chắc.

Bối cảnh cần biết trước:

- `xz` là công cụ nén dữ liệu, và `liblzma` là thư viện của nó. Rất nhiều thứ trong hệ thống Unix/Linux dùng liblzma — nên khi nó bị nhiễm, phạm vi **lan rất xa**.
- Vì sao việc "mã độc nằm trong bản phát hành" là việc **cực kỳ nghiêm trọng**: ai tải bản phát hành chính thức, ai tin tưởng hãng, ai kiểm tra "chữ ký" — tất cả đều không cứu được bạn. Mã độc **đã nằm sẵn trong thứ bạn tải về**, chứ không phải do kẻ tấn công đưa vào sau.

Cơ chế (theo trí nhớ của tôi):

1. Kẻ tấn công đã **đưa mã vào kho mã nguồn của dự án xz** thông qua một loạt thay đổi bình thường về mặt hình thức, và bản phát hành được tạo ra từ kho đó nên **mang theo mã**.
2. Bản thân mã **không nằm dưới dạng mã độc dễ đọc**. Nó được **giấu trong các tệp trông như dữ liệu kiểm thử/đo hiệu năng** — kiểu dữ liệu nhị phân mà người ta quen bỏ qua. **Tôi mô tả theo trí nhớ; tôi không nhớ tên tệp và cũng không nhớ chính xác thuật toán/định dạng mã hoá dùng để che.**
3. Trong **quá trình biên dịch**, các tệp đó **được giải mã và chèn vào mã nguồn liblzma**. Tức là **người xem mã nguồn trước khi biên dịch cũng rất dễ bỏ sót** — vì nó chỉ xuất hiện ở bước giải mã trong lúc build.
4. Kết quả: **liblzma được cài đặt từ bản nhím sẽ chứa mã độc trong mã nhị phân của nó**, và mọi chương trình liên kết với liblzma — trong đó có **OpenSSH** — sẽ mang theo nó.
5. Mục tiêu của mã độc, theo trí nhớ: **thay đổi cách kiểm tra khoá công khai** mà OpenSSH dùng, để **một đoạn khoá của kẻ tấn công được coi là hợp lệ** → tức là **đăng nhập được vào máy đó bằng quyền root**. **Tôi không chốt được tên hàm cụ thể hay kiểu khoá cụ thể; tôi không nêu chi tiết kỹ thuật mình không chắc.**

Cách phát hiện — chi tiết đáng ghi vào bài vì nó cho thấy tại sao sự cố này có thể tồn tại âm thầm:

- Tôi nhớ chi tiết quan trọng này: sự cố lộ ra **không phải vì ai đó tìm mã độc**, mà vì **đăng nhập SSH bị chậm bất thường** (vài trăm mili giây). Người phát hiện lần theo hiệu năng, truy về thay đổi trong quy trình build của xz, và từ đó tìm ra mã.
- **Bài học:** một sự cố chuỗi cung ứng có thể tồn tại mà không bị phát hiện, cho tới khi ai đó để ý đến **triệu chứng thứ yếu** (chậm, lỗi, treo) chứ không phải triệu chứng chính.

2. Phiên bản và cấu hình nào có nguy cơ

Phiên bản:

- Theo trí nhớ của tôi, các bản phát hành **có mã độc là 5.6.0 và 5.6.1**; bản **5.6.2** phát hành ngay sau sự cố là bản đã loại bỏ mã. **Tôi khá chắc** về cặp 5.6.0/5.6.1 và 5.6.2; tôi **không chắc** ngày phát hành cụ thể của từng bản.
- **Quan trọng:** còn có các **bản xây dựng từ kho mã nguồn (git) trong một khoảng thời gian** cũng bị ảnh hưởng, không chỉ hai bản phát hành. **Mức chắc chắn: trung bình** — tôi nhớ có nhắc tới việc này nhưng không nhớ rõ phạm vi.

Cấu hình / điều kiện kích hoạt:

- Đây là phần tôi **rất dễ bịa**, nên tôi nói thẳng: mã chỉ trở thành backdoor **hoạt động** dưới một tập điều kiện build và runtime cụ thể (liên quan tới trình biên dịch, thư viện nền và cách khởi động dịch vụ). **Tôi không liệt kê** các điều kiện đó, vì nhớ sai còn tệ hơn không nói.
- **Điều kiện quan trọng nhất, mà tôi khá chắc:** mã chỉ nằm trong thư viện đã cài, và chỉ có tác dụng khi chương trình **liên kết với liblzma bị nhím** — tiêu biểu là **dịch vụ SSH**. Nếu hệ

thống không dùng OpenSSH, hoặc OpenSSH không dùng liblzma của xz, thì **phạm vi hẹp hơn nhiều**.

- Do đó, khi hỏi **"cài xz 5.6.1 lên máy có bị ảnh hưởng không?"** thì **câu trả lời phải là "không nhất thiết"** — còn khi hỏi **"máy có bản build liblzma lấy từ 5.6.0/5.6.1 không?"** thì câu trả lời là **"phải kiểm tra"**. Tôi thấy nhiều bài viết trộn hai câu hỏi này.

3. Hậu quả có thể xảy ra so với điều đã xác nhận

Đây chính là chỗ bài bạn **nên tách rõ**, vì đây là nơi để nhảy từ "mã độc có thể làm gì" sang "đã xảy ra".

```
| | Có thể xảy ra (theo cơ chế) | Đã được xác nhận |  
|---|---|---|  
| Đăng nhập vào máy bằng khoá của kẻ tấn công | Có — đây là mục tiêu thiết kế của mã |  
Không có báo cáo công khai nào tôi biết |  
| Từ quyền root trên máy đó điều khiển hệ thống | Có | Không có báo cáo công khai nào tôi biết |  
| Số máy bị khai thác thành công | — | Tôi không có dữ liệu và không nêu số liệu |  
| Sự tồn tại của backdoor trong bản phát hành | Có — đã xác nhận | Sự thật đã được công khai rõ ràng |  
| Việc backdoor thực sự kích hoạt được trên hệ thống đang dùng | — | Không có bằng chứng công khai nào |
```

Nói thẳng điều quan trọng nhất của mục này: backdoor tồn tại **là đã xác nhận**; việc nó **được dùng để xâm nhập thật** thì **chưa có bằng chứng công khai**. Nếu bài bạn viết "hacker đã dùng backdoor này để xâm nhập hàng nghìn máy chủ" thì đó là **khẳng định không có căn cứ** — và đây là loại nói quá mà tôi đã gặp nhiều lần trong các bài tóm tắt sự cố này.

4. Cách xử lý

Với hệ thống nghi ngờ đã bị nhiễm:

- Không được chỉ nâng cấp xz rồi cho là xong.** Đây là điểm then chốt: mã độc nằm **trong các tệp nhị phân đã cài**, nên nâng cấp thư viện không tự xóa mã độc khỏi những gì đã chạy và những gì đã liên kết với nó. *Đây là suy luận của tôi từ bản chất "mã nằm trong tệp đã cài", và tôi nghĩ đây là đúng — nhưng hãy đối chiếu hướng dẫn của nhà phân phối trước.*
- Cài lại/hiệu lực lại các gói từ nguồn sạch** của nhà phân phối — vì đó là cách chắc chắn loại được tệp nhị phân nhiễm.
- Kiểm tra dấu vết xâm nhập**, vì nếu backdoor đã kịp hoạt động thì việc thay thư viện không thay thế được việc điều tra.
- Rà soát cơ chế SSH của hệ thống** để chắc chắn không còn cửa vào nào khác.

Với hệ thống không bị nhiễm (phần lớn): cập nhật bản xz sạch, và **không cần** làm gì thêm.

*Về việc "cài đặt lại toàn bộ hệ thống" có cần không: tôi ****không dám khẳng định**** là cần, vì điều đó phụ thuộc vào việc mã có kịp kích hoạt hay không.*

5. "Có phải mọi bản Linux đều bị ảnh hưởng không?" — Câu trả lời là KHÔNG

Đây là câu bạn hỏi rất đúng, và cũng là câu hay bị nói quá nhất. Tôi trả lời thẳng:

> ****Không. Đây không phải kiểu sự cố "mọi hệ thống Linux đều bị ảnh hưởng".****

****Các lý do — mỗi lý do đủ để loại trừ phạm vi rộng:****

| Lý do | Diễn giải |

| ---| ---|

| Mã chỉ nằm trong ****hai bản phát hành**** cụ thể | Ai dùng bản khác, hoặc dùng bản của nhà phân phối đã vá, thì không liên quan |

| Nhà phân phối ****đóng gói riêng**** | Gói của họ được xây dựng trong môi trường của họ, không phải mã nhiễm |

| Điều kiện build/runtime cụ thể | Mã có thể ****không kích hoạt**** dù đã được cài |

| Chỉ ảnh hưởng chương trình ****liên kết với liblzma bị nhiễm**** | Hệ thống không dùng OpenSSH/liblzma thì phạm vi hẹp hơn nhiều |

****Điều tôi nhớ và khá chắc:**** sự cố này ****không lọt vào một bản phát hành ổn định phổ biến nào**** của các nhà phân phối lớn. Đây là tin tốt và cũng là điểm nên nói trong bài. *Tuy nhiên tôi ****không chắc**** chi tiết với từng nhà phân phối, nên ****không nêu tên**** và ****không nêu số liệu****.*

****Cách trả lời vấn đáp cho câu hỏi này — dùng công thức này:****

> ****"Không phải mọi hệ thống Linux. Mã độc chỉ nằm trong hai bản phát hành 5.6.0 và 5.6.1 của xz, còn các nhà phân phối đóng gói riêng và đã loại bỏ nó. Vì vậy phạm vi bị ảnh hưởng hẹp hơn rất nhiều so với cảm giác ban đầu."****

Bảng tách sự thật và suy luận

| Nội dung | Trạng thái |

| ---| ---|

| Đây là sự cố chuỗi cung ứng, không phải lỗ hổng dùng sai cách | ****Sự thật — điểm phải nói đúng**** |

| Mã độc nằm trong bản phát hành upstream, được biên dịch vào liblzma | ****Sự thật**** |

| Công cụ phát hiện là người ngoài, ngày 29/03/2024 | ****Khá chắc về ngày; không nêu tên người**** |

| Mã được che giấu trong tệp trông như dữ liệu kiểm thử và giải mã lúc build | ****Khá chắc về nguyên tắc, không chắc chi tiết**** |

Tên tệp chứa mã che giấu	****Tôi không nhớ — không nêu****
Mục tiêu là thay đổi kiểm tra khoá để đăng nhập quyền root	****Khá chắc về mục tiêu, không chắc chi tiết hàm/khoá****
Bản có mã là 5.6.0 và 5.6.1; 5.6.2 đã loại bỏ	****Khá chắc****
Ngày phát hành từng bản	****Tôi không nhớ chắc****
Còn có bản build từ git trong một khoảng thời gian bị ảnh hưởng	****Trí nhớ mức trung bình****
Điều kiện build/runtime kích hoạt backdoor	****Tôi không liệt kê — không nhớ****
Chỉ ảnh hưởng chương trình liên kết liblzma bị nhiễm, tiêu biểu OpenSSH	****Khá chắc****
OpenSSH có phải mục tiêu cụ thể	****Khá chắc****
Backdoor tồn tại là đã xác nhận	****Sự thật****
Có bằng chứng công khai nào về việc backdoor được dùng để xâm nhập	****Không có — không khẳng định****
Số máy bị khai thác / tên nạn nhân	****Tôi không nêu****
Sự cố không lọt vào bản phát hành ổn định phổ biến của nhà phân phối lớn	****Khá chắc****
Chi tiết với từng nhà phân phối	****Tôi không chắc — không nêu tên****
Nâng cấp xz không tự loại mã khỏi tệp nhị phân đã cài	****Suy luận của tôi, hợp lý****
Có cần cài đặt lại toàn bộ hệ thống không	****Tôi không dám khẳng định****
Một sự cố chuỗi cung ứng có thể tồn tại mà chỉ lộ ra qua triệu chứng phụ	****Nhận xét phân tích của tôi****
CVSS của CVE-2024-3094	****Tôi không chắc — không nêu con số****

Artifact 19 — Prompt log lượt #22 — Thời gian: 00:27 27/09/2026 | Công cụ: OpenCode - Big Pickle

Sự cố CrowdStrike 19/07/2024 — BSOD hàng loạt do nội dung cập nhật của hãng, KHÔNG phải tấn công mạng

****Phân loại — điểm phải nói trước tiên vì nó quyết định cả mục:**** đây ****không phải lỗi hồng****, không phải mã độc, không phải tấn công. Đây là ****sự cố do bản cập nhật của chính nhà cung cấp gây ra****, trong đó ****mã của nhà cung cấp đã bị hệ điều hành dùng sai cách**** một cách không chủ ý. Nếu bài bạn xếp nó cùng nhóm với các lỗi hồng khác mà không nói rõ sự khác biệt, giảng viên sẽ hỏi ngay.

****Nguồn CrowdStrike:****

- Thông báo "Preliminary Post Incident Review" (rà soát sơ bộ sau sự cố), phát hành ****22/07/2024****.
- Bài phân tích kỹ thuật chi tiết (thường được gọi là RCA/điều tra gốc), phát hành ****muộn hơn trong tháng 8/2024****.
- Trang hỗ trợ/hướng dẫn phục hồi của CrowdStrike.

*Tôi ****khá chắc**** về ngày 19/07/2024, về việc có bản rà soát sơ bộ ngày 22/07, và về việc có một bài phân tích kỹ thuật chi tiết hơn trong tháng 8. Tôi ****không chắc**** ngày chính xác của bài phân tích kỹ thuật, và ****không chốt được**** URL chính xác — phải lấy từ trang chủ CrowdStrike.*

1. Lỗi kỹ thuật theo báo cáo RCA

Đây là phần khó nhất, vì báo cáo kỹ thuật nằm ở tầng thấp. Tôi trình bày mức tôi chắc:

****Kiến trúc cần hiểu trước (để "nội dung cập nhật" có nghĩa là gì):****

- CrowdStrike Falcon không đẩy "mã mới" xuống máy khách theo kiểu cập nhật phần mềm thông thường. Thành phần cảm biến chạy sẵn trên máy, và nó nhận ****các tệp cấu hình/nội dung ("channel file")**** từ hệ thống của hãng để tự cấu hình.
- Vì vậy một ****sai sót trong nội dung phát hành**** có thể làm hỏng hàng triệu máy ****mà không cần cài lại phần mềm, không cần khởi động lại, không cần mạng**** — vì máy chủ của hãng chỉ cần phát đi nội dung đó là xong.

****Chuỗi lỗi theo RCA (theo trí nhớ của tôi):****

1. Một ****tệp nội dung**** được phát hành tới các cảm biến Windows — tôi nhớ nó được gọi là ****"Channel File 291"**, và tệp thay thế để gỡ là ****"Channel File 290"**. Tôi ****khá chắc**** về cập số 290/291, nhưng ****không chắc**** đó là cách CrowdStrike gọi chính thức trong báo cáo.*****
2. Tệp nội dung đó chứa một ****cấu hình mà cảm biến hiểu là cấu hình cho một thành phần lọc ở tầng nhân của Windows**** (loại thành phần mà Windows cho phép chương trình đăng ký để theo

dôi thao tác I/O). *Tôi **khá chắc** về bản chất "cấu hình bộ lọc tầng nhân", nhưng **không chốt được** tên thành phần và cấu trúc dữ liệu.*

3. Khi cảm biến đưa cấu hình đó xuống, **Windows nhận cấu hình không hợp lệ theo nghĩa nó không được hỗ trợ** — và kết quả là **tiến trình ở tầng nhân bị dừng**, biểu hiện ra bên ngoài chính là **BSOD** (màn hình xanh vì máy ở tầng nhân không thể tiếp tục chạy và buộc phải khởi động lại).

4. **Điểm cốt lõi của RCA mà tôi nhớ khá rõ và coi là quan trọng nhất:** phần hệ điều hành bị lỗi nằm ở **một đường xử lý trong thành phần Windows**, và **CrowdStrike nói thẳng rằng đây là lỗi trong nội dung họ phát hành, không phải hành vi tấn công và không phải lỗi hỏng bảo mật.** Đồng thời, khi xảy ra sự cố này, **Microsoft chưa được thông báo về đường xử lý đó** — và đó chính là lý do sau này Microsoft phải đưa ra hướng dẫn riêng (tôi nói ở mục 4).

*Mức chắc chắn: khá chắc về ý "lỗi nội dung của hãng + đường xử lý ở thành phần hệ điều hành"; tôi **không nêu** mã lỗi cụ thể hay tên đường xử lý vì không chắc.*

Vì sao lỗi này lại nghiêm trọng đến mức hệ thống sập, mặc dù "chỉ là" nội dung cấu hình:

- Vì cấu hình bị đẩy xuống **tầng nhân**, nên một tham số sai ở đó đủ để làm **toàn hệ thống dừng**. Tầng nhân không có cơ chế "bỏ qua lỗi nhỏ" — nó phải dừng để tránh hỏng dữ liệu.

- Đây là bài học về **ranh giới tin cậy**: mã của nhà cung cấp chạy ở **chế độ đặc quyền cao nhất** và **được tin cậy tuyệt đối** — nên một lỗi cấu hình ở đó có sức phá huỷ lớn hơn nhiều so với lỗi tương tự ở tầng người dùng.

2. Máy nào bị ảnh hưởng

Máy nào BỊ ảnh hưởng (theo trí nhớ của tôi):

- **Máy tính chạy Windows** có cài cảm biến CrowdStrike Falcon.

- Tôi **khá chắc** rằng **máy chạy Linux và macOS không bị ảnh hưởng** trong sự cố này, vì sự cố đến từ một cấu hình phụ thuộc vào thành phần tầng nhân chỉ có ở Windows. *Đây là lý do tôi không nói rộng thành "mọi thiết bị có CrowdStrike".*

- Tôi **không chắc** chi tiết về các phiên bản Windows cụ thể bị ảnh hưởng, và **không nêu phiên bản nào** khi không chắc.

- Tôi **không nêu** máy chủ Windows / Windows Server có bị không — vì không chắc.

Điểm quan trọng về phạm vi: máy **không cần có mạng** cũng bị. Vì máy đã nhận nội dung độc hại từ trước khi dừng, nên **ngắt mạng không cứu được máy đang sập**.

3. Hậu quả đã ghi nhận

| Tầng | Hậu quả | Mức xác nhận |

| --- | --- | --- |

| Máy dừng không khởi động được, hiển thị BSOD | Máy mất khả năng sử dụng cho tới khi xử lý |

Đã xác nhận |

| Nhiều tổ chức bị gián đoạn dịch vụ | Sân bay, bệnh viện, ngân hàng... | ****Đã được báo chí mô tả rộng rãi**** |

| Quy mô máy bị ảnh hưởng | Con số ****khoảng 8,5 triệu**** máy Windows thường được quy cho ****Microsoft**** | *Tôi nhớ con số này nhưng ****không xác nhận**** — phải kiểm tra bài phát biểu của Microsoft. ****Đừng ghi vào bài nếu chưa kiểm chứng****.*

| Thiệt hại tài chính | Có ước tính | ****Tôi không nêu con số và không nêu tên công ty**** |

| Có vụ tấn công nào không | ****Không**** | ****Đã xác nhận**** |

****Câu phải nói rõ về hậu quả nặng nhất:**** mất khả năng sử dụng máy trong một sự cố ***không có kẻ tấn công*** cho thấy ****rủi ro vận hành của phần mềm thương mại có thể lớn hơn rủi ro an ninh trong nhiều kịch bản****. Đây là luận điểm phân tích tốt cho bài.

4. Cách phục hồi

****Hướng dẫn của CrowdStrike mà tôi nhớ (đây là thông tin thực dụng, hãy đối chiếu lại hướng dẫn gốc):****

- ****Khởi động vào chế độ an toàn (Safe Mode).****

- ****Xoá tệp**** có tên theo mẫu `CS\_SYSTEM\_...sys` nằm trong thư mục trình điều khiển của CrowdStrike trên ổ hệ thống. *Tôi khá chắc về mẫu tên tệp và vị trí thư mục, vì đây là thông tin được hướng dẫn khắc phục phát hành rộng rãi; nhưng ****phải theo đúng đường dẫn và mẫu tệp trong hướng dẫn gốc****.*

- ****Khởi động lại bình thường.**** Máy sẽ chạy được, và CrowdStrike đã phát hành lại nội dung đúng.

- ****Cảnh báo quan trọng:**** tôi nhớ CrowdStrike đã ****khuyến cáo không dùng "Safe Mode có mạng"**** cho tình huống này, vì làm thế có thể kéo lại nội dung lỗi. *Mức chắc chắn: khá chắc — nhưng đây đúng là loại chi tiết mà tôi sẽ không dám khẳng định tuyệt đối nếu không đọc lại hướng dẫn gốc.*

- Ngoài ra có nhánh hướng dẫn thứ hai cho máy không khởi động được bình thường nữa. *Tôi không mô tả chi tiết nhánh này.*

****Phía Microsoft (quan trọng về mặt thiết kế hệ thống, và đây là điểm hay bị bỏ qua):****

- Sau sự cố, Microsoft đã phát hành hướng dẫn cho phép/chế tạo cơ chế ****cho phép tải trình điều khiển đã ký nhưng có lỗi hỏng đã biết**** — tức là mở rộng chế độ chặn của nền tảng chống mã độc. *Tôi mô tả theo trí nhớ và ****không nhớ chính xác tên cơ chế hay số KB****. Đây là chi tiết cần tra cứu nếu bạn dùng.*

****Về thời gian phục hồi:**** tôi ****không nêu con số**** vì không chắc.

5. Thay đổi quy trình phát hành

- CrowdStrike đã ****đưa nội dung lỗi về trạng thái vô hiệu**** (lùi về bản 290 trong tên gọi của họ).

- Theo RCA, CrowdStrike nói họ sẽ ****tăng cường kiểm thử và phát hành theo lộ trình từng bậc**** thay vì đẩy một lần cho toàn bộ. *Tôi ****không chốt được**** các hạng mục cụ thể trong cam kết của họ —

chỉ nhớ nội dung chung về kiểm thử và phát hành từng bậc. Nếu bài cần liệt kê, phải lấy nguyên văn từ RCA.*

- Phía Microsoft, sau sự cố, chính sách tải trình điều khiển được **siết lại** — tức phía hệ điều hành cũng thay đổi, không chỉ phía nhà cung cấp. *Tôi nói ở mức khái niệm, không nêu chi tiết cơ chế vì ở mục trên tôi đã nói không nhớ tên.*

6. Phân biệt "lỗi cập nhật" với "tấn công mạng"

Đây là phần bạn yêu cầu, và là điểm mà tôi nghĩ bài bạn nên làm nổi bật nhất trong mục này. Bảng dưới là công cụ trả lời vấn đáp:

Câu hỏi kiểm tra	Nếu là tấn công mạng	Sự cố này
--- --- ---		
Ai làm?	Kẻ tấn công từ bên ngoài	Chính nhà cung cấp phát hành nội dung lỗi
Cần khai thác lỗ hổng không?	Có	Không có lỗ hổng nào
Có mã độc không?	Thường có	Không có mã độc
Dấu hiệu nhận biết	Hoạt động bất thường từ mạng bên ngoài	Thời điểm trùng khớp chính xác với một lần phát hành nội dung
Thứ bị hỏng là gì?	Thường là dữ liệu, tài khoản, hệ thống cụ thể	Một thành phần hệ thống của chính máy người dùng
Cách khắc phục điển hình	Vá lỗ hổng, đổi mật khẩu, xoá dấu vết	Xoá một tệp cấu hình lỗi
Ai chịu trách nhiệm?	Kẻ tấn công, và tổ chức bị lỗ hổng	Nhà cung cấp phần mềm

Vì sao dù chắc chắn không phải tấn công, nhiều người vẫn nghĩ là tấn công:

- Vì dấu hiệu bề mặt rất giống sự cố an ninh: hàng loạt máy mất khả năng sử dụng, hệ thống dừng hàng loạt, thông tin truyền thông vào cuộc.
- Và vì khi sự cố xảy ra, **chưa ai biết nguyên nhân** — nên bản năng mặc định của người đọc là "bị đánh".
- **Bài học:** *cảm giác "giống tấn công" không phải bằng chứng.* Muốn khẳng định là tấn công hay không, phải trả lời được ba câu: có lỗ hổng không, có mã độc không, và có hoạt động từ bên ngoài không.

Một điểm tôi nói thẳng vì nó dễ gây hiểu nhầm: trình điều khiển của CrowdStrike là **trình điều khiển hợp lệ, đã ký, chạy ở tầng nhân** — nên nó có quyền rất lớn. Nhưng **quyền lớn không đồng nghĩa hành vi độc hại**. Tính hợp pháp của trình điều khiển và tính chính đáng của hành vi là **hai câu hỏi khác nhau**, và sự cố này là ví dụ rất sạch cho việc tách hai câu hỏi đó.

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
--- ---	

Không phải tấn công mạng, không có mã độc	****Sự thật — điểm trung tâm****
Không phải lỗ hổng bảo mật	****Sự thật****
Gốc rễ là nội dung cấu hình do hãng phát hành	****Khá chắc****
Ngày 19/07/2024	****Sự thật****
Có bản rà soát sơ bộ 22/07/2024	****Khá chắc****
Ngày của bài phân tích kỹ thuật chi tiết	****Tôi không chắc — chỉ nói "trong tháng 8"*****
URL chính xác các thông báo	****Tôi không chốt được****
Cặp "Channel File 290/291"	****Khá chắc về số; không chắc về cách gọi chính thức****
Nội dung lỗi liên quan tới cấu hình bộ lọc ở tầng nhân	****Khá chắc về bản chất, không chắc tên thành phần****
Hệ quả là tiến trình tầng nhân dừng, biểu hiện là BSOD	****Khá chắc****
CrowdStrike nói đây là lỗi nội dung, không phải tấn công	****Sự thật****
Microsoft chưa được thông báo về đường xử lý bị lỗi khi sự cố xảy ra	****Trí nhớ khá chắc****
Mã lỗi cụ thể / tên đường xử lý	****Tôi không nêu****
Chỉ máy chạy Windows bị ảnh hưởng	****Khá chắc****
Linux và macOS không bị ảnh hưởng	****Khá chắc****
Danh sách phiên bản Windows bị ảnh hưởng	****Tôi không nêu****
Máy chủ Windows / Windows Server	****Tôi không nêu — không chắc****
Quy mô khoảng 8,5 triệu máy	****Trí nhớ, không xác nhận — chỉ dẫn về Microsoft****
Thiệt hại tài chính, tên công ty bị ảnh hưởng	****Tôi không nêu****
Khắc phục: Safe Mode + xoá tệp mẫu CS_SYSTEM_...sys	****Khá chắc; phải theo hướng dẫn gốc****
Cảnh báo không dùng Safe Mode có mạng	****Khá chắc, không khẳng định tuyệt đối****
Máy không cần mạng vẫn bị	****Suy luận hợp lý của tôi****
Nhánh hướng dẫn thứ hai cho máy không khởi động được	****Tôi không mô tả****
Microsoft cho phép tải trình điều khiển đã ký có lỗ hổng đã biết	****Trí nhớ mức trung bình; không nêu tên cơ chế/số KB****
Thời gian phục hồi trung bình	****Tôi không nêu****
Cam kết thay đổi quy trình của CrowdStrike	****Chỉ nói ở mức khái niệm; không chốt chi tiết****
Rủi ro vận hành có thể lớn hơn rủi ro an ninh	****Luận điểm phân tích của tôi****
"Cảm giác giống tấn công" không phải bằng chứng	****Nhận xét phân tích của tôi****
Quyền lớn không đồng nghĩa hành vi độc hại	****Nhận xét phân tích của tôi****

Artifact 20 — Prompt log lượt #23 — Thời gian: 00:33 27/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2025-29927 — Next.js: bỏ qua Middleware bằng một HTTP header, vượt kiểm tra phân quyền

****Phân loại:**** lỗ hổng xác thực/phân quyền thật, thuộc loại ****bỏ qua lớp kiểm tra (security control bypass)****, do chính dự án Next.js công bố và vá.

****Nguồn dự án:**** thông báo bảo mật của Next.js/Vercel, công bố ****18/03/2025****. *Tôi ****khá chắc**** về ngày và về việc đây là thông báo chính thức của dự án. Tôi ****không chốt được**** URL chính xác — phải lấy từ mục thông báo bảo mật của Next.js.*

****Mức độ:**** theo trí nhớ, điểm ****CVSS 9,1****. *Mức chắc chắn: khá chắc, nhưng ****phải mở thông báo để xác nhận****.*

1. Header nào và cơ chế bỏ qua

****Header: `x-middleware-subrequest`**** (tên header: chữ thường, có dấu gạch nối).

****Cơ chế — đây là phần cần hiểu đúng, vì nếu chỉ nói "gửi header là bypass" thì học sinh sẽ hiểu sai:****

- Next.js có một tính năng tên là ****Middleware****: một đoạn mã chạy ****trước**** khi request tới route, và được dùng rất phổ biến cho các việc như: kiểm tra người dùng đã đăng nhập chưa, chặn truy cập theo vai trò, giới hạn tần suất, chặn theo vị trí địa lý, hoặc chuyển hướng.
- Vì Middleware có thể tự gọi lại các request nội bộ, Next.js dùng ****một header nội bộ**** để đánh dấu "request này là request nội bộ, đã đi qua Middleware rồi, không cần chạy lại". Header đó chính là ****x-middleware-subrequest`**.
- ****Lỗ hổng nằm ở chỗ:**** Next.js ****tin vào header do phía người gửi yêu cầu tự tạo ra****. Kẻ tấn công gửi header này từ ngoài, với giá trị được chế tác, và Next.js hiểu nhầm rằng đây là request nội bộ hợp lệ → ****bỏ qua việc chạy Middleware****.
- ****Về chi tiết cách kiểm tra giá trị header bị lỗi:** tôi ****không chốt được**** cấu trúc chính xác của giá trị và cách chuẩn hoá nó, nên ****không mô tả thuật toán****. Tôi chỉ mô tả nguyên lý: giá trị header do bên ngoài kiểm soát và đã được dùng để quyết định có bỏ qua Middleware hay không.*

****Vì sao lỗi này nguy hiểm hơn vẻ ngoài của nó:**** vì trong rất nhiều ứng dụng, ****Middleware là lớp kiểm tra duy nhất**** đứng trước route. Bỏ qua nó = bỏ qua cánh cửa.

2. Ứng dụng cần thế nào mới có nguy cơ vượt quyền

Đây là câu hỏi phân loại nguy cơ, và câu trả lời phải nêu ****bốn điều kiện cùng lúc****:

1. **Ứng dụng chạy Next.js tự quản lý (self-hosted)** — tức chạy Node.js server của bạn, không phải trên nền tảng đám mây của chính đội ngũ phát triển. *Tôi **khá chắc** rằng các ứng dụng chạy trên nền tảng đám mây của Vercel đã được bảo vệ ở lớp biên, nên không bị ảnh hưởng. Đây là điểm phải kiểm tra lại trong thông báo.*
2. **Ứng dụng có dùng Middleware** — nếu không dùng thì không có gì để bỏ qua.
3. **Ứng dụng đặt quyết định phân quyền QUYẾT ĐỊNH trong Middleware** — đây là điều kiện quan trọng nhất. Nếu Middleware chỉ làm chuyện phụ (đổi tiêu đề, ghi log, chuyển hướng) mà việc kiểm tra quyền vẫn nằm ở nơi khác, thì việc bỏ qua Middleware **không tự động đồng nghĩa vượt quyền**.
4. **Có route mà Middleware đáng lẽ phải chặn** — nếu sau khi bỏ qua Middleware thì request tới được một tài nguyên vốn được bảo vệ, thì mới là vượt quyền.

Câu trả lời trung thực cho câu hỏi này — và đây là chỗ dễ nói quá nhất:

> Vượt quyền xảy ra **không phải vì Next.js có lỗi hổng**, mà vì **ứng dụng đặt một quyết định bảo mật vào đúng chỗ mà lỗi hổng đó tấn công**, và **không có lớp kiểm tra thứ hai** ở phía sau.

Điểm thiết kế bảo mật rút ra — tôi nghĩ đây là bài học đáng ghi nhất của mục này:

- Kiểm tra quyền ở **một chỗ duy nhất** (middleware) tạo ra "điểm thắt cổ chai". Một header sai lệch là toàn bộ hệ thống bảo vệ biến mất.
- Nguyên tắc đúng là **phòng thủ nhiều lớp**: middleware kiểm tra nhanh để tiết kiệm tài nguyên, nhưng **route handler hoặc truy vấn dữ liệu phải tự kiểm tra lại**, không được tin tuyệt đối vào middleware.
- Nhận xét này là **phân tích của tôi**, không phải khuyến nghị trong thông báo của dự án.

3. Hậu quả

Tầng	Hậu quả	Mức xác nhận
Middleware không chạy, request tới thẳng route	Bỏ qua lớp kiểm tra	**Đã xác nhận — bản chất lỗi hổng**
Truy cập trang/API vốn được bảo vệ bởi Middleware mà không cần đăng nhập hoặc không đúng vai trò	**Vượt quyền**	**Tùy ứng dụng** — không phải ứng dụng nào cũng vậy
Rò rỉ dữ liệu cụ thể	**Phụ thuộc dữ liệu mà route trả về**	*Tôi **không** mô tả vì không biết ứng dụng của bạn*
Đọc được tệp trên máy chủ	*Tôi **không** khẳng định** khả năng này*	*Tôi **không** xác nhận***
Bị khai thác trên thực tế	Tôi **không** nêu**	*Tôi không có dữ liệu chắc chắn*

Ba điều tôi muốn bạn giữ đúng khi viết:

1. **Lỗi hổng này không tự động "rò rỉ dữ liệu".** Nó chỉ **mở ra cánh cửa**. Dữ liệu có bị lộ hay không phụ thuộc ứng dụng có gì sau cánh cửa đó và có kiểm tra thứ hai không. Nhiều bài tóm tắt ghi "CVE này làm lộ dữ liệu người dùng" — đó là **nói quá**.
2. **Không nói rộng "mọi ứng dụng Next.js đều bị ảnh hưởng"** — còn ba điều kiện nữa đã nêu ở mục 2.
3. **Tôi không đưa con số nạn nhân.** Tôi có cảm giác đã có lần khai thác trên thực tế, nhưng **không nhớ rõ mốc thời gian, quy mô hay chủ thể**, nên tôi để trống thay vì đoán.

4. Các phiên bản vá

- Theo trí nhớ, dự án đã phát hành bản vá cho **nhiều nhánh phiên bản cùng lúc** (cả 14.2.x, 15.x, và các bản mới hơn), vì đây là kiểu lỗi ở lớp framework nên phải vá mọi nhánh đang được hỗ trợ.
- Tôi **không liệt kê số phiên bản cụ thể từ trí nhớ** — đây là loại danh sách mà nhớ sai một số là nguy hiểm, vì người đọc sẽ dùng số đó để quyết định có cần nâng cấp hay không. **Phải lấy nguyên văn từ thông báo.**
- Tôi cũng **không chắc** chi tiết về việc có bản vá tiếp theo nữa do bản vá đầu chưa đủ, hay có phát sinh thêm vấn đề nào liên quan.

Về mặt vận hành, câu duy nhất an toàn khi vấn đáp: **"Em lấy danh sách phiên bản sửa từ thông báo bảo mật của dự án, không ghi nhớ từ trí nhớ."** Đây là câu trả lời được điểm vì nó cho thấy em biết **đâu mới là nguồn đáng tin**.

5. "Có phải mọi ứng dụng Next.js đều lộ dữ liệu không?" — KHÔNG

Đây là câu bạn hỏi rất đúng, vì đây là loại sự cố **đễ bị nói quá nhất**:

> **Không.** Và lý do rất cụ thể, không phải lý do chung chung kiểu "không phải ai cũng bị".

Lý do	Cụ thể nghĩa là gì
Chỉ ứng dụng tự host	Ứng dụng trên nền tảng đám mây của hãng đã được bảo vệ ở lớp trước
Chỉ ứng dụng dùng Middleware	Không dùng Middleware thì không có gì để bỏ qua
Chỉ khi Middleware là lớp quyết định duy nhất	Nếu route tự kiểm tra quyền, bỏ qua middleware vô hại
Lỗi hổng không tự lấy dữ liệu	Nó chỉ bỏ qua lớp kiểm tra; dữ liệu bị lộ hay không phụ thuộc route có trả gì

Công thức trả lời vấn đáp (dùng nguyên văn khung này):

> **"Không phải mọi ứng dụng Next.js. Chỉ ứng dụng tự host, có dùng Middleware để quyết định phân quyền, và không có lớp kiểm tra quyền thứ hai mới bị ảnh hưởng. Bản thân lỗi hổng chỉ bỏ qua lớp kiểm tra chứ không tự thu thập dữ liệu, nên mức lộ dữ liệu phụ thuộc từng ứng dụng."**

****Câu hỏi vấn đáp khó nhất có thể hỏi em ở mục này**** — và câu trả lời đúng là: ****Nếu ứng dụng của em kiểm tra quyền ở cả middleware lẫn nơi xử lý dữ liệu, thì lỗ hổng này chỉ làm mất một lớp kiểm tra chứ không đủ để lộ dữ liệu.****

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
Header là `x-middleware-subrequest`	**Khá chắc**
Nguyên lý: framework tin header từ bên ngoài để quyết định bỏ qua Middleware	**Khá chắc về nguyên lý, không chốt thuật toán**
Cấu trúc giá trị header và cách kiểm tra bị lỗi	**Tôi không mô tả**
Next.js Middleware dùng để kiểm tra đăng nhập/phân quyền	**Sự thật**
Ngày công bố 18/03/2025	**Khá chắc**
URL thông báo	**Tôi không chốt được**
CVSS 9,1	**Khá chắc — cần xác nhận**
Chỉ ứng dụng self-hosted bị ảnh hưởng	**Khá chắc — cần đối chiếu thông báo**
Ứng dụng trên nền tảng đám mây của hãng không bị ảnh hưởng	**Khá chắc**
Cần có Middleware và Middleware là lớp quyết định duy nhất	**Suy luận của tôi — hợp lý**
Lỗ hổng không tự thu thập dữ liệu	**Khá chắc**
Mức lộ dữ liệu phụ thuộc từng ứng dụng	**Suy luận của tôi**
Khả năng đọc tệp trên máy chủ	**Tôi không khẳng định, không xác nhận**
Có bị khai thác trên thực tế không	**Tôi không nêu — không chắc**
Danh sách phiên bản sửa	**Tôi không ghi từ trí nhớ — lấy từ thông báo**
Có bản vá tiếp theo hay không	**Tôi không chắc**
Nguyên tắc phòng thủ nhiều lớp	**Phân tích của tôi, không phải khuyến nghị của dự án**
Middleware là "điểm thắt cổ chai" khi là lớp kiểm tra duy nhất	**Phân tích của tôi**

Artifact 21 — Prompt log lượt #24 — Thời gian: 00:37 27/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2025-55182 — React Server Components: giải mã payload không an toàn, dẫn tới chạy mã từ xa

Phân loại: lỗ hổng thật do **React Team** công bố, thuộc loại **không kiểm soát được dữ liệu** khi giải mã (deserialization), hệ quả là **chạy mã từ xa (RCE)**.

Nguồn: thông báo bảo mật của React Team phát hành **03/12/2025** (tôi **khá chắc** về ngày; đây là đợt công bố tôi nhớ rõ nhất trong năm 2025 vì nó gây tiếng vang lớn). Tôi **không chốt được** URL chính xác của thông báo — phải lấy từ trang phát hành của React.*

Mức độ: theo trí nhớ, điểm **CVSS 10,0**. **Mức chắc chắn:** khá chắc — phải mở thông báo để xác nhận.*

> **Cảnh báo quan trọng về phạm vi trả lời:** đợt công bố này có **hai CVE liên quan tới nhau** (tôi nhớ là **CVE-2025-55182** và **CVE-2025-55183**), và chúng **không cùng hậu quả**. Tôi sẽ tách rõ ở mục 3. Nếu bài bạn gộp là một, mục đó sẽ sai.

1. Lỗi nằm ở đâu trong React Server Components

Bối cảnh — RSC là gì và vì sao có mặt xa lạ trong một sự cố bảo mật:

- React có hai kiểu chạy giao diện: chạy trong trình duyệt, và chạy **trên máy chủ** (nơi có thể đọc cơ sở dữ liệu, đọc tệp tin, chạy mã máy chủ). **React Server Components (RSC)** là mô hình cho phép một phần giao diện được **dựng trên máy chủ**, thay vì gửi mã xuống trình duyệt để chạy.
- Vì một phần cây giao diện được dựng ở máy chủ, nên **giữa trình duyệt và máy chủ có một định dạng dữ liệu đặc biệt** mang kết quả dựng đó về. Định dạng này thường được gọi là **"flight"** hay payload của RSC. Tôi **khá chắc** về khái niệm "flight/payload"; tôi **không chốt được** định dạng byte cụ thể.*
- Cũng vì vậy, máy chủ phải **giải mã** dữ liệu này. Và đó chính là chỗ lỗ hổng nằm ở đây:

> **Lỗi nằm ở phía máy chủ, trong bước giải mã dữ liệu RSC mà máy chủ nhận từ phía trình duyệt.**

Bản chất lỗi — mô tả ở mức khái niệm tôi chắc:

- Bước giải mã đó **không kiểm tra đầy đủ** xem dữ liệu nhận vào có hợp lệ và có thật sự là loại dữ liệu RSC hay không.

- Hệ quả là: kẻ tấn công có thể ****gửi vào dữ liệu tùy ý, không phải dữ liệu RSC hợp lệ****, và bước giải mã vẫn cố xử lý → dẫn tới ****tạo được đối tượng trong bộ nhớ máy chủ theo ý muốn của kẻ tấn công****.

- ***Tôi **không nêu** tên lớp/hàm cụ thể và **không nêu** chuỗi khai thác, vì tôi không chắc và vì đây là loại chi tiết mà bịa ra là vô ích.***

****Vì sao đây là loại lỗi nguy hiểm bậc nhất:**** lỗi hỏng deserialization nằm ở ****phía máy chủ, ở ranh giới tin cậy****, và nó cho phép kẻ tấn công ****quyết định cấu trúc dữ liệu trong bộ nhớ**** — đây là tiền đề của việc chạy mã tùy ý, chứ không phải một lỗi logic nhỏ.

2. Điều kiện để có RCE không cần xác thực

Đây là phần cần tách cẩn thận, vì từ "RCE không cần xác thực" người đọc dễ hiểu nhầm thành "bất kỳ ai cũng chạy được mã trên máy chủ của tôi ngay lập tức".

****Cần ba điều kiện cùng lúc:****

1. ****Ứng dụng thực sự dùng RSC / có điểm cuối (endpoint) nhận dữ liệu RSC từ phía trình duyệt.****
Nếu ứng dụng không có RSC thì không có chỗ để gửi payload.
2. ****Điểm cuối đó không yêu cầu đăng nhập**** — tức nó ****tiếp nhận request không cần bằng chứng xác thực****. Đây là ý nghĩa chính xác của cụm "không cần xác thực": ****lỗi hỏng nằm trước lớp xác thực hoặc tại một đường không có lớp xác thực****, chứ không phải "vượt qua được việc đăng nhập".
3. ****Trên máy chủ có mã/thư viện mà kẻ tấn công lợi dụng được**** để biến "tạo đối tượng tùy ý" thành "chạy mã". ***Tôi **khá chắc** rằng điều kiện này có thật trong họ lỗi deserialization nói chung, nhưng tôi **không chốt được** trong thông báo của React họ nói cụ thể thế nào — phải đọc nguyên văn.***

****Cách nói đúng, an toàn khi vấn đáp:****

> ****"RCE không cần xác thực nghĩa là điểm cuối RSC không yêu cầu đăng nhập, nên kẻ tấn công gửi được payload tới bước giải mã lỗi hỏng. Nó không có nghĩa mọi ứng dụng RSC đều bị chạy mã."***

****Điểm cần nói rõ về giới hạn của từ "không cần xác thực":**** nếu ứng dụng đặt lớp xác thực ****ở trước**** điểm cuối RSC (ví dụ ở proxy hoặc ở chính lớp xử lý request trước khi tới RSC), thì lỗi hỏng vẫn tồn tại nhưng ****không dễ tiếp cận được từ Internet****. Đây là khác biệt giữa "có lỗi hỏng" và "có thể bị khai thác từ xa" — hai câu khác nhau. ***Đây là suy luận của tôi.***

3. Tách hai CVE của cùng đợt công bố

| | ****CVE-2025-55182**** | ****CVE-2025-55183**** |

| --- | --- | --- |

| Bản chất | Giải mã RSC không an toàn | Cùng dòng lỗi ở các gói RSC dành cho môi trường khác nhau |

| Hậu quả chính | ****Chạy mã từ xa (RCE)**** | *Tôi nhớ là ****lộ mã nguồn**** và có thể có ****từ chối dịch vụ****; không chắc mức độ chính xác* |

| Điểm chung | Cùng nguyên nhân gốc, cùng đợt vá | Cùng nguyên nhân gốc, cùng đợt vá |

*Tôi ****không chắc**** mô tả chi tiết hàng này, và ****không dùng**** để kết luận. Mục đích là để bạn thấy: ****phải dẫn đúng số CVE cho đúng hậu quả.**** Nếu bài bạn chỉ ghi 55182 với hậu quả "lộ mã nguồn" thì là gán nhầm.*

4. Gói bị ảnh hưởng và ứng dụng nào KHÔNG bị ảnh hưởng

****Các gói bị ảnh hưởng — tôi nói ở mức nhóm, không ghi số phiên bản:****

- Trong hệ sinh thái React, có ****một nhóm gói riêng phục vụ Server Components****, và ****chính nhóm gói này**** mới chứa phần xử lý RSC ở máy chủ. *Tôi ****không liệt kê tên gói cụ thể từ trí nhớ**** — danh sách tên gói và số phiên bản phải lấy nguyên văn từ thông báo, vì bỏ sót một gói nghĩa là hướng dẫn vá còn thiếu.*

- Các ****framework lớn dùng React Server Components cũng bị ảnh hưởng**** vì chúng ****đóng gói sẵn**** nhóm gói đó bên trong sản phẩm của họ. *Tôi ****không nêu tên framework cụ thể**** ở đây vì mức chắc chắn không đủ; tuy nhiên tôi ****khá chắc**** rằng đây là lý do vấn đề lan rộng hơn mức "dùng React thôi".*

****Ứng dụng KHÔNG bị ảnh hưởng — đây là phần quan trọng vì câu hỏi của bạn hỏi rõ:****

1. ****Ứng dụng React thuần chạy trong trình duyệt, không dùng RSC.**** Tức các ứng dụng dựng giao diện hoàn toàn ở phía trình duyệt, không có phần nào dựng ở máy chủ. *Mức chắc chắn: khá chắc — nếu không có RSC thì không có chỗ giải mã payload RSC ở máy chủ.*
2. ****Ứng dụng chỉ dùng React để hiển thị, không dùng tính năng máy chủ.**** *Khá chắc — là cùng lập luận.*
3. ****Ứng dụng đã chạy bản vá.**** Đương nhiên.

****Câu cần nhấn khi trả lời "có phải mọi app React/Next đều bị không":****

> ****Không. Lỗi nằm trong phần xử lý React Server Components ở máy chủ, nên chỉ ứng dụng nào thực sự dùng tính năng đó mới có bề mặt tấn công. Ứng dụng React thuần chạy trong trình duyệt, hoặc đã vá, thì không bị.****

5. Phiên bản vá

- Tôi ****không ghi danh sách số phiên bản từ trí nhớ**** cho mục này. Lý do rất cụ thể: với lỗ hổng deserialization, từ chối dịch vụ có thể đến từ ****nhiều gói cùng lúc****, nên ghi thiếu một gói là hướng dẫn vá ****không đủ dùng****.

- Điều bạn cần làm: mở thông báo của React Team và ****lấy nguyên danh sách gói + phiên bản sửa**** cho từng gói.

- Với framework đóng gói sẵn, phải dùng **bản phát hành đã vá của chính framework đó**, không chỉ nâng gói React. *Tôi **khá chắc** nguyên tắc này vì nó đúng với cơ chế đóng gói, nhưng hãy kiểm tra với từng framework.*

Một cảnh báo về giai đoạn công bố — mà tôi nói ở mức trí nhớ, không dẫn nguồn: tôi nhớ thông báo ban đầu của React Team **đã phải cập nhật bổ sung** vì thiếu thông tin, và điều đó gây tranh luận trong cộng đồng. *Nếu bài của bạn dẫn thông báo này, hãy luôn lấy **phiên bản mới nhất** của thông báo, đừng dùng bản trích lưu cũ.*

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
---	---
Lỗi ở phía máy chủ trong bước giải mã dữ liệu RSC	Khá chắc
Bản chất: không kiểm tra đầy đủ dữ liệu đầu vào, cho phép tạo đối tượng tùy ý	Khá chắc về nguyên lý, không nêu chi tiết
Tên lớp/hàm, định dạng byte, chuỗi khai thác	Tôi không nêu
Có tên gọi "flight" cho định dạng dữ liệu RSC	Khá chắc
Ngày công bố 03/12/2025	Khá chắc
URL thông báo	Tôi không chốt được
CVSS 10,0	Khá chắc — cần xác nhận
Có CVE-2025-55183 cùng đợt	Khá chắc
Hậu quả của 55183 (lộ mã nguồn / DoS)	Trí nhớ — không chắc
"Không cần xác thực" = điểm cuối RSC không yêu cầu đăng nhập	Suy luận của tôi — hợp lý về mặt khái niệm
Cần thêm mã/thư viện để biến deserialization thành RCE	Tôi không chốt được thông báo nói gì
Lớp xác thực ở trước endpoint làm giảm khả năng khai thác từ xa	Suy luận của tôi
Ứng dụng React thuần trình duyệt không bị ảnh hưởng	Khá chắc
Danh sách gói bị ảnh hưởng	Tôi không ghi — lấy từ thông báo
Tên framework cụ thể bị ảnh hưởng	Tôi không nêu
Framework đóng gói sẵn nên phải vá ở mức framework	Khá chắc về nguyên tắc đóng gói
Có bị khai thác trên thực tế không, quy mô	Tôi không nêu — không chắc
Thông báo ban đầu phải cập nhật bổ sung	Trí nhớ mức trung bình, không dẫn nguồn
Lỗi deserialization là tiền đề của RCE, không phải lỗi logic nhỏ	Phân tích của tôi

Artifact 22 — Prompt log lượt #25 — Thời gian: 00:40 27/09/2026 | Công cụ: OpenCode - Big Pickle

CVE-2025-53770 — SharePoint Server tại chỗ: giả mạo yêu cầu, dẫn tới thực thi mã từ xa

****Phân loại:**** lỗ hổng thật do Microsoft công bố, thuộc loại ****giả mạo (spoofing)**** dẫn tới ****thực thi mã từ xa****, trên ****SharePoint Server cài đặt tại chỗ****.

****Nguồn:**** hướng dẫn khách hàng của Microsoft MSRC đăng ****19/07/2025****, cùng hồ sơ CVE trong công cụ theo dõi cập nhật của Microsoft. ***Mức chắc chắn về ngày: khá chắc. Tôi **không chốt được** URL chính xác — phải lấy từ MSRC.***

****Mức độ:**** theo trí nhớ ****CVSS 9,8**** cho CVE-2025-53770. ***Khá chắc, cần xác nhận. CVE-2025-55171... nói chính xác: CVE-2025-53771 đi kèm có điểm khác; tôi **không chốt** con số.***

****Cảnh báo quan trọng:**** đây ****không phải một CVE đơn lẻ****. Microsoft yêu cầu khách hàng và ****hai lỗ hổng cùng lúc**** (53770 và 53771), và bản vá đã phát hành lần đầu ****đã bị xác nhận là chưa đủ**** nên phải vá tiếp. Tôi trình bày ở mục 6.

1. Điều kiện khai thác

Tách thành hai tầng:

****Tầng kỹ thuật (cần cho để chạy mã trên máy chủ):****

- Máy chủ phải chạy ****SharePoint Server tại chỗ**** và ****còn chưa vá****.
- Kẻ tấn công gửi yêu cầu HTTP với dữ liệu được chế tạo tới một điểm cuối (endpoint) của SharePoint; dữ liệu đó đi qua bước xử lý không kiểm tra đúng nguồn gốc, và từ đó phía máy chủ ****thực thi mã**** với quyền hệ thống.
- ***Tôi **không** nêu tên endpoint cụ thể và **không** nêu cấu trúc payload. Lý do: tôi không chắc chính xác, và đây là loại chi tiết mà bịa ra chỉ làm bài xấu đi mà không giúp ích cho phân phân tích lỗ hổng.***
- ***Mức chắc chắn về việc có cần đồng thời 53771 để không cần xác thực hay không: **không chắc**.** Xem mục 2.*

2. Quan hệ giữa 53770 và 53771 — chỗ dễ gán nhầm nhất

Đây là điểm tôi muốn bạn ghi vào bài cho chính xác, vì tôi nhớ có nhiều tóm tắt gộp hai lỗi này thành một.

| | CVE-2025-53770 | CVE-2025-53771 |

| --- | --- | --- |

| Loại theo Microsoft | ****Giả mạo (spoofing)**** | ****Nâng quyền (elevation of privilege)**** |

| Hệ quả tôi nhớ | Thực thi mã từ xa | Nâng quyền sau khi đã có bước đầu |
| Điểm chung | Cùng sản phẩm, cùng đợt Microsoft Security Response Center xử lý | Cùng sản phẩm, cùng đợt |

*Tôi **không chốt được** Microsoft mô tả chuỗi khai thác chính xác là gì, và **không nêu** một loại kỹ thuật hay gadget cụ thể nào. Những bài viết tôi nhớ có mô tả kiểu "dùng lỗi nâng quyền để thiết lập phiên rồi mới khai thác lỗi giả mạo", nhưng **tôi không dám khẳng định** thứ tự đó.*

Điều chắc chắn, và cũng là điều duy nhất bạn cần cho bài: Microsoft yêu cầu **cài cả hai bản vá** . Vì vậy nếu bạn viết "vá 53770" là **chưa đủ**.

3. Sản phẩm bị ảnh hưởng

- **SharePoint Server cài đặt tại chỗ (on-premises)** — đây là phạm vi của lỗ hổng. Tôi nhớ các phiên bản được Microsoft liệt kê là **SharePoint Server 2016, SharePoint Server 2019 và SharePoint Subscription Edition** . *Mức chắc chắn về danh sách phiên bản: khá chắc, phải đối chiếu MSRC.*
- **SharePoint Online (trong Microsoft 365): không nằm trong phạm vi.** Đây là câu Microsoft trả lời trực tiếp cho các khách hàng dùng Microsoft 365.

Vì sao phân biệt này quan trọng, thay vì là chi tiết hình thức — đây là phần tôi muốn bạn dùng để vấn đáp:

- Kiến trúc khác nhau: bản cài tại chỗ chạy trên máy chủ của doanh nghiệp, còn bản đám mây do Microsoft vận hành và có lớp bảo vệ ở phía nhà cung cấp.
- Người chịu trách nhiệm vá khác nhau: với bản tại chỗ, **quản trị viên của doanh nghiệp** phải tự vá; với bản đám mây, việc nằm ở phía Microsoft.
- Đây cũng là lý do vì sao hậu quả của lỗi này nghiêm trọng: kẻ tấn công nhắm vào **hạ tầng tự vận hành** , nơi không có lớp bảo vệ của bên thứ ba.

4. Điều đã xác nhận về tấn công thực tế

Đây là phần tôi cần thận trọng nhất, vì "đã bị khai thác" là loại khẳng định dễ bị thổi phồng nhất.

Những gì tôi cho là đã được Microsoft xác nhận (mức khá chắc, từ trí nhớ):

- Microsoft đã xác nhận **đang diễn ra tấn công nhắm vào các hệ thống SharePoint tại chỗ chưa vá** , và đây không chỉ là lấy dữ liệu đơn lẻ mà có dấu hiệu **lan truyền như sâu** (tự nhân bản sang máy khác).
- Lỗ hổng đã được **vá trong khoảng 1–2 ngày trước khi Microsoft công bố** , nghĩa là khoảng thời gian giữa lúc lộ ra và lúc vá là rất ngắn. *Tôi nhớ có nhận định rằng lần khai thác đầu tiên quan sát được vào khoảng **18/07/2025** , tức gần như đồng thời với bản vá. Mức chắc chắn: trung bình — phải kiểm tra lại mốc chính xác trong hướng dẫn MSRC.*
- Kẻ tấn công **không chỉ khai thác lỗ hổng mà còn đặt một backdoor lên máy chủ** để giữ quyền sau khi vá. *Đây là điểm tôi nhớ khá rõ và nó giải thích vì sao việc vá không đủ.*

Những gì tôi cố ý không nói:

- **Tôi không nêu tên chiến dịch hay nhóm tấn công.** Tôi có vài tên trong trí nhớ (Microsoft dùng mã tên riêng, các hãng bảo mật dùng mã tên riêng nữa) nhưng **tôi không chắc tên nào ghép với tên nào**, và ghi nhầm tên chiến dịch là lỗi rất dễ bị bắt. Nếu bài cần, hãy lấy trực tiếp từ hướng dẫn MSRC.
- **Tôi không đưa số nạn nhân, số hệ thống bị ảnh hưởng, hay quốc gia hay tổ chức nào bị tấn công.** Không có dữ liệu chắc chắn.

5. Hậu quả

Hậu quả	Mức xác nhận
Thực thi mã tùy ý trên máy chủ SharePoint với quyền hệ thống	**Bản chất lỗ hổng**
Chiếm quyền máy chủ, từ đó đọc/sửa dữ liệu trong site, tài khoản, thư	**Hệ quả trực tiếp của RCE**
Có thể dùng máy chủ đã chiếm làm bước tiếp vào hệ thống khác trong mạng	**Tôi suy luận** — nhưng đây là hiểm họa chuẩn khi RCE xảy ra
Mất khả năng truy cập site, gián đoạn dịch vụ nội bộ	**Phụ thuộc ứng dụng**
Thời điểm lộ dữ liệu	**Tôi không nêu** — không biết hệ thống cụ thể nào bị đọc

Điểm cần nhấn: đây là loại lỗi mà hậu quả **không dừng ở dữ liệu của SharePoint**. Kẻ tấn công có thể cài phần mềm độc, dùng máy chủ này làm bước tiếp. Vì vậy câu trả lời đúng là: **"thực thi mã với quyền hệ thống, từ đó kiểm soát máy chủ cùng toàn bộ dữ liệu và tài khoản trên site đó"** — **không phải "lộ thông tin người dùng"**.

6. Biện pháp khắc phục

a) Cập nhật

- Microsoft đã phát hành bản vá. **Tôi không** ghi mã bản vá cụ thể từ trí nhớ — đây là loại mã mà ghi sai một con số là hậu quả ngay lập tức, và phải tra đúng hệ thống của chính mình.*
- Phải vá **cả 53770 và 53771**.
- **Quan trọng:** tôi nhớ bản vá đầu tiên đã bị xác nhận là chưa đầy đủ, và Microsoft phải phát hành bản vá tiếp theo. Vì vậy câu trả lời đúng ở vấn đáp là: **"bản vá đầu tiên của ngày 19/07/2025 đã được Microsoft xác nhận là chưa đủ, cần áp dụng bản cập nhật bổ sung mà Microsoft phát hành sau đó."** Đây là điểm khác biệt rất dễ bị trừ điểm nếu nói chung chung "cập nhật lên bản vá".

b) Xử lý sau khi vá — phần tôi cho là quan trọng nhất, và tôi tự nhận là thiếu

Vì đã có bằng chứng kẻ tấn công **cài backdoor lên máy chủ**, việc vá chỉ vá cái lỗ hổng, **không đảo ngược được việc đã bị xâm nhập**. Theo tôi hiểu, hướng dẫn của Microsoft có nhắc tới việc dùng công cụ để phát hiện và gỡ backdoor. **Mức chắc chắn: trung bình.**

Điểm tôi thừa nhận không rõ: có một chi tiết về vị trí thư mục mà báo cáo tổng hợp nhắc tới tôi nhớ mơ hồ, và tôi **không dám ghi vào bài** khi chưa đọc hướng dẫn MSRC.*

****c) Xử lý khóa****

Câu hỏi của bạn có nhắc "khóa liên quan". Thằng thằn: ****tôi không xác nhận được Microsoft có yêu cầu xoay vòng (rotate) khóa nào trong vụ này.**** Các khả năng tôi nghĩ tới là khóa mã hóa của SharePoint, khóa máy của IIS dùng cho cookie và phiên, hoặc khóa dịch vụ của farm — nhưng ****đây là suy đoán của tôi, không phải hướng dẫn của hãng.****

Điểm cần nói rõ: trong các sự cố có thực thì mã từ xa, việc xoay vòng khoá bí mật thường là biện pháp ****giảm rủi ro hậu kỳ**** (để phòng thông tin đã bị lấy) chứ không phải bước khắc phục lỗ hổng. Nhưng với SharePoint, nhiều khoá được sinh ra tự động và quản lý qua trang quản trị, nên thao tác xoay vòng cũng không đơn giản như với một ứng dụng thông thường. *Đây là nhận xét của tôi, không phải khuyến nghị của hãng.*

7. Câu trả lời cho từng câu hỏi của bạn — dạng ngắn để dùng khi vấn đáp

- ****Điều kiện khai thác:**** máy chủ SharePoint Server tại chỗ chưa vá, nhận yêu cầu HTTP với dữ liệu chế tác tới điểm cuối xử lý dữ liệu không kiểm tra nguồn gốc → thực thi mã với quyền hệ thống. Microsoft khuyến nghị vá ****cả hai**** CVE.
- ****Sản phẩm bị ảnh hưởng:**** SharePoint Server 2016, 2019, Subscription Edition bản cài tại chỗ. ****Không**** phải SharePoint Online.
- ****Tấn công thực tế:**** Microsoft xác nhận đang có tấn công, có dấu hiệu tự lan truyền, và kẻ tấn công cài backdoor nên việc vá không thay thế cho việc xử lý hậu kỳ.
- ****Hậu quả:**** thực thi mã quyền hệ thống → chiếm máy chủ, đọc/sửa dữ liệu và tài khoản của site, có thể dùng làm bước tiếp vào mạng nội bộ.
- ****Khắc phục:**** áp bản vá (kể cả bản cập nhật bổ sung vì bản đầu chưa đủ), dọn backdoor, và xem xét xoay vòng khoá; ****không**** dừng ở "cài bản vá".

Bảng tách sự thật và suy luận

Nội dung	Trạng thái
--- ---	
Lỗ hổng do Microsoft công bố, loại giả mạo dẫn tới RCE	**Khá chắc**
Ngày công bố 19/07/2025	**Khá chắc**
URL hướng dẫn MSRC	**Tôi không chốt được**
CVE-2025-53770 có CVSS 9,8	**Khá chắc — cần xác nhận**
CVE-2025-53771 là lỗi nâng quyền, phải vá cùng 53770	**Khá chắc**
Điểm CVSS của 53771	**Tôi không chốt**
Chuỗi khai thác chính xác giữa hai lỗi	**Tôi không nêu**
Tên điểm cuối và cấu trúc payload	**Tôi không nêu**
SharePoint Server 2016, 2019, Subscription Edition	**Khá chắc — cần đối chiếu**
SharePoint Online không bị ảnh hưởng	**Khá chắc**
Microsoft xác nhận tấn công đang diễn ra, có dấu hiệu tự lan	**Khá chắc**

Mốc khai thác đầu khoảng 18/07/2025	****Trí nhớ mức trung bình — cần kiểm tra****
Kẻ tấn công cài backdoor lên máy chủ	****Khá chắc****
Vị trí thư mục backdoor	****Tôi không ghi — không chắc****
Tên chiến dịch / nhóm tấn công	****Tôi không nêu — không chắc****
Số nạn nhân, quy mô	****Tôi không nêu****
Bản vá đầu tiên chưa đủ, phải vá bổ sung	****Khá chắc****
Mã bản vá cụ thể	****Tôi không ghi — lấy từ MSRC****
Microsoft có yêu cầu xoay vòng khóa	****Tôi không xác nhận****
Loại khóa có thể liên quan	****Suy đoán của tôi****
RCE → dùng máy chủ làm bước tiếp vào mạng	****Suy luận của tôi****
Xoay vòng khóa là biện pháp hậu kỳ, không phải khắc phục lỗ hổng	****Phân tích của tôi****
Việc vá không thay thế xử lý hậu kỳ khi đã bị xâm nhập	****Phân tích của tôi — hợp lý****

Artifact 23 — Prompt log lượt #26 — Thời gian: 01:29 27/09/2026 | Công cụ: OpenCode - Big Pickle

12 test case cho quạt đứng Senko L1638

Ghi chú về cách tôi hiểu yêu cầu

- Prompt của bạn ghi "đề xuất đúng 12 test case" nhưng lại yêu cầu đánh số **TC01–TC15**. Tôi hiểu ý bạn là: **12 case do AI đề xuất, mang số TC01–TC12, còn TC13–TC15 là 3 edge case bạn tự bổ sung** (vì đề yêu cầu có ít nhất 3 edge case do người học tự tìm mà AI không nêu). Tôi đánh số theo cách đó.

- Tôi **không biết thông số kỹ thuật của Senko L1638**. Bộ 12 case dưới đây được thiết kế cho một chiếc quạt đứng thông thường và chỉ dựa vào những gì **bắt buộc phải có** ở mọi quạt đứng. Mọi chỗ phụ thuộc tính năng có thể có hoặc không (chế độ đảo, hẹn giờ, remote) đều được đánh dấu rõ để bạn xác nhận trước.

- Tôi **cố ý không đưa vào 12 case này** các tình huống phụ thuộc vào điều kiện sử dụng riêng của nhà bạn (khung giờ, thiết bị dùng chung ổ điện, vị trí đặt cụ thể trong phòng). Lý do chính đáng: đề yêu cầu bạn phải tự tìm được ít nhất 3 edge case mà **AI không đề xuất**. Nếu tôi đưa sẵn vào đây thì bạn mất đúng nguồn bằng chứng đó. Phần này tôi dành cho bạn.

Danh mục 12 test case

Mã	Tên case	Nhóm	Video $\leq 60s$	Cần xác nhận tính năng
---	---	---	---	---
TC01	Khởi động từ trạng thái nghỉ	Chức năng cơ bản	Có	Không
TC02	Khởi động lặp lại 20 lần	Độ bền cơ cấu khởi động	Có	Không
TC03	So sánh lực gió giữa các mức tốc độ	Chức năng cơ bản	Có	Có mức tốc độ
TC04	Phản hồi khi thao tác nút điều khiển	Chức năng cơ bản	Có	Có
TC05	Chế độ đảo chiều	Tính năng có thể có	Có (nếu có)	Có
TC06	Chức năng hẹn giờ	Tính năng có thể có	Không	Có
TC07	Độ rung/lắc ở tốc độ cao nhất	Cơ – cân bằng	Có	Không
TC08	Vị trí lệch gây rung theo chu kỳ	Cơ – cân bằng	Không	Không
TC09	Độ ồn và tiếng sột soạt của cơ cấu	Cơ – âm thanh	Có	Không
TC10	Nhiệt độ vỏ sau 60 phút chạy liên tục	Cơ – nhiệt	Không	Không
TC11	Dây nguồn, đầu cắm và chân đế	Cấu trúc/điện	Không	Không
TC12	Khe lồng có lọt vật nhỏ hay không	An toàn người dùng	Có	Không

7 case quay được video ≤ 60 giây (TC01, TC02, TC03, TC04, TC07, TC09, TC12; thêm TC05 nếu máy có chế độ đảo). Nếu chỉ quay 5 video, hãy chọn theo thứ tự: **TC07, TC01, TC03, TC02, TC09** — vì 5 case này dễ lộ ra lỗi thật và dễ quay trong 60 giây.

TC01 — Khởi động từ trạng thái nghỉ

- **Objective:** Xác nhận quạt khởi động được từ trạng thái đã tắt lâu và đo được thời gian từ lúc thao tác đến khi nan quay bắt đầu quay.
- **Input:** Quạt đã tắt và nghỉ ít nhất 5 phút; quạt cắm vào ổ điện ổn định; đặt trên nền phẳng; dụng cụ: đồng hồ bấm giờ.
- **Steps:** 1) Cắm đầu cắm vào ổ, đặt quạt trên nền phẳng. 2) Bấm nút/cò nguồn (ngoài lồng) và bấm đồng hồ cùng lúc. 3) Dừng đồng hồ khi nan quay bắt đầu chuyển động. 4) Ghi lại giá trị. 5) Lặp lại 3 lần để lấy giá trị ổn định nhất.
- **Expected:** Nan quay bắt đầu quay; thân quạt không lắc ngang trong lúc khởi động; thời gian khởi động đo được và ghi thành con số. Ngưỡng thời gian khởi động chuẩn của hãng: **Cần kiểm tra nhãn/hướng dẫn sử dụng** — nếu không có, chỉ dùng giá trị đo được để so sánh giữa các lần thử, không kết luận Pass/Fail theo ngưỡng.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC02 — Khởi động lặp lại 20 lần (độ bền cơ cấu khởi động)

- **Objective:** Kiểm tra khả năng khởi động lặp lại nhiều lần, vì đây là bộ phận thường mòn nhất trên quạt đã dùng lâu và là nơi sinh ra lỗi "phải bấm nút mấy lần mới chạy".
- **Input:** Quạt cắm ổ điện ổn định; đồng hồ bấm giờ; tờ giấy để đếm.
- **Steps:** 1) Tắt quạt, chờ 30 giây. 2) Lặp 20 vòng: bấm nguồn → bấm đồng hồ → dừng đồng hồ khi quay → ghi "khởi động đạt/không đạt" → tắt → chờ 30 giây. 3) Sau mỗi 5 vòng, dừng nghỉ 1 phút. 4) Tổng hợp số vòng khởi động thành công trong 5 giây.
- **Expected:** **Tiêu chí tự định (do người test đặt, không phải thông số hãng):** ít nhất 18/20 vòng khởi động thành công trong 5 giây; không có hiện tượng phải bấm lại lần hai liên tiếp quá 2 vòng. Số lần khởi động khuyến nghị của hãng: **Cần kiểm tra nhãn/hướng dẫn sử dụng** — nếu hãng có ghi thì lấy theo hãng.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC03 — So sánh lực gió giữa các mức tốc độ

- **Objective:** Xác nhận các mức tốc độ tạo ra mức gió khác nhau, đo được bằng cách so độ tác động lên tờ giấy.
- **Input:** Tờ giấy A5; băng dán; thước kẻ; dụng cụ cố định để giữ tờ giấy ở đúng một vị trí cho mọi lần đo.
- **Steps:** 1) Tắt quạt, dán tờ giấy lên vật cứng sao cho mép tờ giấy cách mặt lồng đúng 10 cm, ngang tầm nan quay, ở giữa bề rộng. 2) Bật từng mức tốc độ, giữ mỗi mức 15 giây. 3) Đo khoảng cách từ mép tờ giấy tới vị trí cao nhất mà tờ giấy bị nhấc lên. 4) Ghi thành bảng số theo từng mức tốc độ.
- **Expected:** Khoảng cách tờ giấy bị nhấc lên tăng đơn điệu khi tăng mức tốc độ; hai mức liên kề nhau phải tạo ra hai số đo khác nhau, hoặc nếu bằng nhau thì ghi nhận là khó phân biệt. Ngưỡng so sánh chuẩn của hãng: **Cần kiểm tra nhãn/hướng dẫn sử dụng** — bộ test này dùng số đo được làm chuẩn so sánh nội bộ, không dùng số đó để kết luận lỗi.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC04 — Phản hồi khi thao tác các nút điều khiển

- **Objective:** Phát hiện nút chết hoặc nút phải bấm nhiều lần mới ăn, và kiểm tra trạng thái hiển thị có khớp với thao tác không.
- **Input:** Trước khi chạy, xác nhận kiểu điều khiển của máy: nút cơ, nút cảm ứng, hay có điều khiển từ xa.
- **Steps:** 1) Bấm lần lượt từng nút một lần, quan sát phản hồi. 2) Chọn một nút và bấm liên tiếp 10 lần, đếm số lần "ăn" ngay. 3) Quan sát đèn báo (nếu có) hoặc vị trí nút có thay đổi không. 4) Nếu có điều khiển từ xa: bấm từng nút trên tay cầm, ghi số lần phải bấm.
- **Expected:** Mỗi lần bấm đều có phản hồi quan sát được; đèn hoặc vị trí nút khớp với trạng thái đang chọn. **Tiêu chí tự định:** ít nhất 9/10 lần bấm phải ăn ngay ở lần đầu. Số lần bấm tối đa mà hãng chấp nhận: **Cần kiểm tra nhãn/hướng dẫn sử dụng**.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC05 — Chế độ đảo chiều *(chỉ làm nếu máy có tính năng này)*

- **Objective:** Kiểm tra cơ cấu đảo hướng hoạt động đều và không va chạm trong suốt hành trình.
- **Input:** Xác nhận máy có chế độ đảo; quạt đặt cách tường ít nhất 30 cm trên nền phẳng.
- **Steps:** 1) Bật quạt ở mức tốc độ thấp nhất. 2) Bật chế độ đảo. 3) Chạy liên tục 2 phút, quan sát toàn bộ hành trình đầu nan quay. 4) Lắng nghe có tiếng va, tiếng kẹt hay tiếng cọ không. 5) Ghi lại tầm đảo trái-phải bằng cách đánh dấu vị trí đầu nan quay.
- **Expected:** Đầu nan quay đảo đều sang trái và sang phải; không có tiếng va chạm trong suốt hành trình; tầm đảo lặp lại ổn định giữa các vòng. Tần số đảo danh định: **Cần kiểm tra nhãn/hướng dẫn sử dụng**. **Nếu máy không có tính năng này:** ghi "N/A – không có chế độ đảo" và thay bằng một case dự phòng do bạn chọn.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC06 — Chức năng hẹn giờ *(chỉ làm nếu máy có tính năng này)*

- **Objective:** Kiểm tra quạt có tự tắt đúng thời điểm đã hẹn hay không.
- **Input:** Xác nhận máy có chức năng hẹn giờ; đồng hồ bấm giờ; chọn mức hẹn ngắn nhất mà máy cho phép.
- **Steps:** 1) Bật quạt, đặt hẹn giờ ở mức ngắn nhất. 2) Ghi lại thời điểm đặt hẹn. 3) Chờ đến khi quạt tự tắt, ghi thời điểm tắt thực tế. 4) Tính sai số giữa thời điểm tắt thực tế và thời điểm dự kiến.
- **Expected:** Quạt tự tắt đúng thời điểm đã hẹn hoặc sai số không đáng kể. **Tiêu chí tự định:** sai số không quá 1 phút với mức hẹn ngắn nhất. Danh sách mức hẹn giờ mà máy hỗ trợ: **Cần kiểm tra nhãn/hướng dẫn sử dụng** — phải đọc từ nút trên máy, không suy đoán. **Nếu máy không có tính năng này:** ghi "N/A – không có hẹn giờ" và thay bằng case dự phòng.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC07 — Độ rung/lắc ở tốc độ cao nhất

- **Objective:** Kiểm tra cân bằng và độ ổn định của quạt khi chạy tốc độ cao nhất — đây là dạng lỗi phổ biến nhất trên quạt đã dùng lâu và thường chỉ xuất hiện ở tốc độ cao.
- **Input:** Nền phẳng cứng (không phải thảm); ba tờ giấy A4 đặt dưới từng chân quạt; thước kẻ.
- **Steps:** 1) Đặt quạt lên nền cứng phẳng, đặt một tờ giấy dưới mỗi chân. 2) Bật ở tốc độ cao nhất. 3) Quan sát liên tục 60 giây. 4) Ghi: có lắc ngang thân không, có di chuyển không, dây nguồn có bị kéo theo không. 5) Kiểm tra xem tờ giấy dưới chân nào bị nhấc lên. 6) Nếu có di chuyển, đo khoảng cách lớn nhất quạt dịch chuyển được bằng thước.
- **Expected:** Thân quạt không lắc ngang; quạt không di chuyển trên nền; cả ba chân đều tiếp xúc, tờ giấy dưới chân không bị nhấc lên; dây nguồn không bị kéo căng. Khoảng cách dịch chuyển tối đa chấp nhận được: 0 cm. Ngưỡng rung công khai của hãng: **Cần kiểm tra nhãn/hướng dẫn sử dụng** — dùng tiêu chí quan sát được ở trên.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC08 — Vị trí lệch gây rung theo chu kỳ

- **Objective:** Phát hiện nan quay lệch cân bằng ở một vị trí nhất định, dẫn tới rung theo nhịp — loại lỗi rất dễ bỏ sót vì chỉ xuất hiện ở một góc quay, nhìn thoáng qua sẽ tưởng quạt bình thường.
- **Input:** Cùng bố trí nền và giấy như TC07; quan sát trong phòng yên tĩnh.
- **Steps:** 1) Bật ở tốc độ cao nhất. 2) Ngồi cách quạt 1 mét, quan sát và lắng nghe trong suốt 3 vòng quay đầy đủ. 3) Nếu phát hiện rung theo nhịp: quan sát vị trí nan quay đúng lúc đó bằng cách nhìn qua lồng từ bên ngoài. 4) Ghi lại vị trí lệch dưới dạng mốc giờ, ví dụ "lệch khi nan quay chỉ ngang 12 giờ".
- **Expected:** Không có rung theo nhịp ở bất kỳ vị trí nào. Nếu có rung → ghi nhận vị trí và chuyển thành defect. Tiêu chí cân bằng công khai của hãng: **Cần kiểm tra nhãn/hướng dẫn sử dụng** — dùng tiêu chí quan sát được ở trên.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC09 — Độ ồn và tiếng sột soạt của cơ cấu

- **Objective:** Ghi nhận tiếng ồn phát ra từ cơ cấu, đặc biệt là tiếng sột soạt hoặc reo đều theo nhịp quay — dấu hiệu ổ bi, khớp nối lỏng hoặc lệch cơ cấu.
- **Input:** Không dùng thiết bị đo nếu không có. Dùng thang đánh giá tự định 0–3 (định nghĩa ở Expected).
- **Steps:** 1) Tắt quạt, nghe 30 giây để xác định mức ồn nền của phòng. 2) Bật tốc độ cao nhất, đứng cách 1 mét, nghe 60 giây. 3) Lùi ra cách 3 mét, nghe 30 giây. 4) Ghi mức 0–3 ở cả hai khoảng cách, và ghi riêng có hay không tiếng sột soạt theo nhịp quay.
- **Expected:** **Thang tự định (do người test đặt):** 0 = không nghe thấy; 1 = nghe thấy nhưng dễ chịu; 2 = nghe rõ ở khoảng cách 1 m; 3 = nghe rõ ở khoảng cách 3 m. Không có tiếng sột soạt hoặc reo đều theo nhịp quay ở bất kỳ tốc độ nào. Mức ồn công khai của hãng (nếu có, tính bằng dB): **Cần kiểm tra nhãn/hướng dẫn sử dụng** — nếu hãng không công bố thì dùng thang tự định và ghi rõ là thang tự định.

- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC10 — Nhiệt độ vỏ sau thời gian chạy liên tục

- **Objective:** Kiểm tra vỏ động cơ và nắp motor không nóng bất thường, không nóng tăng dần sau thời gian chạy dài.
- **Input:** Có nhiệt kế nhà bếp hoặc nhiệt kế hồng ngoại nếu có. Nếu không có, dùng phương pháp chạm tay bốn mức và ghi rõ đã dùng phương pháp nào.
- **Steps:** 1) Bật tốc độ cao nhất, chạy liên tục 60 phút. 2) Mỗi 15 phút đo nhiệt độ vỏ động cơ phía sau lồng, bằng cách đặt nhiệt kế lên vỏ hoặc chạm tay từ bên ngoài lồng, không tháo gì. 3) Ghi 4 giá trị. 4) Quan sát có mùi khét, có khói, hoặc có tiếng sột soạt mới xuất hiện không.
- **Expected:** Nhiệt độ vỏ không tăng liên tục ở hai lần đo cuối, tức đã ổn định; tay chịu được khi chạm; không có mùi khét, không có khói. Nếu dùng phương pháp chạm tay, thang tự định: mát / ấm / nóng khó chịu (rút tay ngay) / quá nóng không chịu được. Ngưỡng nhiệt độ vỏ tối đa: **Cần kiểm tra nhãn/hướng dẫn sử dụng** — hầu như quạt dân dụng không công bố, nên tiêu chí dùng để kết luận là "có ổn định giữa 4 lần đo hay không", không dùng một ngưỡng nhiệt độ tuyệt đối.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC11 — Dây nguồn, đầu cắm và chân đế

- **Objective:** Kiểm tra tình trạng dây nguồn, độ khít của đầu cắm và độ chặt của chân đế — ba vị trí thường phát sinh lỗi chết do hao mòn theo thời gian.
- **Input:** Không dùng dụng cụ đặc biệt; chỉ dùng mắt và tay, và chỉ chạm phần vỏ bên ngoài, không tháo gì.
- **Steps:** 1) Quan sát toàn bộ chiều dài dây nguồn, đặc biệt chỗ dây cuộn sát chân đế và chỗ nối vào động cơ: tìm vết xù, vết nứt, đổi màu, đứt gãy. 2) Cắm vào ổ và thử nhẹ xem đầu cắm có vừa khít không, có lỏng tay không; không dùng lực mạnh, không mở ổ cắm. 3) Bật tốc độ cao nhất, đặt tay lên chân đế và lắng nghe có tiếng sột soạt sát vỏ không. 4) Chụp ảnh cận cảnh mọi vị trí bất thường.
- **Expected:** Dây nguồn không có vết xù, nứt, đổi màu hoặc đứt gãy; đầu cắm vừa khít trong ổ; khi quạt chạy không có tiếng sột soạt sát vỏ chân đế. Ngưỡng định lượng cho các hạng mục này: **Cần kiểm tra nhãn/hướng dẫn sử dụng** — hãng thường không công bố, nên tiêu chí là quan sát được hay không quan sát được.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

TC12 — Khe lồng có lọt vật nhỏ hay không (an toàn người dùng)

- **Objective:** Kiểm tra khe lưới lồng có đủ khít để vật nhỏ cầm tay có thể chạm tới vùng nan quay đang quay hay không.
- **Input:** Một vật thử có đường kính xác định, ví dụ cây bút bi hoặc kẹp giấy; thước kẻ hoặc cầu kế để đo trước đường kính vật thử.

- **Steps:** 1) Tắt quạt. 2) Đo và ghi lại đường kính vật thử. 3) Từ phía ngoài, thử lồng vật thử qua khe lưới ở vùng giữa lồng, rồi lặp lại ở vùng sát trục nan quay. 4) Tuyệt đối không đưa tay qua lồng và không dùng vật sắc. 5) Chụp ảnh vật thử cạnh khe lưới để chứng minh kích thước.
- **Expected:** Vật thử không lọt qua khe ở vùng lưới bảo vệ nan quay; khe ở vùng sát trục phải nhỏ hơn khe ở vùng giữa lồng. Kích thước vật thử theo tiêu chuẩn an toàn của hãng: **Cần kiểm tra nhân/hướng dẫn sử dụng** — nếu hãng không công bố, ghi nhận số đo được và so sánh cùng vật thử ở các vùng lưới khác.
- **Actual:** Chưa thực hiện
- **Verdict:** Not Run

Thông tin tôi cần bạn kiểm tra trực tiếp trên quạt trước khi chốt bộ test case

A. Số serial — việc cần làm trước tiên

Đây là mục tôi **không thể tự trả lời thay bạn** và cũng là mục tuyệt đối không được đoán. Bạn cần tự kiểm tra theo thứ tự sau:

1. Nắp động cơ phía sau lồng quạt — chỗ này thường có tem dán, và là nơi phổ biến nhất.
2. Mặt dưới đế hoặc chân quạt.
3. Tem trên dây nguồn.
4. Vỏ hộp / thùng carton của máy.

Cách che 4 ký tự ở giữa: giữ lại 4 ký tự đầu và 3 ký tự cuối, che 4 ký tự ở giữa. Ví dụ serial `L1638-2412-0877` trình bày thành `L163\*\*\*\*\*0877`; serial 12 ký tự `L163824120877` trình bày thành `L163\*\*\*\*\*877`.

Nếu tìm thấy ở cả 4 nơi mà vẫn không có serial: ghi thẳng trong báo cáo là **"Thiết bị không ghi số serial trên thân máy; số serial lấy từ vỏ hộp"** hoặc **"Không ghi serial"**. **Đây là cách trả lời đúng và không bị trừ điểm** — tự chế một dãy số để điền vào ô thì mới là vi phạm. Trong trường hợp này, hãy chụp ảnh tem nhưng che số serial, và ghi rõ trong báo cáo là không có số serial để khai.

B. Ảnh chụp bắt buộc

- Ảnh **thiết bị + thẻ sinh viên** trong cùng một khung hình — đặt thẻ cạnh quạt, chụp sao cho nhìn rõ cả hai.
- Ảnh cận cảnh **nhãn thông số** để đọc được các ký tự.

C. Thông số trên nhãn cần chép lại

Đọc và ghi vào báo cáo: công suất (W), điện áp (V), tần số (Hz), lớp bảo vệ chống giật (Class I hay II), nơi sản xuất, tên hãng, mã model. Ghi riêng **năm sản xuất** nếu nhãn có in tháng năm; nếu nhãn

không in năm thì ghi rõ **"2022 (theo thông tin của người sử dụng)"** chứ không ghi như sự thật của nhãn.

D. Các nút và chế độ cần xác nhận

| Câu hỏi | Vì sao cần biết |

| --- | --- |

| Máy có ****bao nhiêu mức tốc độ****? Tên gọi trên nút là gì? | Quyết định TC03 chạy được và ghi tên mức thay vì số thứ tự |

| Điều khiển bằng ****nút cơ, nút cảm ứng hay có điều khiển từ xa****? | Quyết định cách thao tác ở TC04 |

| Có ****chế độ đảo**** không? Nếu có, nút ở đâu, tên ghi gì? | Quyết định TC05 chạy hay ghi N/A |

| Có ****hẹn giờ**** không? Các mức hẹn ghi trên nút là bao nhiêu? | Quyết định TC06 chạy hay ghi N/A |

| Có ****đèn báo**** không? Báo trạng thái nào? | Quyết định tiêu chí "phản hồi quan sát được" ở TC04 |

| Có ****thang cấp tốc độ**** ghi rõ số vòng/phút không? | Có thể dùng để làm tiêu chí định lượng thay cho thang tự định |

E. Tình huống thực tế của đúng chiếc máy này

- Máy đã dùng được bao lâu, trung bình chạy bao nhiêu giờ mỗi ngày.
- Đã từng tháo lồng, vệ sinh, hay sửa chữa lần nào chưa.
- Hiện đang đặt ở vị trí nào, trên nền cứng hay trên thảm, cách tường bao nhiêu.
- Có dùng chung ổ cắm điện với thiết bị công suất lớn nào không.

Bốn thông tin này ảnh hưởng trực tiếp tới việc giải thích ****vì sao một quan sát bất thường là lỗi của thiết bị hay là hậu quả của cách dùng****, đây chính là phần giảng viên hay hỏi ở vấn đáp.

F. Việc cần hoàn thành sau khi có dữ liệu trên

1. Chốt lại danh sách 12 case: các case nào giữ nguyên, case nào thay bằng case dự phòng vì máy không có tính năng đó.
2. Bổ sung 3 edge case của bạn thành ****TC13, TC14, TC15****, rồi chạy thử tối thiểu 5 case trong đó có ưu tiên 2 edge case.
3. Chụp màn hình hội thoại AI cho thấy 3 case đó không xuất hiện trong 12 case ở trên, và viết phần giải thích vì sao AI bỏ sót.
4. Điền Actual và Verdict sau khi chạy thật; case chưa chạy thì giữ nguyên Chưa thực hiện / Not Run.
5. Chuyển những quan sát bất thường thành GitHub Issue.

Artifact 24 — Prompt log lượt #27 — Thời gian: 22:20 27/09/2026 | Công cụ: Antigravity - Claude Opus 4.6 (Thinking)

(Đã tạo file `Mindmap\_QA\_QC\_ISTQB.md` tại thư mục gốc của bài.)

Mindmap: Vai trò QA/QC trong quy trình kiểm thử theo ISTQB Foundation Level

> **Tài liệu tham chiếu:** ISTQB Certified Tester Foundation Level (CTFL) Syllabus v4.0 — 2023.

1. Lập kế hoạch kiểm thử (Test Planning)

- **Hoạt động chính**

- Xác định phạm vi, mục tiêu và rủi ro kiểm thử
- Lựa chọn phương pháp kiểm thử (test approach)
- Ước lượng công sức, lịch trình và nguồn lực
- Xác định tiêu chí bắt đầu và hoàn tất (entry/exit criteria)

- **Đầu ra**

- Test Plan (kế hoạch kiểm thử)
- Lịch trình kiểm thử (test schedule)

- **Vai trò QA/QC**

- QA: Đảm bảo kế hoạch tuân thủ quy trình tổ chức và tiêu chuẩn chất lượng
- QC: Xác nhận các tiêu chí đo lường được và khả thi để kiểm tra sản phẩm

2. Giám sát và điều khiển kiểm thử (Test Monitoring & Control)

- **Hoạt động chính**

- Thu thập và phân tích các chỉ số kiểm thử (test metrics)
- So sánh tiến độ thực tế với kế hoạch
- Đưa ra hành động điều chỉnh khi lệch kế hoạch
- Báo cáo trạng thái kiểm thử cho các bên liên quan

- **Đầu ra**

- Test Progress Report (báo cáo tiến độ)
- Test Summary Report (báo cáo tổng kết)

- **Vai trò QA/QC**

- QA: Giám sát quy trình kiểm thử có được tuân thủ xuyên suốt không
- QC: Theo dõi tỷ lệ lỗi, test pass/fail để đánh giá chất lượng sản phẩm

3. Phân tích kiểm thử (Test Analysis)

- **Hoạt động chính**

- Phân tích test basis (yêu cầu, thiết kế, code) để xác định điều kiện kiểm thử
- Xác định và ưu tiên các điều kiện kiểm thử (test conditions)
- Đánh giá khả năng kiểm thử của test basis
- Phát hiện lỗi trong test basis (yêu cầu mâu thuẫn, thiếu sót)

- **Đầu ra**

- Danh sách điều kiện kiểm thử đã ưu tiên

- Báo cáo lỗi trên test basis (defects in requirements)
- **Vai trò QA/QC**
 - QA: Xác nhận test basis đủ rõ ràng và đầy đủ để phân tích
 - QC: Đảm bảo các điều kiện kiểm thử bao phủ đúng yêu cầu nghiệp vụ

4. Thiết kế kiểm thử (Test Design)

- **Hoạt động chính**
 - Thiết kế test case từ các điều kiện kiểm thử
 - Áp dụng kỹ thuật thiết kế kiểm thử (phân vùng tương đương, giá trị biên, bảng quyết định...)
 - Xác định dữ liệu kiểm thử cần thiết
 - Thiết kế môi trường kiểm thử
- **Đầu ra**
 - Test cases (trường hợp kiểm thử)
 - Yêu cầu dữ liệu kiểm thử (test data requirements)
 - Yêu cầu môi trường kiểm thử (test environment requirements)
- **Vai trò QA/QC**
 - QA: Rà soát test case tuân thủ chuẩn viết và kỹ thuật thiết kế đã chọn
 - QC: Kiểm tra test case phủ đúng và đủ các yêu cầu chức năng/phi chức năng

5. Triển khai kiểm thử (Test Implementation)

- **Hoạt động chính**
 - Tạo và ưu tiên quy trình kiểm thử (test procedures / test scripts)
 - Tạo bộ kiểm thử (test suites) từ các test procedures
 - Chuẩn bị dữ liệu kiểm thử và cài đặt môi trường
 - Xác nhận mọi điều kiện entry criteria đã đáp ứng
- **Đầu ra**
 - Test procedures / automated test scripts
 - Test suites
 - Dữ liệu và môi trường kiểm thử sẵn sàng
- **Vai trò QA/QC**
 - QA: Xác minh môi trường kiểm thử đáp ứng đúng yêu cầu đã thiết kế
 - QC: Kiểm tra dữ liệu kiểm thử hợp lệ, đầy đủ và có thể truy vết

6. Thực thi kiểm thử (Test Execution)

- **Hoạt động chính**
 - Chạy test case theo thứ tự ưu tiên trong test suite
 - So sánh kết quả thực tế với kết quả mong đợi
 - Ghi nhận lỗi (log defects) và phân tích nguyên nhân thất bại
 - Thực thi kiểm thử lại (re-testing) và kiểm thử hồi quy (regression testing)
- **Đầu ra**
 - Test logs (nhật ký kiểm thử)
 - Defect reports (báo cáo lỗi)
 - Kết quả pass/fail/blocked cho từng test case
- **Vai trò QA/QC**
 - QA: Đảm bảo quy trình ghi nhận lỗi và tái kiểm thử được tuân thủ nhất quán

- QC: Xác nhận kết quả kiểm thử phản ánh đúng chất lượng thực tế của sản phẩm

7. Hoàn tất kiểm thử (Test Completion)

- ****Hoạt động chính****
 - Kiểm tra exit criteria / definition of done đã đạt
 - Đóng các báo cáo lỗi còn mở hoặc chuyển sang backlog
 - Viết báo cáo tổng kết kiểm thử (test summary report)
 - Lưu trữ testware để tái sử dụng (test cases, scripts, data, môi trường)
 - Rút kinh nghiệm (lessons learned)
- ****Đầu ra****
 - Test Summary Report (báo cáo tổng kết cuối cùng)
 - Danh sách lỗi còn mở hoặc rủi ro chấp nhận
 - Testware được lưu trữ
 - Bài học kinh nghiệm (lessons learned)
- ****Vai trò QA/QC****
 - QA: Đánh giá toàn bộ quy trình kiểm thử có tuân thủ kế hoạch và chuẩn tổ chức không
 - QC: Xác nhận sản phẩm đạt ngưỡng chất lượng để phát hành dựa trên số liệu kiểm thử

8. AI hỗ trợ trong quy trình kiểm thử

- ****Lập kế hoạch****
 - Phân tích rủi ro tự động từ tài liệu yêu cầu
 - Ước lượng công sức kiểm thử dựa trên dữ liệu lịch sử
- ****Phân tích & Thiết kế****
 - Đề xuất test case từ yêu cầu/user story
 - Sinh dữ liệu kiểm thử tự động (boundary, random, negative)
- ****Triển khai & Thực thi****
 - Sinh và bảo trì test script tự động
 - Phát hiện thay đổi giao diện để cập nhật locator
 - Phân loại và gom nhóm lỗi tự động
- ****Giám sát & Hoàn tất****
 - Tổng hợp dashboard và báo cáo chỉ số kiểm thử
 - Tóm tắt xu hướng lỗi và đề xuất vùng cần kiểm thử hồi quy
- ****Giới hạn của AI****
 - Không thay thế được kiểm thử khám phá (exploratory testing) đòi hỏi trực giác con người
 - Không thể đánh giá trải nghiệm người dùng (UX) thực tế
 - Kết quả AI cần được QA/QC xác minh trước khi sử dụng chính thức

Artifact 25 — Prompt log lượt #28 — Thời gian: 22:46 27/09/2026 | Công cụ: Antigravity - Gemini 3.1 Pro

Đã sử dụng công cụ `@mermaid-js/mermaid-cli` thông qua npx để vẽ sơ đồ dạng hình, vì các kỹ năng tìm được từ `skills.sh` liên quan đến `excalidraw` hoặc `mermaid` đều yêu cầu công cụ ngoài hoặc tích hợp riêng, không áp dụng trực tiếp được cho môi trường này. Do đó, tôi đã sử dụng giải pháp tự vẽ sơ đồ tư duy bằng cú pháp Mermaid `mindmap` và xuất bằng `mmdc`. (File Markdown gốc vẫn được giữ nguyên).

Trong quá trình chuyển đổi sang hình ảnh, tôi phải rút gọn một số nhãn dài để hình ảnh không bị lỗi hoặc đè chữ (Ví dụ: "Thiết kế môi trường kiểm thử" -> "Thiết kế test env").

Các file đầu ra:

- File mã nguồn sơ đồ: `/home/zinn/zinn/test/hw01/Mindmap\_QA\_QC\_ISTQB.mmd`
- File ảnh vector: `/home/zinn/zinn/test/hw01/Mindmap\_QA\_QC\_ISTQB.svg`
- File ảnh PNG độ phân giải cao: `/home/zinn/zinn/test/hw01/Mindmap\_QA\_QC\_ISTQB.png`